

2026 SIEM USE CASE ENGINEERING PLAYBOOK

**100 DETAILED USE CASES FOR RULE
CREATION, ALERT DESIGN, INCIDENT
GROUPING AND SOC RESPONSE**

BY IZZMIER IZZUDDIN

Part 1. Detection Engineering Methodology for 2026

A 2026 SIEM use case must be more than a single event trigger. It should describe a realistic threat scenario, identify the logs required, define the building blocks, state the rule logic, generate a useful alert, create an incident when evidence is strong and guide the analyst towards containment or closure. The goal is not to create more alerts. The goal is to create better decisions.

Use Case to Rule to Alert to Incident Flow

Stage	Explanation	Expected Output
Use Case	Defines the threat or control condition that should be detected.	Threat scenario, business risk, log sources and MITRE mapping.
Building Blocks	Reusable lists, definitions or context used by rules.	Privileged users, sensitive applications, critical assets, approved scanners, known countries.
Rule Creation	Implements detection logic in SIEM language.	KQL, SPL, AQL, Sigma, EQL or vendor-specific rule.
Alert	Generates a signal when the rule condition is met.	Alert title, impacted entities, evidence summary and recommended next step.
Incident	Groups related alerts into one investigation case.	Timeline, scope, owner, containment status, evidence, closure reason.
Tuning	Improves signal quality after real operation.	Threshold changes, exception logic, baseline updates and rule review notes.

Recommended Building Block Library

Building Block	Purpose
BB: Privileged Users	List of admin, domain admin, cloud admin, PAM-managed and security-sensitive accounts.
BB: Critical Assets	Domain controllers, payment systems, core banking, HR/payroll, customer data platforms, backup servers and internet-facing services.
BB: Sensitive Applications	Applications that process confidential, regulated, customer, financial or privileged operational data.
BB: Approved Change Window	Approved maintenance windows from change management or service desk.
BB: Approved Admin Workstations	Known hardened jump boxes or privileged access workstations.
BB: Approved Scanners	Vulnerability scanners, inventory scanners, monitoring systems and red-team/purple-team infrastructure.
BB: Approved Vendor Access	Authorised vendor identities, source IP ranges, access windows and supported systems.
BB: Threat Intel IOC Match	Domains, IPs, hashes, URLs, ASN and infrastructure from trusted threat intelligence.
BB: Risky Sign-in	Identity events with unusual country, impossible travel, anonymous proxy, token anomaly or MFA concern.
BB: Sensitive Data Pattern	DLP patterns for customer data, financial data, source code, credentials, classified reports and regulated information.
BB: Non-Human Identities	Service accounts, API tokens, service principals, automation accounts, bots and AI agents.
BB: High-Risk OAuth Permissions	Mail, files, directory, offline access, admin consent or tenant-wide consent permissions.

Rule Quality Principles

- Start from attacker or risk behaviour, not only from available logs.
- Use correlation where single events are too weak to justify an incident.
- Add entity context: user, host, IP, device, application, service account, data repository and session.
- Use business context: asset criticality, department, data sensitivity, service owner and regulatory relevance.
- Use dynamic severity or risk scoring where possible, based on confidence and impact.
- Document triage and response actions so L1/L2 analysts do not guess.
- Review rule performance monthly for critical detections and quarterly for lower-risk detections.
- Treat false positive reduction and detection coverage as a balanced engineering decision.

Part 2. Master List of 100 Use Cases

No.	Category	2026 Use Case	MITRE ATT&CK
1	Identity and Access	Multiple Failed Logins Followed by Successful Authentication	T1110 Brute Force; T1078 Valid Accounts
2	Identity and Access	Impossible Travel Across Cloud and VPN Sessions	T1078 Valid Accounts; T1550 Use Alternate Authentication Material
3	Identity and Access	MFA Push Fatigue or Repeated MFA Challenge Abuse	T1621 Multi-Factor Authentication Request Generation
4	Identity and Access	New MFA Method Registered After Risky Sign-in	T1098 Account Manipulation; T1556 Modify Authentication Process
5	Identity and Access	MFA Disabled or Authentication Method Removed	T1556 Modify Authentication Process; T1098 Account Manipulation
6	Identity and Access	Password Spray Against Multiple Users	T1110.003 Password Spraying
7	Identity and Access	Targeted Brute Force Against a Privileged Account	T1110 Brute Force; T1078 Valid Accounts
8	Identity and Access	Dormant Account Suddenly Active	T1078 Valid Accounts
9	Identity and Access	Disabled Account Authentication Attempt	T1078 Valid Accounts
10	Identity and Access	Admin Login from Unmanaged or Non-Compliant Device	T1078.004 Cloud Accounts
11	Identity and Access	Privileged Login Outside Normal Operating Window	T1078 Valid Accounts
12	Identity and Access	Successful Legacy Authentication to Cloud Mailbox	T1078.004 Cloud Accounts
13	Identity and Access	Login from Anonymous Proxy or TOR Exit Node	T1090 Proxy; T1078 Valid Accounts
14	Identity and Access	Session Token Replay Across Unusual ASN or Device	T1550 Use Alternate Authentication Material
15	Identity and Access	Risky Sign-in Followed by Sensitive Application Access	T1078 Valid Accounts; T1530 Data from Cloud Storage
16	Privileged Access, AD and PAM	User Added to Domain Admins or Global Admins	T1098 Account Manipulation; T1078 Valid Accounts
17	Privileged Access, AD and PAM	DCSync or Directory Replication Abuse Indicator	T1003.006 DCSync
18	Privileged Access, AD and PAM	Kerberoasting-Like Service Ticket Request Spike	T1558.003 Kerberoasting
19	Privileged Access, AD and PAM	GPO Modified to Weaken Security Controls	T1484 Domain Policy Modification; T1562 Impair Defenses
20	Privileged Access, AD and PAM	Remote Service Creation on Multiple Hosts	T1021 Remote Services; T1543 Create or Modify System Process
21	Privileged Access, AD and PAM	WMI Remote Execution from Unusual Host	T1047 Windows Management Instrumentation
22	Privileged Access, AD and PAM	PAM Password Checkout Without Approved Ticket	T1078 Valid Accounts
23	Privileged Access, AD and PAM	Break-Glass Account Used	T1078 Valid Accounts
24	Privileged Access, AD and PAM	Privileged Session Recording Disabled or Missing	T1562 Impair Defenses
25	Privileged Access, AD and PAM	Vendor Privileged Access Outside Approved Window	T1078 Valid Accounts; T1199 Trusted Relationship

No.	Category	2026 Use Case	MITRE ATT&CK
26	Email, BEC and	Phishing Email Delivered and User Clicked Link	T1566.002 Spearphishing

	Collaboration		Link; T1204 User Execution
27	Email, BEC and Collaboration	Suspicious ZIP Attachment Containing LNK or Script	T1566.001 Spearphishing Attachment; T1204 User Execution
28	Email, BEC and Collaboration	Teams or SharePoint Suspicious File Shared Internally	T1204 User Execution; T1105 Ingress Tool Transfer
29	Email, BEC and Collaboration	Mailbox Forwarding Rule to External Domain	T1114 Email Collection; T1537 Transfer Data to Cloud Account
30	Email, BEC and Collaboration	Inbox Rule Created to Hide Security or Finance Emails	T1564 Hide Artifacts; T1114 Email Collection
31	Email, BEC and Collaboration	Mass Outbound Email from User Mailbox	T1586 Compromise Accounts; T1078.004 Cloud Accounts
32	Email, BEC and Collaboration	BEC Payment Instruction Change Request	T1656 Impersonation; T1566 Phishing
33	Email, BEC and Collaboration	Executive Display Name Spoofing	T1656 Impersonation; T1566 Phishing
34	Email, BEC and Collaboration	QR Phishing Email	T1566.002 Spearphishing Link
35	Email, BEC and Collaboration	Mailbox Delegation or FullAccess Permission Added	T1098 Account Manipulation; T1114 Email Collection
36	Endpoint, Malware and Living-off-the-Land	Office Application Spawns PowerShell	T1059.001 PowerShell; T1204 User Execution
37	Endpoint, Malware and Living-off-the-Land	Encoded or Obfuscated PowerShell Command	T1059.001 PowerShell; T1027 Obfuscated Files or Information
38	Endpoint, Malware and Living-off-the-Land	PowerShell Downloads Remote Content	T1105 Ingress Tool Transfer; T1059.001 PowerShell
39	Endpoint, Malware and Living-off-the-Land	LNK File Launches Command Interpreter	T1204 User Execution; T1059 Command and Scripting Interpreter
40	Endpoint, Malware and Living-off-the-Land	Rundll32 Execution from User-Writable Path	T1218.011 Rundll32
41	Endpoint, Malware and Living-off-the-Land	Mshta Execution from Email or Browser Context	T1218.005 Mshta
42	Endpoint, Malware and Living-off-the-Land	Certutil or Bitsadmin Used to Download File	T1105 Ingress Tool Transfer; T1218 System Binary Proxy Execution
43	Endpoint, Malware and Living-off-the-Land	Suspicious Scheduled Task Created	T1053 Scheduled Task/Job; T1053.005 Scheduled Task
44	Endpoint, Malware and Living-off-the-Land	Registry Run Key Persistence	T1547.001 Registry Run Keys / Startup Folder
45	Endpoint, Malware and Living-off-the-Land	Suspicious LSASS Access	T1003.001 LSASS Memory
46	Endpoint, Malware and Living-off-the-Land	Security Tool Disabled or Tampered	T1562 Impair Defenses
47	Endpoint, Malware and Living-off-the-Land	Same Suspicious Hash Executed on Multiple Hosts	T1105 Ingress Tool Transfer; T1204 User Execution
48	Ransomware and Destructive Activity	Volume Shadow Copy Deletion	T1490 Inhibit System Recovery
49	Ransomware and Destructive Activity	Backup Repository Deletion or Tampering	T1490 Inhibit System Recovery
50	Ransomware and Destructive Activity	Mass File Rename or Modification Spike	T1486 Data Encrypted for Impact

No.	Category	2026 Use Case	MITRE ATT&CK
-----	----------	---------------	--------------

51	Ransomware and Destructive Activity	Ransom Note Pattern Across Multiple Hosts	T1486 Data Encrypted for Impact
52	Ransomware and Destructive Activity	Remote Admin Tool Abuse Before Impact	T1219 Remote Access Software; T1021 Remote Services
53	Ransomware and Destructive Activity	Security Logs Cleared on Server	T1070.001 Clear Windows Event Logs
54	Ransomware and Destructive Activity	Mass Service Stop on Critical Host	T1489 Service Stop
55	Ransomware and Destructive Activity	Data Staging and Large Archive Creation Before Upload	T1560 Archive Collected Data; T1041 Exfiltration Over C2 Channel
56	Cloud, SaaS, OAuth and Non-Human Identity	New OAuth Application Consent	T1098 Account Manipulation
57	Cloud, SaaS, OAuth and Non-Human Identity	High-Risk OAuth Permissions Granted	T1098 Account Manipulation; T1114 Email Collection
58	Cloud, SaaS, OAuth and Non-Human Identity	OAuth Consent After Risky Login	T1098 Account Manipulation; T1078.004 Cloud Accounts
59	Cloud, SaaS, OAuth and Non-Human Identity	Service Principal Secret or Certificate Added	T1098 Account Manipulation
60	Cloud, SaaS, OAuth and Non-Human Identity	Service Principal Used from New Country or ASN	T1078.004 Cloud Accounts; T1550 Use Alternate Authentication Material
61	Cloud, SaaS, OAuth and Non-Human Identity	AI Agent Identity Created or Granted Access	T1136 Create Account; T1098 Account Manipulation
62	Cloud, SaaS, OAuth and Non-Human Identity	AI Agent Performs Abnormal Volume of Actions	T1078.004 Cloud Accounts; T1530 Data from Cloud Storage
63	Cloud, SaaS, OAuth and Non-Human Identity	Conditional Access Policy Modified	T1556 Modify Authentication Process; T1562 Impair Defenses
64	Cloud, SaaS, OAuth and Non-Human Identity	Cloud Audit Logging Disabled or Reduced	T1562.008 Disable or Modify Cloud Logs
65	Cloud, SaaS, OAuth and Non-Human Identity	Cloud Admin Role Assigned	T1098 Account Manipulation
66	Cloud, SaaS, OAuth and Non-Human Identity	External Guest Added to Sensitive Workspace	T1136 Create Account; T1530 Data from Cloud Storage
67	Cloud, SaaS, OAuth and Non-Human Identity	Guest User Mass Download from SharePoint	T1530 Data from Cloud Storage
68	Cloud, SaaS, OAuth and Non-Human Identity	DLP or Sensitivity Label Policy Modified	T1562 Impair Defenses
69	API, Application and Web Security	Excessive API Calls to Sensitive Endpoint	T1499 Endpoint Denial of Service; T1530 Data from Cloud Storage
70	API, Application and Web Security	API Token Used from New Source IP	T1550 Use Alternate Authentication Material; T1078 Valid Accounts
71	API, Application and Web Security	API Activity Without Matching Interactive Login	T1550 Use Alternate Authentication Material
72	API, Application and Web Security	Sequential Object ID Access Pattern	T1087 Account Discovery; T1190 Exploit Public-Facing Application
73	API, Application and Web Security	Broken Function Level Authorisation Indicator	T1190 Exploit Public-Facing Application; T1098 Account Manipulation
74	API, Application and Web Security	WAF Exploit Attempt Allowed	T1190 Exploit Public-Facing Application
75	API, Application and Web Security	Web Exploit Followed by Server Process Creation	T1190 Exploit Public-Facing

	Security		Application; T1059 Command and Scripting Interpreter
--	----------	--	--

No.	Category	2026 Use Case	MITRE ATT&CK
76	API, Application and Web Security	Suspicious File Upload to Web Application	T1190 Exploit Public-Facing Application; T1505.003 Web Shell
77	API, Application and Web Security	Admin Portal Brute Force	T1110 Brute Force; T1190 Exploit Public-Facing Application
78	API, Application and Web Security	Business Logic Abuse in Transaction Flow	T1565 Data Manipulation; T1530 Data from Cloud Storage
79	Network, Perimeter and Threat Intelligence	Internal Host Communicates with Known Malicious IP	T1071 Application Layer Protocol
80	Network, Perimeter and Threat Intelligence	Malicious Domain Resolution	T1071.004 DNS
81	Network, Perimeter and Threat Intelligence	C2 Beacons Pattern	T1071 Application Layer Protocol; T1102 Web Service
82	Network, Perimeter and Threat Intelligence	Internal Port Scanning from Workstation	T1046 Network Service Discovery
83	Network, Perimeter and Threat Intelligence	VPN Login Followed by Internal Scan	T1133 External Remote Services; T1046 Network Service Discovery
84	Network, Perimeter and Threat Intelligence	Large Outbound Transfer to Rare Destination	T1041 Exfiltration Over C2 Channel; T1048 Exfiltration Over Alternative Protocol
85	Network, Perimeter and Threat Intelligence	DNS Tunneling Indicator	T1048 Exfiltration Over Alternative Protocol; T1071.004 DNS
86	Network, Perimeter and Threat Intelligence	High-Severity IPS Block Against Critical Asset	T1190 Exploit Public-Facing Application; T1595 Active Scanning
87	Data Leakage, Insider Risk and AI Security	Sensitive File Uploaded to External Storage	T1048 Exfiltration Over Alternative Protocol; T1537 Transfer Data to Cloud Account
88	Data Leakage, Insider Risk and AI Security	Sensitive Data Sent to Unapproved GenAI Tool	T1048 Exfiltration Over Alternative Protocol
89	Data Leakage, Insider Risk and AI Security	Source Code Uploaded to AI Platform	T1048 Exfiltration Over Alternative Protocol
90	Data Leakage, Insider Risk and AI Security	Mass SharePoint Download by User	T1530 Data from Cloud Storage
91	Data Leakage, Insider Risk and AI Security	Sensitive Data Copied to USB	T1052 Exfiltration Over Physical Medium
92	Data Leakage, Insider Risk and AI Security	Data Access Spike Before User Exit	T1005 Data from Local System; T1039 Data from Network Shared Drive
93	Data Leakage, Insider Risk and AI Security	Privileged User Exports Sensitive Report	T1005 Data from Local System; T1530 Data from Cloud Storage
94	Data Leakage, Insider Risk and AI Security	Email with Sensitive Attachment Sent to Personal Domain	T1537 Transfer Data to Cloud Account
95	Data Leakage, Insider Risk and AI Security	Repeated Access Denied to Restricted Folders	T1083 File and Directory Discovery; T1039 Data from Network Shared Drive
96	Data Leakage, Insider	Abnormal Sensitive Printing Volume	T1052 Exfiltration Over

	Risk and AI Security		Physical Medium
97	Governance, Control Monitoring and Crypto Readiness	Critical Log Source Stops Sending Logs to SIEM	T1562 Impair Defenses
98	Governance, Control Monitoring and Crypto Readiness	SIEM Detection Rule Disabled or Modified	T1562 Impair Defenses
99	Governance, Control Monitoring and Crypto Readiness	Private Key or Certificate Exported Unexpectedly	T1552 Unsecured Credentials
100	Governance, Control Monitoring and Crypto Readiness	Quantum-Vulnerable Cryptography on Sensitive Long-Lived Data	T1552 Unsecured Credentials; Governance Control

Part 3. Detailed 2026 SIEM Use Case Blueprints

Each use case below is written as a practical blueprint. The simulated examples are not intended to be copied blindly into production. They should be adapted to the organisation's SIEM platform, log schema, technology stack, naming convention, business process, regulatory expectations and risk appetite.

Use Case 001: Multiple Failed Logins Followed by Successful Authentication

Category	Identity and Access
MITRE ATT&CK Mapping	T1110 Brute Force; T1078 Valid Accounts
Detection Objective	Detect and investigate multiple failed logins followed by successful authentication using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Entra ID Sign-in Logs, AD Security Logs, VPN Logs, IAM Risk Events
Recommended Building Blocks	BB: Known Corporate Countries, BB: Privileged Users, BB: Allowed VPN Ranges, BB: Service Accounts Exclusion
Recommended Alert Name	2026 - Multiple Failed Logins Followed by Successful Authentication
Recommended Incident Name	Possible Multiple Failed Logins Followed by Successful Authentication Investigation

1. Scenario

A user receives many failed authentication attempts from a hosting provider IP, followed by a successful cloud login and immediate access to email and file repositories.

Identity-led intrusion is one of the most important 2026 detection areas because attackers increasingly try to log in using stolen credentials, tokens or weakened authentication rather than only deploying obvious malware.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1110 Brute Force; T1078 Valid Accounts. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Entra ID Sign-in Logs	Provides cloud identity evidence for Multiple Failed Logins Followed by Successful Authentication. Key fields include user principal name, sign-in time, source IP, country, ASN, device ID, compliance state, MFA result, conditional access result, client app and target application. This telemetry shows whether the activity is normal user access or suspicious identity behaviour.	Simulation: user=farah.finance@company.com, app=Exchange Online, source_ip=185.220.101.34, country=DE, device=Unknown, MFA=satisfied_by_token, result=Success. This is abnormal because the user normally authenticates from Malaysia using a managed device.
AD Security Logs	Provides on-premise identity and Windows authentication evidence for Multiple Failed Logins Followed by Successful Authentication. Useful fields include Event ID 4624, 4625, 4672, 4720, 4728, 4732, 4768, 4769, 4771, logon type, source workstation, target account and privilege assignment.	Simulation: EventID=4625 repeated failures from WS-0441, followed by EventID=4624 successful logon type 10 to SRV-FILE01. If EventID=4672 also appears, the account received privileged logon rights.
VPN Logs	Shows remote access activity related to	Simulation: VPN login at 09:05 from

	Multiple Failed Logins Followed by Successful Authentication, including login time, public source IP, assigned internal IP, VPN gateway, session duration and disconnect reason. It is useful for correlating cloud sign-ins with remote network access and internal movement.	185.220.101.34 assigned internal IP 10.44.21.77, then the same user performs M365 access at 09:08. This supports a single attacker session rather than two unrelated events.
IAM Risk Events	Adds identity risk scoring and risk reason for Multiple Failed Logins Followed by Successful Authentication. It helps distinguish normal authentication from signals such as anonymous IP, unfamiliar sign-in properties, leaked credentials, atypical travel, malware-linked IP or suspicious inbox activity.	Simulation: riskLevel=High, riskReason=unfamiliarFeatures+anonymousIP, userRisk=Medium. This should increase confidence when correlated with successful login or sensitive application access.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Multiple Failed Logins Followed by Successful Authentication, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Multiple Failed Logins Followed by Successful Authentication. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Multiple Failed Logins Followed by Successful Authentication. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Multiple Failed Logins Followed by Successful Authentication. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Multiple Failed Logins Followed by Successful Authentication was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource /	Identifies the application, mailbox,	Simulation: application=SharePoint Online,

Object	SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Multiple Failed Logins Followed by Successful Authentication. This allows SOC to assess business impact and data sensitivity.	resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Multiple Failed Logins Followed by Successful Authentication, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Known Corporate Countries: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Privileged Users: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Allowed VPN Ranges: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Service Accounts Exclusion: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Known Corporate Countries, BB: Privileged Users, BB: Allowed VPN Ranges];

FROM Entra ID Sign-in Logs, AD Security Logs, VPN Logs

WHERE TimeGenerated >= now() - lookback

AND event_matches('Multiple Failed Logins Followed by Successful Authentication')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Multiple Failed Logins Followed by Successful Authentication
Incident Name	Possible Multiple Failed Logins Followed by Successful Authentication Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Identity and Access

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Multiple Failed Logins Followed by Successful Authentication Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 09:03:00	Entra ID Sign-in Logs	user1001@example.local	WS-2001	203.0.113.8	Initial signal	Event indicates multiple failed logins followed by successful authentication.
2026-05-18 09:05:00	AD Security Logs	user1001@example.local	WS-2001	203.0.113.8	Context signal	Entity context matched BB: Known Corporate Countries.
2026-05-18 09:10:00	VPN Logs	user1001@example.local	WS-2001	10.20.1.12	Follow-on activity	Related activity observed in M365.
2026-05-18 09:13:00	SIEM Correlation	user1001@example.local	WS-2001	203.0.113.8	Rule matched	Correlation matched building blocks: BB: Known Corporate Countries, BB: Privileged Users.
2026-05-18 09:21:00	SOC Case Record	user1001@example.local	WS-2001	203.0.113.8	Incident created	Incident created for Multiple Failed Logins Followed by Successful Authentication with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?

- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- Was MFA satisfied normally, bypassed, repeatedly challenged or modified?
- Should active sessions or tokens be revoked while validation is ongoing?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Consider session revocation, password reset, MFA reset, OAuth grant removal, conditional access review and account disablement based on confirmation.
- Hunt for the same IP, application, token, user-agent, app ID or consent pattern across the tenant.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Known Corporate Countries, BB: Privileged Users, BB: Allowed VPN Ranges, BB: Service Accounts Exclusion.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 002: Impossible Travel Across Cloud and VPN Sessions

Category	Identity and Access
MITRE ATT&CK Mapping	T1078 Valid Accounts; T1550 Use Alternate Authentication Material
Detection Objective	Detect and investigate impossible travel across cloud and vpn sessions using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Entra ID Sign-in Logs, VPN Logs, GeoIP Enrichment, M365 Audit
Recommended Building Blocks	BB: User Travel Exception, BB: Approved Remote Access Countries, BB: High-Risk Geographies
Recommended Alert Name	2026 - Impossible Travel Across Cloud and VPN Sessions
Recommended Incident Name	Possible Impossible Travel Across Cloud and VPN Sessions Investigation

1. Scenario

A user signs in from Kuala Lumpur, then appears 12 minutes later from Europe using the same account, followed by SharePoint access.

Identity-led intrusion is one of the most important 2026 detection areas because attackers increasingly try to log in using stolen credentials, tokens or weakened authentication rather than only deploying obvious malware.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1078 Valid Accounts; T1550 Use Alternate Authentication Material. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Entra ID Sign-in Logs	Provides cloud identity evidence for Impossible Travel Across Cloud and VPN Sessions. Key fields include user principal name, sign-in time, source IP, country, ASN, device ID, compliance state, MFA result, conditional access result, client app and target application. This telemetry shows whether the activity is normal user access or suspicious identity behaviour.	Simulation: user=farah.finance@company.com, app=Exchange Online, source_ip=185.220.101.34, country=DE, device=Unknown, MFA=satisfied_by_token, result=Success. This is abnormal because the user normally authenticates from Malaysia using a managed device.
VPN Logs	Shows remote access activity related to Impossible Travel Across Cloud and VPN Sessions, including login time, public source IP, assigned internal IP, VPN gateway, session duration and disconnect reason. It is useful for correlating cloud sign-ins with remote network access and internal movement.	Simulation: VPN login at 09:05 from 185.220.101.34 assigned internal IP 10.44.21.77, then the same user performs M365 access at 09:08. This supports a single attacker session rather than two unrelated events.
GeoIP Enrichment	Shows the network origin and destination of activity linked to Impossible Travel Across Cloud and VPN Sessions. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.

M365 Audit	Provides post-authentication activity for Impossible Travel Across Cloud and VPN Sessions. It shows what the user or application did after login, such as mailbox access, inbox rule creation, file download, file sharing, Teams activity, OneDrive sync, SharePoint access and administrative changes.	Simulation: 09:20 MailItemsAccessed from Exchange Online; 09:24 New-InboxRule forwards mail externally; 09:32 FileDownloaded from /Finance/Budget2026.xlsx. This converts a login anomaly into a possible account compromise or data exposure incident.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Impossible Travel Across Cloud and VPN Sessions, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Impossible Travel Across Cloud and VPN Sessions. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Impossible Travel Across Cloud and VPN Sessions. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Impossible Travel Across Cloud and VPN Sessions. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Impossible Travel Across Cloud and VPN Sessions was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Impossible Travel Across Cloud and VPN Sessions. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Impossible Travel Across Cloud and VPN Sessions, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were

	resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.
--	--	---

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: User Travel Exception: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Approved Remote Access Countries: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: High-Risk Geographies: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: User Travel Exception, BB: Approved Remote Access Countries, BB: High-Risk Geographies];

FROM Entra ID Sign-in Logs, VPN Logs, GeoIP Enrichment

WHERE TimeGenerated >= now() - lookback

AND event_matches('Impossible Travel Across Cloud and VPN Sessions')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Impossible Travel Across Cloud and VPN Sessions
Incident Name	Possible Impossible Travel Across Cloud and VPN Sessions Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Identity and Access

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Impossible Travel Across Cloud and VPN Sessions Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 09:06:00	Entra ID Sign-in Logs	user1002@example.local	WS-2002	203.0.113.15	Initial signal	Event indicates impossible travel across cloud and vpn sessions.
2026-05-18 09:08:00	VPN Logs	user1002@example.local	WS-2002	203.0.113.15	Context signal	Entity context matched BB: User Travel Exception.
2026-05-18 09:13:00	GeoIP Enrichment	user1002@example.local	WS-2002	10.20.2.23	Follow-on activity	Related activity observed in M365.
2026-05-18 09:16:00	SIEM Correlation	user1002@example.local	WS-2002	203.0.113.15	Rule matched	Correlation matched building blocks: BB: User Travel Exception, BB: Approved Remote Access Countries.
2026-05-18 09:24:00	SOC Case Record	user1002@example.local	WS-2002	203.0.113.15	Incident created	Incident created for Impossible Travel Across Cloud and VPN Sessions with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- Was MFA satisfied normally, bypassed, repeatedly challenged or modified?
- Should active sessions or tokens be revoked while validation is ongoing?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.

- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Consider session revocation, password reset, MFA reset, OAuth grant removal, conditional access review and account disablement based on confirmation.
- Hunt for the same IP, application, token, user-agent, app ID or consent pattern across the tenant.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: User Travel Exception, BB: Approved Remote Access Countries, BB: High-Risk Geographies.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 003: MFA Push Fatigue or Repeated MFA Challenge Abuse

Category	Identity and Access
MITRE ATT&CK Mapping	T1621 Multi-Factor Authentication Request Generation
Detection Objective	Detect and investigate mfa push fatigue or repeated mfa challenge abuse using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Entra ID MFA Logs, Identity Protection, Sign-in Logs
Recommended Building Blocks	BB: MFA Push Count Threshold, BB: VIP Users, BB: Approved Helpdesk Reset Window
Recommended Alert Name	2026 - MFA Push Fatigue or Repeated MFA Challenge Abuse
Recommended Incident Name	Possible MFA Push Fatigue or Repeated MFA Challenge Abuse Investigation

1. Scenario

A user receives repeated MFA prompts late at night despite not initiating any login, suggesting an attacker is trying to pressure the user into approval.

Identity-led intrusion is one of the most important 2026 detection areas because attackers increasingly try to log in using stolen credentials, tokens or weakened authentication rather than only deploying obvious malware.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1621 Multi-Factor Authentication Request Generation. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Entra ID MFA Logs	Provides cloud identity evidence for MFA Push Fatigue or Repeated MFA Challenge Abuse. Key fields include user principal name, sign-in time, source IP, country, ASN, device ID, compliance state, MFA result, conditional access result, client app and target application. This telemetry shows whether the activity is normal user access or suspicious identity behaviour.	Simulation: user=farah.finance@company.com, app=Exchange Online, source_ip=185.220.101.34, country=DE, device=Unknown, MFA=satisfied_by_token, result=Success. This is abnormal because the user normally authenticates from Malaysia using a managed device.
Identity Protection	Adds identity risk scoring and risk reason for MFA Push Fatigue or Repeated MFA Challenge Abuse. It helps distinguish normal authentication from signals such as anonymous IP, unfamiliar sign-in properties, leaked credentials, atypical travel, malware-linked IP or suspicious inbox activity.	Simulation: riskLevel=High, riskReason=unfamiliarFeatures+anonymousIP, userRisk=Medium. This should increase confidence when correlated with successful login or sensitive application access.
Sign-in Logs	Provides cloud identity evidence for MFA Push Fatigue or Repeated MFA Challenge Abuse. Key fields include user principal name, sign-in time, source IP, country, ASN, device ID, compliance state, MFA result, conditional access result, client app and target application. This telemetry shows whether the	Simulation: user=farah.finance@company.com, app=Exchange Online, source_ip=185.220.101.34, country=DE, device=Unknown, MFA=satisfied_by_token, result=Success. This is abnormal because the user normally authenticates from Malaysia using a managed device.

	activity is normal user access or suspicious identity behaviour.	
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For MFA Push Fatigue or Repeated MFA Challenge Abuse, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in MFA Push Fatigue or Repeated MFA Challenge Abuse. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to MFA Push Fatigue or Repeated MFA Challenge Abuse. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to MFA Push Fatigue or Repeated MFA Challenge Abuse. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in MFA Push Fatigue or Repeated MFA Challenge Abuse was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during MFA Push Fatigue or Repeated MFA Challenge Abuse. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For MFA Push Fatigue or Repeated MFA Challenge Abuse, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity

	incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	exists, document containment evidence and close as attempted/blocked.
--	--	---

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: MFA Push Count Threshold: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: VIP Users: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Approved Helpdesk Reset Window: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: MFA Push Count Threshold, BB: VIP Users, BB: Approved Helpdesk Reset Window];

FROM Entra ID MFA Logs, Identity Protection, Sign-in Logs

WHERE TimeGenerated >= now() - lookback

AND event_matches('MFA Push Fatigue or Repeated MFA Challenge Abuse')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - MFA Push Fatigue or Repeated MFA Challenge Abuse
Incident Name	Possible MFA Push Fatigue or Repeated MFA Challenge Abuse Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Identity and Access

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible MFA Push Fatigue or Repeated MFA Challenge Abuse Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 09:09:00	Entra ID MFA Logs	user1003@example.local	WS-2003	203.0.113.22	Initial signal	Event indicates mfa push fatigue or repeated mfa challenge abuse.
2026-05-18 09:11:00	Identity Protection	user1003@example.local	WS-2003	203.0.113.22	Context signal	Entity context matched BB: MFA Push Count Threshold.
2026-05-18 09:16:00	Sign-in Logs	user1003@example.local	WS-2003	10.20.3.34	Follow-on activity	Related activity observed in M365.
2026-05-18 09:19:00	SIEM Correlation	user1003@example.local	WS-2003	203.0.113.22	Rule matched	Correlation matched building blocks: BB: MFA Push Count Threshold, BB: VIP Users.
2026-05-18 09:27:00	SOC Case Record	user1003@example.local	WS-2003	203.0.113.22	Incident created	Incident created for MFA Push Fatigue or Repeated MFA Challenge Abuse with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- Was MFA satisfied normally, bypassed, repeatedly challenged or modified?
- Should active sessions or tokens be revoked while validation is ongoing?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.

- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Consider session revocation, password reset, MFA reset, OAuth grant removal, conditional access review and account disablement based on confirmation.
- Hunt for the same IP, application, token, user-agent, app ID or consent pattern across the tenant.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: MFA Push Count Threshold, BB: VIP Users, BB: Approved Helpdesk Reset Window.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 004: New MFA Method Registered After Risky Sign-in

Category	Identity and Access
MITRE ATT&CK Mapping	T1098 Account Manipulation; T1556 Modify Authentication Process
Detection Objective	Detect and investigate new mfa method registered after risky sign-in using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Entra ID Audit Logs, Sign-in Logs, MFA Registration Events
Recommended Building Blocks	BB: Risky Sign-in, BB: MFA Method Change, BB: Privileged Users
Recommended Alert Name	2026 - New MFA Method Registered After Risky Sign-in
Recommended Incident Name	Possible New MFA Method Registered After Risky Sign-in Investigation

1. Scenario

A risky login is followed by a new phone number or authenticator app being added to the account.

Identity-led intrusion is one of the most important 2026 detection areas because attackers increasingly try to log in using stolen credentials, tokens or weakened authentication rather than only deploying obvious malware.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1098 Account Manipulation; T1556 Modify Authentication Process. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Entra ID Audit Logs	Provides cloud identity evidence for New MFA Method Registered After Risky Sign-in. Key fields include user principal name, sign-in time, source IP, country, ASN, device ID, compliance state, MFA result, conditional access result, client app and target application. This telemetry shows whether the activity is normal user access or suspicious identity behaviour.	Simulation: user=farah.finance@company.com, app=Exchange Online, source_ip=185.220.101.34, country=DE, device=Unknown, MFA=satisfied_by_token, result=Success. This is abnormal because the user normally authenticates from Malaysia using a managed device.
Sign-in Logs	Provides cloud identity evidence for New MFA Method Registered After Risky Sign-in. Key fields include user principal name, sign-in time, source IP, country, ASN, device ID, compliance state, MFA result, conditional access result, client app and target application. This telemetry shows whether the activity is normal user access or suspicious identity behaviour.	Simulation: user=farah.finance@company.com, app=Exchange Online, source_ip=185.220.101.34, country=DE, device=Unknown, MFA=satisfied_by_token, result=Success. This is abnormal because the user normally authenticates from Malaysia using a managed device.
MFA Registration Events	Adds external intelligence context to New MFA Method Registered After Risky Sign-in. IOC, actor, campaign, reputation, first-seen date and confidence help prioritise alerts and connect internal evidence to known malicious infrastructure.	Simulation: destination IP matched TI feed as malware C2 with confidence=High, first_seen=2026-02-10. If internal host communicated successfully, investigate compromise evidence.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For New MFA Method Registered After Risky Sign-in, the analyst	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The

	must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	close timing increases investigation confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in New MFA Method Registered After Risky Sign-in. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to New MFA Method Registered After Risky Sign-in. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to New MFA Method Registered After Risky Sign-in. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in New MFA Method Registered After Risky Sign-in was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during New MFA Method Registered After Risky Sign-in. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For New MFA Method Registered After Risky Sign-in, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Risky Sign-in: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: MFA Method Change: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Privileged Users: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Risky Sign-in, BB: MFA Method Change, BB: Privileged Users];

FROM Entra ID Audit Logs, Sign-in Logs, MFA Registration Events

WHERE TimeGenerated >= now() - lookback

AND event_matches('New MFA Method Registered After Risky Sign-in')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - New MFA Method Registered After Risky Sign-in
Incident Name	Possible New MFA Method Registered After Risky Sign-in Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Identity and Access

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible New MFA Method Registered After Risky Sign-in Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.

- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 09:12:00	Entra ID Audit Logs	user1004@example.local	WS-2004	203.0.113.29	Initial signal	Event indicates new mfa method registered after risky sign-in.
2026-05-18 09:14:00	Sign-in Logs	user1004@example.local	WS-2004	203.0.113.29	Context signal	Entity context matched BB: Risky Sign-in.
2026-05-18 09:19:00	MFA Registration Events	user1004@example.local	WS-2004	10.20.4.45	Follow-on activity	Related activity observed in M365.
2026-05-18 09:22:00	SIEM Correlation	user1004@example.local	WS-2004	203.0.113.29	Rule matched	Correlation matched building blocks: BB: Risky Sign-in, BB: MFA Method Change.
2026-05-18 09:30:00	SOC Case Record	user1004@example.local	WS-2004	203.0.113.29	Incident created	Incident created for New MFA Method Registered After Risky Sign-in with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- Was MFA satisfied normally, bypassed, repeatedly challenged or modified?
- Should active sessions or tokens be revoked while validation is ongoing?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Consider session revocation, password reset, MFA reset, OAuth grant removal, conditional access review and account disablement based on confirmation.
- Hunt for the same IP, application, token, user-agent, app ID or consent pattern across the tenant.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Risky Sign-in, BB: MFA Method Change, BB: Privileged Users.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 005: MFA Disabled or Authentication Method Removed

Category	Identity and Access
MITRE ATT&CK Mapping	T1556 Modify Authentication Process; T1098 Account Manipulation
Detection Objective	Detect and investigate mfa disabled or authentication method removed using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Entra ID Audit Logs, IAM Change Logs
Recommended Building Blocks	BB: Authentication Control Change, BB: Privileged Users, BB: Approved IAM Change Tickets
Recommended Alert Name	2026 - MFA Disabled or Authentication Method Removed
Recommended Incident Name	Possible MFA Disabled or Authentication Method Removed Investigation

1. Scenario

An account has MFA removed without a corresponding approved IAM change, weakening identity protection.

Identity-led intrusion is one of the most important 2026 detection areas because attackers increasingly try to log in using stolen credentials, tokens or weakened authentication rather than only deploying obvious malware.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1556 Modify Authentication Process; T1098 Account Manipulation. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Entra ID Audit Logs	Provides cloud identity evidence for MFA Disabled or Authentication Method Removed. Key fields include user principal name, sign-in time, source IP, country, ASN, device ID, compliance state, MFA result, conditional access result, client app and target application. This telemetry shows whether the activity is normal user access or suspicious identity behaviour.	Simulation: user=farah.finance@company.com, app=Exchange Online, source_ip=185.220.101.34, country=DE, device=Unknown, MFA=satisfied_by_token, result=Success. This is abnormal because the user normally authenticates from Malaysia using a managed device.
IAM Change Logs	Provides supporting evidence for MFA Disabled or Authentication Method Removed. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for MFA Disabled or Authentication Method Removed. If the evidence is incomplete, the analyst should request the missing log source before closure.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For MFA Disabled or Authentication Method Removed, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.

User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in MFA Disabled or Authentication Method Removed. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to MFA Disabled or Authentication Method Removed. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to MFA Disabled or Authentication Method Removed. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in MFA Disabled or Authentication Method Removed was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during MFA Disabled or Authentication Method Removed. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For MFA Disabled or Authentication Method Removed, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Authentication Control Change: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Privileged Users: maintain the list owner, update frequency, source of truth and exception approval process.

- BB: Approved IAM Change Tickets: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Authentication Control Change, BB: Privileged Users, BB: Approved IAM Change Tickets];

FROM Entra ID Audit Logs, IAM Change Logs

WHERE TimeGenerated >= now() - lookback

AND event_matches('MFA Disabled or Authentication Method Removed')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - MFA Disabled or Authentication Method Removed
Incident Name	Possible MFA Disabled or Authentication Method Removed Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Identity and Access

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible MFA Disabled or Authentication Method Removed Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 09:15:00	Entra ID Audit Logs	user1005@example.local	WS-2005	203.0.113.36	Initial signal	Event indicates mfa disabled or authentication method removed.
2026-05-18 09:17:00	IAM Change Logs	user1005@example.local	WS-2005	203.0.113.36	Context signal	Entity context matched BB: Authentication Control Change.
2026-05-18 09:22:00	Entra ID Audit Logs	user1005@example.local	WS-2005	10.20.5.56	Follow-on activity	Related activity observed in M365.
2026-05-18 09:25:00	SIEM Correlation	user1005@example.local	WS-2005	203.0.113.36	Rule matched	Correlation matched building blocks: BB: Authentication Control Change, BB: Privileged Users.
2026-05-18 09:33:00	SOC Case Record	user1005@example.local	WS-2005	203.0.113.36	Incident created	Incident created for MFA Disabled or Authentication Method Removed with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- Was MFA satisfied normally, bypassed, repeatedly challenged or modified?
- Should active sessions or tokens be revoked while validation is ongoing?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Consider session revocation, password reset, MFA reset, OAuth grant removal, conditional access review and account disablement based on confirmation.
- Hunt for the same IP, application, token, user-agent, app ID or consent pattern across the tenant.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.

- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Authentication Control Change, BB: Privileged Users, BB: Approved IAM Change Tickets.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 006: Password Spray Against Multiple Users

Category	Identity and Access
MITRE ATT&CK Mapping	T1110.003 Password Spraying
Detection Objective	Detect and investigate password spray against multiple users using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Entra ID Sign-in Logs, AD Security Logs, VPN Logs, WAF Login Logs
Recommended Building Blocks	BB: Failed Login Threshold, BB: External Source IP, BB: Known Scanner Exclusion
Recommended Alert Name	2026 - Password Spray Against Multiple Users
Recommended Incident Name	Possible Password Spray Against Multiple Users Investigation

1. Scenario

One source IP tries a small number of passwords across many user accounts to avoid lockout thresholds.

Identity-led intrusion is one of the most important 2026 detection areas because attackers increasingly try to log in using stolen credentials, tokens or weakened authentication rather than only deploying obvious malware.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1110.003 Password Spraying. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Entra ID Sign-in Logs	Provides cloud identity evidence for Password Spray Against Multiple Users. Key fields include user principal name, sign-in time, source IP, country, ASN, device ID, compliance state, MFA result, conditional access result, client app and target application. This telemetry shows whether the activity is normal user access or suspicious identity behaviour.	Simulation: user=farah.finance@company.com, app=Exchange Online, source_ip=185.220.101.34, country=DE, device=Unknown, MFA=satisfied_by_token, result=Success. This is abnormal because the user normally authenticates from Malaysia using a managed device.
AD Security Logs	Provides on-premise identity and Windows authentication evidence for Password Spray Against Multiple Users. Useful fields include Event ID 4624, 4625, 4672, 4720, 4728, 4732, 4768, 4769, 4771, logon type, source workstation, target account and privilege assignment.	Simulation: EventID=4625 repeated failures from WS-0441, followed by EventID=4624 successful logon type 10 to SRV-FILE01. If EventID=4672 also appears, the account received privileged logon rights.
VPN Logs	Shows remote access activity related to Password Spray Against Multiple Users, including login time, public source IP, assigned internal IP, VPN gateway, session duration and disconnect reason. It is useful for correlating cloud sign-ins with remote network access and internal movement.	Simulation: VPN login at 09:05 from 185.220.101.34 assigned internal IP 10.44.21.77, then the same user performs M365 access at 09:08. This supports a single attacker session rather than two unrelated events.
WAF Login Logs	Shows web attack evidence for Password Spray Against Multiple Users, including request URI, source IP, HTTP method,	Simulation: URI=/api/account?id=10522' OR '1'='1, action=Allowed, response=200. If followed by server process creation, raise as

	payload pattern, rule ID, action, response code and whether the exploit attempt was blocked or allowed.	possible web compromise.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Password Spray Against Multiple Users, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Password Spray Against Multiple Users. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Password Spray Against Multiple Users. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Password Spray Against Multiple Users. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Password Spray Against Multiple Users was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Password Spray Against Multiple Users. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Password Spray Against Multiple Users, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Failed Login Threshold: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: External Source IP: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Known Scanner Exclusion: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Failed Login Threshold, BB: External Source IP, BB: Known Scanner Exclusion];

FROM Entra ID Sign-in Logs, AD Security Logs, VPN Logs

WHERE TimeGenerated >= now() - lookback

AND event_matches('Password Spray Against Multiple Users')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Password Spray Against Multiple Users
Incident Name	Possible Password Spray Against Multiple Users Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Identity and Access

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Password Spray Against Multiple Users Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.

- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 09:18:00	Entra ID Sign-in Logs	user1006@example.local	WS-2006	203.0.113.43	Initial signal	Event indicates password spray against multiple users.
2026-05-18 09:20:00	AD Security Logs	user1006@example.local	WS-2006	203.0.113.43	Context signal	Entity context matched BB: Failed Login Threshold.
2026-05-18 09:25:00	VPN Logs	user1006@example.local	WS-2006	10.20.6.67	Follow-on activity	Related activity observed in M365.
2026-05-18 09:28:00	SIEM Correlation	user1006@example.local	WS-2006	203.0.113.43	Rule matched	Correlation matched building blocks: BB: Failed Login Threshold, BB: External Source IP.
2026-05-18 09:36:00	SOC Case Record	user1006@example.local	WS-2006	203.0.113.43	Incident created	Incident created for Password Spray Against Multiple Users with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- Was MFA satisfied normally, bypassed, repeatedly challenged or modified?
- Should active sessions or tokens be revoked while validation is ongoing?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Consider session revocation, password reset, MFA reset, OAuth grant removal, conditional access review and account disablement based on confirmation.
- Hunt for the same IP, application, token, user-agent, app ID or consent pattern across the tenant.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Failed Login Threshold, BB: External Source IP, BB: Known Scanner Exclusion.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 007: Targeted Brute Force Against a Privileged Account

Category	Identity and Access
MITRE ATT&CK Mapping	T1110 Brute Force; T1078 Valid Accounts
Detection Objective	Detect and investigate targeted brute force against a privileged account using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	AD Security Logs, Entra ID Sign-in Logs, PAM Logs
Recommended Building Blocks	BB: Privileged Users, BB: Critical Admin Accounts, BB: Failed Login Threshold
Recommended Alert Name	2026 - Targeted Brute Force Against a Privileged Account
Recommended Incident Name	Possible Targeted Brute Force Against a Privileged Account Investigation

1. Scenario

A domain admin or cloud admin account receives a high number of failed logins from one or more external sources.

Identity-led intrusion is one of the most important 2026 detection areas because attackers increasingly try to log in using stolen credentials, tokens or weakened authentication rather than only deploying obvious malware.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1110 Brute Force; T1078 Valid Accounts. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
AD Security Logs	Provides on-premise identity and Windows authentication evidence for Targeted Brute Force Against a Privileged Account. Useful fields include Event ID 4624, 4625, 4672, 4720, 4728, 4732, 4768, 4769, 4771, logon type, source workstation, target account and privilege assignment.	Simulation: EventID=4625 repeated failures from WS-0441, followed by EventID=4624 successful logon type 10 to SRV-FILE01. If EventID=4672 also appears, the account received privileged logon rights.
Entra ID Sign-in Logs	Provides cloud identity evidence for Targeted Brute Force Against a Privileged Account. Key fields include user principal name, sign-in time, source IP, country, ASN, device ID, compliance state, MFA result, conditional access result, client app and target application. This telemetry shows whether the activity is normal user access or suspicious identity behaviour.	Simulation: user=farah.finance@company.com, app=Exchange Online, source_ip=185.220.101.34, country=DE, device=Unknown, MFA=satisfied_by_token, result=Success. This is abnormal because the user normally authenticates from Malaysia using a managed device.
PAM Logs	Provides privileged session evidence for Targeted Brute Force Against a Privileged Account. It links admin activity to approved access requests, password checkouts, session recordings, commands executed, target systems and vendor/user identity.	Simulation: admin checked out domain admin password at 02:11 with no matching change ticket, then logged into SRV-DC01. This requires privileged access validation.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Targeted Brute Force Against a Privileged Account, the analyst	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The

	must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	close timing increases investigation confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Targeted Brute Force Against a Privileged Account. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Targeted Brute Force Against a Privileged Account. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Targeted Brute Force Against a Privileged Account. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Targeted Brute Force Against a Privileged Account was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Targeted Brute Force Against a Privileged Account. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Targeted Brute Force Against a Privileged Account, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Privileged Users: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Critical Admin Accounts: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Failed Login Threshold: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Privileged Users, BB: Critical Admin Accounts, BB: Failed Login Threshold];

FROM AD Security Logs, Entra ID Sign-in Logs, PAM Logs

WHERE TimeGenerated >= now() - lookback

AND event_matches('Targeted Brute Force Against a Privileged Account')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Targeted Brute Force Against a Privileged Account
Incident Name	Possible Targeted Brute Force Against a Privileged Account Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Identity and Access

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Targeted Brute Force Against a Privileged Account Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.

- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 09:21:00	AD Security Logs	user1007@example.local	WS-2007	203.0.113.50	Initial signal	Event indicates targeted brute force against a privileged account.
2026-05-18 09:23:00	Entra ID Sign-in Logs	user1007@example.local	WS-2007	203.0.113.50	Context signal	Entity context matched BB: Privileged Users.
2026-05-18 09:28:00	PAM Logs	user1007@example.local	WS-2007	10.20.7.78	Follow-on activity	Related activity observed in M365.
2026-05-18 09:31:00	SIEM Correlation	user1007@example.local	WS-2007	203.0.113.50	Rule matched	Correlation matched building blocks: BB: Privileged Users, BB: Critical Admin Accounts.
2026-05-18 09:39:00	SOC Case Record	user1007@example.local	WS-2007	203.0.113.50	Incident created	Incident created for Targeted Brute Force Against a Privileged Account with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- Was MFA satisfied normally, bypassed, repeatedly challenged or modified?
- Should active sessions or tokens be revoked while validation is ongoing?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Consider session revocation, password reset, MFA reset, OAuth grant removal, conditional access review and account disablement based on confirmation.
- Hunt for the same IP, application, token, user-agent, app ID or consent pattern across the tenant.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Privileged Users, BB: Critical Admin Accounts, BB: Failed Login Threshold.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 008: Dormant Account Suddenly Active

Category	Identity and Access
MITRE ATT&CK Mapping	T1078 Valid Accounts
Detection Objective	Detect and investigate dormant account suddenly active using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	AD Security Logs, Entra ID Sign-in Logs, HR Feed, IAM Lifecycle Logs
Recommended Building Blocks	BB: Dormant Account 60 Days, BB: Terminated Users, BB: Non-Human Account Exclusion
Recommended Alert Name	2026 - Dormant Account Suddenly Active
Recommended Incident Name	Possible Dormant Account Suddenly Active Investigation

1. Scenario

An account that has not logged in for more than 90 days suddenly authenticates to VPN or cloud email.

Identity-led intrusion is one of the most important 2026 detection areas because attackers increasingly try to log in using stolen credentials, tokens or weakened authentication rather than only deploying obvious malware.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1078 Valid Accounts. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
AD Security Logs	Provides on-premise identity and Windows authentication evidence for Dormant Account Suddenly Active. Useful fields include Event ID 4624, 4625, 4672, 4720, 4728, 4732, 4768, 4769, 4771, logon type, source workstation, target account and privilege assignment.	Simulation: EventID=4625 repeated failures from WS-0441, followed by EventID=4624 successful logon type 10 to SRV-FILE01. If EventID=4672 also appears, the account received privileged logon rights.
Entra ID Sign-in Logs	Provides cloud identity evidence for Dormant Account Suddenly Active. Key fields include user principal name, sign-in time, source IP, country, ASN, device ID, compliance state, MFA result, conditional access result, client app and target application. This telemetry shows whether the activity is normal user access or suspicious identity behaviour.	Simulation: user=farah.finance@company.com, app=Exchange Online, source_ip=185.220.101.34, country=DE, device=Unknown, MFA=satisfied_by_token, result=Success. This is abnormal because the user normally authenticates from Malaysia using a managed device.
HR Feed	Provides workforce context for Dormant Account Suddenly Active. HR data such as department, role, resignation status, transfer, leave or termination date helps support insider risk and access review decisions.	Simulation: user has resignation date in 7 days and downloads abnormal volume from sensitive repository. This does not prove misuse but justifies investigation and management validation.
IAM Lifecycle Logs	Provides supporting evidence for Dormant Account Suddenly Active. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Dormant Account Suddenly Active. If the evidence is incomplete, the analyst should request the

	other suspicious activity in the same timeline.	missing log source before closure.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Dormant Account Suddenly Active, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Dormant Account Suddenly Active. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Dormant Account Suddenly Active. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Dormant Account Suddenly Active. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Dormant Account Suddenly Active was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Dormant Account Suddenly Active. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Dormant Account Suddenly Active, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Dormant Account 60 Days: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Terminated Users: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Non-Human Account Exclusion: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Dormant Account 60 Days, BB: Terminated Users, BB: Non-Human Account Exclusion];

FROM AD Security Logs, Entra ID Sign-in Logs, HR Feed

WHERE TimeGenerated >= now() - lookback

AND event_matches('Dormant Account Suddenly Active')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Dormant Account Suddenly Active
Incident Name	Possible Dormant Account Suddenly Active Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Identity and Access

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Dormant Account Suddenly Active Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.

- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 09:24:00	AD Security Logs	user1008@example.local	WS-2008	203.0.113.57	Initial signal	Event indicates dormant account suddenly active.
2026-05-18 09:26:00	Entra ID Sign-in Logs	user1008@example.local	WS-2008	203.0.113.57	Context signal	Entity context matched BB: Dormant Account 60 Days.
2026-05-18 09:31:00	HR Feed	user1008@example.local	WS-2008	10.20.8.89	Follow-on activity	Related activity observed in M365.
2026-05-18 09:34:00	SIEM Correlation	user1008@example.local	WS-2008	203.0.113.57	Rule matched	Correlation matched building blocks: BB: Dormant Account 60 Days, BB: Terminated Users.
2026-05-18 09:42:00	SOC Case Record	user1008@example.local	WS-2008	203.0.113.57	Incident created	Incident created for Dormant Account Suddenly Active with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- Was MFA satisfied normally, bypassed, repeatedly challenged or modified?
- Should active sessions or tokens be revoked while validation is ongoing?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Consider session revocation, password reset, MFA reset, OAuth grant removal, conditional access review and account disablement based on confirmation.
- Hunt for the same IP, application, token, user-agent, app ID or consent pattern across the tenant.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Dormant Account 60 Days, BB: Terminated Users, BB: Non-Human Account Exclusion.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 009: Disabled Account Authentication Attempt

Category	Identity and Access
MITRE ATT&CK Mapping	T1078 Valid Accounts
Detection Objective	Detect and investigate disabled account authentication attempt using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	AD Security Logs, Entra ID Sign-in Logs, VPN Logs
Recommended Building Blocks	BB: Disabled Accounts, BB: External Source IP, BB: Known Scanner Exclusion
Recommended Alert Name	2026 - Disabled Account Authentication Attempt
Recommended Incident Name	Possible Disabled Account Authentication Attempt Investigation

1. Scenario

A disabled or deprovisioned account is used in an authentication attempt, indicating stale credentials or password reuse testing.

Identity-led intrusion is one of the most important 2026 detection areas because attackers increasingly try to log in using stolen credentials, tokens or weakened authentication rather than only deploying obvious malware.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1078 Valid Accounts. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
AD Security Logs	Provides on-premise identity and Windows authentication evidence for Disabled Account Authentication Attempt. Useful fields include Event ID 4624, 4625, 4672, 4720, 4728, 4732, 4768, 4769, 4771, logon type, source workstation, target account and privilege assignment.	Simulation: EventID=4625 repeated failures from WS-0441, followed by EventID=4624 successful logon type 10 to SRV-FILE01. If EventID=4672 also appears, the account received privileged logon rights.
Entra ID Sign-in Logs	Provides cloud identity evidence for Disabled Account Authentication Attempt. Key fields include user principal name, sign-in time, source IP, country, ASN, device ID, compliance state, MFA result, conditional access result, client app and target application. This telemetry shows whether the activity is normal user access or suspicious identity behaviour.	Simulation: user=farah.finance@company.com, app=Exchange Online, source_ip=185.220.101.34, country=DE, device=Unknown, MFA=satisfied_by_token, result=Success. This is abnormal because the user normally authenticates from Malaysia using a managed device.
VPN Logs	Shows remote access activity related to Disabled Account Authentication Attempt, including login time, public source IP, assigned internal IP, VPN gateway, session duration and disconnect reason. It is useful for correlating cloud sign-ins with remote network access and internal movement.	Simulation: VPN login at 09:05 from 185.220.101.34 assigned internal IP 10.44.21.77, then the same user performs M365 access at 09:08. This supports a single attacker session rather than two unrelated events.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Disabled Account Authentication Attempt, the analyst must	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The

	compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	close timing increases investigation confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Disabled Account Authentication Attempt. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Disabled Account Authentication Attempt. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Disabled Account Authentication Attempt. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Disabled Account Authentication Attempt was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Disabled Account Authentication Attempt. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Disabled Account Authentication Attempt, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Disabled Accounts: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: External Source IP: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Known Scanner Exclusion: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Disabled Accounts, BB: External Source IP, BB: Known Scanner Exclusion];

FROM AD Security Logs, Entra ID Sign-in Logs, VPN Logs

WHERE TimeGenerated >= now() - lookback

AND event_matches('Disabled Account Authentication Attempt')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Disabled Account Authentication Attempt
Incident Name	Possible Disabled Account Authentication Attempt Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Identity and Access

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Disabled Account Authentication Attempt Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 09:27:00	AD Security Logs	user1009@example.local	WS-2009	203.0.113.64	Initial signal	Event indicates disabled account authentication attempt.
2026-05-18 09:29:00	Entra ID Sign-in Logs	user1009@example.local	WS-2009	203.0.113.64	Context signal	Entity context matched BB: Disabled Accounts.
2026-05-18 09:34:00	VPN Logs	user1009@example.local	WS-2009	10.20.9.100	Follow-on activity	Related activity observed in M365.
2026-05-18 09:37:00	SIEM Correlation	user1009@example.local	WS-2009	203.0.113.64	Rule matched	Correlation matched building blocks: BB: Disabled Accounts, BB: External Source IP.
2026-05-18 09:45:00	SOC Case Record	user1009@example.local	WS-2009	203.0.113.64	Incident created	Incident created for Disabled Account Authentication Attempt with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- Was MFA satisfied normally, bypassed, repeatedly challenged or modified?
- Should active sessions or tokens be revoked while validation is ongoing?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Consider session revocation, password reset, MFA reset, OAuth grant removal, conditional access review and account disablement based on confirmation.
- Hunt for the same IP, application, token, user-agent, app ID or consent pattern across the tenant.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Disabled Accounts, BB: External Source IP, BB: Known Scanner Exclusion.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 010: Admin Login from Unmanaged or Non-Compliant Device

Category	Identity and Access
MITRE ATT&CK Mapping	T1078.004 Cloud Accounts
Detection Objective	Detect and investigate admin login from unmanaged or non-compliant device using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Entra ID Sign-in Logs, Device Compliance Logs, MDM Logs
Recommended Building Blocks	BB: Privileged Users, BB: Compliant Devices, BB: Admin Portals
Recommended Alert Name	2026 - Admin Login from Unmanaged or Non-Compliant Device
Recommended Incident Name	Possible Admin Login from Unmanaged or Non-Compliant Device Investigation

1. Scenario

A privileged user signs in to an admin portal using a device not managed by the organisation.

Identity-led intrusion is one of the most important 2026 detection areas because attackers increasingly try to log in using stolen credentials, tokens or weakened authentication rather than only deploying obvious malware.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1078.004 Cloud Accounts. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Entra ID Sign-in Logs	Provides cloud identity evidence for Admin Login from Unmanaged or Non-Compliant Device. Key fields include user principal name, sign-in time, source IP, country, ASN, device ID, compliance state, MFA result, conditional access result, client app and target application. This telemetry shows whether the activity is normal user access or suspicious identity behaviour.	Simulation: user=farah.finance@company.com, app=Exchange Online, source_ip=185.220.101.34, country=DE, device=Unknown, MFA=satisfied_by_token, result=Success. This is abnormal because the user normally authenticates from Malaysia using a managed device.
Device Compliance Logs	Identifies the endpoint, server, cloud workload or application component connected to Admin Login from Unmanaged or Non-Compliant Device. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
MDM Logs	Provides supporting evidence for Admin Login from Unmanaged or Non-Compliant Device. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Admin Login from Unmanaged or Non-Compliant Device. If the evidence is incomplete, the analyst should request the missing log source before closure.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Admin Login from	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access;

	Unmanaged or Non-Compliant Device, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Admin Login from Unmanaged or Non-Compliant Device. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Admin Login from Unmanaged or Non-Compliant Device. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Admin Login from Unmanaged or Non-Compliant Device. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Admin Login from Unmanaged or Non-Compliant Device was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Admin Login from Unmanaged or Non-Compliant Device. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Admin Login from Unmanaged or Non-Compliant Device, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Privileged Users: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Compliant Devices: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Admin Portals: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Privileged Users, BB: Compliant Devices, BB: Admin Portals];

FROM Entra ID Sign-in Logs, Device Compliance Logs, MDM Logs

WHERE TimeGenerated >= now() - lookback

AND event_matches('Admin Login from Unmanaged or Non-Compliant Device')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Admin Login from Unmanaged or Non-Compliant Device
Incident Name	Possible Admin Login from Unmanaged or Non-Compliant Device Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Identity and Access

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Admin Login from Unmanaged or Non-Compliant Device Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.

- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 09:30:00	Entra ID Sign-in Logs	user1010@example.local	WS-2010	203.0.113.71	Initial signal	Event indicates admin login from unmanaged or non-compliant device.
2026-05-18 09:32:00	Device Compliance Logs	user1010@example.local	WS-2010	203.0.113.71	Context signal	Entity context matched BB: Privileged Users.
2026-05-18 09:37:00	MDM Logs	user1010@example.local	WS-2010	10.20.10.111	Follow-on activity	Related activity observed in M365.
2026-05-18 09:40:00	SIEM Correlation	user1010@example.local	WS-2010	203.0.113.71	Rule matched	Correlation matched building blocks: BB: Privileged Users, BB: Compliant Devices.
2026-05-18 09:48:00	SOC Case Record	user1010@example.local	WS-2010	203.0.113.71	Incident created	Incident created for Admin Login from Unmanaged or Non-Compliant Device with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- Was MFA satisfied normally, bypassed, repeatedly challenged or modified?
- Should active sessions or tokens be revoked while validation is ongoing?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Consider session revocation, password reset, MFA reset, OAuth grant removal, conditional access review and account disablement based on confirmation.
- Hunt for the same IP, application, token, user-agent, app ID or consent pattern across the tenant.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.

- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Privileged Users, BB: Compliant Devices, BB: Admin Portals.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 011: Privileged Login Outside Normal Operating Window

Category	Identity and Access
MITRE ATT&CK Mapping	T1078 Valid Accounts
Detection Objective	Detect and investigate privileged login outside normal operating window using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	PAM Logs, AD Security Logs, Entra ID Sign-in Logs, Change Management Feed
Recommended Building Blocks	BB: Privileged Users, BB: Approved Change Window, BB: Emergency Access Accounts
Recommended Alert Name	2026 - Privileged Login Outside Normal Operating Window
Recommended Incident Name	Possible Privileged Login Outside Normal Operating Window Investigation

1. Scenario

A privileged account is used at 02:00 without an approved change request or incident record.

Identity-led intrusion is one of the most important 2026 detection areas because attackers increasingly try to log in using stolen credentials, tokens or weakened authentication rather than only deploying obvious malware.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1078 Valid Accounts. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
PAM Logs	Provides privileged session evidence for Privileged Login Outside Normal Operating Window. It links admin activity to approved access requests, password checkouts, session recordings, commands executed, target systems and vendor/user identity.	Simulation: admin checked out domain admin password at 02:11 with no matching change ticket, then logged into SRV-DC01. This requires privileged access validation.
AD Security Logs	Provides on-premise identity and Windows authentication evidence for Privileged Login Outside Normal Operating Window. Useful fields include Event ID 4624, 4625, 4672, 4720, 4728, 4732, 4768, 4769, 4771, logon type, source workstation, target account and privilege assignment.	Simulation: EventID=4625 repeated failures from WS-0441, followed by EventID=4624 successful logon type 10 to SRV-FILE01. If EventID=4672 also appears, the account received privileged logon rights.
Entra ID Sign-in Logs	Provides cloud identity evidence for Privileged Login Outside Normal Operating Window. Key fields include user principal name, sign-in time, source IP, country, ASN, device ID, compliance state, MFA result, conditional access result, client app and target application. This telemetry shows whether the activity is normal user access or suspicious identity behaviour.	Simulation: user=farah.finance@company.com, app=Exchange Online, source_ip=185.220.101.34, country=DE, device=Unknown, MFA=satisfied_by_token, result=Success. This is abnormal because the user normally authenticates from Malaysia using a managed device.
Change Management Feed	Provides supporting evidence for Privileged Login Outside Normal Operating Window. The analyst should	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Privileged

	confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Login Outside Normal Operating Window. If the evidence is incomplete, the analyst should request the missing log source before closure.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Privileged Login Outside Normal Operating Window, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Privileged Login Outside Normal Operating Window. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Privileged Login Outside Normal Operating Window. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Privileged Login Outside Normal Operating Window. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Privileged Login Outside Normal Operating Window was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Privileged Login Outside Normal Operating Window. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Privileged Login Outside Normal Operating Window, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

	proves whether the activity was benign, attempted, blocked, successful or still unknown.	
--	--	--

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Privileged Users: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Approved Change Window: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Emergency Access Accounts: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Privileged Users, BB: Approved Change Window, BB: Emergency Access Accounts];

FROM PAM Logs, AD Security Logs, Entra ID Sign-in Logs

WHERE TimeGenerated >= now() - lookback

AND event_matches('Privileged Login Outside Normal Operating Window')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Privileged Login Outside Normal Operating Window
Incident Name	Possible Privileged Login Outside Normal Operating Window Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Identity and Access

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Privileged Login Outside Normal Operating Window Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 09:33:00	PAM Logs	user1011@example.local	WS-2011	203.0.113.78	Initial signal	Event indicates privileged login outside normal operating window.
2026-05-18 09:35:00	AD Security Logs	user1011@example.local	WS-2011	203.0.113.78	Context signal	Entity context matched BB: Privileged Users.
2026-05-18 09:40:00	Entra ID Sign-in Logs	user1011@example.local	WS-2011	10.20.11.122	Follow-on activity	Related activity observed in M365.
2026-05-18 09:43:00	SIEM Correlation	user1011@example.local	WS-2011	203.0.113.78	Rule matched	Correlation matched building blocks: BB: Privileged Users, BB: Approved Change Window.
2026-05-18 09:51:00	SOC Case Record	user1011@example.local	WS-2011	203.0.113.78	Incident created	Incident created for Privileged Login Outside Normal Operating Window with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- Was MFA satisfied normally, bypassed, repeatedly challenged or modified?
- Should active sessions or tokens be revoked while validation is ongoing?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.

- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Consider session revocation, password reset, MFA reset, OAuth grant removal, conditional access review and account disablement based on confirmation.
- Hunt for the same IP, application, token, user-agent, app ID or consent pattern across the tenant.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Privileged Users, BB: Approved Change Window, BB: Emergency Access Accounts.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 012: Successful Legacy Authentication to Cloud Mailbox

Category	Identity and Access
MITRE ATT&CK Mapping	T1078.004 Cloud Accounts
Detection Objective	Detect and investigate successful legacy authentication to cloud mailbox using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Entra ID Sign-in Logs, Exchange Online Logs
Recommended Building Blocks	BB: Legacy Auth Protocols, BB: Sensitive Mailboxes, BB: Approved Legacy Exceptions
Recommended Alert Name	2026 - Successful Legacy Authentication to Cloud Mailbox
Recommended Incident Name	Possible Successful Legacy Authentication to Cloud Mailbox Investigation

1. Scenario

A mailbox is accessed using legacy/basic authentication that bypasses modern conditional access expectations.

Identity-led intrusion is one of the most important 2026 detection areas because attackers increasingly try to log in using stolen credentials, tokens or weakened authentication rather than only deploying obvious malware.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1078.004 Cloud Accounts. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Entra ID Sign-in Logs	Provides cloud identity evidence for Successful Legacy Authentication to Cloud Mailbox. Key fields include user principal name, sign-in time, source IP, country, ASN, device ID, compliance state, MFA result, conditional access result, client app and target application. This telemetry shows whether the activity is normal user access or suspicious identity behaviour.	Simulation: user=farah.finance@company.com, app=Exchange Online, source_ip=185.220.101.34, country=DE, device=Unknown, MFA=satisfied_by_token, result=Success. This is abnormal because the user normally authenticates from Malaysia using a managed device.
Exchange Online Logs	Provides post-authentication activity for Successful Legacy Authentication to Cloud Mailbox. It shows what the user or application did after login, such as mailbox access, inbox rule creation, file download, file sharing, Teams activity, OneDrive sync, SharePoint access and administrative changes.	Simulation: 09:20 MailItemsAccessed from Exchange Online; 09:24 New-InboxRule forwards mail externally; 09:32 FileDownloaded from /Finance/Budget2026.xlsx. This converts a login anomaly into a possible account compromise or data exposure incident.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Successful Legacy Authentication to Cloud Mailbox, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.

	incident.	
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Successful Legacy Authentication to Cloud Mailbox. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Successful Legacy Authentication to Cloud Mailbox. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Successful Legacy Authentication to Cloud Mailbox. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Successful Legacy Authentication to Cloud Mailbox was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Successful Legacy Authentication to Cloud Mailbox. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Successful Legacy Authentication to Cloud Mailbox, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Legacy Auth Protocols: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Sensitive Mailboxes: maintain the list owner, update frequency, source of truth and exception approval process.

- BB: Approved Legacy Exceptions: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Legacy Auth Protocols, BB: Sensitive Mailboxes, BB: Approved Legacy Exceptions];

FROM Entra ID Sign-in Logs, Exchange Online Logs

WHERE TimeGenerated >= now() - lookback

AND event_matches('Successful Legacy Authentication to Cloud Mailbox')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Successful Legacy Authentication to Cloud Mailbox
Incident Name	Possible Successful Legacy Authentication to Cloud Mailbox Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Identity and Access

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Successful Legacy Authentication to Cloud Mailbox Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 09:36:00	Entra ID Sign-in Logs	user1012@example.local	WS-2012	203.0.113.85	Initial signal	Event indicates successful legacy authentication to cloud mailbox.
2026-05-18 09:38:00	Exchange Online Logs	user1012@example.local	WS-2012	203.0.113.85	Context signal	Entity context matched BB: Legacy Auth Protocols.
2026-05-18 09:43:00	Entra ID Sign-in Logs	user1012@example.local	WS-2012	10.20.12.133	Follow-on activity	Related activity observed in M365.
2026-05-18 09:46:00	SIEM Correlation	user1012@example.local	WS-2012	203.0.113.85	Rule matched	Correlation matched building blocks: BB: Legacy Auth Protocols, BB: Sensitive Mailboxes.
2026-05-18 09:54:00	SOC Case Record	user1012@example.local	WS-2012	203.0.113.85	Incident created	Incident created for Successful Legacy Authentication to Cloud Mailbox with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- Was MFA satisfied normally, bypassed, repeatedly challenged or modified?
- Should active sessions or tokens be revoked while validation is ongoing?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Consider session revocation, password reset, MFA reset, OAuth grant removal, conditional access review and account disablement based on confirmation.
- Hunt for the same IP, application, token, user-agent, app ID or consent pattern across the tenant.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.

- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Legacy Auth Protocols, BB: Sensitive Mailboxes, BB: Approved Legacy Exceptions.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 013: Login from Anonymous Proxy or TOR Exit Node

Category	Identity and Access
MITRE ATT&CK Mapping	T1090 Proxy; T1078 Valid Accounts
Detection Objective	Detect and investigate login from anonymous proxy or tor exit node using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Entra ID Sign-in Logs, VPN Logs, Threat Intel GeoIP
Recommended Building Blocks	BB: Anonymous Proxy IPs, BB: TOR Exit Nodes, BB: Approved VPN Providers
Recommended Alert Name	2026 - Login from Anonymous Proxy or TOR Exit Node
Recommended Incident Name	Possible Login from Anonymous Proxy or TOR Exit Node Investigation

1. Scenario

A valid user login originates from anonymisation infrastructure and is followed by cloud resource access.

Identity-led intrusion is one of the most important 2026 detection areas because attackers increasingly try to log in using stolen credentials, tokens or weakened authentication rather than only deploying obvious malware.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1090 Proxy; T1078 Valid Accounts. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Entra ID Sign-in Logs	Provides cloud identity evidence for Login from Anonymous Proxy or TOR Exit Node. Key fields include user principal name, sign-in time, source IP, country, ASN, device ID, compliance state, MFA result, conditional access result, client app and target application. This telemetry shows whether the activity is normal user access or suspicious identity behaviour.	Simulation: user=farah.finance@company.com, app=Exchange Online, source_ip=185.220.101.34, country=DE, device=Unknown, MFA=satisfied_by_token, result=Success. This is abnormal because the user normally authenticates from Malaysia using a managed device.
VPN Logs	Shows remote access activity related to Login from Anonymous Proxy or TOR Exit Node, including login time, public source IP, assigned internal IP, VPN gateway, session duration and disconnect reason. It is useful for correlating cloud sign-ins with remote network access and internal movement.	Simulation: VPN login at 09:05 from 185.220.101.34 assigned internal IP 10.44.21.77, then the same user performs M365 access at 09:08. This supports a single attacker session rather than two unrelated events.
Threat Intel GeoIP	Shows the network origin and destination of activity linked to Login from Anonymous Proxy or TOR Exit Node. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Login from	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access;

	Anonymous Proxy or TOR Exit Node, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Login from Anonymous Proxy or TOR Exit Node. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Login from Anonymous Proxy or TOR Exit Node. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Login from Anonymous Proxy or TOR Exit Node. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Login from Anonymous Proxy or TOR Exit Node was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Login from Anonymous Proxy or TOR Exit Node. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Login from Anonymous Proxy or TOR Exit Node, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Anonymous Proxy IPs: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: TOR Exit Nodes: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Approved VPN Providers: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Anonymous Proxy IPs, BB: TOR Exit Nodes, BB: Approved VPN Providers];

FROM Entra ID Sign-in Logs, VPN Logs, Threat Intel GeoIP

WHERE TimeGenerated >= now() - lookback

AND event_matches('Login from Anonymous Proxy or TOR Exit Node')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Login from Anonymous Proxy or TOR Exit Node
Incident Name	Possible Login from Anonymous Proxy or TOR Exit Node Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Identity and Access

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Login from Anonymous Proxy or TOR Exit Node Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.

- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 09:39:00	Entra ID Sign-in Logs	user1013@example.local	WS-2013	203.0.113.92	Initial signal	Event indicates login from anonymous proxy or tor exit node.
2026-05-18 09:41:00	VPN Logs	user1013@example.local	WS-2013	203.0.113.92	Context signal	Entity context matched BB: Anonymous Proxy IPs.
2026-05-18 09:46:00	Threat Intel GeolIP	user1013@example.local	WS-2013	10.20.13.144	Follow-on activity	Related activity observed in M365.
2026-05-18 09:49:00	SIEM Correlation	user1013@example.local	WS-2013	203.0.113.92	Rule matched	Correlation matched building blocks: BB: Anonymous Proxy IPs, BB: TOR Exit Nodes.
2026-05-18 09:57:00	SOC Case Record	user1013@example.local	WS-2013	203.0.113.92	Incident created	Incident created for Login from Anonymous Proxy or TOR Exit Node with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- Was MFA satisfied normally, bypassed, repeatedly challenged or modified?
- Should active sessions or tokens be revoked while validation is ongoing?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Consider session revocation, password reset, MFA reset, OAuth grant removal, conditional access review and account disablement based on confirmation.
- Hunt for the same IP, application, token, user-agent, app ID or consent pattern across the tenant.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Anonymous Proxy IPs, BB: TOR Exit Nodes, BB: Approved VPN Providers.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 014: Session Token Replay Across Unusual ASN or Device

Category	Identity and Access
MITRE ATT&CK Mapping	T1550 Use Alternate Authentication Material
Detection Objective	Detect and investigate session token replay across unusual asn or device using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Entra ID Sign-in Logs, M365 Audit, CASB Logs, Proxy Logs
Recommended Building Blocks	BB: New Device For User, BB: New ASN For User, BB: MFA Not Satisfied, BB: Sensitive Apps
Recommended Alert Name	2026 - Session Token Replay Across Unusual ASN or Device
Recommended Incident Name	Possible Session Token Replay Across Unusual ASN or Device Investigation

1. Scenario

A user session appears to continue from a different network and device without normal interactive MFA flow.

Identity-led intrusion is one of the most important 2026 detection areas because attackers increasingly try to log in using stolen credentials, tokens or weakened authentication rather than only deploying obvious malware.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1550 Use Alternate Authentication Material. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Entra ID Sign-in Logs	Provides cloud identity evidence for Session Token Replay Across Unusual ASN or Device. Key fields include user principal name, sign-in time, source IP, country, ASN, device ID, compliance state, MFA result, conditional access result, client app and target application. This telemetry shows whether the activity is normal user access or suspicious identity behaviour.	Simulation: user=farah.finance@company.com, app=Exchange Online, source_ip=185.220.101.34, country=DE, device=Unknown, MFA=satisfied_by_token, result=Success. This is abnormal because the user normally authenticates from Malaysia using a managed device.
M365 Audit	Provides post-authentication activity for Session Token Replay Across Unusual ASN or Device. It shows what the user or application did after login, such as mailbox access, inbox rule creation, file download, file sharing, Teams activity, OneDrive sync, SharePoint access and administrative changes.	Simulation: 09:20 MailItemsAccessed from Exchange Online; 09:24 New-InboxRule forwards mail externally; 09:32 FileDownloaded from /Finance/Budget2026.xlsx. This converts a login anomaly into a possible account compromise or data exposure incident.
CASB Logs	Shows data protection evidence for Session Token Replay Across Unusual ASN or Device. DLP/CASB telemetry confirms whether sensitive data was uploaded, shared, pasted, copied, synchronised or transferred to external services.	Simulation: DLP policy=Customer PII, destination=personal-cloud.example, action=AllowedWithAlert, file=Customer_List_2026.xlsx. This is evidence for possible data leakage.
Proxy Logs	Shows outbound web access linked to Session Token Replay Across Unusual ASN or Device, including URL, domain,	Simulation: user=farah.finance, url=hxxps://unknown-file-share.example/upload,

	category, upload/download size, HTTP method, user-agent, action and reputation. It helps confirm phishing clicks, payload downloads, C2, exfiltration or unapproved AI/cloud tool usage.	bytes_out=524288000, action=Allowed. If this occurs after sensitive file access, investigate possible exfiltration.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Session Token Replay Across Unusual ASN or Device, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Session Token Replay Across Unusual ASN or Device. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Session Token Replay Across Unusual ASN or Device. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Session Token Replay Across Unusual ASN or Device. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Session Token Replay Across Unusual ASN or Device was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Session Token Replay Across Unusual ASN or Device. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Session Token Replay Across Unusual ASN or Device, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on

	be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	activity exists, document containment evidence and close as attempted/blocked.
--	---	--

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: New Device For User: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: New ASN For User: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: MFA Not Satisfied: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Sensitive Apps: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: New Device For User, BB: New ASN For User, BB: MFA Not Satisfied];

FROM Entra ID Sign-in Logs, M365 Audit, CASB Logs

WHERE TimeGenerated >= now() - lookback

AND event_matches('Session Token Replay Across Unusual ASN or Device')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Session Token Replay Across Unusual ASN or Device
Incident Name	Possible Session Token Replay Across Unusual ASN or Device Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Identity and Access

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token,

file hash or destination within a 24-hour window. The incident should be titled 'Possible Session Token Replay Across Unusual ASN or Device Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 09:42:00	Entra ID Sign-in Logs	user1014@example.local	WS-2014	203.0.113.99	Initial signal	Event indicates session token replay across unusual asn or device.
2026-05-18 09:44:00	M365 Audit	user1014@example.local	WS-2014	203.0.113.99	Context signal	Entity context matched BB: New Device For User.
2026-05-18 09:49:00	CASB Logs	user1014@example.local	WS-2014	10.20.14.155	Follow-on activity	Related activity observed in M365.
2026-05-18 09:52:00	SIEM Correlation	user1014@example.local	WS-2014	203.0.113.99	Rule matched	Correlation matched building blocks: BB: New Device For User, BB: New ASN For User.
2026-05-18 10:00:00	SOC Case Record	user1014@example.local	WS-2014	203.0.113.99	Incident created	Incident created for Session Token Replay Across Unusual ASN or Device with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- Was MFA satisfied normally, bypassed, repeatedly challenged or modified?
- Should active sessions or tokens be revoked while validation is ongoing?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.

- Consider session revocation, password reset, MFA reset, OAuth grant removal, conditional access review and account disablement based on confirmation.
- Hunt for the same IP, application, token, user-agent, app ID or consent pattern across the tenant.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: New Device For User, BB: New ASN For User, BB: MFA Not Satisfied, BB: Sensitive Apps.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 015: Risky Sign-in Followed by Sensitive Application Access

Category	Identity and Access
MITRE ATT&CK Mapping	T1078 Valid Accounts; T1530 Data from Cloud Storage
Detection Objective	Detect and investigate risky sign-in followed by sensitive application access using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Entra ID Sign-in Logs, M365 Audit, SaaS Audit Logs, CASB Logs
Recommended Building Blocks	BB: Risky Sign-in, BB: Sensitive Applications, BB: Critical Data Repositories
Recommended Alert Name	2026 - Risky Sign-in Followed by Sensitive Application Access
Recommended Incident Name	Possible Risky Sign-in Followed by Sensitive Application Access Investigation

1. Scenario

A suspicious sign-in is followed by access to HR, finance or customer-data platforms.

Identity-led intrusion is one of the most important 2026 detection areas because attackers increasingly try to log in using stolen credentials, tokens or weakened authentication rather than only deploying obvious malware.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1078 Valid Accounts; T1530 Data from Cloud Storage. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Entra ID Sign-in Logs	Provides cloud identity evidence for Risky Sign-in Followed by Sensitive Application Access. Key fields include user principal name, sign-in time, source IP, country, ASN, device ID, compliance state, MFA result, conditional access result, client app and target application. This telemetry shows whether the activity is normal user access or suspicious identity behaviour.	Simulation: user=farah.finance@company.com, app=Exchange Online, source_ip=185.220.101.34, country=DE, device=Unknown, MFA=satisfied_by_token, result=Success. This is abnormal because the user normally authenticates from Malaysia using a managed device.
M365 Audit	Provides post-authentication activity for Risky Sign-in Followed by Sensitive Application Access. It shows what the user or application did after login, such as mailbox access, inbox rule creation, file download, file sharing, Teams activity, OneDrive sync, SharePoint access and administrative changes.	Simulation: 09:20 MailItemsAccessed from Exchange Online; 09:24 New-InboxRule forwards mail externally; 09:32 FileDownloaded from /Finance/Budget2026.xlsx. This converts a login anomaly into a possible account compromise or data exposure incident.
SaaS Audit Logs	Provides supporting evidence for Risky Sign-in Followed by Sensitive Application Access. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Risky Sign-in Followed by Sensitive Application Access. If the evidence is incomplete, the analyst should request the missing log source before closure.
CASB Logs	Shows data protection evidence for Risky Sign-in Followed by Sensitive Application Access. DLP/CASB telemetry confirms	Simulation: DLP policy=Customer PII, destination=personal-cloud.example, action=AllowedWithAlert,

	whether sensitive data was uploaded, shared, pasted, copied, synchronised or transferred to external services.	file=Customer_List_2026.xlsx. This is evidence for possible data leakage.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Risky Sign-in Followed by Sensitive Application Access, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Risky Sign-in Followed by Sensitive Application Access. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Risky Sign-in Followed by Sensitive Application Access. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Risky Sign-in Followed by Sensitive Application Access. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Risky Sign-in Followed by Sensitive Application Access was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Risky Sign-in Followed by Sensitive Application Access. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Risky Sign-in Followed by Sensitive Application Access, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment

	telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	evidence and close as attempted/blocked.
--	--	--

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Risky Sign-in: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Sensitive Applications: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Critical Data Repositories: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Risky Sign-in, BB: Sensitive Applications, BB: Critical Data Repositories];

FROM Entra ID Sign-in Logs, M365 Audit, SaaS Audit Logs

WHERE TimeGenerated >= now() - lookback

AND event_matches('Risky Sign-in Followed by Sensitive Application Access')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Risky Sign-in Followed by Sensitive Application Access
Incident Name	Possible Risky Sign-in Followed by Sensitive Application Access Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Identity and Access

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token,

file hash or destination within a 24-hour window. The incident should be titled 'Possible Risky Sign-in Followed by Sensitive Application Access Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 09:45:00	Entra ID Sign-in Logs	user1015@example.local	WS-2015	203.0.113.106	Initial signal	Event indicates risky sign-in followed by sensitive application access.
2026-05-18 09:47:00	M365 Audit	user1015@example.local	WS-2015	203.0.113.106	Context signal	Entity context matched BB: Risky Sign-in.
2026-05-18 09:52:00	SaaS Audit Logs	user1015@example.local	WS-2015	10.20.15.166	Follow-on activity	Related activity observed in M365.
2026-05-18 09:55:00	SIEM Correlation	user1015@example.local	WS-2015	203.0.113.106	Rule matched	Correlation matched building blocks: BB: Risky Sign-in, BB: Sensitive Applications.
2026-05-18 10:03:00	SOC Case Record	user1015@example.local	WS-2015	203.0.113.106	Incident created	Incident created for Risky Sign-in Followed by Sensitive Application Access with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- Was MFA satisfied normally, bypassed, repeatedly challenged or modified?
- Should active sessions or tokens be revoked while validation is ongoing?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.

- Consider session revocation, password reset, MFA reset, OAuth grant removal, conditional access review and account disablement based on confirmation.
- Hunt for the same IP, application, token, user-agent, app ID or consent pattern across the tenant.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Risky Sign-in, BB: Sensitive Applications, BB: Critical Data Repositories.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 016: User Added to Domain Admins or Global Admins

Category	Privileged Access, AD and PAM
MITRE ATT&CK Mapping	T1098 Account Manipulation; T1078 Valid Accounts
Detection Objective	Detect and investigate user added to domain admins or global admins using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	AD Security Logs, Entra ID Audit Logs, PAM Logs
Recommended Building Blocks	BB: Privileged Groups, BB: Approved Change Tickets, BB: Break-Glass Accounts
Recommended Alert Name	2026 - User Added to Domain Admins or Global Admins
Recommended Incident Name	Possible User Added to Domain Admins or Global Admins Investigation

1. Scenario

A normal account is added to a high-privilege group outside a documented change window.

Privileged access monitoring protects the control plane of the organisation. A single unauthorised privileged action can change policy, disable controls, expose credentials or enable lateral movement.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1098 Account Manipulation; T1078 Valid Accounts. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
AD Security Logs	Provides on-premise identity and Windows authentication evidence for User Added to Domain Admins or Global Admins. Useful fields include Event ID 4624, 4625, 4672, 4720, 4728, 4732, 4768, 4769, 4771, logon type, source workstation, target account and privilege assignment.	Simulation: EventID=4625 repeated failures from WS-0441, followed by EventID=4624 successful logon type 10 to SRV-FILE01. If EventID=4672 also appears, the account received privileged logon rights.
Entra ID Audit Logs	Provides cloud identity evidence for User Added to Domain Admins or Global Admins. Key fields include user principal name, sign-in time, source IP, country, ASN, device ID, compliance state, MFA result, conditional access result, client app and target application. This telemetry shows whether the activity is normal user access or suspicious identity behaviour.	Simulation: user=farah.finance@company.com, app=Exchange Online, source_ip=185.220.101.34, country=DE, device=Unknown, MFA=satisfied_by_token, result=Success. This is abnormal because the user normally authenticates from Malaysia using a managed device.
PAM Logs	Provides privileged session evidence for User Added to Domain Admins or Global Admins. It links admin activity to approved access requests, password checkouts, session recordings, commands executed, target systems and vendor/user identity.	Simulation: admin checked out domain admin password at 02:11 with no matching change ticket, then logged into SRV-DC01. This requires privileged access validation.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For User Added to Domain Admins or Global Admins, the analyst must compare the first suspicious event,	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation

	the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in User Added to Domain Admins or Global Admins. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to User Added to Domain Admins or Global Admins. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to User Added to Domain Admins or Global Admins. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in User Added to Domain Admins or Global Admins was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during User Added to Domain Admins or Global Admins. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For User Added to Domain Admins or Global Admins, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Privileged Groups: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Approved Change Tickets: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Break-Glass Accounts: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Privileged Groups, BB: Approved Change Tickets, BB: Break-Glass Accounts];

FROM AD Security Logs, Entra ID Audit Logs, PAM Logs

WHERE TimeGenerated >= now() - lookback

AND event_matches('User Added to Domain Admins or Global Admins')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - User Added to Domain Admins or Global Admins
Incident Name	Possible User Added to Domain Admins or Global Admins Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Privileged Access, AD and PAM

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible User Added to Domain Admins or Global Admins Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.

- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 09:48:00	AD Security Logs	user1016@example.local	WS-2016	203.0.113.113	Initial signal	Event indicates user added to domain admins or global admins.
2026-05-18 09:50:00	Entra ID Audit Logs	user1016@example.local	WS-2016	203.0.113.113	Context signal	Entity context matched BB: Privileged Groups.
2026-05-18 09:55:00	PAM Logs	user1016@example.local	WS-2016	10.20.16.177	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 09:58:00	SIEM Correlation	user1016@example.local	WS-2016	203.0.113.113	Rule matched	Correlation matched building blocks: BB: Privileged Groups, BB: Approved Change Tickets.
2026-05-18 10:06:00	SOC Case Record	user1016@example.local	WS-2016	203.0.113.113	Incident created	Incident created for User Added to Domain Admins or Global Admins with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.

- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Privileged Groups, BB: Approved Change Tickets, BB: Break-Glass Accounts.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 017: DCSync or Directory Replication Abuse Indicator

Category	Privileged Access, AD and PAM
MITRE ATT&CK Mapping	T1003.006 DCSync
Detection Objective	Detect and investigate dcsync or directory replication abuse indicator using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	AD Directory Service Logs, Windows Security Logs, EDR
Recommended Building Blocks	BB: Domain Controllers, BB: Approved Replication Accounts, BB: Privileged Users
Recommended Alert Name	2026 - DCSync or Directory Replication Abuse Indicator
Recommended Incident Name	Possible DCSync or Directory Replication Abuse Indicator Investigation

1. Scenario

A non-domain-controller account performs replication-like directory access that may indicate credential theft attempt.

Privileged access monitoring protects the control plane of the organisation. A single unauthorised privileged action can change policy, disable controls, expose credentials or enable lateral movement.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1003.006 DCSync. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
AD Directory Service Logs	Provides supporting evidence for DCSync or Directory Replication Abuse Indicator. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for DCSync or Directory Replication Abuse Indicator. If the evidence is incomplete, the analyst should request the missing log source before closure.
Windows Security Logs	Provides on-premise identity and Windows authentication evidence for DCSync or Directory Replication Abuse Indicator. Useful fields include Event ID 4624, 4625, 4672, 4720, 4728, 4732, 4768, 4769, 4771, logon type, source workstation, target account and privilege assignment.	Simulation: EventID=4625 repeated failures from WS-0441, followed by EventID=4624 successful logon type 10 to SRV-FILE01. If EventID=4672 also appears, the account received privileged logon rights.
EDR	Provides endpoint execution and host-level evidence for DCSync or Directory Replication Abuse Indicator. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device isolation status and sensor health.	Simulation: parent=explorer.exe, child=powershell.exe, command='-EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution rather than only file delivery.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For DCSync or Directory Replication Abuse Indicator, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.

	reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in DCSync or Directory Replication Abuse Indicator. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to DCSync or Directory Replication Abuse Indicator. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to DCSync or Directory Replication Abuse Indicator. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in DCSync or Directory Replication Abuse Indicator was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during DCSync or Directory Replication Abuse Indicator. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For DCSync or Directory Replication Abuse Indicator, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Domain Controllers: maintain the list owner, update frequency, source of truth and exception approval process.

- BB: Approved Replication Accounts: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Privileged Users: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Domain Controllers, BB: Approved Replication Accounts, BB: Privileged Users];

FROM AD Directory Service Logs, Windows Security Logs, EDR

WHERE TimeGenerated >= now() - lookback

AND event_matches('DCSync or Directory Replication Abuse Indicator')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - DCSync or Directory Replication Abuse Indicator
Incident Name	Possible DCSync or Directory Replication Abuse Indicator Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Privileged Access, AD and PAM

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible DCSync or Directory Replication Abuse Indicator Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 09:51:00	AD Directory Service Logs	user1017@example.local	WS-2017	203.0.113.120	Initial signal	Event indicates dcsync or directory replication abuse indicator.
2026-05-18 09:53:00	Windows Security Logs	user1017@example.local	WS-2017	203.0.113.120	Context signal	Entity context matched BB: Domain Controllers.
2026-05-18 09:58:00	EDR	user1017@example.local	WS-2017	10.20.17.188	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 10:01:00	SIEM Correlation	user1017@example.local	WS-2017	203.0.113.120	Rule matched	Correlation matched building blocks: BB: Domain Controllers, BB: Approved Replication Accounts.
2026-05-18 10:09:00	SOC Case Record	user1017@example.local	WS-2017	203.0.113.120	Incident created	Incident created for DCSync or Directory Replication Abuse Indicator with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Domain Controllers, BB: Approved Replication Accounts, BB: Privileged Users.

- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 018: Kerberoasting-Like Service Ticket Request Spike

Category	Privileged Access, AD and PAM
MITRE ATT&CK Mapping	T1558.003 Kerberoasting
Detection Objective	Detect and investigate kerberoasting-like service ticket request spike using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	AD Kerberos Logs, Windows Security Event 4769, SIEM Aggregation
Recommended Building Blocks	BB: Service Accounts, BB: High-Value SPNs, BB: Normal Ticket Baseline
Recommended Alert Name	2026 - Kerberoasting-Like Service Ticket Request Spike
Recommended Incident Name	Possible Kerberoasting-Like Service Ticket Request Spike Investigation

1. Scenario

One user requests service tickets for many SPNs in a short period, suggesting offline password attack preparation.

Privileged access monitoring protects the control plane of the organisation. A single unauthorised privileged action can change policy, disable controls, expose credentials or enable lateral movement.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1558.003 Kerberoasting. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
AD Kerberos Logs	Provides on-premise identity and Windows authentication evidence for Kerberoasting-Like Service Ticket Request Spike. Useful fields include Event ID 4624, 4625, 4672, 4720, 4728, 4732, 4768, 4769, 4771, logon type, source workstation, target account and privilege assignment.	Simulation: EventID=4625 repeated failures from WS-0441, followed by EventID=4624 successful logon type 10 to SRV-FILE01. If EventID=4672 also appears, the account received privileged logon rights.
Windows Security Event 4769	Provides on-premise identity and Windows authentication evidence for Kerberoasting-Like Service Ticket Request Spike. Useful fields include Event ID 4624, 4625, 4672, 4720, 4728, 4732, 4768, 4769, 4771, logon type, source workstation, target account and privilege assignment.	Simulation: EventID=4625 repeated failures from WS-0441, followed by EventID=4624 successful logon type 10 to SRV-FILE01. If EventID=4672 also appears, the account received privileged logon rights.
SIEM Aggregation	Adds external intelligence context to Kerberoasting-Like Service Ticket Request Spike. IOC, actor, campaign, reputation, first-seen date and confidence help prioritise alerts and connect internal evidence to known malicious infrastructure.	Simulation: destination IP matched TI feed as malware C2 with confidence=High, first_seen=2026-02-10. If internal host communicated successfully, investigate compromise evidence.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Kerberoasting-Like Service Ticket Request Spike, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.

	decide whether the activity is an isolated event or part of a chained incident.	
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Kerberoasting-Like Service Ticket Request Spike. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Kerberoasting-Like Service Ticket Request Spike. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Kerberoasting-Like Service Ticket Request Spike. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Kerberoasting-Like Service Ticket Request Spike was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Kerberoasting-Like Service Ticket Request Spike. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Kerberoasting-Like Service Ticket Request Spike, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Service Accounts: maintain the list owner, update frequency, source of truth and exception approval process.

- BB: High-Value SPNs: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Normal Ticket Baseline: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Service Accounts, BB: High-Value SPNs, BB: Normal Ticket Baseline];

FROM AD Kerberos Logs, Windows Security Event 4769, SIEM Aggregation

WHERE TimeGenerated >= now() - lookback

AND event_matches('Kerberoasting-Like Service Ticket Request Spike')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Kerberoasting-Like Service Ticket Request Spike
Incident Name	Possible Kerberoasting-Like Service Ticket Request Spike Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Privileged Access, AD and PAM

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Kerberoasting-Like Service Ticket Request Spike Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 09:54:00	AD Kerberos Logs	user1018@example.local	WS-2018	203.0.113.127	Initial signal	Event indicates kerberoasting-like service ticket request spike.
2026-05-18 09:56:00	Windows Security Event 4769	user1018@example.local	WS-2018	203.0.113.127	Context signal	Entity context matched BB: Service Accounts.
2026-05-18 10:01:00	SIEM Aggregation	user1018@example.local	WS-2018	10.20.18.199	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 10:04:00	SIEM Correlation	user1018@example.local	WS-2018	203.0.113.127	Rule matched	Correlation matched building blocks: BB: Service Accounts, BB: High-Value SPNs.
2026-05-18 10:12:00	SOC Case Record	user1018@example.local	WS-2018	203.0.113.127	Incident created	Incident created for Kerberoasting-Like Service Ticket Request Spike with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Service Accounts, BB: High-Value SPNs, BB: Normal Ticket Baseline.

- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 019: GPO Modified to Weaken Security Controls

Category	Privileged Access, AD and PAM
MITRE ATT&CK Mapping	T1484 Domain Policy Modification; T1562 Impair Defenses
Detection Objective	Detect and investigate gpo modified to weaken security controls using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	AD GPO Change Logs, Windows Security Logs, EDR Policy Logs
Recommended Building Blocks	BB: Critical GPOs, BB: Security Baseline Policies, BB: Approved Change Window
Recommended Alert Name	2026 - GPO Modified to Weaken Security Controls
Recommended Incident Name	Possible GPO Modified to Weaken Security Controls Investigation

1. Scenario

A Group Policy Object is changed to disable logging, antivirus, script restrictions or firewall settings.

Privileged access monitoring protects the control plane of the organisation. A single unauthorised privileged action can change policy, disable controls, expose credentials or enable lateral movement.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1484 Domain Policy Modification; T1562 Impair Defenses. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
AD GPO Change Logs	Provides supporting evidence for GPO Modified to Weaken Security Controls. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for GPO Modified to Weaken Security Controls. If the evidence is incomplete, the analyst should request the missing log source before closure.
Windows Security Logs	Provides on-premise identity and Windows authentication evidence for GPO Modified to Weaken Security Controls. Useful fields include Event ID 4624, 4625, 4672, 4720, 4728, 4732, 4768, 4769, 4771, logon type, source workstation, target account and privilege assignment.	Simulation: EventID=4625 repeated failures from WS-0441, followed by EventID=4624 successful logon type 10 to SRV-FILE01. If EventID=4672 also appears, the account received privileged logon rights.
EDR Policy Logs	Provides endpoint execution and host-level evidence for GPO Modified to Weaken Security Controls. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device isolation status and sensor health.	Simulation: parent=explorer.exe, child=powershell.exe, command='-EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution rather than only file delivery.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For GPO Modified to Weaken Security Controls, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.

	reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in GPO Modified to Weaken Security Controls. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to GPO Modified to Weaken Security Controls. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to GPO Modified to Weaken Security Controls. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in GPO Modified to Weaken Security Controls was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during GPO Modified to Weaken Security Controls. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For GPO Modified to Weaken Security Controls, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Critical GPOs: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Security Baseline Policies: maintain the list owner, update frequency, source of truth and exception approval process.

- BB: Approved Change Window: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Critical GPOs, BB: Security Baseline Policies, BB: Approved Change Window];

FROM AD GPO Change Logs, Windows Security Logs, EDR Policy Logs

WHERE TimeGenerated >= now() - lookback

AND event_matches('GPO Modified to Weaken Security Controls')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - GPO Modified to Weaken Security Controls
Incident Name	Possible GPO Modified to Weaken Security Controls Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Privileged Access, AD and PAM

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible GPO Modified to Weaken Security Controls Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 09:57:00	AD GPO Change Logs	user1019@example.local	WS-2019	203.0.113.134	Initial signal	Event indicates gpo modified to weaken security controls.
2026-05-18 09:59:00	Windows Security Logs	user1019@example.local	WS-2019	203.0.113.134	Context signal	Entity context matched BB: Critical GPOs.
2026-05-18 10:04:00	EDR Policy Logs	user1019@example.local	WS-2019	10.20.19.210	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 10:07:00	SIEM Correlation	user1019@example.local	WS-2019	203.0.113.134	Rule matched	Correlation matched building blocks: BB: Critical GPOs, BB: Security Baseline Policies.
2026-05-18 10:15:00	SOC Case Record	user1019@example.local	WS-2019	203.0.113.134	Incident created	Incident created for GPO Modified to Weaken Security Controls with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Critical GPOs, BB: Security Baseline Policies, BB: Approved Change Window.

- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 020: Remote Service Creation on Multiple Hosts

Category	Privileged Access, AD and PAM
MITRE ATT&CK Mapping	T1021 Remote Services; T1543 Create or Modify System Process
Detection Objective	Detect and investigate remote service creation on multiple hosts using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Windows Security Logs, Sysmon, EDR, AD Logs
Recommended Building Blocks	BB: Admin Shares, BB: Approved Deployment Tools, BB: Critical Servers
Recommended Alert Name	2026 - Remote Service Creation on Multiple Hosts
Recommended Incident Name	Possible Remote Service Creation on Multiple Hosts Investigation

1. Scenario

A single admin account creates services remotely across many endpoints, which may indicate lateral movement.

Privileged access monitoring protects the control plane of the organisation. A single unauthorised privileged action can change policy, disable controls, expose credentials or enable lateral movement.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1021 Remote Services; T1543 Create or Modify System Process. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Windows Security Logs	Provides on-premise identity and Windows authentication evidence for Remote Service Creation on Multiple Hosts. Useful fields include Event ID 4624, 4625, 4672, 4720, 4728, 4732, 4768, 4769, 4771, logon type, source workstation, target account and privilege assignment.	Simulation: EventID=4625 repeated failures from WS-0441, followed by EventID=4624 successful logon type 10 to SRV-FILE01. If EventID=4672 also appears, the account received privileged logon rights.
Sysmon	Provides endpoint execution and host-level evidence for Remote Service Creation on Multiple Hosts. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device isolation status and sensor health.	Simulation: parent=explorer.exe, child=powershell.exe, command='-EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution rather than only file delivery.
EDR	Provides endpoint execution and host-level evidence for Remote Service Creation on Multiple Hosts. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device isolation status and sensor health.	Simulation: parent=explorer.exe, child=powershell.exe, command='-EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution rather than only file delivery.
AD Logs	Provides supporting evidence for Remote Service Creation on Multiple Hosts. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Remote Service Creation on Multiple Hosts. If the evidence is incomplete, the analyst should request the missing log source before

	activity in the same timeline.	closure.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Remote Service Creation on Multiple Hosts, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Remote Service Creation on Multiple Hosts. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Remote Service Creation on Multiple Hosts. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Remote Service Creation on Multiple Hosts. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Remote Service Creation on Multiple Hosts was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Remote Service Creation on Multiple Hosts. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Remote Service Creation on Multiple Hosts, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Admin Shares: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Approved Deployment Tools: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Critical Servers: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Admin Shares, BB: Approved Deployment Tools, BB: Critical Servers];

FROM Windows Security Logs, Sysmon, EDR

WHERE TimeGenerated >= now() - lookback

AND event_matches('Remote Service Creation on Multiple Hosts')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Remote Service Creation on Multiple Hosts
Incident Name	Possible Remote Service Creation on Multiple Hosts Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Privileged Access, AD and PAM

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Remote Service Creation on Multiple Hosts Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.

- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 10:00:00	Windows Security Logs	user1020@example.local	WS-2020	203.0.113.141	Initial signal	Event indicates remote service creation on multiple hosts.
2026-05-18 10:02:00	Sysmon	user1020@example.local	WS-2020	203.0.113.141	Context signal	Entity context matched BB: Admin Shares.
2026-05-18 10:07:00	EDR	user1020@example.local	WS-2020	10.20.20.221	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 10:10:00	SIEM Correlation	user1020@example.local	WS-2020	203.0.113.141	Rule matched	Correlation matched building blocks: BB: Admin Shares, BB: Approved Deployment Tools.
2026-05-18 10:18:00	SOC Case Record	user1020@example.local	WS-2020	203.0.113.141	Incident created	Incident created for Remote Service Creation on Multiple Hosts with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Admin Shares, BB: Approved Deployment Tools, BB: Critical Servers.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 021: WMI Remote Execution from Unusual Host

Category	Privileged Access, AD and PAM
MITRE ATT&CK Mapping	T1047 Windows Management Instrumentation
Detection Objective	Detect and investigate wmi remote execution from unusual host using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Windows Event Logs, Sysmon, EDR, Network Logs
Recommended Building Blocks	BB: Approved Admin Workstations, BB: Server Admin Group, BB: WMI Usage Baseline
Recommended Alert Name	2026 - WMI Remote Execution from Unusual Host
Recommended Incident Name	Possible WMI Remote Execution from Unusual Host Investigation

1. Scenario

A user workstation initiates WMI execution against a server outside expected administration paths.

Privileged access monitoring protects the control plane of the organisation. A single unauthorised privileged action can change policy, disable controls, expose credentials or enable lateral movement.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1047 Windows Management Instrumentation. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Windows Event Logs	Provides supporting evidence for WMI Remote Execution from Unusual Host. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for WMI Remote Execution from Unusual Host. If the evidence is incomplete, the analyst should request the missing log source before closure.
Sysmon	Provides endpoint execution and host-level evidence for WMI Remote Execution from Unusual Host. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device isolation status and sensor health.	Simulation: parent=explorer.exe, child=powershell.exe, command='-EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution rather than only file delivery.
EDR	Provides endpoint execution and host-level evidence for WMI Remote Execution from Unusual Host. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device isolation status and sensor health.	Simulation: parent=explorer.exe, child=powershell.exe, command='-EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution rather than only file delivery.
Network Logs	Provides network movement and perimeter evidence for WMI Remote Execution from Unusual Host. Important fields include source, destination, port, protocol, bytes in/out, action, rule name,	Simulation: source=10.44.21.77, destination=10.10.4.20, port=445, action=Allowed, repeated across 30 hosts. This supports lateral movement or internal scanning analysis.

	zone, IPS signature and session duration.	
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For WMI Remote Execution from Unusual Host, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in WMI Remote Execution from Unusual Host. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to WMI Remote Execution from Unusual Host. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to WMI Remote Execution from Unusual Host. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in WMI Remote Execution from Unusual Host was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during WMI Remote Execution from Unusual Host. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For WMI Remote Execution from Unusual Host, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Approved Admin Workstations: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Server Admin Group: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: WMI Usage Baseline: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Approved Admin Workstations, BB: Server Admin Group, BB: WMI Usage Baseline];

FROM Windows Event Logs, Sysmon, EDR

WHERE TimeGenerated >= now() - lookback

AND event_matches('WMI Remote Execution from Unusual Host')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - WMI Remote Execution from Unusual Host
Incident Name	Possible WMI Remote Execution from Unusual Host Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Privileged Access, AD and PAM

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible WMI Remote Execution from Unusual Host Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.

- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 10:03:00	Windows Event Logs	user1021@example.local	WS-2021	203.0.113.148	Initial signal	Event indicates wmi remote execution from unusual host.
2026-05-18 10:05:00	Sysmon	user1021@example.local	WS-2021	203.0.113.148	Context signal	Entity context matched BB: Approved Admin Workstations.
2026-05-18 10:10:00	EDR	user1021@example.local	WS-2021	10.20.21.232	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 10:13:00	SIEM Correlation	user1021@example.local	WS-2021	203.0.113.148	Rule matched	Correlation matched building blocks: BB: Approved Admin Workstations, BB: Server Admin Group.
2026-05-18 10:21:00	SOC Case Record	user1021@example.local	WS-2021	203.0.113.148	Incident created	Incident created for WMI Remote Execution from Unusual Host with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Approved Admin Workstations, BB: Server Admin Group, BB: WMI Usage Baseline.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 022: PAM Password Checkout Without Approved Ticket

Category	Privileged Access, AD and PAM
MITRE ATT&CK Mapping	T1078 Valid Accounts
Detection Objective	Detect and investigate pam password checkout without approved ticket using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	PAM Logs, ITSM/Change Logs, AD Security Logs
Recommended Building Blocks	BB: PAM Managed Accounts, BB: Approved Ticket Reference, BB: Critical Systems
Recommended Alert Name	2026 - PAM Password Checkout Without Approved Ticket
Recommended Incident Name	Possible PAM Password Checkout Without Approved Ticket Investigation

1. Scenario

A privileged password is checked out without an incident, change or service request record.

Privileged access monitoring protects the control plane of the organisation. A single unauthorised privileged action can change policy, disable controls, expose credentials or enable lateral movement.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1078 Valid Accounts. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
PAM Logs	Provides privileged session evidence for PAM Password Checkout Without Approved Ticket. It links admin activity to approved access requests, password checkouts, session recordings, commands executed, target systems and vendor/user identity.	Simulation: admin checked out domain admin password at 02:11 with no matching change ticket, then logged into SRV-DC01. This requires privileged access validation.
ITSM/Change Logs	Provides supporting evidence for PAM Password Checkout Without Approved Ticket. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for PAM Password Checkout Without Approved Ticket. If the evidence is incomplete, the analyst should request the missing log source before closure.
AD Security Logs	Provides on-premise identity and Windows authentication evidence for PAM Password Checkout Without Approved Ticket. Useful fields include Event ID 4624, 4625, 4672, 4720, 4728, 4732, 4768, 4769, 4771, logon type, source workstation, target account and privilege assignment.	Simulation: EventID=4625 repeated failures from WS-0441, followed by EventID=4624 successful logon type 10 to SRV-FILE01. If EventID=4672 also appears, the account received privileged logon rights.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For PAM Password Checkout Without Approved Ticket, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.

	cannot decide whether the activity is an isolated event or part of a chained incident.	
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in PAM Password Checkout Without Approved Ticket. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to PAM Password Checkout Without Approved Ticket. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to PAM Password Checkout Without Approved Ticket. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in PAM Password Checkout Without Approved Ticket was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during PAM Password Checkout Without Approved Ticket. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For PAM Password Checkout Without Approved Ticket, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: PAM Managed Accounts: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Approved Ticket Reference: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Critical Systems: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: PAM Managed Accounts, BB: Approved Ticket Reference, BB: Critical Systems];

FROM PAM Logs, ITSM/Change Logs, AD Security Logs

WHERE TimeGenerated >= now() - lookback

AND event_matches('PAM Password Checkout Without Approved Ticket')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - PAM Password Checkout Without Approved Ticket
Incident Name	Possible PAM Password Checkout Without Approved Ticket Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Privileged Access, AD and PAM

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible PAM Password Checkout Without Approved Ticket Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.

- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 10:06:00	PAM Logs	user1022@example.local	WS-2022	203.0.113.155	Initial signal	Event indicates pam password checkout without approved ticket.
2026-05-18 10:08:00	ITSM/Change Logs	user1022@example.local	WS-2022	203.0.113.155	Context signal	Entity context matched BB: PAM Managed Accounts.
2026-05-18 10:13:00	AD Security Logs	user1022@example.local	WS-2022	10.20.22.243	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 10:16:00	SIEM Correlation	user1022@example.local	WS-2022	203.0.113.155	Rule matched	Correlation matched building blocks: BB: PAM Managed Accounts, BB: Approved Ticket Reference.
2026-05-18 10:24:00	SOC Case Record	user1022@example.local	WS-2022	203.0.113.155	Incident created	Incident created for PAM Password Checkout Without Approved Ticket with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: PAM Managed Accounts, BB: Approved Ticket Reference, BB: Critical Systems.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 023: Break-Glass Account Used

Category	Privileged Access, AD and PAM
MITRE ATT&CK Mapping	T1078 Valid Accounts
Detection Objective	Detect and investigate break-glass account used using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Entra ID Sign-in Logs, AD Security Logs, PAM Logs
Recommended Building Blocks	BB: Break-Glass Accounts, BB: Emergency Approval List, BB: Critical Alerts
Recommended Alert Name	2026 - Break-Glass Account Used
Recommended Incident Name	Possible Break-Glass Account Used Investigation

1. Scenario

An emergency account is used to sign in when no active outage or incident has been declared.

Privileged access monitoring protects the control plane of the organisation. A single unauthorised privileged action can change policy, disable controls, expose credentials or enable lateral movement.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1078 Valid Accounts. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Entra ID Sign-in Logs	Provides cloud identity evidence for Break-Glass Account Used. Key fields include user principal name, sign-in time, source IP, country, ASN, device ID, compliance state, MFA result, conditional access result, client app and target application. This telemetry shows whether the activity is normal user access or suspicious identity behaviour.	Simulation: user=farah.finance@company.com, app=Exchange Online, source_ip=185.220.101.34, country=DE, device=Unknown, MFA=satisfied_by_token, result=Success. This is abnormal because the user normally authenticates from Malaysia using a managed device.
AD Security Logs	Provides on-premise identity and Windows authentication evidence for Break-Glass Account Used. Useful fields include Event ID 4624, 4625, 4672, 4720, 4728, 4732, 4768, 4769, 4771, logon type, source workstation, target account and privilege assignment.	Simulation: EventID=4625 repeated failures from WS-0441, followed by EventID=4624 successful logon type 10 to SRV-FILE01. If EventID=4672 also appears, the account received privileged logon rights.
PAM Logs	Provides privileged session evidence for Break-Glass Account Used. It links admin activity to approved access requests, password checkouts, session recordings, commands executed, target systems and vendor/user identity.	Simulation: admin checked out domain admin password at 02:11 with no matching change ticket, then logged into SRV-DC01. This requires privileged access validation.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Break-Glass Account Used, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.

	SOC cannot decide whether the activity is an isolated event or part of a chained incident.	
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Break-Glass Account Used. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Break-Glass Account Used. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Break-Glass Account Used. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Break-Glass Account Used was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Break-Glass Account Used. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Break-Glass Account Used, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Break-Glass Accounts: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Emergency Approval List: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Critical Alerts: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Break-Glass Accounts, BB: Emergency Approval List, BB: Critical Alerts];

FROM Entra ID Sign-in Logs, AD Security Logs, PAM Logs

WHERE TimeGenerated >= now() - lookback

AND event_matches('Break-Glass Account Used')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Break-Glass Account Used
Incident Name	Possible Break-Glass Account Used Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Privileged Access, AD and PAM

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Break-Glass Account Used Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 10:09:00	Entra ID Sign-in Logs	user1023@example.local	WS-2023	203.0.113.162	Initial signal	Event indicates break-glass account used.

2026-05-18 10:11:00	AD Security Logs	user1023@example.local	WS-2023	203.0.113.162	Context signal	Entity context matched BB: Break-Glass Accounts.
2026-05-18 10:16:00	PAM Logs	user1023@example.local	WS-2023	10.20.23.4	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 10:19:00	SIEM Correlation	user1023@example.local	WS-2023	203.0.113.162	Rule matched	Correlation matched building blocks: BB: Break-Glass Accounts, BB: Emergency Approval List.
2026-05-18 10:27:00	SOC Case Record	user1023@example.local	WS-2023	203.0.113.162	Incident created	Incident created for Break-Glass Account Used with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Break-Glass Accounts, BB: Emergency Approval List, BB: Critical Alerts.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.

- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 024: Privileged Session Recording Disabled or Missing

Category	Privileged Access, AD and PAM
MITRE ATT&CK Mapping	T1562 Impair Defenses
Detection Objective	Detect and investigate privileged session recording disabled or missing using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	PAM Logs, Session Recording Logs, Admin Portal Audit
Recommended Building Blocks	BB: PAM Sessions, BB: Recording Required Systems, BB: Approved Exemptions
Recommended Alert Name	2026 - Privileged Session Recording Disabled or Missing
Recommended Incident Name	Possible Privileged Session Recording Disabled or Missing Investigation

1. Scenario

A privileged session begins, but expected session recording or audit evidence is missing or disabled.

Privileged access monitoring protects the control plane of the organisation. A single unauthorised privileged action can change policy, disable controls, expose credentials or enable lateral movement.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1562 Impair Defenses. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
PAM Logs	Provides privileged session evidence for Privileged Session Recording Disabled or Missing. It links admin activity to approved access requests, password checkouts, session recordings, commands executed, target systems and vendor/user identity.	Simulation: admin checked out domain admin password at 02:11 with no matching change ticket, then logged into SRV-DC01. This requires privileged access validation.
Session Recording Logs	Provides supporting evidence for Privileged Session Recording Disabled or Missing. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Privileged Session Recording Disabled or Missing. If the evidence is incomplete, the analyst should request the missing log source before closure.
Admin Portal Audit	Provides supporting evidence for Privileged Session Recording Disabled or Missing. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Privileged Session Recording Disabled or Missing. If the evidence is incomplete, the analyst should request the missing log source before closure.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Privileged Session Recording Disabled or Missing, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.

	event or part of a chained incident.	
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Privileged Session Recording Disabled or Missing. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Privileged Session Recording Disabled or Missing. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Privileged Session Recording Disabled or Missing. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Privileged Session Recording Disabled or Missing was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Privileged Session Recording Disabled or Missing. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Privileged Session Recording Disabled or Missing, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: PAM Sessions: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Recording Required Systems: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Approved Exemptions: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: PAM Sessions, BB: Recording Required Systems, BB: Approved Exemptions];

FROM PAM Logs, Session Recording Logs, Admin Portal Audit

WHERE TimeGenerated >= now() - lookback

AND event_matches('Privileged Session Recording Disabled or Missing')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Privileged Session Recording Disabled or Missing
Incident Name	Possible Privileged Session Recording Disabled or Missing Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Privileged Access, AD and PAM

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Privileged Session Recording Disabled or Missing Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18	PAM Logs	user1024@example.local	WS-2024	203.0.113.169	Initial signal	Event indicates privileged session

10:12:00						recording disabled or missing.
2026-05-18 10:14:00	Session Recording Logs	user1024@example.local	WS-2024	203.0.113.169	Context signal	Entity context matched BB: PAM Sessions.
2026-05-18 10:19:00	Admin Portal Audit	user1024@example.local	WS-2024	10.20.24.15	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 10:22:00	SIEM Correlation	user1024@example.local	WS-2024	203.0.113.169	Rule matched	Correlation matched building blocks: BB: PAM Sessions, BB: Recording Required Systems.
2026-05-18 10:30:00	SOC Case Record	user1024@example.local	WS-2024	203.0.113.169	Incident created	Incident created for Privileged Session Recording Disabled or Missing with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: PAM Sessions, BB: Recording Required Systems, BB: Approved Exemptions.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.

- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 025: Vendor Privileged Access Outside Approved Window

Category	Privileged Access, AD and PAM
MITRE ATT&CK Mapping	T1078 Valid Accounts; T1199 Trusted Relationship
Detection Objective	Detect and investigate vendor privileged access outside approved window using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	PAM Logs, VPN Logs, Vendor Access Logs, Change Calendar
Recommended Building Blocks	BB: Vendor Accounts, BB: Approved Vendor Window, BB: Critical Systems
Recommended Alert Name	2026 - Vendor Privileged Access Outside Approved Window
Recommended Incident Name	Possible Vendor Privileged Access Outside Approved Window Investigation

1. Scenario

A third-party vendor account accesses production systems outside the scheduled maintenance window.

Privileged access monitoring protects the control plane of the organisation. A single unauthorised privileged action can change policy, disable controls, expose credentials or enable lateral movement.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1078 Valid Accounts; T1199 Trusted Relationship. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
PAM Logs	Provides privileged session evidence for Vendor Privileged Access Outside Approved Window. It links admin activity to approved access requests, password checkouts, session recordings, commands executed, target systems and vendor/user identity.	Simulation: admin checked out domain admin password at 02:11 with no matching change ticket, then logged into SRV-DC01. This requires privileged access validation.
VPN Logs	Shows remote access activity related to Vendor Privileged Access Outside Approved Window, including login time, public source IP, assigned internal IP, VPN gateway, session duration and disconnect reason. It is useful for correlating cloud sign-ins with remote network access and internal movement.	Simulation: VPN login at 09:05 from 185.220.101.34 assigned internal IP 10.44.21.77, then the same user performs M365 access at 09:08. This supports a single attacker session rather than two unrelated events.
Vendor Access Logs	Provides supporting evidence for Vendor Privileged Access Outside Approved Window. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Vendor Privileged Access Outside Approved Window. If the evidence is incomplete, the analyst should request the missing log source before closure.
Change Calendar	Provides supporting evidence for Vendor Privileged Access Outside Approved Window. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Vendor Privileged Access Outside Approved Window. If the evidence is incomplete, the

	and whether it links to other suspicious activity in the same timeline.	analyst should request the missing log source before closure.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Vendor Privileged Access Outside Approved Window, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Vendor Privileged Access Outside Approved Window. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Vendor Privileged Access Outside Approved Window. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Vendor Privileged Access Outside Approved Window. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Vendor Privileged Access Outside Approved Window was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Vendor Privileged Access Outside Approved Window. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Vendor Privileged Access Outside Approved Window, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

	proves whether the activity was benign, attempted, blocked, successful or still unknown.	
--	--	--

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Vendor Accounts: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Approved Vendor Window: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Critical Systems: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Vendor Accounts, BB: Approved Vendor Window, BB: Critical Systems];

FROM PAM Logs, VPN Logs, Vendor Access Logs

WHERE TimeGenerated >= now() - lookback

AND event_matches('Vendor Privileged Access Outside Approved Window')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Vendor Privileged Access Outside Approved Window
Incident Name	Possible Vendor Privileged Access Outside Approved Window Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Privileged Access, AD and PAM

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Vendor Privileged Access Outside

Approved Window Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 10:15:00	PAM Logs	user1025@example.local	WS-2025	203.0.113.176	Initial signal	Event indicates vendor privileged access outside approved window.
2026-05-18 10:17:00	VPN Logs	user1025@example.local	WS-2025	203.0.113.176	Context signal	Entity context matched BB: Vendor Accounts.
2026-05-18 10:22:00	Vendor Access Logs	user1025@example.local	WS-2025	10.20.25.26	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 10:25:00	SIEM Correlation	user1025@example.local	WS-2025	203.0.113.176	Rule matched	Correlation matched building blocks: BB: Vendor Accounts, BB: Approved Vendor Window.
2026-05-18 10:33:00	SOC Case Record	user1025@example.local	WS-2025	203.0.113.176	Incident created	Incident created for Vendor Privileged Access Outside Approved Window with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.

- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Vendor Accounts, BB: Approved Vendor Window, BB: Critical Systems.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 026: Phishing Email Delivered and User Clicked Link

Category	Email, BEC and Collaboration
MITRE ATT&CK Mapping	T1566.002 Spearphishing Link; T1204 User Execution
Detection Objective	Detect and investigate phishing email delivered and user clicked link using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Email Gateway, M365 Defender, URL Click Logs, Proxy Logs
Recommended Building Blocks	BB: Phishing Verdict, BB: User Clicked URL, BB: Suspicious Domain Age
Recommended Alert Name	2026 - Phishing Email Delivered and User Clicked Link
Recommended Incident Name	Possible Phishing Email Delivered and User Clicked Link Investigation

1. Scenario

A user receives a phishing email and clicks a link leading to a fake authentication page.

Email and collaboration platforms remain high-frequency entry points for phishing, social engineering, malware delivery and business email compromise. Detection must connect message delivery, user action, identity activity and endpoint evidence.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1566.002 Spearphishing Link; T1204 User Execution. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Email Gateway	Provides message delivery and threat verdict evidence for Phishing Email Delivered and User Clicked Link. It helps confirm sender, recipient, subject, attachment name, URL, verdict, delivery status and whether the user interacted with the message.	Simulation: sender=external-payments@example.com, recipient=finance@company.com, attachment=Invoice.zip, verdict=Suspicious, delivered=True. This is the starting point for phishing or malware investigation.
M365 Defender	Provides post-authentication activity for Phishing Email Delivered and User Clicked Link. It shows what the user or application did after login, such as mailbox access, inbox rule creation, file download, file sharing, Teams activity, OneDrive sync, SharePoint access and administrative changes.	Simulation: 09:20 MailItemsAccessed from Exchange Online; 09:24 New-InboxRule forwards mail externally; 09:32 FileDownloaded from /Finance/Budget2026.xlsx. This converts a login anomaly into a possible account compromise or data exposure incident.
URL Click Logs	Provides supporting evidence for Phishing Email Delivered and User Clicked Link. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Phishing Email Delivered and User Clicked Link. If the evidence is incomplete, the analyst should request the missing log source before closure.
Proxy Logs	Shows outbound web access linked to Phishing Email Delivered and User Clicked Link, including URL, domain, category,	Simulation: user=farah.finance, url=hxxps://unknown-file-share.example/upload,

	upload/download size, HTTP method, user-agent, action and reputation. It helps confirm phishing clicks, payload downloads, C2, exfiltration or unapproved AI/cloud tool usage.	bytes_out=524288000, action=Allowed. If this occurs after sensitive file access, investigate possible exfiltration.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Phishing Email Delivered and User Clicked Link, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Phishing Email Delivered and User Clicked Link. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Phishing Email Delivered and User Clicked Link. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Phishing Email Delivered and User Clicked Link. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Phishing Email Delivered and User Clicked Link was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Phishing Email Delivered and User Clicked Link. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Phishing Email Delivered and User Clicked Link, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

	the activity was benign, attempted, blocked, successful or still unknown.	
--	---	--

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Phishing Verdict: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: User Clicked URL: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Suspicious Domain Age: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Phishing Verdict, BB: User Clicked URL, BB: Suspicious Domain Age];

FROM Email Gateway, M365 Defender, URL Click Logs

WHERE TimeGenerated >= now() - lookback

AND event_matches('Phishing Email Delivered and User Clicked Link')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Phishing Email Delivered and User Clicked Link
Incident Name	Possible Phishing Email Delivered and User Clicked Link Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Email, BEC and Collaboration

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Phishing Email Delivered and User

Clicked Link Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 10:18:00	Email Gateway	user1026@example.local	WS-2026	203.0.113.183	Initial signal	Event indicates phishing email delivered and user clicked link.
2026-05-18 10:20:00	M365 Defender	user1026@example.local	WS-2026	203.0.113.183	Context signal	Entity context matched BB: Phishing Verdict.
2026-05-18 10:25:00	URL Click Logs	user1026@example.local	WS-2026	10.20.26.37	Follow-on activity	Related activity observed in M365.
2026-05-18 10:28:00	SIEM Correlation	user1026@example.local	WS-2026	203.0.113.183	Rule matched	Correlation matched building blocks: BB: Phishing Verdict, BB: User Clicked URL.
2026-05-18 10:36:00	SOC Case Record	user1026@example.local	WS-2026	203.0.113.183	Incident created	Incident created for Phishing Email Delivered and User Clicked Link with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Remove or quarantine malicious messages, block sender/domain/URL/hash where appropriate and search for additional recipients.
- Notify affected users and validate whether credentials were entered or attachments were opened.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Phishing Verdict, BB: User Clicked URL, BB: Suspicious Domain Age.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 027: Suspicious ZIP Attachment Containing LNK or Script

Category	Email, BEC and Collaboration
MITRE ATT&CK Mapping	T1566.001 Spearphishing Attachment; T1204 User Execution
Detection Objective	Detect and investigate suspicious zip attachment containing lnk or script using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Email Gateway, Sandbox Logs, EDR File Events
Recommended Building Blocks	BB: Archive Attachment, BB: High-Risk File Extension, BB: External Sender
Recommended Alert Name	2026 - Suspicious ZIP Attachment Containing LNK or Script
Recommended Incident Name	Possible Suspicious ZIP Attachment Containing LNK or Script Investigation

1. Scenario

An external email delivers an archive containing a shortcut or script that appears to be a document.

Email and collaboration platforms remain high-frequency entry points for phishing, social engineering, malware delivery and business email compromise. Detection must connect message delivery, user action, identity activity and endpoint evidence.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1566.001 Spearphishing Attachment; T1204 User Execution. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Email Gateway	Provides message delivery and threat verdict evidence for Suspicious ZIP Attachment Containing LNK or Script. It helps confirm sender, recipient, subject, attachment name, URL, verdict, delivery status and whether the user interacted with the message.	Simulation: sender=external-payments@example.com, recipient=finance@company.com, attachment=Invoice.zip, verdict=Suspicious, delivered=True. This is the starting point for phishing or malware investigation.
Sandbox Logs	Provides supporting evidence for Suspicious ZIP Attachment Containing LNK or Script. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Suspicious ZIP Attachment Containing LNK or Script. If the evidence is incomplete, the analyst should request the missing log source before closure.
EDR File Events	Provides endpoint execution and host-level evidence for Suspicious ZIP Attachment Containing LNK or Script. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device isolation status and sensor health.	Simulation: parent=explorer.exe, child=powershell.exe, command='-EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution rather than only file delivery.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Suspicious ZIP Attachment Containing LNK or Script, the	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The

	analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	close timing increases investigation confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Suspicious ZIP Attachment Containing LNK or Script. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Suspicious ZIP Attachment Containing LNK or Script. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Suspicious ZIP Attachment Containing LNK or Script. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Suspicious ZIP Attachment Containing LNK or Script was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Suspicious ZIP Attachment Containing LNK or Script. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Suspicious ZIP Attachment Containing LNK or Script, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Archive Attachment: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: High-Risk File Extension: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: External Sender: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Archive Attachment, BB: High-Risk File Extension, BB: External Sender];

FROM Email Gateway, Sandbox Logs, EDR File Events

WHERE TimeGenerated >= now() - lookback

AND event_matches('Suspicious ZIP Attachment Containing LNK or Script')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Suspicious ZIP Attachment Containing LNK or Script
Incident Name	Possible Suspicious ZIP Attachment Containing LNK or Script Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Email, BEC and Collaboration

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Suspicious ZIP Attachment Containing LNK or Script Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.

- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 10:21:00	Email Gateway	user1027@example.local	WS-2027	203.0.113.190	Initial signal	Event indicates suspicious zip attachment containing lnk or script.
2026-05-18 10:23:00	Sandbox Logs	user1027@example.local	WS-2027	203.0.113.190	Context signal	Entity context matched BB: Archive Attachment.
2026-05-18 10:28:00	EDR File Events	user1027@example.local	WS-2027	10.20.27.48	Follow-on activity	Related activity observed in M365.
2026-05-18 10:31:00	SIEM Correlation	user1027@example.local	WS-2027	203.0.113.190	Rule matched	Correlation matched building blocks: BB: Archive Attachment, BB: High-Risk File Extension.
2026-05-18 10:39:00	SOC Case Record	user1027@example.local	WS-2027	203.0.113.190	Incident created	Incident created for Suspicious ZIP Attachment Containing LNK or Script with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Remove or quarantine malicious messages, block sender/domain/URL/hash where appropriate and search for additional recipients.
- Notify affected users and validate whether credentials were entered or attachments were opened.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.

- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Archive Attachment, BB: High-Risk File Extension, BB: External Sender.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 028: Teams or SharePoint Suspicious File Shared Internally

Category	Email, BEC and Collaboration
MITRE ATT&CK Mapping	T1204 User Execution; T1105 Ingress Tool Transfer
Detection Objective	Detect and investigate teams or sharepoint suspicious file shared internally using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Teams Audit Logs, SharePoint Audit Logs, EDR, Proxy
Recommended Building Blocks	BB: Suspicious File Type, BB: Internal Sender Recently Risky, BB: Collaboration Platform File Share
Recommended Alert Name	2026 - Teams or SharePoint Suspicious File Shared Internally
Recommended Incident Name	Possible Teams or SharePoint Suspicious File Shared Internally Investigation

1. Scenario

A compromised user sends a ZIP file through Teams to another employee, leading to endpoint execution.

Email and collaboration platforms remain high-frequency entry points for phishing, social engineering, malware delivery and business email compromise. Detection must connect message delivery, user action, identity activity and endpoint evidence.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1204 User Execution; T1105 Ingress Tool Transfer. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Teams Audit Logs	Provides supporting evidence for Teams or SharePoint Suspicious File Shared Internally. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Teams or SharePoint Suspicious File Shared Internally. If the evidence is incomplete, the analyst should request the missing log source before closure.
SharePoint Audit Logs	Provides post-authentication activity for Teams or SharePoint Suspicious File Shared Internally. It shows what the user or application did after login, such as mailbox access, inbox rule creation, file download, file sharing, Teams activity, OneDrive sync, SharePoint access and administrative changes.	Simulation: 09:20 MailItemsAccessed from Exchange Online; 09:24 New-InboxRule forwards mail externally; 09:32 FileDownloaded from /Finance/Budget2026.xlsx. This converts a login anomaly into a possible account compromise or data exposure incident.
EDR	Provides endpoint execution and host-level evidence for Teams or SharePoint Suspicious File Shared Internally. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device isolation status and sensor health.	Simulation: parent=explorer.exe, child=powershell.exe, command='-EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution rather than only file delivery.
Proxy	Shows outbound web access linked to	Simulation: user=farah.finance,

	Teams or SharePoint Suspicious File Shared Internally, including URL, domain, category, upload/download size, HTTP method, user-agent, action and reputation. It helps confirm phishing clicks, payload downloads, C2, exfiltration or unapproved AI/cloud tool usage.	url=hxxps://unknown-file-share.example/upload, bytes_out=524288000, action=Allowed. If this occurs after sensitive file access, investigate possible exfiltration.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Teams or SharePoint Suspicious File Shared Internally, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Teams or SharePoint Suspicious File Shared Internally. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Teams or SharePoint Suspicious File Shared Internally. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Teams or SharePoint Suspicious File Shared Internally. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Teams or SharePoint Suspicious File Shared Internally was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Teams or SharePoint Suspicious File Shared Internally. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Teams or SharePoint Suspicious File Shared Internally, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were

	resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.
--	--	---

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Suspicious File Type: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Internal Sender Recently Risky: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Collaboration Platform File Share: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Suspicious File Type, BB: Internal Sender Recently Risky, BB: Collaboration Platform File Share];

FROM Teams Audit Logs, SharePoint Audit Logs, EDR

WHERE TimeGenerated >= now() - lookback

AND event_matches('Teams or SharePoint Suspicious File Shared Internally')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Teams or SharePoint Suspicious File Shared Internally
Incident Name	Possible Teams or SharePoint Suspicious File Shared Internally Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Email, BEC and Collaboration

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Teams or SharePoint Suspicious File Shared Internally Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 10:24:00	Teams Audit Logs	user1028@example.local	WS-2028	203.0.113.197	Initial signal	Event indicates teams or sharepoint suspicious file shared internally.
2026-05-18 10:26:00	SharePoint Audit Logs	user1028@example.local	WS-2028	203.0.113.197	Context signal	Entity context matched BB: Suspicious File Type.
2026-05-18 10:31:00	EDR	user1028@example.local	WS-2028	10.20.28.59	Follow-on activity	Related activity observed in M365.
2026-05-18 10:34:00	SIEM Correlation	user1028@example.local	WS-2028	203.0.113.197	Rule matched	Correlation matched building blocks: BB: Suspicious File Type, BB: Internal Sender Recently Risky.
2026-05-18 10:42:00	SOC Case Record	user1028@example.local	WS-2028	203.0.113.197	Incident created	Incident created for Teams or SharePoint Suspicious File Shared Internally with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.

- Remove or quarantine malicious messages, block sender/domain/URL/hash where appropriate and search for additional recipients.
- Notify affected users and validate whether credentials were entered or attachments were opened.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Suspicious File Type, BB: Internal Sender Recently Risky, BB: Collaboration Platform File Share.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 029: Mailbox Forwarding Rule to External Domain

Category	Email, BEC and Collaboration
MITRE ATT&CK Mapping	T1114 Email Collection; T1537 Transfer Data to Cloud Account
Detection Objective	Detect and investigate mailbox forwarding rule to external domain using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Exchange Audit Logs, M365 Unified Audit, Entra ID Sign-ins
Recommended Building Blocks	BB: External Forwarding Domain, BB: Mailbox Rule Creation, BB: Risky Sign-in
Recommended Alert Name	2026 - Mailbox Forwarding Rule to External Domain
Recommended Incident Name	Possible Mailbox Forwarding Rule to External Domain Investigation

1. Scenario

A new rule forwards all mailbox content to an external mailbox.

Email and collaboration platforms remain high-frequency entry points for phishing, social engineering, malware delivery and business email compromise. Detection must connect message delivery, user action, identity activity and endpoint evidence.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1114 Email Collection; T1537 Transfer Data to Cloud Account. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Exchange Audit Logs	Provides post-authentication activity for Mailbox Forwarding Rule to External Domain. It shows what the user or application did after login, such as mailbox access, inbox rule creation, file download, file sharing, Teams activity, OneDrive sync, SharePoint access and administrative changes.	Simulation: 09:20 MailItemsAccessed from Exchange Online; 09:24 New-InboxRule forwards mail externally; 09:32 FileDownloaded from /Finance/Budget2026.xlsx. This converts a login anomaly into a possible account compromise or data exposure incident.
M365 Unified Audit	Provides post-authentication activity for Mailbox Forwarding Rule to External Domain. It shows what the user or application did after login, such as mailbox access, inbox rule creation, file download, file sharing, Teams activity, OneDrive sync, SharePoint access and administrative changes.	Simulation: 09:20 MailItemsAccessed from Exchange Online; 09:24 New-InboxRule forwards mail externally; 09:32 FileDownloaded from /Finance/Budget2026.xlsx. This converts a login anomaly into a possible account compromise or data exposure incident.
Entra ID Sign-ins	Provides cloud identity evidence for Mailbox Forwarding Rule to External Domain. Key fields include user principal name, sign-in time, source IP, country, ASN, device ID, compliance state, MFA result, conditional access result, client app and target application. This telemetry shows whether the activity is normal user access or suspicious identity behaviour.	Simulation: user=farah.finance@company.com, app=Exchange Online, source_ip=185.220.101.34, country=DE, device=Unknown, MFA=satisfied_by_token, result=Success. This is abnormal because the user normally authenticates from Malaysia using a managed device.

TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Mailbox Forwarding Rule to External Domain, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Mailbox Forwarding Rule to External Domain. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Mailbox Forwarding Rule to External Domain. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Mailbox Forwarding Rule to External Domain. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Mailbox Forwarding Rule to External Domain was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Mailbox Forwarding Rule to External Domain. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Mailbox Forwarding Rule to External Domain, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: External Forwarding Domain: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Mailbox Rule Creation: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Risky Sign-in: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: External Forwarding Domain, BB: Mailbox Rule Creation, BB: Risky Sign-in];

FROM Exchange Audit Logs, M365 Unified Audit, Entra ID Sign-ins

WHERE TimeGenerated >= now() - lookback

AND event_matches('Mailbox Forwarding Rule to External Domain')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Mailbox Forwarding Rule to External Domain
Incident Name	Possible Mailbox Forwarding Rule to External Domain Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Email, BEC and Collaboration

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Mailbox Forwarding Rule to External Domain Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.

- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 10:27:00	Exchange Audit Logs	user1029@example.local	WS- 2029	203.0.113.204	Initial signal	Event indicates mailbox forwarding rule to external domain.
2026-05-18 10:29:00	M365 Unified Audit	user1029@example.local	WS- 2029	203.0.113.204	Context signal	Entity context matched BB: External Forwarding Domain.
2026-05-18 10:34:00	Entra ID Sign- ins	user1029@example.local	WS- 2029	10.20.29.70	Follow-on activity	Related activity observed in M365.
2026-05-18 10:37:00	SIEM Correlation	user1029@example.local	WS- 2029	203.0.113.204	Rule matched	Correlation matched building blocks: BB: External Forwarding Domain, BB: Mailbox Rule Creation.
2026-05-18 10:45:00	SOC Case Record	user1029@example.local	WS- 2029	203.0.113.204	Incident created	Incident created for Mailbox Forwarding Rule to External Domain with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Remove or quarantine malicious messages, block sender/domain/URL/hash where appropriate and search for additional recipients.
- Notify affected users and validate whether credentials were entered or attachments were opened.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.

- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: External Forwarding Domain, BB: Mailbox Rule Creation, BB: Risky Sign-in.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 030: Inbox Rule Created to Hide Security or Finance Emails

Category	Email, BEC and Collaboration
MITRE ATT&CK Mapping	T1564 Hide Artifacts; T1114 Email Collection
Detection Objective	Detect and investigate inbox rule created to hide security or finance emails using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Exchange Audit Logs, M365 Unified Audit
Recommended Building Blocks	BB: Suspicious Inbox Rule Keywords, BB: External Forwarding, BB: Risky Sign-in
Recommended Alert Name	2026 - Inbox Rule Created to Hide Security or Finance Emails
Recommended Incident Name	Possible Inbox Rule Created to Hide Security or Finance Emails Investigation

1. Scenario

A new inbox rule deletes or moves emails containing words such as payment, invoice, alert or security.

Email and collaboration platforms remain high-frequency entry points for phishing, social engineering, malware delivery and business email compromise. Detection must connect message delivery, user action, identity activity and endpoint evidence.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1564 Hide Artifacts; T1114 Email Collection. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Exchange Audit Logs	Provides post-authentication activity for Inbox Rule Created to Hide Security or Finance Emails. It shows what the user or application did after login, such as mailbox access, inbox rule creation, file download, file sharing, Teams activity, OneDrive sync, SharePoint access and administrative changes.	Simulation: 09:20 MailItemsAccessed from Exchange Online; 09:24 New-InboxRule forwards mail externally; 09:32 FileDownloaded from /Finance/Budget2026.xlsx. This converts a login anomaly into a possible account compromise or data exposure incident.
M365 Unified Audit	Provides post-authentication activity for Inbox Rule Created to Hide Security or Finance Emails. It shows what the user or application did after login, such as mailbox access, inbox rule creation, file download, file sharing, Teams activity, OneDrive sync, SharePoint access and administrative changes.	Simulation: 09:20 MailItemsAccessed from Exchange Online; 09:24 New-InboxRule forwards mail externally; 09:32 FileDownloaded from /Finance/Budget2026.xlsx. This converts a login anomaly into a possible account compromise or data exposure incident.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Inbox Rule Created to Hide Security or Finance Emails, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.

User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Inbox Rule Created to Hide Security or Finance Emails. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Inbox Rule Created to Hide Security or Finance Emails. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Inbox Rule Created to Hide Security or Finance Emails. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Inbox Rule Created to Hide Security or Finance Emails was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Inbox Rule Created to Hide Security or Finance Emails. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Inbox Rule Created to Hide Security or Finance Emails, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Suspicious Inbox Rule Keywords: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: External Forwarding: maintain the list owner, update frequency, source of truth and exception approval process.

- BB: Risky Sign-in: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Suspicious Inbox Rule Keywords, BB: External Forwarding, BB: Risky Sign-in];

FROM Exchange Audit Logs, M365 Unified Audit

WHERE TimeGenerated >= now() - lookback

AND event_matches('Inbox Rule Created to Hide Security or Finance Emails')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Inbox Rule Created to Hide Security or Finance Emails
Incident Name	Possible Inbox Rule Created to Hide Security or Finance Emails Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Email, BEC and Collaboration

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Inbox Rule Created to Hide Security or Finance Emails Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
------	--------	------	------	-----------	-------	-----------------

2026-05-18 10:30:00	Exchange Audit Logs	user1030@example.local	WS- 2030	203.0.113.211	Initial signal	Event indicates inbox rule created to hide security or finance emails.
2026-05-18 10:32:00	M365 Unified Audit	user1030@example.local	WS- 2030	203.0.113.211	Context signal	Entity context matched BB: Suspicious Inbox Rule Keywords.
2026-05-18 10:37:00	Exchange Audit Logs	user1030@example.local	WS- 2030	10.20.0.81	Follow-on activity	Related activity observed in M365.
2026-05-18 10:40:00	SIEM Correlation	user1030@example.local	WS- 2030	203.0.113.211	Rule matched	Correlation matched building blocks: BB: Suspicious Inbox Rule Keywords, BB: External Forwarding.
2026-05-18 10:48:00	SOC Case Record	user1030@example.local	WS- 2030	203.0.113.211	Incident created	Incident created for Inbox Rule Created to Hide Security or Finance Emails with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Remove or quarantine malicious messages, block sender/domain/URL/hash where appropriate and search for additional recipients.
- Notify affected users and validate whether credentials were entered or attachments were opened.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Suspicious Inbox Rule Keywords, BB: External Forwarding, BB: Risky Sign-in.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 031: Mass Outbound Email from User Mailbox

Category	Email, BEC and Collaboration
MITRE ATT&CK Mapping	T1586 Compromise Accounts; T1078.004 Cloud Accounts
Detection Objective	Detect and investigate mass outbound email from user mailbox using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Exchange Message Trace, M365 Audit, Email Gateway
Recommended Building Blocks	BB: Outbound Email Baseline, BB: External Recipient Count, BB: Risky Sign-in
Recommended Alert Name	2026 - Mass Outbound Email from User Mailbox
Recommended Incident Name	Possible Mass Outbound Email from User Mailbox Investigation

1. Scenario

A mailbox suddenly sends hundreds of emails to external recipients shortly after a suspicious login.

Email and collaboration platforms remain high-frequency entry points for phishing, social engineering, malware delivery and business email compromise. Detection must connect message delivery, user action, identity activity and endpoint evidence.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1586 Compromise Accounts; T1078.004 Cloud Accounts. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Exchange Message Trace	Provides post-authentication activity for Mass Outbound Email from User Mailbox. It shows what the user or application did after login, such as mailbox access, inbox rule creation, file download, file sharing, Teams activity, OneDrive sync, SharePoint access and administrative changes.	Simulation: 09:20 MailItemsAccessed from Exchange Online; 09:24 New-InboxRule forwards mail externally; 09:32 FileDownloaded from /Finance/Budget2026.xlsx. This converts a login anomaly into a possible account compromise or data exposure incident.
M365 Audit	Provides post-authentication activity for Mass Outbound Email from User Mailbox. It shows what the user or application did after login, such as mailbox access, inbox rule creation, file download, file sharing, Teams activity, OneDrive sync, SharePoint access and administrative changes.	Simulation: 09:20 MailItemsAccessed from Exchange Online; 09:24 New-InboxRule forwards mail externally; 09:32 FileDownloaded from /Finance/Budget2026.xlsx. This converts a login anomaly into a possible account compromise or data exposure incident.
Email Gateway	Provides message delivery and threat verdict evidence for Mass Outbound Email from User Mailbox. It helps confirm sender, recipient, subject, attachment name, URL, verdict, delivery status and whether the user interacted with the message.	Simulation: sender=external-payments@example.com, recipient=finance@company.com, attachment=Invoice.zip, verdict=Suspicious, delivered=True. This is the starting point for phishing or malware investigation.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Mass Outbound Email from User Mailbox, the analyst must compare the first suspicious event, the	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation

	confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Mass Outbound Email from User Mailbox. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Mass Outbound Email from User Mailbox. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Mass Outbound Email from User Mailbox. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Mass Outbound Email from User Mailbox was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Mass Outbound Email from User Mailbox. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Mass Outbound Email from User Mailbox, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Outbound Email Baseline: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: External Recipient Count: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Risky Sign-in: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Outbound Email Baseline, BB: External Recipient Count, BB: Risky Sign-in];

FROM Exchange Message Trace, M365 Audit, Email Gateway

WHERE TimeGenerated >= now() - lookback

AND event_matches('Mass Outbound Email from User Mailbox')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Mass Outbound Email from User Mailbox
Incident Name	Possible Mass Outbound Email from User Mailbox Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Email, BEC and Collaboration

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Mass Outbound Email from User Mailbox Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.

- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 10:33:00	Exchange Message Trace	user1031@example.local	WS- 2031	203.0.113.218	Initial signal	Event indicates mass outbound email from user mailbox.
2026-05-18 10:35:00	M365 Audit	user1031@example.local	WS- 2031	203.0.113.218	Context signal	Entity context matched BB: Outbound Email Baseline.
2026-05-18 10:40:00	Email Gateway	user1031@example.local	WS- 2031	10.20.1.92	Follow-on activity	Related activity observed in M365.
2026-05-18 10:43:00	SIEM Correlation	user1031@example.local	WS- 2031	203.0.113.218	Rule matched	Correlation matched building blocks: BB: Outbound Email Baseline, BB: External Recipient Count.
2026-05-18 10:51:00	SOC Case Record	user1031@example.local	WS- 2031	203.0.113.218	Incident created	Incident created for Mass Outbound Email from User Mailbox with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Remove or quarantine malicious messages, block sender/domain/URL/hash where appropriate and search for additional recipients.
- Notify affected users and validate whether credentials were entered or attachments were opened.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.

- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Outbound Email Baseline, BB: External Recipient Count, BB: Risky Sign-in.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 032: BEC Payment Instruction Change Request

Category	Email, BEC and Collaboration
MITRE ATT&CK Mapping	T1656 Impersonation; T1566 Phishing
Detection Objective	Detect and investigate bec payment instruction change request using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Email Gateway, M365 Audit, DLP, Mailbox Logs
Recommended Building Blocks	BB: Finance Keywords, BB: External Sender, BB: Executive Impersonation Names
Recommended Alert Name	2026 - BEC Payment Instruction Change Request
Recommended Incident Name	Possible BEC Payment Instruction Change Request Investigation

1. Scenario

A supplier-like email asks finance to change bank account details or urgently process payment.

Email and collaboration platforms remain high-frequency entry points for phishing, social engineering, malware delivery and business email compromise. Detection must connect message delivery, user action, identity activity and endpoint evidence.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1656 Impersonation; T1566 Phishing. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Email Gateway	Provides message delivery and threat verdict evidence for BEC Payment Instruction Change Request. It helps confirm sender, recipient, subject, attachment name, URL, verdict, delivery status and whether the user interacted with the message.	Simulation: sender=external-payments@example.com, recipient=finance@company.com, attachment=Invoice.zip, verdict=Suspicious, delivered=True. This is the starting point for phishing or malware investigation.
M365 Audit	Provides post-authentication activity for BEC Payment Instruction Change Request. It shows what the user or application did after login, such as mailbox access, inbox rule creation, file download, file sharing, Teams activity, OneDrive sync, SharePoint access and administrative changes.	Simulation: 09:20 MailItemsAccessed from Exchange Online; 09:24 New-InboxRule forwards mail externally; 09:32 FileDownloaded from /Finance/Budget2026.xlsx. This converts a login anomaly into a possible account compromise or data exposure incident.
DLP	Shows data protection evidence for BEC Payment Instruction Change Request. DLP/CASB telemetry confirms whether sensitive data was uploaded, shared, pasted, copied, synchronised or transferred to external services.	Simulation: DLP policy=Customer PII, destination=personal-cloud.example, action=AllowedWithAlert, file=Customer_List_2026.xlsx. This is evidence for possible data leakage.
Mailbox Logs	Provides supporting evidence for BEC Payment Instruction Change Request. The analyst should confirm whether this telemetry proves the event occurred,	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for BEC Payment Instruction Change Request. If the

	whether the action succeeded and whether it links to other suspicious activity in the same timeline.	evidence is incomplete, the analyst should request the missing log source before closure.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For BEC Payment Instruction Change Request, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in BEC Payment Instruction Change Request. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to BEC Payment Instruction Change Request. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to BEC Payment Instruction Change Request. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in BEC Payment Instruction Change Request was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during BEC Payment Instruction Change Request. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For BEC Payment Instruction Change Request, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Finance Keywords: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: External Sender: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Executive Impersonation Names: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Finance Keywords, BB: External Sender, BB: Executive Impersonation Names];

FROM Email Gateway, M365 Audit, DLP

WHERE TimeGenerated >= now() - lookback

AND event_matches('BEC Payment Instruction Change Request')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - BEC Payment Instruction Change Request
Incident Name	Possible BEC Payment Instruction Change Request Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Email, BEC and Collaboration

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible BEC Payment Instruction Change Request Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.

- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 10:36:00	Email Gateway	user1032@example.local	WS-2032	203.0.113.225	Initial signal	Event indicates bec payment instruction change request.
2026-05-18 10:38:00	M365 Audit	user1032@example.local	WS-2032	203.0.113.225	Context signal	Entity context matched BB: Finance Keywords.
2026-05-18 10:43:00	DLP	user1032@example.local	WS-2032	10.20.2.103	Follow-on activity	Related activity observed in M365.
2026-05-18 10:46:00	SIEM Correlation	user1032@example.local	WS-2032	203.0.113.225	Rule matched	Correlation matched building blocks: BB: Finance Keywords, BB: External Sender.
2026-05-18 10:54:00	SOC Case Record	user1032@example.local	WS-2032	203.0.113.225	Incident created	Incident created for BEC Payment Instruction Change Request with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Remove or quarantine malicious messages, block sender/domain/URL/hash where appropriate and search for additional recipients.
- Notify affected users and validate whether credentials were entered or attachments were opened.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.

- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Finance Keywords, BB: External Sender, BB: Executive Impersonation Names.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 033: Executive Display Name Spoofing

Category	Email, BEC and Collaboration
MITRE ATT&CK Mapping	T1656 Impersonation; T1566 Phishing
Detection Objective	Detect and investigate executive display name spoofing using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Email Gateway, DMARC/SPF/DKIM Results, Threat Intel
Recommended Building Blocks	BB: Executive Names, BB: External Sender, BB: Lookalike Domain
Recommended Alert Name	2026 - Executive Display Name Spoofing
Recommended Incident Name	Possible Executive Display Name Spoofing Investigation

1. Scenario

An external sender uses the display name of a senior executive and asks for urgent action.

Email and collaboration platforms remain high-frequency entry points for phishing, social engineering, malware delivery and business email compromise. Detection must connect message delivery, user action, identity activity and endpoint evidence.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1656 Impersonation; T1566 Phishing. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Email Gateway	Provides message delivery and threat verdict evidence for Executive Display Name Spoofing. It helps confirm sender, recipient, subject, attachment name, URL, verdict, delivery status and whether the user interacted with the message.	Simulation: sender=external-payments@example.com, recipient=finance@company.com, attachment=Invoice.zip, verdict=Suspicious, delivered=True. This is the starting point for phishing or malware investigation.
DMARC/SPF/DKIM Results	Explains whether the activity in Executive Display Name Spoofing was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Threat Intel	Adds external intelligence context to Executive Display Name Spoofing. IOC, actor, campaign, reputation, first-seen date and confidence help prioritise alerts and connect internal evidence to known malicious infrastructure.	Simulation: destination IP matched TI feed as malware C2 with confidence=High, first_seen=2026-02-10. If internal host communicated successfully, investigate compromise evidence.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Executive Display Name Spoofing, the analyst must compare the first suspicious event, the confirming event and any follow-on	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.

	activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Executive Display Name Spoofing. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Executive Display Name Spoofing. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Executive Display Name Spoofing. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Executive Display Name Spoofing was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Executive Display Name Spoofing. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Executive Display Name Spoofing, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Executive Names: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: External Sender: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Lookalike Domain: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Executive Names, BB: External Sender, BB: Lookalike Domain];

FROM Email Gateway, DMARC/SPF/DKIM Results, Threat Intel

WHERE TimeGenerated >= now() - lookback

AND event_matches('Executive Display Name Spoofing')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Executive Display Name Spoofing
Incident Name	Possible Executive Display Name Spoofing Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Email, BEC and Collaboration

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Executive Display Name Spoofing Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 10:39:00	Email Gateway	user1033@example.local	WS-2033	203.0.113.232	Initial signal	Event indicates executive display name spoofing.
2026-05-18 10:41:00	DMARC/SPF/DKIM Results	user1033@example.local	WS-2033	203.0.113.232	Context signal	Entity context matched BB: Executive Names.
2026-05-18 10:46:00	Threat Intel	user1033@example.local	WS-2033	10.20.3.114	Follow-on activity	Related activity observed in M365.
2026-05-18 10:49:00	SIEM Correlation	user1033@example.local	WS-2033	203.0.113.232	Rule matched	Correlation matched building blocks: BB: Executive Names, BB: External Sender.
2026-05-18 10:57:00	SOC Case Record	user1033@example.local	WS-2033	203.0.113.232	Incident created	Incident created for Executive Display Name Spoofing with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Remove or quarantine malicious messages, block sender/domain/URL/hash where appropriate and search for additional recipients.
- Notify affected users and validate whether credentials were entered or attachments were opened.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Executive Names, BB: External Sender, BB: Lookalike Domain.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 034: QR Phishing Email

Category	Email, BEC and Collaboration
MITRE ATT&CK Mapping	T1566.002 Spearphishing Link
Detection Objective	Detect and investigate qr phishing email using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Email Gateway, OCR/Sandbox Metadata, Proxy URL Logs
Recommended Building Blocks	BB: QR Code Detected, BB: Suspicious Landing Domain, BB: Credential Form Indicator
Recommended Alert Name	2026 - QR Phishing Email
Recommended Incident Name	Possible QR Phishing Email Investigation

1. Scenario

An email asks the user to scan a QR code to verify mailbox access, bypassing normal URL inspection.

Email and collaboration platforms remain high-frequency entry points for phishing, social engineering, malware delivery and business email compromise. Detection must connect message delivery, user action, identity activity and endpoint evidence.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1566.002 Spearphishing Link. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Email Gateway	Provides message delivery and threat verdict evidence for QR Phishing Email. It helps confirm sender, recipient, subject, attachment name, URL, verdict, delivery status and whether the user interacted with the message.	Simulation: sender=external-payments@example.com, recipient=finance@company.com, attachment=Invoice.zip, verdict=Suspicious, delivered=True. This is the starting point for phishing or malware investigation.
OCR/Sandbox Metadata	Provides supporting evidence for QR Phishing Email. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for QR Phishing Email. If the evidence is incomplete, the analyst should request the missing log source before closure.
Proxy URL Logs	Shows outbound web access linked to QR Phishing Email, including URL, domain, category, upload/download size, HTTP method, user-agent, action and reputation. It helps confirm phishing clicks, payload downloads, C2, exfiltration or unapproved AI/cloud tool usage.	Simulation: user=farah.finance, url=hxxps://unknown-file-share.example/upload, bytes_out=524288000, action=Allowed. If this occurs after sensitive file access, investigate possible exfiltration.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For QR Phishing Email, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.

	decide whether the activity is an isolated event or part of a chained incident.	
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in QR Phishing Email. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to QR Phishing Email. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to QR Phishing Email. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in QR Phishing Email was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during QR Phishing Email. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For QR Phishing Email, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: QR Code Detected: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Suspicious Landing Domain: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Credential Form Indicator: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: QR Code Detected, BB: Suspicious Landing Domain, BB: Credential Form Indicator];

FROM Email Gateway, OCR/Sandbox Metadata, Proxy URL Logs

WHERE TimeGenerated >= now() - lookback

AND event_matches('QR Phishing Email')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - QR Phishing Email
Incident Name	Possible QR Phishing Email Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Email, BEC and Collaboration

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible QR Phishing Email Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 10:42:00	Email Gateway	user1034@example.local	WS-2034	203.0.113.239	Initial signal	Event indicates qr phishing email.

2026-05-18 10:44:00	OCR/Sandbox Metadata	user1034@example.local	WS-2034	203.0.113.239	Context signal	Entity context matched BB: QR Code Detected.
2026-05-18 10:49:00	Proxy URL Logs	user1034@example.local	WS-2034	10.20.4.125	Follow-on activity	Related activity observed in M365.
2026-05-18 10:52:00	SIEM Correlation	user1034@example.local	WS-2034	203.0.113.239	Rule matched	Correlation matched building blocks: BB: QR Code Detected, BB: Suspicious Landing Domain.
2026-05-18 11:00:00	SOC Case Record	user1034@example.local	WS-2034	203.0.113.239	Incident created	Incident created for QR Phishing Email with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Remove or quarantine malicious messages, block sender/domain/URL/hash where appropriate and search for additional recipients.
- Notify affected users and validate whether credentials were entered or attachments were opened.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: QR Code Detected, BB: Suspicious Landing Domain, BB: Credential Form Indicator.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.

- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 035: Mailbox Delegation or FullAccess Permission Added

Category	Email, BEC and Collaboration
MITRE ATT&CK Mapping	T1098 Account Manipulation; T1114 Email Collection
Detection Objective	Detect and investigate mailbox delegation or fullaccess permission added using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Exchange Audit Logs, M365 Unified Audit
Recommended Building Blocks	BB: Sensitive Mailboxes, BB: Delegation Change, BB: Approved Access Request
Recommended Alert Name	2026 - Mailbox Delegation or FullAccess Permission Added
Recommended Incident Name	Possible Mailbox Delegation or FullAccess Permission Added Investigation

1. Scenario

A user or admin grants mailbox FullAccess or SendAs permission without approved access request.

Email and collaboration platforms remain high-frequency entry points for phishing, social engineering, malware delivery and business email compromise. Detection must connect message delivery, user action, identity activity and endpoint evidence.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1098 Account Manipulation; T1114 Email Collection. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Exchange Audit Logs	Provides post-authentication activity for Mailbox Delegation or FullAccess Permission Added. It shows what the user or application did after login, such as mailbox access, inbox rule creation, file download, file sharing, Teams activity, OneDrive sync, SharePoint access and administrative changes.	Simulation: 09:20 MailItemsAccessed from Exchange Online; 09:24 New-InboxRule forwards mail externally; 09:32 FileDownloaded from /Finance/Budget2026.xlsx. This converts a login anomaly into a possible account compromise or data exposure incident.
M365 Unified Audit	Provides post-authentication activity for Mailbox Delegation or FullAccess Permission Added. It shows what the user or application did after login, such as mailbox access, inbox rule creation, file download, file sharing, Teams activity, OneDrive sync, SharePoint access and administrative changes.	Simulation: 09:20 MailItemsAccessed from Exchange Online; 09:24 New-InboxRule forwards mail externally; 09:32 FileDownloaded from /Finance/Budget2026.xlsx. This converts a login anomaly into a possible account compromise or data exposure incident.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Mailbox Delegation or FullAccess Permission Added, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.

User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Mailbox Delegation or FullAccess Permission Added. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Mailbox Delegation or FullAccess Permission Added. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Mailbox Delegation or FullAccess Permission Added. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Mailbox Delegation or FullAccess Permission Added was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Mailbox Delegation or FullAccess Permission Added. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Mailbox Delegation or FullAccess Permission Added, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Sensitive Mailboxes: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Delegation Change: maintain the list owner, update frequency, source of truth and exception approval process.

- BB: Approved Access Request: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Sensitive Mailboxes, BB: Delegation Change, BB: Approved Access Request];

FROM Exchange Audit Logs, M365 Unified Audit

WHERE TimeGenerated >= now() - lookback

AND event_matches('Mailbox Delegation or FullAccess Permission Added')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Mailbox Delegation or FullAccess Permission Added
Incident Name	Possible Mailbox Delegation or FullAccess Permission Added Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Email, BEC and Collaboration

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Mailbox Delegation or FullAccess Permission Added Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 10:45:00	Exchange Audit Logs	user1035@example.local	WS- 2035	203.0.113.246	Initial signal	Event indicates mailbox delegation or fullaccess permission added.
2026-05-18 10:47:00	M365 Unified Audit	user1035@example.local	WS- 2035	203.0.113.246	Context signal	Entity context matched BB: Sensitive Mailboxes.
2026-05-18 10:52:00	Exchange Audit Logs	user1035@example.local	WS- 2035	10.20.5.136	Follow-on activity	Related activity observed in M365.
2026-05-18 10:55:00	SIEM Correlation	user1035@example.local	WS- 2035	203.0.113.246	Rule matched	Correlation matched building blocks: BB: Sensitive Mailboxes, BB: Delegation Change.
2026-05-18 11:03:00	SOC Case Record	user1035@example.local	WS- 2035	203.0.113.246	Incident created	Incident created for Mailbox Delegation or FullAccess Permission Added with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Remove or quarantine malicious messages, block sender/domain/URL/hash where appropriate and search for additional recipients.
- Notify affected users and validate whether credentials were entered or attachments were opened.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Sensitive Mailboxes, BB: Delegation Change, BB: Approved Access Request.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 036: Office Application Spawns PowerShell

Category	Endpoint, Malware and Living-off-the-Land
MITRE ATT&CK Mapping	T1059.001 PowerShell; T1204 User Execution
Detection Objective	Detect and investigate office application spawns powershell using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	EDR Process Events, Sysmon, Email Gateway
Recommended Building Blocks	BB: Office Parent Process, BB: Script Interpreter Child, BB: External Sender Attachment
Recommended Alert Name	2026 - Office Application Spawns PowerShell
Recommended Incident Name	Possible Office Application Spawns PowerShell Investigation

1. Scenario

A user opens a document and Office launches PowerShell with suspicious command-line parameters.

Endpoint use cases must focus on behaviour, not only known malware. Living-off-the-land techniques abuse native tools and normal administrative binaries, so context and parent-child process relationships are essential.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1059.001 PowerShell; T1204 User Execution. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
EDR Process Events	Provides endpoint execution and host-level evidence for Office Application Spawns PowerShell. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device isolation status and sensor health.	Simulation: parent=explorer.exe, child=powershell.exe, command='-EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution rather than only file delivery.
Sysmon	Provides endpoint execution and host-level evidence for Office Application Spawns PowerShell. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device isolation status and sensor health.	Simulation: parent=explorer.exe, child=powershell.exe, command='-EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution rather than only file delivery.
Email Gateway	Provides message delivery and threat verdict evidence for Office Application Spawns PowerShell. It helps confirm sender, recipient, subject, attachment name, URL, verdict, delivery status and whether the user interacted with the message.	Simulation: sender=external-payments@example.com, recipient=finance@company.com, attachment=Invoice.zip, verdict=Suspicious, delivered=True. This is the starting point for phishing or malware investigation.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Office Application Spawns PowerShell, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.

	reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Office Application Spawns PowerShell. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Office Application Spawns PowerShell. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Office Application Spawns PowerShell. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Office Application Spawns PowerShell was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Office Application Spawns PowerShell. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Office Application Spawns PowerShell, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Office Parent Process: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Script Interpreter Child: maintain the list owner, update frequency, source of truth and exception approval process.

- BB: External Sender Attachment: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Office Parent Process, BB: Script Interpreter Child, BB: External Sender Attachment];

FROM EDR Process Events, Sysmon, Email Gateway

WHERE TimeGenerated >= now() - lookback

AND event_matches('Office Application Spawns PowerShell')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Office Application Spawns PowerShell
Incident Name	Possible Office Application Spawns PowerShell Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Endpoint, Malware and Living-off-the-Land

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Office Application Spawns PowerShell Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 10:48:00	EDR Process Events	user1036@example.local	WS-2036	203.0.113.3	Initial signal	Event indicates office application spawns powershell.
2026-05-18 10:50:00	Sysmon	user1036@example.local	WS-2036	203.0.113.3	Context signal	Entity context matched BB: Office Parent Process.
2026-05-18 10:55:00	Email Gateway	user1036@example.local	WS-2036	10.20.6.147	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 10:58:00	SIEM Correlation	user1036@example.local	WS-2036	203.0.113.3	Rule matched	Correlation matched building blocks: BB: Office Parent Process, BB: Script Interpreter Child.
2026-05-18 11:06:00	SOC Case Record	user1036@example.local	WS-2036	203.0.113.3	Incident created	Incident created for Office Application Spawns PowerShell with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- What is the parent-child process chain and command-line context?
- Should the endpoint or server be isolated immediately?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Contain affected endpoint or server if execution, credential access, persistence, lateral movement or impact indicators are confirmed.
- Collect process tree, file hash, command line, network destination and memory/EDR evidence where required.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Office Parent Process, BB: Script Interpreter Child, BB: External Sender Attachment.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 037: Encoded or Obfuscated PowerShell Command

Category	Endpoint, Malware and Living-off-the-Land
MITRE ATT&CK Mapping	T1059.001 PowerShell; T1027 Obfuscated Files or Information
Detection Objective	Detect and investigate encoded or obfuscated powershell command using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	EDR, Sysmon Event 1, PowerShell Logs
Recommended Building Blocks	BB: EncodedCommand, BB: Suspicious PowerShell Flags, BB: User-Writable Path
Recommended Alert Name	2026 - Encoded or Obfuscated PowerShell Command
Recommended Incident Name	Possible Encoded or Obfuscated PowerShell Command Investigation

1. Scenario

PowerShell executes with encoded or hidden command flags from a user directory.

Endpoint use cases must focus on behaviour, not only known malware. Living-off-the-land techniques abuse native tools and normal administrative binaries, so context and parent-child process relationships are essential.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1059.001 PowerShell; T1027 Obfuscated Files or Information. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
EDR	Provides endpoint execution and host-level evidence for Encoded or Obfuscated PowerShell Command. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device isolation status and sensor health.	Simulation: parent=explorer.exe, child=powershell.exe, command='-EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution rather than only file delivery.
Sysmon Event 1	Provides endpoint execution and host-level evidence for Encoded or Obfuscated PowerShell Command. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device isolation status and sensor health.	Simulation: parent=explorer.exe, child=powershell.exe, command='-EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution rather than only file delivery.
PowerShell Logs	Provides supporting evidence for Encoded or Obfuscated PowerShell Command. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Encoded or Obfuscated PowerShell Command. If the evidence is incomplete, the analyst should request the missing log source before closure.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Encoded or Obfuscated PowerShell Command, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order.	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.

	Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Encoded or Obfuscated PowerShell Command. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Encoded or Obfuscated PowerShell Command. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Encoded or Obfuscated PowerShell Command. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Encoded or Obfuscated PowerShell Command was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Encoded or Obfuscated PowerShell Command. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Encoded or Obfuscated PowerShell Command, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: EncodedCommand: maintain the list owner, update frequency, source of truth and exception approval process.

- BB: Suspicious PowerShell Flags: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: User-Writable Path: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: EncodedCommand, BB: Suspicious PowerShell Flags, BB: User-Writable Path];

FROM EDR, Sysmon Event 1, PowerShell Logs

WHERE TimeGenerated >= now() - lookback

AND event_matches('Encoded or Obfuscated PowerShell Command')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Encoded or Obfuscated PowerShell Command
Incident Name	Possible Encoded or Obfuscated PowerShell Command Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Endpoint, Malware and Living-off-the-Land

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Encoded or Obfuscated PowerShell Command Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 10:51:00	EDR	user1037@example.local	WS-2037	203.0.113.10	Initial signal	Event indicates encoded or obfuscated powershell command.
2026-05-18 10:53:00	Sysmon Event 1	user1037@example.local	WS-2037	203.0.113.10	Context signal	Entity context matched BB: EncodedCommand.
2026-05-18 10:58:00	PowerShell Logs	user1037@example.local	WS-2037	10.20.7.158	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 11:01:00	SIEM Correlation	user1037@example.local	WS-2037	203.0.113.10	Rule matched	Correlation matched building blocks: BB: EncodedCommand, BB: Suspicious PowerShell Flags.
2026-05-18 11:09:00	SOC Case Record	user1037@example.local	WS-2037	203.0.113.10	Incident created	Incident created for Encoded or Obfuscated PowerShell Command with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- What is the parent-child process chain and command-line context?
- Should the endpoint or server be isolated immediately?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Contain affected endpoint or server if execution, credential access, persistence, lateral movement or impact indicators are confirmed.
- Collect process tree, file hash, command line, network destination and memory/EDR evidence where required.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: EncodedCommand, BB: Suspicious PowerShell Flags, BB: User-Writable Path.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 038: PowerShell Downloads Remote Content

Category	Endpoint, Malware and Living-off-the-Land
MITRE ATT&CK Mapping	T1105 Ingress Tool Transfer; T1059.001 PowerShell
Detection Objective	Detect and investigate powershell downloads remote content using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	EDR, Proxy Logs, DNS Logs, PowerShell Logs
Recommended Building Blocks	BB: PowerShell Network, BB: Suspicious Domain, BB: Newly Seen Destination
Recommended Alert Name	2026 - PowerShell Downloads Remote Content
Recommended Incident Name	Possible PowerShell Downloads Remote Content Investigation

1. Scenario

PowerShell attempts to download a script or payload from an external domain.

Endpoint use cases must focus on behaviour, not only known malware. Living-off-the-land techniques abuse native tools and normal administrative binaries, so context and parent-child process relationships are essential.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1105 Ingress Tool Transfer; T1059.001 PowerShell. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
EDR	Provides endpoint execution and host-level evidence for PowerShell Downloads Remote Content. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device isolation status and sensor health.	Simulation: parent=explorer.exe, child=powershell.exe, command='-EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution rather than only file delivery.
Proxy Logs	Shows outbound web access linked to PowerShell Downloads Remote Content, including URL, domain, category, upload/download size, HTTP method, user-agent, action and reputation. It helps confirm phishing clicks, payload downloads, C2, exfiltration or unapproved AI/cloud tool usage.	Simulation: user=farah.finance, url=hxxps://unknown-file-share.example/upload, bytes_out=524288000, action=Allowed. If this occurs after sensitive file access, investigate possible exfiltration.
DNS Logs	Shows domain resolution behaviour for PowerShell Downloads Remote Content. DNS logs help identify newly observed domains, C2 beaconing, DNS tunnelling, malware callbacks and suspicious infrastructure before or after endpoint/network activity.	Simulation: host=BSN-LT-0441 repeatedly queries a long random subdomain every 60 seconds. This may indicate beaconing or tunnelling when correlated with endpoint process activity.
PowerShell Logs	Provides supporting evidence for PowerShell Downloads Remote Content. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for PowerShell Downloads Remote Content. If the evidence is incomplete, the analyst should request

	whether it links to other suspicious activity in the same timeline.	the missing log source before closure.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For PowerShell Downloads Remote Content, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in PowerShell Downloads Remote Content. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to PowerShell Downloads Remote Content. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to PowerShell Downloads Remote Content. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in PowerShell Downloads Remote Content was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during PowerShell Downloads Remote Content. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For PowerShell Downloads Remote Content, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: PowerShell Network: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Suspicious Domain: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Newly Seen Destination: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: PowerShell Network, BB: Suspicious Domain, BB: Newly Seen Destination];

FROM EDR, Proxy Logs, DNS Logs

WHERE TimeGenerated >= now() - lookback

AND event_matches('PowerShell Downloads Remote Content')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - PowerShell Downloads Remote Content
Incident Name	Possible PowerShell Downloads Remote Content Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Endpoint, Malware and Living-off-the-Land

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible PowerShell Downloads Remote Content Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.

- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 10:54:00	EDR	user1038@example.local	WS-2038	203.0.113.17	Initial signal	Event indicates powershell downloads remote content.
2026-05-18 10:56:00	Proxy Logs	user1038@example.local	WS-2038	203.0.113.17	Context signal	Entity context matched BB: PowerShell Network.
2026-05-18 11:01:00	DNS Logs	user1038@example.local	WS-2038	10.20.8.169	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 11:04:00	SIEM Correlation	user1038@example.local	WS-2038	203.0.113.17	Rule matched	Correlation matched building blocks: BB: PowerShell Network, BB: Suspicious Domain.
2026-05-18 11:12:00	SOC Case Record	user1038@example.local	WS-2038	203.0.113.17	Incident created	Incident created for PowerShell Downloads Remote Content with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- What is the parent-child process chain and command-line context?
- Should the endpoint or server be isolated immediately?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Contain affected endpoint or server if execution, credential access, persistence, lateral movement or impact indicators are confirmed.
- Collect process tree, file hash, command line, network destination and memory/EDR evidence where required.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.

- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: PowerShell Network, BB: Suspicious Domain, BB: Newly Seen Destination.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 039: LNK File Launches Command Interpreter

Category	Endpoint, Malware and Living-off-the-Land
MITRE ATT&CK Mapping	T1204 User Execution; T1059 Command and Scripting Interpreter
Detection Objective	Detect and investigate lnk file launches command interpreter using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	EDR File Events, EDR Process Events, Sysmon
Recommended Building Blocks	BB: LNK Execution, BB: Command Interpreter Child, BB: User Downloads Path
Recommended Alert Name	2026 - LNK File Launches Command Interpreter
Recommended Incident Name	Possible LNK File Launches Command Interpreter Investigation

1. Scenario

A shortcut file disguised as a PDF launches cmd.exe or PowerShell.

Endpoint use cases must focus on behaviour, not only known malware. Living-off-the-land techniques abuse native tools and normal administrative binaries, so context and parent-child process relationships are essential.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1204 User Execution; T1059 Command and Scripting Interpreter. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
EDR File Events	Provides endpoint execution and host-level evidence for LNK File Launches Command Interpreter. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device isolation status and sensor health.	Simulation: parent=explorer.exe, child=powershell.exe, command='-EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution rather than only file delivery.
EDR Process Events	Provides endpoint execution and host-level evidence for LNK File Launches Command Interpreter. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device isolation status and sensor health.	Simulation: parent=explorer.exe, child=powershell.exe, command='-EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution rather than only file delivery.
Sysmon	Provides endpoint execution and host-level evidence for LNK File Launches Command Interpreter. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device isolation status and sensor health.	Simulation: parent=explorer.exe, child=powershell.exe, command='-EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution rather than only file delivery.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For LNK File Launches Command Interpreter, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.

	reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in LNK File Launches Command Interpreter. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to LNK File Launches Command Interpreter. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to LNK File Launches Command Interpreter. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in LNK File Launches Command Interpreter was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during LNK File Launches Command Interpreter. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For LNK File Launches Command Interpreter, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: LNK Execution: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Command Interpreter Child: maintain the list owner, update frequency, source of truth and exception approval process.

- BB: User Downloads Path: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: LNK Execution, BB: Command Interpreter Child, BB: User Downloads Path];

FROM EDR File Events, EDR Process Events, Sysmon

WHERE TimeGenerated >= now() - lookback

AND event_matches('LNK File Launches Command Interpreter')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - LNK File Launches Command Interpreter
Incident Name	Possible LNK File Launches Command Interpreter Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Endpoint, Malware and Living-off-the-Land

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible LNK File Launches Command Interpreter Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
------	--------	------	------	-----------	-------	-----------------

2026-05-18 10:57:00	EDR File Events	user1039@example.local	WS-2039	203.0.113.24	Initial signal	Event indicates lnk file launches command interpreter.
2026-05-18 10:59:00	EDR Process Events	user1039@example.local	WS-2039	203.0.113.24	Context signal	Entity context matched BB: LNK Execution.
2026-05-18 11:04:00	Sysmon	user1039@example.local	WS-2039	10.20.9.180	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 11:07:00	SIEM Correlation	user1039@example.local	WS-2039	203.0.113.24	Rule matched	Correlation matched building blocks: BB: LNK Execution, BB: Command Interpreter Child.
2026-05-18 11:15:00	SOC Case Record	user1039@example.local	WS-2039	203.0.113.24	Incident created	Incident created for LNK File Launches Command Interpreter with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- What is the parent-child process chain and command-line context?
- Should the endpoint or server be isolated immediately?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Contain affected endpoint or server if execution, credential access, persistence, lateral movement or impact indicators are confirmed.
- Collect process tree, file hash, command line, network destination and memory/EDR evidence where required.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: LNK Execution, BB: Command Interpreter Child, BB: User Downloads Path.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 040: Rundll32 Execution from User-Writable Path

Category	Endpoint, Malware and Living-off-the-Land
MITRE ATT&CK Mapping	T1218.011 Rundll32
Detection Objective	Detect and investigate rundll32 execution from user-writable path using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	EDR, Sysmon, File Reputation
Recommended Building Blocks	BB: Rundll32 Execution, BB: User-Writable DLL Path, BB: Unsigned File
Recommended Alert Name	2026 - Rundll32 Execution from User-Writable Path
Recommended Incident Name	Possible Rundll32 Execution from User-Writable Path Investigation

1. Scenario

rundll32.exe runs a DLL from Downloads, Temp or AppData rather than a trusted system path.

Endpoint use cases must focus on behaviour, not only known malware. Living-off-the-land techniques abuse native tools and normal administrative binaries, so context and parent-child process relationships are essential.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1218.011 Rundll32. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
EDR	Provides endpoint execution and host-level evidence for Rundll32 Execution from User-Writable Path. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device isolation status and sensor health.	Simulation: parent=explorer.exe, child=powershell.exe, command='-EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution rather than only file delivery.
Sysmon	Provides endpoint execution and host-level evidence for Rundll32 Execution from User-Writable Path. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device isolation status and sensor health.	Simulation: parent=explorer.exe, child=powershell.exe, command='-EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution rather than only file delivery.
File Reputation	Adds external intelligence context to Rundll32 Execution from User-Writable Path. IOC, actor, campaign, reputation, first-seen date and confidence help prioritise alerts and connect internal evidence to known malicious infrastructure.	Simulation: destination IP matched TI feed as malware C2 with confidence=High, first_seen=2026-02-10. If internal host communicated successfully, investigate compromise evidence.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Rundll32 Execution from User-Writable Path, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.

	decide whether the activity is an isolated event or part of a chained incident.	
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Rundll32 Execution from User-Writable Path. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Rundll32 Execution from User-Writable Path. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Rundll32 Execution from User-Writable Path. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Rundll32 Execution from User-Writable Path was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Rundll32 Execution from User-Writable Path. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Rundll32 Execution from User-Writable Path, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Rundll32 Execution: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: User-Writable DLL Path: maintain the list owner, update frequency, source of truth and exception approval process.

- BB: Unsigned File: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Rundll32 Execution, BB: User-Writable DLL Path, BB: Unsigned File];

FROM EDR, Sysmon, File Reputation

WHERE TimeGenerated >= now() - lookback

AND event_matches('Rundll32 Execution from User-Writable Path')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Rundll32 Execution from User-Writable Path
Incident Name	Possible Rundll32 Execution from User-Writable Path Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Endpoint, Malware and Living-off-the-Land

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Rundll32 Execution from User-Writable Path Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
------	--------	------	------	-----------	-------	-----------------

2026-05-18 11:00:00	EDR	user1040@example.local	WS-2040	203.0.113.31	Initial signal	Event indicates rundll32 execution from user-writable path.
2026-05-18 11:02:00	Sysmon	user1040@example.local	WS-2040	203.0.113.31	Context signal	Entity context matched BB: Rundll32 Execution.
2026-05-18 11:07:00	File Reputation	user1040@example.local	WS-2040	10.20.10.191	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 11:10:00	SIEM Correlation	user1040@example.local	WS-2040	203.0.113.31	Rule matched	Correlation matched building blocks: BB: Rundll32 Execution, BB: User-Writable DLL Path.
2026-05-18 11:18:00	SOC Case Record	user1040@example.local	WS-2040	203.0.113.31	Incident created	Incident created for Rundll32 Execution from User-Writable Path with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- What is the parent-child process chain and command-line context?
- Should the endpoint or server be isolated immediately?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Contain affected endpoint or server if execution, credential access, persistence, lateral movement or impact indicators are confirmed.
- Collect process tree, file hash, command line, network destination and memory/EDR evidence where required.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Rundll32 Execution, BB: User-Writable DLL Path, BB: Unsigned File.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 041: Mshta Execution from Email or Browser Context

Category	Endpoint, Malware and Living-off-the-Land
MITRE ATT&CK Mapping	T1218.005 Mshta
Detection Objective	Detect and investigate mshta execution from email or browser context using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	EDR, Sysmon, Email Gateway, Browser Telemetry
Recommended Building Blocks	BB: Mshta Execution, BB: Suspicious Parent Process, BB: External URL Argument
Recommended Alert Name	2026 - Mshta Execution from Email or Browser Context
Recommended Incident Name	Possible Mshta Execution from Email or Browser Context Investigation

1. Scenario

mshta.exe is launched from an email or browser process and retrieves remote content.

Endpoint use cases must focus on behaviour, not only known malware. Living-off-the-land techniques abuse native tools and normal administrative binaries, so context and parent-child process relationships are essential.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1218.005 Mshta. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
EDR	Provides endpoint execution and host-level evidence for Mshta Execution from Email or Browser Context. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device isolation status and sensor health.	Simulation: parent=explorer.exe, child=powershell.exe, command='-EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution rather than only file delivery.
Sysmon	Provides endpoint execution and host-level evidence for Mshta Execution from Email or Browser Context. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device isolation status and sensor health.	Simulation: parent=explorer.exe, child=powershell.exe, command='-EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution rather than only file delivery.
Email Gateway	Provides message delivery and threat verdict evidence for Mshta Execution from Email or Browser Context. It helps confirm sender, recipient, subject, attachment name, URL, verdict, delivery status and whether the user interacted with the message.	Simulation: sender=external-payments@example.com, recipient=finance@company.com, attachment=Invoice.zip, verdict=Suspicious, delivered=True. This is the starting point for phishing or malware investigation.
Browser Telemetry	Provides supporting evidence for Mshta Execution from Email or Browser Context. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Mshta Execution from Email or Browser Context. If the evidence is incomplete, the analyst should request the missing log source before closure.

TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Mshta Execution from Email or Browser Context, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Mshta Execution from Email or Browser Context. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Mshta Execution from Email or Browser Context. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Mshta Execution from Email or Browser Context. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Mshta Execution from Email or Browser Context was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Mshta Execution from Email or Browser Context. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Mshta Execution from Email or Browser Context, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Mshta Execution: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Suspicious Parent Process: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: External URL Argument: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Mshta Execution, BB: Suspicious Parent Process, BB: External URL Argument];

FROM EDR, Sysmon, Email Gateway

WHERE TimeGenerated >= now() - lookback

AND event_matches('Mshta Execution from Email or Browser Context')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Mshta Execution from Email or Browser Context
Incident Name	Possible Mshta Execution from Email or Browser Context Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Endpoint, Malware and Living-off-the-Land

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Mshta Execution from Email or Browser Context Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.

- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 11:03:00	EDR	user1041@example.local	WS-2041	203.0.113.38	Initial signal	Event indicates mshta execution from email or browser context.
2026-05-18 11:05:00	Sysmon	user1041@example.local	WS-2041	203.0.113.38	Context signal	Entity context matched BB: Mshta Execution.
2026-05-18 11:10:00	Email Gateway	user1041@example.local	WS-2041	10.20.11.202	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 11:13:00	SIEM Correlation	user1041@example.local	WS-2041	203.0.113.38	Rule matched	Correlation matched building blocks: BB: Mshta Execution, BB: Suspicious Parent Process.
2026-05-18 11:21:00	SOC Case Record	user1041@example.local	WS-2041	203.0.113.38	Incident created	Incident created for Mshta Execution from Email or Browser Context with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- What is the parent-child process chain and command-line context?
- Should the endpoint or server be isolated immediately?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Contain affected endpoint or server if execution, credential access, persistence, lateral movement or impact indicators are confirmed.
- Collect process tree, file hash, command line, network destination and memory/EDR evidence where required.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Mshta Execution, BB: Suspicious Parent Process, BB: External URL Argument.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 042: Certutil or Bitsadmin Used to Download File

Category	Endpoint, Malware and Living-off-the-Land
MITRE ATT&CK Mapping	T1105 Ingress Tool Transfer; T1218 System Binary Proxy Execution
Detection Objective	Detect and investigate certutil or bitsadmin used to download file using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	EDR, Sysmon, Proxy Logs
Recommended Building Blocks	BB: LOLBin Download, BB: External Destination, BB: User Workstation
Recommended Alert Name	2026 - Certutil or Bitsadmin Used to Download File
Recommended Incident Name	Possible Certutil or Bitsadmin Used to Download File Investigation

1. Scenario

A native Windows utility is used to download a file from the internet.

Endpoint use cases must focus on behaviour, not only known malware. Living-off-the-land techniques abuse native tools and normal administrative binaries, so context and parent-child process relationships are essential.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1105 Ingress Tool Transfer; T1218 System Binary Proxy Execution. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
EDR	Provides endpoint execution and host-level evidence for Certutil or Bitsadmin Used to Download File. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device isolation status and sensor health.	Simulation: parent=explorer.exe, child=powershell.exe, command='-EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution rather than only file delivery.
Sysmon	Provides endpoint execution and host-level evidence for Certutil or Bitsadmin Used to Download File. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device isolation status and sensor health.	Simulation: parent=explorer.exe, child=powershell.exe, command='-EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution rather than only file delivery.
Proxy Logs	Shows outbound web access linked to Certutil or Bitsadmin Used to Download File, including URL, domain, category, upload/download size, HTTP method, user-agent, action and reputation. It helps confirm phishing clicks, payload downloads, C2, exfiltration or unapproved AI/cloud tool usage.	Simulation: user=farah.finance, url=hxxps://unknown-file-share.example/upload, bytes_out=524288000, action=Allowed. If this occurs after sensitive file access, investigate possible exfiltration.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Certutil or Bitsadmin Used to Download File, the analyst must compare the first suspicious event, the confirming event and any follow-on activity	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation

	in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Certutil or Bitsadmin Used to Download File. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Certutil or Bitsadmin Used to Download File. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Certutil or Bitsadmin Used to Download File. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Certutil or Bitsadmin Used to Download File was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Certutil or Bitsadmin Used to Download File. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Certutil or Bitsadmin Used to Download File, do not review the telemetry as isolated rows. Reconstruct the evidencing sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: LOLBin Download: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: External Destination: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: User Workstation: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: LOLBin Download, BB: External Destination, BB: User Workstation];

FROM EDR, Sysmon, Proxy Logs

WHERE TimeGenerated >= now() - lookback

AND event_matches('Certutil or Bitsadmin Used to Download File')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Certutil or Bitsadmin Used to Download File
Incident Name	Possible Certutil or Bitsadmin Used to Download File Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Endpoint, Malware and Living-off-the-Land

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Certutil or Bitsadmin Used to Download File Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18	EDR	user1042@example.local	WS-2042	203.0.113.45	Initial signal	Event indicates certutil or bitsadmin used to

11:06:00						download file.
2026-05-18 11:08:00	Sysmon	user1042@example.local	WS-2042	203.0.113.45	Context signal	Entity context matched BB: LOLBin Download.
2026-05-18 11:13:00	Proxy Logs	user1042@example.local	WS-2042	10.20.12.213	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 11:16:00	SIEM Correlation	user1042@example.local	WS-2042	203.0.113.45	Rule matched	Correlation matched building blocks: BB: LOLBin Download, BB: External Destination.
2026-05-18 11:24:00	SOC Case Record	user1042@example.local	WS-2042	203.0.113.45	Incident created	Incident created for Certutil or Bitsadmin Used to Download File with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- What is the parent-child process chain and command-line context?
- Should the endpoint or server be isolated immediately?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Contain affected endpoint or server if execution, credential access, persistence, lateral movement or impact indicators are confirmed.
- Collect process tree, file hash, command line, network destination and memory/EDR evidence where required.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: LOLBin Download, BB: External Destination, BB: User Workstation.

- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 043: Suspicious Scheduled Task Created

Category	Endpoint, Malware and Living-off-the-Land
MITRE ATT&CK Mapping	T1053 Scheduled Task/Job; T1053.005 Scheduled Task
Detection Objective	Detect and investigate suspicious scheduled task created using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Windows Event Logs, Sysmon, EDR
Recommended Building Blocks	BB: Scheduled Task Creation, BB: Script Interpreter Action, BB: User-Writable Path
Recommended Alert Name	2026 - Suspicious Scheduled Task Created
Recommended Incident Name	Possible Suspicious Scheduled Task Created Investigation

1. Scenario

A scheduled task is created to run PowerShell or a script repeatedly from a user directory.

Endpoint use cases must focus on behaviour, not only known malware. Living-off-the-land techniques abuse native tools and normal administrative binaries, so context and parent-child process relationships are essential.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1053 Scheduled Task/Job; T1053.005 Scheduled Task. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Windows Event Logs	Provides supporting evidence for Suspicious Scheduled Task Created. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Suspicious Scheduled Task Created. If the evidence is incomplete, the analyst should request the missing log source before closure.
Sysmon	Provides endpoint execution and host-level evidence for Suspicious Scheduled Task Created. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device isolation status and sensor health.	Simulation: parent=explorer.exe, child=powershell.exe, command='-EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution rather than only file delivery.
EDR	Provides endpoint execution and host-level evidence for Suspicious Scheduled Task Created. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device isolation status and sensor health.	Simulation: parent=explorer.exe, child=powershell.exe, command='-EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution rather than only file delivery.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Suspicious Scheduled Task Created, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.

	timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Suspicious Scheduled Task Created. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Suspicious Scheduled Task Created. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Suspicious Scheduled Task Created. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Suspicious Scheduled Task Created was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Suspicious Scheduled Task Created. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Suspicious Scheduled Task Created, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Scheduled Task Creation: maintain the list owner, update frequency, source of truth and exception approval process.

- BB: Script Interpreter Action: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: User-Writable Path: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Scheduled Task Creation, BB: Script Interpreter Action, BB: User-Writable Path];

FROM Windows Event Logs, Sysmon, EDR

WHERE TimeGenerated >= now() - lookback

AND event_matches('Suspicious Scheduled Task Created')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Suspicious Scheduled Task Created
Incident Name	Possible Suspicious Scheduled Task Created Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Endpoint, Malware and Living-off-the-Land

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Suspicious Scheduled Task Created Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 11:09:00	Windows Event Logs	user1043@example.local	WS-2043	203.0.113.52	Initial signal	Event indicates suspicious scheduled task created.
2026-05-18 11:11:00	Sysmon	user1043@example.local	WS-2043	203.0.113.52	Context signal	Entity context matched BB: Scheduled Task Creation.
2026-05-18 11:16:00	EDR	user1043@example.local	WS-2043	10.20.13.224	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 11:19:00	SIEM Correlation	user1043@example.local	WS-2043	203.0.113.52	Rule matched	Correlation matched building blocks: BB: Scheduled Task Creation, BB: Script Interpreter Action.
2026-05-18 11:27:00	SOC Case Record	user1043@example.local	WS-2043	203.0.113.52	Incident created	Incident created for Suspicious Scheduled Task Created with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- What is the parent-child process chain and command-line context?
- Should the endpoint or server be isolated immediately?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Contain affected endpoint or server if execution, credential access, persistence, lateral movement or impact indicators are confirmed.
- Collect process tree, file hash, command line, network destination and memory/EDR evidence where required.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Scheduled Task Creation, BB: Script Interpreter Action, BB: User-Writable Path.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 044: Registry Run Key Persistence

Category	Endpoint, Malware and Living-off-the-Land
MITRE ATT&CK Mapping	T1547.001 Registry Run Keys / Startup Folder
Detection Objective	Detect and investigate registry run key persistence using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Sysmon Registry Events, EDR
Recommended Building Blocks	BB: Autorun Registry Path, BB: User-Writable Executable, BB: Unknown Publisher
Recommended Alert Name	2026 - Registry Run Key Persistence
Recommended Incident Name	Possible Registry Run Key Persistence Investigation

1. Scenario

A Run key is created pointing to an executable under AppData or Temp.

Endpoint use cases must focus on behaviour, not only known malware. Living-off-the-land techniques abuse native tools and normal administrative binaries, so context and parent-child process relationships are essential.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1547.001 Registry Run Keys / Startup Folder. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Sysmon Registry Events	Provides endpoint execution and host-level evidence for Registry Run Key Persistence. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device isolation status and sensor health.	Simulation: parent=explorer.exe, child=powershell.exe, command='-EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution rather than only file delivery.
EDR	Provides endpoint execution and host-level evidence for Registry Run Key Persistence. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device isolation status and sensor health.	Simulation: parent=explorer.exe, child=powershell.exe, command='-EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution rather than only file delivery.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Registry Run Key Persistence, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Registry Run Key Persistence. This field is required	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same

	for entity mapping, privilege validation, historical baseline review and ownership confirmation.	account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Registry Run Key Persistence. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Registry Run Key Persistence. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Registry Run Key Persistence was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Registry Run Key Persistence. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Registry Run Key Persistence, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Autorun Registry Path: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: User-Writable Executable: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Unknown Publisher: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.

- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Autorun Registry Path, BB: User-Writable Executable, BB: Unknown Publisher];

FROM Sysmon Registry Events, EDR

WHERE TimeGenerated >= now() - lookback

AND event_matches('Registry Run Key Persistence')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Registry Run Key Persistence
Incident Name	Possible Registry Run Key Persistence Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Endpoint, Malware and Living-off-the-Land

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Registry Run Key Persistence Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 11:12:00	Sysmon Registry Events	user1044@example.local	WS-2044	203.0.113.59	Initial signal	Event indicates registry run key persistence.
2026-05-18 11:14:00	EDR	user1044@example.local	WS-2044	203.0.113.59	Context signal	Entity context matched BB: Autorun Registry Path.
2026-05-18 11:19:00	Sysmon Registry Events	user1044@example.local	WS-2044	10.20.14.235	Follow-on activity	Related activity observed in InternalApplication.

2026-05-18 11:22:00	SIEM Correlation	user1044@example.local	WS-2044	203.0.113.59	Rule matched	Correlation matched building blocks: BB: Autorun Registry Path, BB: User-Writable Executable.
2026-05-18 11:30:00	SOC Case Record	user1044@example.local	WS-2044	203.0.113.59	Incident created	Incident created for Registry Run Key Persistence with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- What is the parent-child process chain and command-line context?
- Should the endpoint or server be isolated immediately?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Contain affected endpoint or server if execution, credential access, persistence, lateral movement or impact indicators are confirmed.
- Collect process tree, file hash, command line, network destination and memory/EDR evidence where required.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Autorun Registry Path, BB: User-Writable Executable, BB: Unknown Publisher.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.

- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 045: Suspicious LSASS Access

Category	Endpoint, Malware and Living-off-the-Land
MITRE ATT&CK Mapping	T1003.001 LSASS Memory
Detection Objective	Detect and investigate suspicious lsass access using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	EDR, Sysmon Event 10, Windows Security Logs
Recommended Building Blocks	BB: LSASS Access, BB: Non-Standard Process, BB: Credential Theft Tools Exclusion
Recommended Alert Name	2026 - Suspicious LSASS Access
Recommended Incident Name	Possible Suspicious LSASS Access Investigation

1. Scenario

An unsigned or abnormal process opens LSASS memory with high access rights.

Endpoint use cases must focus on behaviour, not only known malware. Living-off-the-land techniques abuse native tools and normal administrative binaries, so context and parent-child process relationships are essential.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1003.001 LSASS Memory. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
EDR	Provides endpoint execution and host-level evidence for Suspicious LSASS Access. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device isolation status and sensor health.	Simulation: parent=explorer.exe, child=powershell.exe, command='-EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution rather than only file delivery.
Sysmon Event 10	Provides endpoint execution and host-level evidence for Suspicious LSASS Access. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device isolation status and sensor health.	Simulation: parent=explorer.exe, child=powershell.exe, command='-EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution rather than only file delivery.
Windows Security Logs	Provides on-premise identity and Windows authentication evidence for Suspicious LSASS Access. Useful fields include Event ID 4624, 4625, 4672, 4720, 4728, 4732, 4768, 4769, 4771, logon type, source workstation, target account and privilege assignment.	Simulation: EventID=4625 repeated failures from WS-0441, followed by EventID=4624 successful logon type 10 to SRV-FILE01. If EventID=4672 also appears, the account received privileged logon rights.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Suspicious LSASS Access, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.

	whether the activity is an isolated event or part of a chained incident.	
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Suspicious LSASS Access. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Suspicious LSASS Access. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Suspicious LSASS Access. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Suspicious LSASS Access was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Suspicious LSASS Access. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Suspicious LSASS Access, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: LSASS Access: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Non-Standard Process: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Credential Theft Tools Exclusion: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: LSASS Access, BB: Non-Standard Process, BB: Credential Theft Tools Exclusion];

FROM EDR, Sysmon Event 10, Windows Security Logs

WHERE TimeGenerated >= now() - lookback

AND event_matches('Suspicious LSASS Access')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Suspicious LSASS Access
Incident Name	Possible Suspicious LSASS Access Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Endpoint, Malware and Living-off-the-Land

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Suspicious LSASS Access Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 11:15:00	EDR	user1045@example.local	WS-2045	203.0.113.66	Initial signal	Event indicates suspicious lsass access.

2026-05-18 11:17:00	Sysmon Event 10	user1045@example.local	WS-2045	203.0.113.66	Context signal	Entity context matched BB: LSASS Access.
2026-05-18 11:22:00	Windows Security Logs	user1045@example.local	WS-2045	10.20.15.246	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 11:25:00	SIEM Correlation	user1045@example.local	WS-2045	203.0.113.66	Rule matched	Correlation matched building blocks: BB: LSASS Access, BB: Non-Standard Process.
2026-05-18 11:33:00	SOC Case Record	user1045@example.local	WS-2045	203.0.113.66	Incident created	Incident created for Suspicious LSASS Access with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- What is the parent-child process chain and command-line context?
- Should the endpoint or server be isolated immediately?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Contain affected endpoint or server if execution, credential access, persistence, lateral movement or impact indicators are confirmed.
- Collect process tree, file hash, command line, network destination and memory/EDR evidence where required.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: LSASS Access, BB: Non-Standard Process, BB: Credential Theft Tools Exclusion.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.

- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 046: Security Tool Disabled or Tampered

Category	Endpoint, Malware and Living-off-the-Land
MITRE ATT&CK Mapping	T1562 Impair Defenses
Detection Objective	Detect and investigate security tool disabled or tampered using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	EDR Health Logs, Windows Services, AV Logs, Sysmon
Recommended Building Blocks	BB: EDR Service Stop, BB: AV Policy Change, BB: Critical Servers
Recommended Alert Name	2026 - Security Tool Disabled or Tampered
Recommended Incident Name	Possible Security Tool Disabled or Tampered Investigation

1. Scenario

Endpoint protection service is stopped or policy is weakened before suspicious activity continues.

Endpoint use cases must focus on behaviour, not only known malware. Living-off-the-land techniques abuse native tools and normal administrative binaries, so context and parent-child process relationships are essential.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1562 Impair Defenses. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
EDR Health Logs	Provides endpoint execution and host-level evidence for Security Tool Disabled or Tampered. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device isolation status and sensor health.	Simulation: parent=explorer.exe, child=powershell.exe, command='-EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution rather than only file delivery.
Windows Services	Provides supporting evidence for Security Tool Disabled or Tampered. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Security Tool Disabled or Tampered. If the evidence is incomplete, the analyst should request the missing log source before closure.
AV Logs	Provides supporting evidence for Security Tool Disabled or Tampered. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Security Tool Disabled or Tampered. If the evidence is incomplete, the analyst should request the missing log source before closure.
Sysmon	Provides endpoint execution and host-level evidence for Security Tool Disabled or Tampered. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device isolation status and sensor health.	Simulation: parent=explorer.exe, child=powershell.exe, command='-EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution rather than only file delivery.

TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Security Tool Disabled or Tampered, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Security Tool Disabled or Tampered. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Security Tool Disabled or Tampered. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Security Tool Disabled or Tampered. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Security Tool Disabled or Tampered was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Security Tool Disabled or Tampered. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Security Tool Disabled or Tampered, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: EDR Service Stop: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: AV Policy Change: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Critical Servers: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: EDR Service Stop, BB: AV Policy Change, BB: Critical Servers];

FROM EDR Health Logs, Windows Services, AV Logs

WHERE TimeGenerated >= now() - lookback

AND event_matches('Security Tool Disabled or Tampered')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Security Tool Disabled or Tampered
Incident Name	Possible Security Tool Disabled or Tampered Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Endpoint, Malware and Living-off-the-Land

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Security Tool Disabled or Tampered Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.

- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 11:18:00	EDR Health Logs	user1046@example.local	WS-2046	203.0.113.73	Initial signal	Event indicates security tool disabled or tampered.
2026-05-18 11:20:00	Windows Services	user1046@example.local	WS-2046	203.0.113.73	Context signal	Entity context matched BB: EDR Service Stop.
2026-05-18 11:25:00	AV Logs	user1046@example.local	WS-2046	10.20.16.7	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 11:28:00	SIEM Correlation	user1046@example.local	WS-2046	203.0.113.73	Rule matched	Correlation matched building blocks: BB: EDR Service Stop, BB: AV Policy Change.
2026-05-18 11:36:00	SOC Case Record	user1046@example.local	WS-2046	203.0.113.73	Incident created	Incident created for Security Tool Disabled or Tampered with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- What is the parent-child process chain and command-line context?
- Should the endpoint or server be isolated immediately?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Contain affected endpoint or server if execution, credential access, persistence, lateral movement or impact indicators are confirmed.
- Collect process tree, file hash, command line, network destination and memory/EDR evidence where required.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.

- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: EDR Service Stop, BB: AV Policy Change, BB: Critical Servers.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 047: Same Suspicious Hash Executed on Multiple Hosts

Category	Endpoint, Malware and Living-off-the-Land
MITRE ATT&CK Mapping	T1105 Ingress Tool Transfer; T1204 User Execution
Detection Objective	Detect and investigate same suspicious hash executed on multiple hosts using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	EDR File Events, EDR Process Events, Threat Intel
Recommended Building Blocks	BB: Unknown File Hash, BB: Multi-Host Execution, BB: Malware Reputation
Recommended Alert Name	2026 - Same Suspicious Hash Executed on Multiple Hosts
Recommended Incident Name	Possible Same Suspicious Hash Executed on Multiple Hosts Investigation

1. Scenario

The same unknown executable appears and runs on multiple workstations within a short period.

Endpoint use cases must focus on behaviour, not only known malware. Living-off-the-land techniques abuse native tools and normal administrative binaries, so context and parent-child process relationships are essential.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1105 Ingress Tool Transfer; T1204 User Execution. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
EDR File Events	Provides endpoint execution and host-level evidence for Same Suspicious Hash Executed on Multiple Hosts. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device isolation status and sensor health.	Simulation: parent=explorer.exe, child=powershell.exe, command='-EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution rather than only file delivery.
EDR Process Events	Provides endpoint execution and host-level evidence for Same Suspicious Hash Executed on Multiple Hosts. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device isolation status and sensor health.	Simulation: parent=explorer.exe, child=powershell.exe, command='-EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution rather than only file delivery.
Threat Intel	Adds external intelligence context to Same Suspicious Hash Executed on Multiple Hosts. IOC, actor, campaign, reputation, first-seen date and confidence help prioritise alerts and connect internal evidence to known malicious infrastructure.	Simulation: destination IP matched TI feed as malware C2 with confidence=High, first_seen=2026-02-10. If internal host communicated successfully, investigate compromise evidence.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Same Suspicious Hash Executed on Multiple Hosts, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order.	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.

	Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Same Suspicious Hash Executed on Multiple Hosts. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Same Suspicious Hash Executed on Multiple Hosts. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Same Suspicious Hash Executed on Multiple Hosts. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Same Suspicious Hash Executed on Multiple Hosts was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Same Suspicious Hash Executed on Multiple Hosts. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Same Suspicious Hash Executed on Multiple Hosts, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Unknown File Hash: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Multi-Host Execution: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Malware Reputation: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Unknown File Hash, BB: Multi-Host Execution, BB: Malware Reputation];

FROM EDR File Events, EDR Process Events, Threat Intel

WHERE TimeGenerated >= now() - lookback

AND event_matches('Same Suspicious Hash Executed on Multiple Hosts')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Same Suspicious Hash Executed on Multiple Hosts
Incident Name	Possible Same Suspicious Hash Executed on Multiple Hosts Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Endpoint, Malware and Living-off-the-Land

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Same Suspicious Hash Executed on Multiple Hosts Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.

- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 11:21:00	EDR File Events	user1047@example.local	WS-2047	203.0.113.80	Initial signal	Event indicates same suspicious hash executed on multiple hosts.
2026-05-18 11:23:00	EDR Process Events	user1047@example.local	WS-2047	203.0.113.80	Context signal	Entity context matched BB: Unknown File Hash.
2026-05-18 11:28:00	Threat Intel	user1047@example.local	WS-2047	10.20.17.18	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 11:31:00	SIEM Correlation	user1047@example.local	WS-2047	203.0.113.80	Rule matched	Correlation matched building blocks: BB: Unknown File Hash, BB: Multi-Host Execution.
2026-05-18 11:39:00	SOC Case Record	user1047@example.local	WS-2047	203.0.113.80	Incident created	Incident created for Same Suspicious Hash Executed on Multiple Hosts with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- What is the parent-child process chain and command-line context?
- Should the endpoint or server be isolated immediately?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Contain affected endpoint or server if execution, credential access, persistence, lateral movement or impact indicators are confirmed.
- Collect process tree, file hash, command line, network destination and memory/EDR evidence where required.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.

- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Unknown File Hash, BB: Multi-Host Execution, BB: Malware Reputation.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 048: Volume Shadow Copy Deletion

Category	Ransomware and Destructive Activity
MITRE ATT&CK Mapping	T1490 Inhibit System Recovery
Detection Objective	Detect and investigate volume shadow copy deletion using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	EDR Process Events, Windows Logs, PowerShell Logs
Recommended Building Blocks	BB: Recovery Tampering Commands, BB: Server Criticality, BB: Admin Account
Recommended Alert Name	2026 - Volume Shadow Copy Deletion
Recommended Incident Name	Possible Volume Shadow Copy Deletion Investigation

1. Scenario

A host runs commands that delete local recovery snapshots, often seen before encryption activity.

Ransomware detection in 2026 must focus on precursor behaviour before impact. Backup tampering, lateral movement, recovery inhibition, file-staging and mass modification patterns are more valuable than waiting for encryption to complete.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1490 Inhibit System Recovery. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
EDR Process Events	Provides endpoint execution and host-level evidence for Volume Shadow Copy Deletion. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device isolation status and sensor health.	Simulation: parent=explorer.exe, child=powershell.exe, command='-EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution rather than only file delivery.
Windows Logs	Provides supporting evidence for Volume Shadow Copy Deletion. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Volume Shadow Copy Deletion. If the evidence is incomplete, the analyst should request the missing log source before closure.
PowerShell Logs	Provides supporting evidence for Volume Shadow Copy Deletion. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Volume Shadow Copy Deletion. If the evidence is incomplete, the analyst should request the missing log source before closure.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Volume Shadow Copy Deletion, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.

	timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Volume Shadow Copy Deletion. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Volume Shadow Copy Deletion. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Volume Shadow Copy Deletion. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Volume Shadow Copy Deletion was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Volume Shadow Copy Deletion. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Volume Shadow Copy Deletion, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Recovery Tampering Commands: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Server Criticality: maintain the list owner, update frequency, source of truth and exception approval process.

- BB: Admin Account: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Recovery Tampering Commands, BB: Server Criticality, BB: Admin Account];

FROM EDR Process Events, Windows Logs, PowerShell Logs

WHERE TimeGenerated >= now() - lookback

AND event_matches('Volume Shadow Copy Deletion')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Volume Shadow Copy Deletion
Incident Name	Possible Volume Shadow Copy Deletion Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Ransomware and Destructive Activity

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Volume Shadow Copy Deletion Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-	EDR Process	user1048@example.local	WS-	203.0.113.87	Initial	Event indicates volume

18 11:24:00	Events		2048		signal	shadow copy deletion.
2026-05-18 11:26:00	Windows Logs	user1048@example.local	WS-2048	203.0.113.87	Context signal	Entity context matched BB: Recovery Tampering Commands.
2026-05-18 11:31:00	PowerShell Logs	user1048@example.local	WS-2048	10.20.18.29	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 11:34:00	SIEM Correlation	user1048@example.local	WS-2048	203.0.113.87	Rule matched	Correlation matched building blocks: BB: Recovery Tampering Commands, BB: Server Criticality.
2026-05-18 11:42:00	SOC Case Record	user1048@example.local	WS-2048	203.0.113.87	Incident created	Incident created for Volume Shadow Copy Deletion with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- What is the parent-child process chain and command-line context?
- Should the endpoint or server be isolated immediately?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Contain affected endpoint or server if execution, credential access, persistence, lateral movement or impact indicators are confirmed.
- Collect process tree, file hash, command line, network destination and memory/EDR evidence where required.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Recovery Tampering Commands, BB: Server Criticality, BB: Admin Account.

- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 049: Backup Repository Deletion or Tampering

Category	Ransomware and Destructive Activity
MITRE ATT&CK Mapping	T1490 Inhibit System Recovery
Detection Objective	Detect and investigate backup repository deletion or tampering using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Backup Platform Logs, PAM Logs, Windows Logs
Recommended Building Blocks	BB: Backup Admin Accounts, BB: Critical Backup Repository, BB: Approved Backup Jobs
Recommended Alert Name	2026 - Backup Repository Deletion or Tampering
Recommended Incident Name	Possible Backup Repository Deletion or Tampering Investigation

1. Scenario

A backup admin account deletes restore points or modifies retention unexpectedly.

Ransomware detection in 2026 must focus on precursor behaviour before impact. Backup tampering, lateral movement, recovery inhibition, file-staging and mass modification patterns are more valuable than waiting for encryption to complete.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1490 Inhibit System Recovery. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Backup Platform Logs	Provides supporting evidence for Backup Repository Deletion or Tampering. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Backup Repository Deletion or Tampering. If the evidence is incomplete, the analyst should request the missing log source before closure.
PAM Logs	Provides privileged session evidence for Backup Repository Deletion or Tampering. It links admin activity to approved access requests, password checkouts, session recordings, commands executed, target systems and vendor/user identity.	Simulation: admin checked out domain admin password at 02:11 with no matching change ticket, then logged into SRV-DC01. This requires privileged access validation.
Windows Logs	Provides supporting evidence for Backup Repository Deletion or Tampering. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Backup Repository Deletion or Tampering. If the evidence is incomplete, the analyst should request the missing log source before closure.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Backup Repository Deletion or Tampering, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.

	decide whether the activity is an isolated event or part of a chained incident.	
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Backup Repository Deletion or Tampering. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Backup Repository Deletion or Tampering. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Backup Repository Deletion or Tampering. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Backup Repository Deletion or Tampering was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Backup Repository Deletion or Tampering. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Backup Repository Deletion or Tampering, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Backup Admin Accounts: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Critical Backup Repository: maintain the list owner, update frequency, source of truth and exception approval process.

- BB: Approved Backup Jobs: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Backup Admin Accounts, BB: Critical Backup Repository, BB: Approved Backup Jobs];

FROM Backup Platform Logs, PAM Logs, Windows Logs

WHERE TimeGenerated >= now() - lookback

AND event_matches('Backup Repository Deletion or Tampering')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Backup Repository Deletion or Tampering
Incident Name	Possible Backup Repository Deletion or Tampering Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Ransomware and Destructive Activity

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Backup Repository Deletion or Tampering Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
------	--------	------	------	-----------	-------	-----------------

2026-05-18 11:27:00	Backup Platform Logs	user1049@example.local	WS-2049	203.0.113.94	Initial signal	Event indicates backup repository deletion or tampering.
2026-05-18 11:29:00	PAM Logs	user1049@example.local	WS-2049	203.0.113.94	Context signal	Entity context matched BB: Backup Admin Accounts.
2026-05-18 11:34:00	Windows Logs	user1049@example.local	WS-2049	10.20.19.40	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 11:37:00	SIEM Correlation	user1049@example.local	WS-2049	203.0.113.94	Rule matched	Correlation matched building blocks: BB: Backup Admin Accounts, BB: Critical Backup Repository.
2026-05-18 11:45:00	SOC Case Record	user1049@example.local	WS-2049	203.0.113.94	Incident created	Incident created for Backup Repository Deletion or Tampering with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- What is the parent-child process chain and command-line context?
- Should the endpoint or server be isolated immediately?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Contain affected endpoint or server if execution, credential access, persistence, lateral movement or impact indicators are confirmed.
- Collect process tree, file hash, command line, network destination and memory/EDR evidence where required.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Backup Admin Accounts, BB: Critical Backup Repository, BB: Approved Backup Jobs.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 050: Mass File Rename or Modification Spike

Category	Ransomware and Destructive Activity
MITRE ATT&CK Mapping	T1486 Data Encrypted for Impact
Detection Objective	Detect and investigate mass file rename or modification spike using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	File Server Audit, EDR File Events, Windows Logs
Recommended Building Blocks	BB: File Rename Rate, BB: Sensitive Shares, BB: Known Backup Processes
Recommended Alert Name	2026 - Mass File Rename or Modification Spike
Recommended Incident Name	Possible Mass File Rename or Modification Spike Investigation

1. Scenario

One endpoint modifies thousands of files across a share in minutes.

Ransomware detection in 2026 must focus on precursor behaviour before impact. Backup tampering, lateral movement, recovery inhibition, file-staging and mass modification patterns are more valuable than waiting for encryption to complete.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1486 Data Encrypted for Impact. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
File Server Audit	Provides supporting evidence for Mass File Rename or Modification Spike. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Mass File Rename or Modification Spike. If the evidence is incomplete, the analyst should request the missing log source before closure.
EDR File Events	Provides endpoint execution and host-level evidence for Mass File Rename or Modification Spike. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device isolation status and sensor health.	Simulation: parent=explorer.exe, child=powershell.exe, command='- EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution rather than only file delivery.
Windows Logs	Provides supporting evidence for Mass File Rename or Modification Spike. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Mass File Rename or Modification Spike. If the evidence is incomplete, the analyst should request the missing log source before closure.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Mass File Rename or Modification Spike, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.

	reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Mass File Rename or Modification Spike. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Mass File Rename or Modification Spike. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Mass File Rename or Modification Spike. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Mass File Rename or Modification Spike was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Mass File Rename or Modification Spike. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Mass File Rename or Modification Spike, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: File Rename Rate: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Sensitive Shares: maintain the list owner, update frequency, source of truth and exception approval process.

- BB: Known Backup Processes: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: File Rename Rate, BB: Sensitive Shares, BB: Known Backup Processes];

FROM File Server Audit, EDR File Events, Windows Logs

WHERE TimeGenerated >= now() - lookback

AND event_matches('Mass File Rename or Modification Spike')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Mass File Rename or Modification Spike
Incident Name	Possible Mass File Rename or Modification Spike Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Ransomware and Destructive Activity

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Mass File Rename or Modification Spike Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 11:30:00	File Server Audit	user1050@example.local	WS-2050	203.0.113.101	Initial signal	Event indicates mass file rename or modification spike.
2026-05-18 11:32:00	EDR File Events	user1050@example.local	WS-2050	203.0.113.101	Context signal	Entity context matched BB: File Rename Rate.
2026-05-18 11:37:00	Windows Logs	user1050@example.local	WS-2050	10.20.20.51	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 11:40:00	SIEM Correlation	user1050@example.local	WS-2050	203.0.113.101	Rule matched	Correlation matched building blocks: BB: File Rename Rate, BB: Sensitive Shares.
2026-05-18 11:48:00	SOC Case Record	user1050@example.local	WS-2050	203.0.113.101	Incident created	Incident created for Mass File Rename or Modification Spike with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- What is the parent-child process chain and command-line context?
- Should the endpoint or server be isolated immediately?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Contain affected endpoint or server if execution, credential access, persistence, lateral movement or impact indicators are confirmed.
- Collect process tree, file hash, command line, network destination and memory/EDR evidence where required.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: File Rename Rate, BB: Sensitive Shares, BB: Known Backup Processes.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 051: Ransom Note Pattern Across Multiple Hosts

Category	Ransomware and Destructive Activity
MITRE ATT&CK Mapping	T1486 Data Encrypted for Impact
Detection Objective	Detect and investigate ransom note pattern across multiple hosts using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	EDR File Events, File Server Audit
Recommended Building Blocks	BB: Ransom Note Filename Pattern, BB: Multi-Host File Creation, BB: Sensitive Shares
Recommended Alert Name	2026 - Ransom Note Pattern Across Multiple Hosts
Recommended Incident Name	Possible Ransom Note Pattern Across Multiple Hosts Investigation

1. Scenario

Identical recovery-note files appear across many folders and hosts.

Ransomware detection in 2026 must focus on precursor behaviour before impact. Backup tampering, lateral movement, recovery inhibition, file-staging and mass modification patterns are more valuable than waiting for encryption to complete.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1486 Data Encrypted for Impact. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
EDR File Events	Provides endpoint execution and host-level evidence for Ransom Note Pattern Across Multiple Hosts. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device isolation status and sensor health.	Simulation: parent=explorer.exe, child=powershell.exe, command='-EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution rather than only file delivery.
File Server Audit	Provides supporting evidence for Ransom Note Pattern Across Multiple Hosts. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Ransom Note Pattern Across Multiple Hosts. If the evidence is incomplete, the analyst should request the missing log source before closure.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Ransom Note Pattern Across Multiple Hosts, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Ransom Note Pattern Across Multiple Hosts. This	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same

	field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Ransom Note Pattern Across Multiple Hosts. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Ransom Note Pattern Across Multiple Hosts. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Ransom Note Pattern Across Multiple Hosts was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Ransom Note Pattern Across Multiple Hosts. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Ransom Note Pattern Across Multiple Hosts, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Ransom Note Filename Pattern: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Multi-Host File Creation: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Sensitive Shares: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Ransom Note Filename Pattern, BB: Multi-Host File Creation, BB: Sensitive Shares];

FROM EDR File Events, File Server Audit

WHERE TimeGenerated >= now() - lookback

AND event_matches('Ransom Note Pattern Across Multiple Hosts')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Ransom Note Pattern Across Multiple Hosts
Incident Name	Possible Ransom Note Pattern Across Multiple Hosts Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Ransomware and Destructive Activity

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Ransom Note Pattern Across Multiple Hosts Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18	EDR File Events	user1051@example.local	WS-2051	203.0.113.108	Initial signal	Event indicates ransom note pattern across

11:33:00						multiple hosts.
2026-05-18 11:35:00	File Server Audit	user1051@example.local	WS-2051	203.0.113.108	Context signal	Entity context matched BB: Ransom Note Filename Pattern.
2026-05-18 11:40:00	EDR File Events	user1051@example.local	WS-2051	10.20.21.62	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 11:43:00	SIEM Correlation	user1051@example.local	WS-2051	203.0.113.108	Rule matched	Correlation matched building blocks: BB: Ransom Note Filename Pattern, BB: Multi-Host File Creation.
2026-05-18 11:51:00	SOC Case Record	user1051@example.local	WS-2051	203.0.113.108	Incident created	Incident created for Ransom Note Pattern Across Multiple Hosts with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- What is the parent-child process chain and command-line context?
- Should the endpoint or server be isolated immediately?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Contain affected endpoint or server if execution, credential access, persistence, lateral movement or impact indicators are confirmed.
- Collect process tree, file hash, command line, network destination and memory/EDR evidence where required.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Ransom Note Filename Pattern, BB: Multi-Host File Creation, BB: Sensitive Shares.

- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 052: Remote Admin Tool Abuse Before Impact

Category	Ransomware and Destructive Activity
MITRE ATT&CK Mapping	T1219 Remote Access Software; T1021 Remote Services
Detection Objective	Detect and investigate remote admin tool abuse before impact using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	EDR, Network Logs, PAM Logs
Recommended Building Blocks	BB: Approved Remote Tools, BB: Multi-Host Execution, BB: Critical Server Access
Recommended Alert Name	2026 - Remote Admin Tool Abuse Before Impact
Recommended Incident Name	Possible Remote Admin Tool Abuse Before Impact Investigation

1. Scenario

An unapproved remote administration tool is installed and used across many endpoints.

Ransomware detection in 2026 must focus on precursor behaviour before impact. Backup tampering, lateral movement, recovery inhibition, file-staging and mass modification patterns are more valuable than waiting for encryption to complete.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1219 Remote Access Software; T1021 Remote Services. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
EDR	Provides endpoint execution and host-level evidence for Remote Admin Tool Abuse Before Impact. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device isolation status and sensor health.	Simulation: parent=explorer.exe, child=powershell.exe, command='-EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution rather than only file delivery.
Network Logs	Provides network movement and perimeter evidence for Remote Admin Tool Abuse Before Impact. Important fields include source, destination, port, protocol, bytes in/out, action, rule name, zone, IPS signature and session duration.	Simulation: source=10.44.21.77, destination=10.10.4.20, port=445, action=Allowed, repeated across 30 hosts. This supports lateral movement or internal scanning analysis.
PAM Logs	Provides privileged session evidence for Remote Admin Tool Abuse Before Impact. It links admin activity to approved access requests, password checkouts, session recordings, commands executed, target systems and vendor/user identity.	Simulation: admin checked out domain admin password at 02:11 with no matching change ticket, then logged into SRV-DC01. This requires privileged access validation.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Remote Admin Tool Abuse Before Impact, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.

	event or part of a chained incident.	
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Remote Admin Tool Abuse Before Impact. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Remote Admin Tool Abuse Before Impact. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Remote Admin Tool Abuse Before Impact. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Remote Admin Tool Abuse Before Impact was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Remote Admin Tool Abuse Before Impact. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Remote Admin Tool Abuse Before Impact, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Approved Remote Tools: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Multi-Host Execution: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Critical Server Access: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Approved Remote Tools, BB: Multi-Host Execution, BB: Critical Server Access];

FROM EDR, Network Logs, PAM Logs

WHERE TimeGenerated >= now() - lookback

AND event_matches('Remote Admin Tool Abuse Before Impact')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Remote Admin Tool Abuse Before Impact
Incident Name	Possible Remote Admin Tool Abuse Before Impact Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Ransomware and Destructive Activity

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Remote Admin Tool Abuse Before Impact Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18	EDR	user1052@example.local	WS-2052	203.0.113.115	Initial signal	Event indicates remote admin tool abuse

11:36:00						before impact.
2026-05-18 11:38:00	Network Logs	user1052@example.local	WS-2052	203.0.113.115	Context signal	Entity context matched BB: Approved Remote Tools.
2026-05-18 11:43:00	PAM Logs	user1052@example.local	WS-2052	10.20.22.73	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 11:46:00	SIEM Correlation	user1052@example.local	WS-2052	203.0.113.115	Rule matched	Correlation matched building blocks: BB: Approved Remote Tools, BB: Multi-Host Execution.
2026-05-18 11:54:00	SOC Case Record	user1052@example.local	WS-2052	203.0.113.115	Incident created	Incident created for Remote Admin Tool Abuse Before Impact with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- What is the parent-child process chain and command-line context?
- Should the endpoint or server be isolated immediately?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Contain affected endpoint or server if execution, credential access, persistence, lateral movement or impact indicators are confirmed.
- Collect process tree, file hash, command line, network destination and memory/EDR evidence where required.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Approved Remote Tools, BB: Multi-Host Execution, BB: Critical Server Access.

- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 053: Security Logs Cleared on Server

Category	Ransomware and Destructive Activity
MITRE ATT&CK Mapping	T1070.001 Clear Windows Event Logs
Detection Objective	Detect and investigate security logs cleared on server using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Windows Security Logs, EDR, SIEM Health
Recommended Building Blocks	BB: Event Log Cleared, BB: Critical Servers, BB: Privileged Users
Recommended Alert Name	2026 - Security Logs Cleared on Server
Recommended Incident Name	Possible Security Logs Cleared on Server Investigation

1. Scenario

Windows Security logs are cleared after privileged access to a server.

Ransomware detection in 2026 must focus on precursor behaviour before impact. Backup tampering, lateral movement, recovery inhibition, file-staging and mass modification patterns are more valuable than waiting for encryption to complete.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1070.001 Clear Windows Event Logs. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Windows Security Logs	Provides on-premise identity and Windows authentication evidence for Security Logs Cleared on Server. Useful fields include Event ID 4624, 4625, 4672, 4720, 4728, 4732, 4768, 4769, 4771, logon type, source workstation, target account and privilege assignment.	Simulation: EventID=4625 repeated failures from WS-0441, followed by EventID=4624 successful logon type 10 to SRV-FILE01. If EventID=4672 also appears, the account received privileged logon rights.
EDR	Provides endpoint execution and host-level evidence for Security Logs Cleared on Server. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device isolation status and sensor health.	Simulation: parent=explorer.exe, child=powershell.exe, command='- EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution rather than only file delivery.
SIEM Health	Provides supporting evidence for Security Logs Cleared on Server. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Security Logs Cleared on Server. If the evidence is incomplete, the analyst should request the missing log source before closure.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Security Logs Cleared on Server, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.

	timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Security Logs Cleared on Server. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Security Logs Cleared on Server. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Security Logs Cleared on Server. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Security Logs Cleared on Server was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Security Logs Cleared on Server. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Security Logs Cleared on Server, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Event Log Cleared: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Critical Servers: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Privileged Users: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Event Log Cleared, BB: Critical Servers, BB: Privileged Users];

FROM Windows Security Logs, EDR, SIEM Health

WHERE TimeGenerated >= now() - lookback

AND event_matches('Security Logs Cleared on Server')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Security Logs Cleared on Server
Incident Name	Possible Security Logs Cleared on Server Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Ransomware and Destructive Activity

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Security Logs Cleared on Server Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 11:39:00	Windows Security Logs	user1053@example.local	SRV-153	203.0.113.122	Initial signal	Event indicates security logs cleared on server.

2026-05-18 11:41:00	EDR	user1053@example.local	SRV-153	203.0.113.122	Context signal	Entity context matched BB: Event Log Cleared.
2026-05-18 11:46:00	SIEM Health	user1053@example.local	SRV-153	10.20.23.84	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 11:49:00	SIEM Correlation	user1053@example.local	SRV-153	203.0.113.122	Rule matched	Correlation matched building blocks: BB: Event Log Cleared, BB: Critical Servers.
2026-05-18 11:57:00	SOC Case Record	user1053@example.local	SRV-153	203.0.113.122	Incident created	Incident created for Security Logs Cleared on Server with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- What is the parent-child process chain and command-line context?
- Should the endpoint or server be isolated immediately?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Contain affected endpoint or server if execution, credential access, persistence, lateral movement or impact indicators are confirmed.
- Collect process tree, file hash, command line, network destination and memory/EDR evidence where required.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Event Log Cleared, BB: Critical Servers, BB: Privileged Users.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.

- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 054: Mass Service Stop on Critical Host

Category	Ransomware and Destructive Activity
MITRE ATT&CK Mapping	T1489 Service Stop
Detection Objective	Detect and investigate mass service stop on critical host using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Windows Service Logs, EDR Process Events, Application Logs
Recommended Building Blocks	BB: Critical Services, BB: Mass Service Stop, BB: Approved Maintenance Window
Recommended Alert Name	2026 - Mass Service Stop on Critical Host
Recommended Incident Name	Possible Mass Service Stop on Critical Host Investigation

1. Scenario

Multiple backup, database or endpoint protection services stop in a short time window.

Ransomware detection in 2026 must focus on precursor behaviour before impact. Backup tampering, lateral movement, recovery inhibition, file-staging and mass modification patterns are more valuable than waiting for encryption to complete.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1489 Service Stop. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Windows Service Logs	Provides supporting evidence for Mass Service Stop on Critical Host. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Mass Service Stop on Critical Host. If the evidence is incomplete, the analyst should request the missing log source before closure.
EDR Process Events	Provides endpoint execution and host-level evidence for Mass Service Stop on Critical Host. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device isolation status and sensor health.	Simulation: parent=explorer.exe, child=powershell.exe, command='-EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution rather than only file delivery.
Application Logs	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Mass Service Stop on Critical Host. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Mass Service Stop on Critical Host, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.

	whether the activity is an isolated event or part of a chained incident.	
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Mass Service Stop on Critical Host. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Mass Service Stop on Critical Host. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Mass Service Stop on Critical Host. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Mass Service Stop on Critical Host was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Mass Service Stop on Critical Host. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Mass Service Stop on Critical Host, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Critical Services: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Mass Service Stop: maintain the list owner, update frequency, source of truth and exception approval process.

- BB: Approved Maintenance Window: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Critical Services, BB: Mass Service Stop, BB: Approved Maintenance Window];

FROM Windows Service Logs, EDR Process Events, Application Logs

WHERE TimeGenerated >= now() - lookback

AND event_matches('Mass Service Stop on Critical Host')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Mass Service Stop on Critical Host
Incident Name	Possible Mass Service Stop on Critical Host Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Ransomware and Destructive Activity

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Mass Service Stop on Critical Host Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
------	--------	------	------	-----------	-------	-----------------

2026-05-18 11:42:00	Windows Service Logs	user1054@example.local	WS-2054	203.0.113.129	Initial signal	Event indicates mass service stop on critical host.
2026-05-18 11:44:00	EDR Process Events	user1054@example.local	WS-2054	203.0.113.129	Context signal	Entity context matched BB: Critical Services.
2026-05-18 11:49:00	Application Logs	user1054@example.local	WS-2054	10.20.24.95	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 11:52:00	SIEM Correlation	user1054@example.local	WS-2054	203.0.113.129	Rule matched	Correlation matched building blocks: BB: Critical Services, BB: Mass Service Stop.
2026-05-18 12:00:00	SOC Case Record	user1054@example.local	WS-2054	203.0.113.129	Incident created	Incident created for Mass Service Stop on Critical Host with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- What is the parent-child process chain and command-line context?
- Should the endpoint or server be isolated immediately?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Contain affected endpoint or server if execution, credential access, persistence, lateral movement or impact indicators are confirmed.
- Collect process tree, file hash, command line, network destination and memory/EDR evidence where required.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Critical Services, BB: Mass Service Stop, BB: Approved Maintenance Window.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 055: Data Staging and Large Archive Creation Before Upload

Category	Ransomware and Destructive Activity
MITRE ATT&CK Mapping	T1560 Archive Collected Data; T1041 Exfiltration Over C2 Channel
Detection Objective	Detect and investigate data staging and large archive creation before upload using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	EDR File Events, Proxy Logs, DLP, File Server Audit
Recommended Building Blocks	BB: Large Archive Creation, BB: Sensitive Folder, BB: External Upload
Recommended Alert Name	2026 - Data Staging and Large Archive Creation Before Upload
Recommended Incident Name	Possible Data Staging and Large Archive Creation Before Upload Investigation

1. Scenario

Large archives are created from sensitive folders and shortly after uploaded externally.

Ransomware detection in 2026 must focus on precursor behaviour before impact. Backup tampering, lateral movement, recovery inhibition, file-staging and mass modification patterns are more valuable than waiting for encryption to complete.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1560 Archive Collected Data; T1041 Exfiltration Over C2 Channel. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
EDR File Events	Provides endpoint execution and host-level evidence for Data Staging and Large Archive Creation Before Upload. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device isolation status and sensor health.	Simulation: parent=explorer.exe, child=powershell.exe, command='-EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution rather than only file delivery.
Proxy Logs	Shows outbound web access linked to Data Staging and Large Archive Creation Before Upload, including URL, domain, category, upload/download size, HTTP method, user-agent, action and reputation. It helps confirm phishing clicks, payload downloads, C2, exfiltration or unapproved AI/cloud tool usage.	Simulation: user=farah.finance, url=hxxps://unknown-file-share.example/upload, bytes_out=524288000, action=Allowed. If this occurs after sensitive file access, investigate possible exfiltration.
DLP	Shows data protection evidence for Data Staging and Large Archive Creation Before Upload. DLP/CASB telemetry confirms whether sensitive data was uploaded, shared, pasted, copied, synchronised or transferred to external services.	Simulation: DLP policy=Customer PII, destination=personal-cloud.example, action=AllowedWithAlert, file=Customer_List_2026.xlsx. This is evidence for possible data leakage.
File Server Audit	Provides supporting evidence for Data Staging and Large Archive Creation Before Upload. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Data Staging and Large Archive Creation Before Upload. If the evidence is incomplete, the analyst should request the missing log

	activity in the same timeline.	source before closure.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Data Staging and Large Archive Creation Before Upload, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Data Staging and Large Archive Creation Before Upload. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Data Staging and Large Archive Creation Before Upload. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Data Staging and Large Archive Creation Before Upload. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Data Staging and Large Archive Creation Before Upload was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Data Staging and Large Archive Creation Before Upload. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Data Staging and Large Archive Creation Before Upload, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Large Archive Creation: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Sensitive Folder: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: External Upload: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Large Archive Creation, BB: Sensitive Folder, BB: External Upload];

FROM EDR File Events, Proxy Logs, DLP

WHERE TimeGenerated >= now() - lookback

AND event_matches('Data Staging and Large Archive Creation Before Upload')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Data Staging and Large Archive Creation Before Upload
Incident Name	Possible Data Staging and Large Archive Creation Before Upload Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Ransomware and Destructive Activity

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Data Staging and Large Archive Creation Before Upload Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.

- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 11:45:00	EDR File Events	user1055@example.local	WS-2055	203.0.113.136	Initial signal	Event indicates data staging and large archive creation before upload.
2026-05-18 11:47:00	Proxy Logs	user1055@example.local	WS-2055	203.0.113.136	Context signal	Entity context matched BB: Large Archive Creation.
2026-05-18 11:52:00	DLP	user1055@example.local	WS-2055	10.20.25.106	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 11:55:00	SIEM Correlation	user1055@example.local	WS-2055	203.0.113.136	Rule matched	Correlation matched building blocks: BB: Large Archive Creation, BB: Sensitive Folder.
2026-05-18 12:03:00	SOC Case Record	user1055@example.local	WS-2055	203.0.113.136	Incident created	Incident created for Data Staging and Large Archive Creation Before Upload with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- What is the parent-child process chain and command-line context?
- Should the endpoint or server be isolated immediately?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Contain affected endpoint or server if execution, credential access, persistence, lateral movement or impact indicators are confirmed.
- Collect process tree, file hash, command line, network destination and memory/EDR evidence where required.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.

- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Large Archive Creation, BB: Sensitive Folder, BB: External Upload.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 056: New OAuth Application Consent

Category	Cloud, SaaS, OAuth and Non-Human Identity
MITRE ATT&CK Mapping	T1098 Account Manipulation
Detection Objective	Detect and investigate new oauth application consent using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Entra ID Audit Logs, Cloud App Security, M365 Audit
Recommended Building Blocks	BB: OAuth Consent Event, BB: Approved Enterprise Apps, BB: Sensitive Users
Recommended Alert Name	2026 - New OAuth Application Consent
Recommended Incident Name	Possible New OAuth Application Consent Investigation

1. Scenario

A user grants access to a previously unseen third-party application.

Cloud and SaaS use cases must monitor human and non-human identities, OAuth grants, service principals, AI agents, guest access, policy changes and data access because cloud compromise can persist even after password reset.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1098 Account Manipulation. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Entra ID Audit Logs	Provides cloud identity evidence for New OAuth Application Consent. Key fields include user principal name, sign-in time, source IP, country, ASN, device ID, compliance state, MFA result, conditional access result, client app and target application. This telemetry shows whether the activity is normal user access or suspicious identity behaviour.	Simulation: user=farah.finance@company.com, app=Exchange Online, source_ip=185.220.101.34, country=DE, device=Unknown, MFA=satisfied_by_token, result=Success. This is abnormal because the user normally authenticates from Malaysia using a managed device.
Cloud App Security	Provides supporting evidence for New OAuth Application Consent. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for New OAuth Application Consent. If the evidence is incomplete, the analyst should request the missing log source before closure.
M365 Audit	Provides post-authentication activity for New OAuth Application Consent. It shows what the user or application did after login, such as mailbox access, inbox rule creation, file download, file sharing, Teams activity, OneDrive sync, SharePoint access and administrative changes.	Simulation: 09:20 MailItemsAccessed from Exchange Online; 09:24 New-InboxRule forwards mail externally; 09:32 FileDownloaded from /Finance/Budget2026.xlsx. This converts a login anomaly into a possible account compromise or data exposure incident.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For New OAuth Application Consent, the analyst must compare the first suspicious event, the	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation

	confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in New OAuth Application Consent. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to New OAuth Application Consent. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to New OAuth Application Consent. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in New OAuth Application Consent was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during New OAuth Application Consent. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For New OAuth Application Consent, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: OAuth Consent Event: maintain the list owner, update frequency, source of truth and exception approval process.

- BB: Approved Enterprise Apps: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Sensitive Users: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: OAuth Consent Event, BB: Approved Enterprise Apps, BB: Sensitive Users];

FROM Entra ID Audit Logs, Cloud App Security, M365 Audit

WHERE TimeGenerated >= now() - lookback

AND event_matches('New OAuth Application Consent')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - New OAuth Application Consent
Incident Name	Possible New OAuth Application Consent Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Cloud, SaaS, OAuth and Non-Human Identity

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible New OAuth Application Consent Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 11:48:00	Entra ID Audit Logs	user1056@example.local	SRV-156	203.0.113.143	Initial signal	Event indicates new oauth application consent.
2026-05-18 11:50:00	Cloud App Security	user1056@example.local	SRV-156	203.0.113.143	Context signal	Entity context matched BB: OAuth Consent Event.
2026-05-18 11:55:00	M365 Audit	user1056@example.local	SRV-156	10.20.26.117	Follow-on activity	Related activity observed in M365.
2026-05-18 11:58:00	SIEM Correlation	user1056@example.local	SRV-156	203.0.113.143	Rule matched	Correlation matched building blocks: BB: OAuth Consent Event, BB: Approved Enterprise Apps.
2026-05-18 12:06:00	SOC Case Record	user1056@example.local	SRV-156	203.0.113.143	Incident created	Incident created for New OAuth Application Consent with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- Was MFA satisfied normally, bypassed, repeatedly challenged or modified?
- Should active sessions or tokens be revoked while validation is ongoing?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Consider session revocation, password reset, MFA reset, OAuth grant removal, conditional access review and account disablement based on confirmation.
- Hunt for the same IP, application, token, user-agent, app ID or consent pattern across the tenant.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: OAuth Consent Event, BB: Approved Enterprise Apps, BB: Sensitive Users.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 057: High-Risk OAuth Permissions Granted

Category	Cloud, SaaS, OAuth and Non-Human Identity
MITRE ATT&CK Mapping	T1098 Account Manipulation; T1114 Email Collection
Detection Objective	Detect and investigate high-risk oauth permissions granted using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Entra ID Audit Logs, Graph Audit Logs, M365 Audit
Recommended Building Blocks	BB: High-Risk OAuth Permissions, BB: Unverified Publisher, BB: Privileged Users
Recommended Alert Name	2026 - High-Risk OAuth Permissions Granted
Recommended Incident Name	Possible High-Risk OAuth Permissions Granted Investigation

1. Scenario

An OAuth app is granted Mail.Read, Files.Read.All, offline_access or Directory.Read.All.

Cloud and SaaS use cases must monitor human and non-human identities, OAuth grants, service principals, AI agents, guest access, policy changes and data access because cloud compromise can persist even after password reset.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1098 Account Manipulation; T1114 Email Collection. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Entra ID Audit Logs	Provides cloud identity evidence for High-Risk OAuth Permissions Granted. Key fields include user principal name, sign-in time, source IP, country, ASN, device ID, compliance state, MFA result, conditional access result, client app and target application. This telemetry shows whether the activity is normal user access or suspicious identity behaviour.	Simulation: user=farah.finance@company.com, app=Exchange Online, source_ip=185.220.101.34, country=DE, device=Unknown, MFA=satisfied_by_token, result=Success. This is abnormal because the user normally authenticates from Malaysia using a managed device.
Graph Audit Logs	Provides supporting evidence for High-Risk OAuth Permissions Granted. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for High-Risk OAuth Permissions Granted. If the evidence is incomplete, the analyst should request the missing log source before closure.
M365 Audit	Provides post-authentication activity for High-Risk OAuth Permissions Granted. It shows what the user or application did after login, such as mailbox access, inbox rule creation, file download, file sharing, Teams activity, OneDrive sync, SharePoint access and administrative changes.	Simulation: 09:20 MailItemsAccessed from Exchange Online; 09:24 New-InboxRule forwards mail externally; 09:32 FileDownloaded from /Finance/Budget2026.xlsx. This converts a login anomaly into a possible account compromise or data exposure incident.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For High-Risk OAuth Permissions Granted, the analyst must compare the first suspicious event, the	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation

	confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in High-Risk OAuth Permissions Granted. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to High-Risk OAuth Permissions Granted. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to High-Risk OAuth Permissions Granted. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in High-Risk OAuth Permissions Granted was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during High-Risk OAuth Permissions Granted. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For High-Risk OAuth Permissions Granted, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: High-Risk OAuth Permissions: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Unverified Publisher: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Privileged Users: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: High-Risk OAuth Permissions, BB: Unverified Publisher, BB: Privileged Users];

FROM Entra ID Audit Logs, Graph Audit Logs, M365 Audit

WHERE TimeGenerated >= now() - lookback

AND event_matches('High-Risk OAuth Permissions Granted')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - High-Risk OAuth Permissions Granted
Incident Name	Possible High-Risk OAuth Permissions Granted Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Cloud, SaaS, OAuth and Non-Human Identity

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible High-Risk OAuth Permissions Granted Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 11:51:00	Entra ID Audit Logs	user1057@example.local	SRV-157	203.0.113.150	Initial signal	Event indicates high-risk oauth permissions granted.
2026-05-18 11:53:00	Graph Audit Logs	user1057@example.local	SRV-157	203.0.113.150	Context signal	Entity context matched BB: High-Risk OAuth Permissions.
2026-05-18 11:58:00	M365 Audit	user1057@example.local	SRV-157	10.20.27.128	Follow-on activity	Related activity observed in M365.
2026-05-18 12:01:00	SIEM Correlation	user1057@example.local	SRV-157	203.0.113.150	Rule matched	Correlation matched building blocks: BB: High-Risk OAuth Permissions, BB: Unverified Publisher.
2026-05-18 12:09:00	SOC Case Record	user1057@example.local	SRV-157	203.0.113.150	Incident created	Incident created for High-Risk OAuth Permissions Granted with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- Was MFA satisfied normally, bypassed, repeatedly challenged or modified?
- Should active sessions or tokens be revoked while validation is ongoing?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Consider session revocation, password reset, MFA reset, OAuth grant removal, conditional access review and account disablement based on confirmation.
- Hunt for the same IP, application, token, user-agent, app ID or consent pattern across the tenant.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: High-Risk OAuth Permissions, BB: Unverified Publisher, BB: Privileged Users.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 058: OAuth Consent After Risky Login

Category	Cloud, SaaS, OAuth and Non-Human Identity
MITRE ATT&CK Mapping	T1098 Account Manipulation; T1078.004 Cloud Accounts
Detection Objective	Detect and investigate oauth consent after risky login using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Entra ID Sign-in Logs, Entra ID Audit Logs, M365 Audit
Recommended Building Blocks	BB: Risky Sign-in, BB: OAuth Consent Event, BB: New App For Tenant
Recommended Alert Name	2026 - OAuth Consent After Risky Login
Recommended Incident Name	Possible OAuth Consent After Risky Login Investigation

1. Scenario

A suspicious login is followed by consent to an unknown application.

Cloud and SaaS use cases must monitor human and non-human identities, OAuth grants, service principals, AI agents, guest access, policy changes and data access because cloud compromise can persist even after password reset.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1098 Account Manipulation; T1078.004 Cloud Accounts. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Entra ID Sign-in Logs	Provides cloud identity evidence for OAuth Consent After Risky Login. Key fields include user principal name, sign-in time, source IP, country, ASN, device ID, compliance state, MFA result, conditional access result, client app and target application. This telemetry shows whether the activity is normal user access or suspicious identity behaviour.	Simulation: user=farah.finance@company.com, app=Exchange Online, source_ip=185.220.101.34, country=DE, device=Unknown, MFA=satisfied_by_token, result=Success. This is abnormal because the user normally authenticates from Malaysia using a managed device.
Entra ID Audit Logs	Provides cloud identity evidence for OAuth Consent After Risky Login. Key fields include user principal name, sign-in time, source IP, country, ASN, device ID, compliance state, MFA result, conditional access result, client app and target application. This telemetry shows whether the activity is normal user access or suspicious identity behaviour.	Simulation: user=farah.finance@company.com, app=Exchange Online, source_ip=185.220.101.34, country=DE, device=Unknown, MFA=satisfied_by_token, result=Success. This is abnormal because the user normally authenticates from Malaysia using a managed device.
M365 Audit	Provides post-authentication activity for OAuth Consent After Risky Login. It shows what the user or application did after login, such as mailbox access, inbox rule creation, file download, file sharing, Teams activity, OneDrive sync, SharePoint access and administrative changes.	Simulation: 09:20 MailItemsAccessed from Exchange Online; 09:24 New-InboxRule forwards mail externally; 09:32 FileDownloaded from /Finance/Budget2026.xlsx. This converts a login anomaly into a possible account compromise or data exposure incident.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For OAuth Consent After	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access;

	Risky Login, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in OAuth Consent After Risky Login. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to OAuth Consent After Risky Login. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to OAuth Consent After Risky Login. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in OAuth Consent After Risky Login was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during OAuth Consent After Risky Login. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For OAuth Consent After Risky Login, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Risky Sign-in: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: OAuth Consent Event: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: New App For Tenant: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Risky Sign-in, BB: OAuth Consent Event, BB: New App For Tenant];

FROM Entra ID Sign-in Logs, Entra ID Audit Logs, M365 Audit

WHERE TimeGenerated >= now() - lookback

AND event_matches('OAuth Consent After Risky Login')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - OAuth Consent After Risky Login
Incident Name	Possible OAuth Consent After Risky Login Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Cloud, SaaS, OAuth and Non-Human Identity

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible OAuth Consent After Risky Login Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.

- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 11:54:00	Entra ID Sign-in Logs	user1058@example.local	SRV-158	203.0.113.157	Initial signal	Event indicates oauth consent after risky login.
2026-05-18 11:56:00	Entra ID Audit Logs	user1058@example.local	SRV-158	203.0.113.157	Context signal	Entity context matched BB: Risky Sign-in.
2026-05-18 12:01:00	M365 Audit	user1058@example.local	SRV-158	10.20.28.139	Follow-on activity	Related activity observed in M365.
2026-05-18 12:04:00	SIEM Correlation	user1058@example.local	SRV-158	203.0.113.157	Rule matched	Correlation matched building blocks: BB: Risky Sign-in, BB: OAuth Consent Event.
2026-05-18 12:12:00	SOC Case Record	user1058@example.local	SRV-158	203.0.113.157	Incident created	Incident created for OAuth Consent After Risky Login with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- Was MFA satisfied normally, bypassed, repeatedly challenged or modified?
- Should active sessions or tokens be revoked while validation is ongoing?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Consider session revocation, password reset, MFA reset, OAuth grant removal, conditional access review and account disablement based on confirmation.
- Hunt for the same IP, application, token, user-agent, app ID or consent pattern across the tenant.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.

- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Risky Sign-in, BB: OAuth Consent Event, BB: New App For Tenant.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 059: Service Principal Secret or Certificate Added

Category	Cloud, SaaS, OAuth and Non-Human Identity
MITRE ATT&CK Mapping	T1098 Account Manipulation
Detection Objective	Detect and investigate service principal secret or certificate added using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Entra ID Audit Logs, Cloud IAM Logs
Recommended Building Blocks	BB: Service Principal Credential Change, BB: Production Apps, BB: Approved Change Tickets
Recommended Alert Name	2026 - Service Principal Secret or Certificate Added
Recommended Incident Name	Possible Service Principal Secret or Certificate Added Investigation

1. Scenario

A new client secret or certificate is added to a production service principal.

Cloud and SaaS use cases must monitor human and non-human identities, OAuth grants, service principals, AI agents, guest access, policy changes and data access because cloud compromise can persist even after password reset.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1098 Account Manipulation. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Entra ID Audit Logs	Provides cloud identity evidence for Service Principal Secret or Certificate Added. Key fields include user principal name, sign-in time, source IP, country, ASN, device ID, compliance state, MFA result, conditional access result, client app and target application. This telemetry shows whether the activity is normal user access or suspicious identity behaviour.	Simulation: user=farah.finance@company.com, app=Exchange Online, source_ip=185.220.101.34, country=DE, device=Unknown, MFA=satisfied_by_token, result=Success. This is abnormal because the user normally authenticates from Malaysia using a managed device.
Cloud IAM Logs	Provides supporting evidence for Service Principal Secret or Certificate Added. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Service Principal Secret or Certificate Added. If the evidence is incomplete, the analyst should request the missing log source before closure.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Service Principal Secret or Certificate Added, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.
User / Account / Service	Identifies the human account, admin	Simulation:

Principal	account, service account or cloud application identity involved in Service Principal Secret or Certificate Added. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Service Principal Secret or Certificate Added. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Service Principal Secret or Certificate Added. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Service Principal Secret or Certificate Added was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Service Principal Secret or Certificate Added. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Service Principal Secret or Certificate Added, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Service Principal Credential Change: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Production Apps: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Approved Change Tickets: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Service Principal Credential Change, BB: Production Apps, BB: Approved Change Tickets];

FROM Entra ID Audit Logs, Cloud IAM Logs

WHERE TimeGenerated >= now() - lookback

AND event_matches('Service Principal Secret or Certificate Added')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Service Principal Secret or Certificate Added
Incident Name	Possible Service Principal Secret or Certificate Added Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Cloud, SaaS, OAuth and Non-Human Identity

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Service Principal Secret or Certificate Added Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 11:57:00	Entra ID Audit Logs	user1059@example.local	SRV-159	203.0.113.164	Initial signal	Event indicates service principal

						secret or certificate added.
2026-05-18 11:59:00	Cloud IAM Logs	user1059@example.local	SRV-159	203.0.113.164	Context signal	Entity context matched BB: Service Principal Credential Change.
2026-05-18 12:04:00	Entra ID Audit Logs	user1059@example.local	SRV-159	10.20.29.150	Follow-on activity	Related activity observed in M365.
2026-05-18 12:07:00	SIEM Correlation	user1059@example.local	SRV-159	203.0.113.164	Rule matched	Correlation matched building blocks: BB: Service Principal Credential Change, BB: Production Apps.
2026-05-18 12:15:00	SOC Case Record	user1059@example.local	SRV-159	203.0.113.164	Incident created	Incident created for Service Principal Secret or Certificate Added with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- Was MFA satisfied normally, bypassed, repeatedly challenged or modified?
- Should active sessions or tokens be revoked while validation is ongoing?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Consider session revocation, password reset, MFA reset, OAuth grant removal, conditional access review and account disablement based on confirmation.
- Hunt for the same IP, application, token, user-agent, app ID or consent pattern across the tenant.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Service Principal Credential Change, BB: Production Apps, BB: Approved Change Tickets.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 060: Service Principal Used from New Country or ASN

Category	Cloud, SaaS, OAuth and Non-Human Identity
MITRE ATT&CK Mapping	T1078.004 Cloud Accounts; T1550 Use Alternate Authentication Material
Detection Objective	Detect and investigate service principal used from new country or asn using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Cloud Sign-in Logs, API Gateway Logs, Proxy
Recommended Building Blocks	BB: Non-Human Identities, BB: New ASN, BB: Expected Source IPs
Recommended Alert Name	2026 - Service Principal Used from New Country or ASN
Recommended Incident Name	Possible Service Principal Used from New Country or ASN Investigation

1. Scenario

A machine identity normally used by internal systems authenticates from an external cloud hosting provider.

Cloud and SaaS use cases must monitor human and non-human identities, OAuth grants, service principals, AI agents, guest access, policy changes and data access because cloud compromise can persist even after password reset.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1078.004 Cloud Accounts; T1550 Use Alternate Authentication Material. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Cloud Sign-in Logs	Provides cloud identity evidence for Service Principal Used from New Country or ASN. Key fields include user principal name, sign-in time, source IP, country, ASN, device ID, compliance state, MFA result, conditional access result, client app and target application. This telemetry shows whether the activity is normal user access or suspicious identity behaviour.	Simulation: user=farah.finance@company.com, app=Exchange Online, source_ip=185.220.101.34, country=DE, device=Unknown, MFA=satisfied_by_token, result=Success. This is abnormal because the user normally authenticates from Malaysia using a managed device.
API Gateway Logs	Provides application and API behaviour evidence for Service Principal Used from New Country or ASN. Key fields include token/client ID, user ID, endpoint, method, response code, request rate, object ID accessed and authentication result.	Simulation: token_id=svc-prod-22, source_ip=203.0.113.50, endpoint=/api/customer/statement, request_count=18,000 in 10 minutes. This may indicate token theft or automated data harvesting.
Proxy	Shows outbound web access linked to Service Principal Used from New Country or ASN, including URL, domain, category, upload/download size, HTTP method, user-agent, action and reputation. It helps confirm phishing clicks, payload downloads, C2, exfiltration or unapproved AI/cloud tool usage.	Simulation: user=farah.finance, url=hxxps://unknown-file-share.example/upload, bytes_out=524288000, action=Allowed. If this occurs after sensitive file access, investigate possible exfiltration.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Service Principal Used from New Country or ASN, the analyst must compare the first suspicious event,	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation

	the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Service Principal Used from New Country or ASN. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Service Principal Used from New Country or ASN. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Service Principal Used from New Country or ASN. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Service Principal Used from New Country or ASN was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Service Principal Used from New Country or ASN. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Service Principal Used from New Country or ASN, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Non-Human Identities: maintain the list owner, update frequency, source of truth and exception approval process.

- BB: New ASN: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Expected Source IPs: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Non-Human Identities, BB: New ASN, BB: Expected Source IPs];

FROM Cloud Sign-in Logs, API Gateway Logs, Proxy

WHERE TimeGenerated >= now() - lookback

AND event_matches('Service Principal Used from New Country or ASN')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Service Principal Used from New Country or ASN
Incident Name	Possible Service Principal Used from New Country or ASN Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Cloud, SaaS, OAuth and Non-Human Identity

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Service Principal Used from New Country or ASN Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 12:00:00	Cloud Sign-in Logs	user1060@example.local	SRV-160	203.0.113.171	Initial signal	Event indicates service principal used from new country or asn.
2026-05-18 12:02:00	API Gateway Logs	user1060@example.local	SRV-160	203.0.113.171	Context signal	Entity context matched BB: Non- Human Identities.
2026-05-18 12:07:00	Proxy	user1060@example.local	SRV-160	10.20.0.161	Follow-on activity	Related activity observed in M365.
2026-05-18 12:10:00	SIEM Correlation	user1060@example.local	SRV-160	203.0.113.171	Rule matched	Correlation matched building blocks: BB: Non-Human Identities, BB: New ASN.
2026-05-18 12:18:00	SOC Case Record	user1060@example.local	SRV-160	203.0.113.171	Incident created	Incident created for Service Principal Used from New Country or ASN with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- Was MFA satisfied normally, bypassed, repeatedly challenged or modified?
- Should active sessions or tokens be revoked while validation is ongoing?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Consider session revocation, password reset, MFA reset, OAuth grant removal, conditional access review and account disablement based on confirmation.
- Hunt for the same IP, application, token, user-agent, app ID or consent pattern across the tenant.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.

- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Non-Human Identities, BB: New ASN, BB: Expected Source IPs.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 061: AI Agent Identity Created or Granted Access

Category	Cloud, SaaS, OAuth and Non-Human Identity
MITRE ATT&CK Mapping	T1136 Create Account; T1098 Account Manipulation
Detection Objective	Detect and investigate ai agent identity created or granted access using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	IAM Logs, AI Platform Audit, Cloud App Logs
Recommended Building Blocks	BB: AI Agent Accounts, BB: Sensitive Data Sources, BB: Approved AI Projects
Recommended Alert Name	2026 - AI Agent Identity Created or Granted Access
Recommended Incident Name	Possible AI Agent Identity Created or Granted Access Investigation

1. Scenario

A new AI assistant or automation identity is created and granted access to internal repositories.

Cloud and SaaS use cases must monitor human and non-human identities, OAuth grants, service principals, AI agents, guest access, policy changes and data access because cloud compromise can persist even after password reset.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1136 Create Account; T1098 Account Manipulation. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
IAM Logs	Provides supporting evidence for AI Agent Identity Created or Granted Access. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for AI Agent Identity Created or Granted Access. If the evidence is incomplete, the analyst should request the missing log source before closure.
AI Platform Audit	Provides supporting evidence for AI Agent Identity Created or Granted Access. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for AI Agent Identity Created or Granted Access. If the evidence is incomplete, the analyst should request the missing log source before closure.
Cloud App Logs	Provides supporting evidence for AI Agent Identity Created or Granted Access. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for AI Agent Identity Created or Granted Access. If the evidence is incomplete, the analyst should request the missing log source before closure.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For AI Agent Identity Created or Granted Access, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.

	reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in AI Agent Identity Created or Granted Access. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to AI Agent Identity Created or Granted Access. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to AI Agent Identity Created or Granted Access. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in AI Agent Identity Created or Granted Access was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during AI Agent Identity Created or Granted Access. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For AI Agent Identity Created or Granted Access, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: AI Agent Accounts: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Sensitive Data Sources: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Approved AI Projects: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: AI Agent Accounts, BB: Sensitive Data Sources, BB: Approved AI Projects];

FROM IAM Logs, AI Platform Audit, Cloud App Logs

WHERE TimeGenerated >= now() - lookback

AND event_matches('AI Agent Identity Created or Granted Access')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - AI Agent Identity Created or Granted Access
Incident Name	Possible AI Agent Identity Created or Granted Access Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Cloud, SaaS, OAuth and Non-Human Identity

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible AI Agent Identity Created or Granted Access Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 12:03:00	IAM Logs	user1061@example.local	SRV-161	203.0.113.178	Initial signal	Event indicates ai agent identity

						created or granted access.
2026-05-18 12:05:00	AI Platform Audit	user1061@example.local	SRV-161	203.0.113.178	Context signal	Entity context matched BB: AI Agent Accounts.
2026-05-18 12:10:00	Cloud App Logs	user1061@example.local	SRV-161	10.20.1.172	Follow-on activity	Related activity observed in M365.
2026-05-18 12:13:00	SIEM Correlation	user1061@example.local	SRV-161	203.0.113.178	Rule matched	Correlation matched building blocks: BB: AI Agent Accounts, BB: Sensitive Data Sources.
2026-05-18 12:21:00	SOC Case Record	user1061@example.local	SRV-161	203.0.113.178	Incident created	Incident created for AI Agent Identity Created or Granted Access with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- Was MFA satisfied normally, bypassed, repeatedly challenged or modified?
- Should active sessions or tokens be revoked while validation is ongoing?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Consider session revocation, password reset, MFA reset, OAuth grant removal, conditional access review and account disablement based on confirmation.
- Hunt for the same IP, application, token, user-agent, app ID or consent pattern across the tenant.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: AI Agent Accounts, BB: Sensitive Data Sources, BB: Approved AI Projects.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 062: AI Agent Performs Abnormal Volume of Actions

Category	Cloud, SaaS, OAuth and Non-Human Identity
MITRE ATT&CK Mapping	T1078.004 Cloud Accounts; T1530 Data from Cloud Storage
Detection Objective	Detect and investigate ai agent performs abnormal volume of actions using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	AI Platform Audit, SaaS Audit Logs, DLP, CASB
Recommended Building Blocks	BB: AI Agent Accounts, BB: Action Baseline, BB: Sensitive Repository
Recommended Alert Name	2026 - AI Agent Performs Abnormal Volume of Actions
Recommended Incident Name	Possible AI Agent Performs Abnormal Volume of Actions Investigation

1. Scenario

An AI agent reads or exports many files beyond its normal workflow pattern.

Cloud and SaaS use cases must monitor human and non-human identities, OAuth grants, service principals, AI agents, guest access, policy changes and data access because cloud compromise can persist even after password reset.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1078.004 Cloud Accounts; T1530 Data from Cloud Storage. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
AI Platform Audit	Provides supporting evidence for AI Agent Performs Abnormal Volume of Actions. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for AI Agent Performs Abnormal Volume of Actions. If the evidence is incomplete, the analyst should request the missing log source before closure.
SaaS Audit Logs	Provides supporting evidence for AI Agent Performs Abnormal Volume of Actions. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for AI Agent Performs Abnormal Volume of Actions. If the evidence is incomplete, the analyst should request the missing log source before closure.
DLP	Shows data protection evidence for AI Agent Performs Abnormal Volume of Actions. DLP/CASB telemetry confirms whether sensitive data was uploaded, shared, pasted, copied, synchronised or transferred to external services.	Simulation: DLP policy=Customer PII, destination=personal-cloud.example, action=AllowedWithAlert, file=Customer_List_2026.xlsx. This is evidence for possible data leakage.
CASB	Shows data protection evidence for AI Agent Performs Abnormal Volume of Actions. DLP/CASB telemetry confirms whether sensitive data was uploaded, shared, pasted, copied, synchronised or transferred to external services.	Simulation: DLP policy=Customer PII, destination=personal-cloud.example, action=AllowedWithAlert, file=Customer_List_2026.xlsx. This is evidence for possible data leakage.

TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For AI Agent Performs Abnormal Volume of Actions, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in AI Agent Performs Abnormal Volume of Actions. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to AI Agent Performs Abnormal Volume of Actions. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to AI Agent Performs Abnormal Volume of Actions. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in AI Agent Performs Abnormal Volume of Actions was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during AI Agent Performs Abnormal Volume of Actions. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For AI Agent Performs Abnormal Volume of Actions, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: AI Agent Accounts: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Action Baseline: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Sensitive Repository: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: AI Agent Accounts, BB: Action Baseline, BB: Sensitive Repository];

FROM AI Platform Audit, SaaS Audit Logs, DLP

WHERE TimeGenerated >= now() - lookback

AND event_matches('AI Agent Performs Abnormal Volume of Actions')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - AI Agent Performs Abnormal Volume of Actions
Incident Name	Possible AI Agent Performs Abnormal Volume of Actions Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Cloud, SaaS, OAuth and Non-Human Identity

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible AI Agent Performs Abnormal Volume of Actions Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.

- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 12:06:00	AI Platform Audit	user1062@example.local	SRV-162	203.0.113.185	Initial signal	Event indicates ai agent performs abnormal volume of actions.
2026-05-18 12:08:00	SaaS Audit Logs	user1062@example.local	SRV-162	203.0.113.185	Context signal	Entity context matched BB: AI Agent Accounts.
2026-05-18 12:13:00	DLP	user1062@example.local	SRV-162	10.20.2.183	Follow-on activity	Related activity observed in M365.
2026-05-18 12:16:00	SIEM Correlation	user1062@example.local	SRV-162	203.0.113.185	Rule matched	Correlation matched building blocks: BB: AI Agent Accounts, BB: Action Baseline.
2026-05-18 12:24:00	SOC Case Record	user1062@example.local	SRV-162	203.0.113.185	Incident created	Incident created for AI Agent Performs Abnormal Volume of Actions with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- Was MFA satisfied normally, bypassed, repeatedly challenged or modified?
- Should active sessions or tokens be revoked while validation is ongoing?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Consider session revocation, password reset, MFA reset, OAuth grant removal, conditional access review and account disablement based on confirmation.
- Hunt for the same IP, application, token, user-agent, app ID or consent pattern across the tenant.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.

- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: AI Agent Accounts, BB: Action Baseline, BB: Sensitive Repository.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 063: Conditional Access Policy Modified

Category	Cloud, SaaS, OAuth and Non-Human Identity
MITRE ATT&CK Mapping	T1556 Modify Authentication Process; T1562 Impair Defenses
Detection Objective	Detect and investigate conditional access policy modified using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Entra ID Audit Logs, Security Admin Logs
Recommended Building Blocks	BB: Conditional Access Policies, BB: Approved IAM Change, BB: Privileged Users
Recommended Alert Name	2026 - Conditional Access Policy Modified
Recommended Incident Name	Possible Conditional Access Policy Modified Investigation

1. Scenario

A Conditional Access policy requiring MFA is disabled or weakened.

Cloud and SaaS use cases must monitor human and non-human identities, OAuth grants, service principals, AI agents, guest access, policy changes and data access because cloud compromise can persist even after password reset.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1556 Modify Authentication Process; T1562 Impair Defenses. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Entra ID Audit Logs	Provides cloud identity evidence for Conditional Access Policy Modified. Key fields include user principal name, sign-in time, source IP, country, ASN, device ID, compliance state, MFA result, conditional access result, client app and target application. This telemetry shows whether the activity is normal user access or suspicious identity behaviour.	Simulation: user=farah.finance@company.com, app=Exchange Online, source_ip=185.220.101.34, country=DE, device=Unknown, MFA=satisfied_by_token, result=Success. This is abnormal because the user normally authenticates from Malaysia using a managed device.
Security Admin Logs	Provides supporting evidence for Conditional Access Policy Modified. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Conditional Access Policy Modified. If the evidence is incomplete, the analyst should request the missing log source before closure.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Conditional Access Policy Modified, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.
User / Account / Service	Identifies the human account, admin account, service account or cloud	Simulation: account=farah.finance@company.com,

Principal	application identity involved in Conditional Access Policy Modified. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Conditional Access Policy Modified. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Conditional Access Policy Modified. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Conditional Access Policy Modified was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Conditional Access Policy Modified. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Conditional Access Policy Modified, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Conditional Access Policies: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Approved IAM Change: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Privileged Users: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Conditional Access Policies, BB: Approved IAM Change, BB: Privileged Users];

FROM Entra ID Audit Logs, Security Admin Logs

WHERE TimeGenerated >= now() - lookback

AND event_matches('Conditional Access Policy Modified')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Conditional Access Policy Modified
Incident Name	Possible Conditional Access Policy Modified Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Cloud, SaaS, OAuth and Non-Human Identity

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Conditional Access Policy Modified Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 12:09:00	Entra ID Audit Logs	user1063@example.local	SRV-163	203.0.113.192	Initial signal	Event indicates conditional access policy modified.

2026-05-18 12:11:00	Security Admin Logs	user1063@example.local	SRV-163	203.0.113.192	Context signal	Entity context matched BB: Conditional Access Policies.
2026-05-18 12:16:00	Entra ID Audit Logs	user1063@example.local	SRV-163	10.20.3.194	Follow-on activity	Related activity observed in M365.
2026-05-18 12:19:00	SIEM Correlation	user1063@example.local	SRV-163	203.0.113.192	Rule matched	Correlation matched building blocks: BB: Conditional Access Policies, BB: Approved IAM Change.
2026-05-18 12:27:00	SOC Case Record	user1063@example.local	SRV-163	203.0.113.192	Incident created	Incident created for Conditional Access Policy Modified with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- Was MFA satisfied normally, bypassed, repeatedly challenged or modified?
- Should active sessions or tokens be revoked while validation is ongoing?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Consider session revocation, password reset, MFA reset, OAuth grant removal, conditional access review and account disablement based on confirmation.
- Hunt for the same IP, application, token, user-agent, app ID or consent pattern across the tenant.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Conditional Access Policies, BB: Approved IAM Change, BB: Privileged Users.

- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 064: Cloud Audit Logging Disabled or Reduced

Category	Cloud, SaaS, OAuth and Non-Human Identity
MITRE ATT&CK Mapping	T1562.008 Disable or Modify Cloud Logs
Detection Objective	Detect and investigate cloud audit logging disabled or reduced using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Cloud Audit Logs, Admin Activity Logs, SIEM Health
Recommended Building Blocks	BB: Critical Logging Controls, BB: Cloud Admins, BB: Approved Change Tickets
Recommended Alert Name	2026 - Cloud Audit Logging Disabled or Reduced
Recommended Incident Name	Possible Cloud Audit Logging Disabled or Reduced Investigation

1. Scenario

Audit logging is disabled or retention is reduced for a cloud tenant or subscription.

Cloud and SaaS use cases must monitor human and non-human identities, OAuth grants, service principals, AI agents, guest access, policy changes and data access because cloud compromise can persist even after password reset.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1562.008 Disable or Modify Cloud Logs. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Cloud Audit Logs	Provides cloud control-plane evidence for Cloud Audit Logging Disabled or Reduced. It records role assignments, policy changes, key creation, storage exposure, logging changes, resource creation and administrative actions.	Simulation: actor=admin@company.com, operation=UpdateConditionalAccessPolicy, result=Success, change=MFA policy disabled. If preceded by risky login, treat as possible cloud takeover.
Admin Activity Logs	Adds external intelligence context to Cloud Audit Logging Disabled or Reduced. IOC, actor, campaign, reputation, first-seen date and confidence help prioritise alerts and connect internal evidence to known malicious infrastructure.	Simulation: destination IP matched TI feed as malware C2 with confidence=High, first_seen=2026-02-10. If internal host communicated successfully, investigate compromise evidence.
SIEM Health	Provides supporting evidence for Cloud Audit Logging Disabled or Reduced. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Cloud Audit Logging Disabled or Reduced. If the evidence is incomplete, the analyst should request the missing log source before closure.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Cloud Audit Logging Disabled or Reduced, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.

	event or part of a chained incident.	
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Cloud Audit Logging Disabled or Reduced. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Cloud Audit Logging Disabled or Reduced. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Cloud Audit Logging Disabled or Reduced. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Cloud Audit Logging Disabled or Reduced was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Cloud Audit Logging Disabled or Reduced. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Cloud Audit Logging Disabled or Reduced, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Critical Logging Controls: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Cloud Admins: maintain the list owner, update frequency, source of truth and exception approval process.

- BB: Approved Change Tickets: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Critical Logging Controls, BB: Cloud Admins, BB: Approved Change Tickets];

FROM Cloud Audit Logs, Admin Activity Logs, SIEM Health

WHERE TimeGenerated >= now() - lookback

AND event_matches('Cloud Audit Logging Disabled or Reduced')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Cloud Audit Logging Disabled or Reduced
Incident Name	Possible Cloud Audit Logging Disabled or Reduced Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Cloud, SaaS, OAuth and Non-Human Identity

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Cloud Audit Logging Disabled or Reduced Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 12:12:00	Cloud Audit Logs	user1064@example.local	SRV-164	203.0.113.199	Initial signal	Event indicates cloud audit logging disabled or reduced.
2026-05-18 12:14:00	Admin Activity Logs	user1064@example.local	SRV-164	203.0.113.199	Context signal	Entity context matched BB: Critical Logging Controls.
2026-05-18 12:19:00	SIEM Health	user1064@example.local	SRV-164	10.20.4.205	Follow-on activity	Related activity observed in M365.
2026-05-18 12:22:00	SIEM Correlation	user1064@example.local	SRV-164	203.0.113.199	Rule matched	Correlation matched building blocks: BB: Critical Logging Controls, BB: Cloud Admins.
2026-05-18 12:30:00	SOC Case Record	user1064@example.local	SRV-164	203.0.113.199	Incident created	Incident created for Cloud Audit Logging Disabled or Reduced with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- Was MFA satisfied normally, bypassed, repeatedly challenged or modified?
- Should active sessions or tokens be revoked while validation is ongoing?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Consider session revocation, password reset, MFA reset, OAuth grant removal, conditional access review and account disablement based on confirmation.
- Hunt for the same IP, application, token, user-agent, app ID or consent pattern across the tenant.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Critical Logging Controls, BB: Cloud Admins, BB: Approved Change Tickets.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 065: Cloud Admin Role Assigned

Category	Cloud, SaaS, OAuth and Non-Human Identity
MITRE ATT&CK Mapping	T1098 Account Manipulation
Detection Objective	Detect and investigate cloud admin role assigned using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Entra ID Audit Logs, Cloud IAM Logs
Recommended Building Blocks	BB: Cloud Admin Roles, BB: Approved Access Request, BB: Break-Glass Accounts
Recommended Alert Name	2026 - Cloud Admin Role Assigned
Recommended Incident Name	Possible Cloud Admin Role Assigned Investigation

1. Scenario

A user or service principal is assigned Global Administrator, Owner or similar high-impact role.

Cloud and SaaS use cases must monitor human and non-human identities, OAuth grants, service principals, AI agents, guest access, policy changes and data access because cloud compromise can persist even after password reset.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1098 Account Manipulation. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Entra ID Audit Logs	Provides cloud identity evidence for Cloud Admin Role Assigned. Key fields include user principal name, sign-in time, source IP, country, ASN, device ID, compliance state, MFA result, conditional access result, client app and target application. This telemetry shows whether the activity is normal user access or suspicious identity behaviour.	Simulation: user=farah.finance@company.com, app=Exchange Online, source_ip=185.220.101.34, country=DE, device=Unknown, MFA=satisfied_by_token, result=Success. This is abnormal because the user normally authenticates from Malaysia using a managed device.
Cloud IAM Logs	Provides supporting evidence for Cloud Admin Role Assigned. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Cloud Admin Role Assigned. If the evidence is incomplete, the analyst should request the missing log source before closure.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Cloud Admin Role Assigned, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Cloud	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard

	Admin Role Assigned. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Cloud Admin Role Assigned. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Cloud Admin Role Assigned. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Cloud Admin Role Assigned was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Cloud Admin Role Assigned. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Cloud Admin Role Assigned, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Cloud Admin Roles: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Approved Access Request: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Break-Glass Accounts: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.

- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Cloud Admin Roles, BB: Approved Access Request, BB: Break-Glass Accounts];

FROM Entra ID Audit Logs, Cloud IAM Logs

WHERE TimeGenerated >= now() - lookback

AND event_matches('Cloud Admin Role Assigned')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Cloud Admin Role Assigned
Incident Name	Possible Cloud Admin Role Assigned Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Cloud, SaaS, OAuth and Non-Human Identity

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Cloud Admin Role Assigned Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 12:15:00	Entra ID Audit Logs	user1065@example.local	SRV-165	203.0.113.206	Initial signal	Event indicates cloud admin role assigned.
2026-05-18 12:17:00	Cloud IAM Logs	user1065@example.local	SRV-165	203.0.113.206	Context signal	Entity context matched BB: Cloud Admin Roles.
2026-05-18 12:22:00	Entra ID Audit Logs	user1065@example.local	SRV-165	10.20.5.216	Follow-on activity	Related activity observed in M365.
2026-05-18	SIEM	user1065@example.local	SRV-165	203.0.113.206	Rule	Correlation matched

12:25:00	Correlation				matched	building blocks: BB: Cloud Admin Roles, BB: Approved Access Request.
2026-05-18 12:33:00	SOC Case Record	user1065@example.local	SRV-165	203.0.113.206	Incident created	Incident created for Cloud Admin Role Assigned with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- Was MFA satisfied normally, bypassed, repeatedly challenged or modified?
- Should active sessions or tokens be revoked while validation is ongoing?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Consider session revocation, password reset, MFA reset, OAuth grant removal, conditional access review and account disablement based on confirmation.
- Hunt for the same IP, application, token, user-agent, app ID or consent pattern across the tenant.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Cloud Admin Roles, BB: Approved Access Request, BB: Break-Glass Accounts.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.

- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 066: External Guest Added to Sensitive Workspace

Category	Cloud, SaaS, OAuth and Non-Human Identity
MITRE ATT&CK Mapping	T1136 Create Account; T1530 Data from Cloud Storage
Detection Objective	Detect and investigate external guest added to sensitive workspace using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Teams Audit, SharePoint Audit, Entra ID Audit
Recommended Building Blocks	BB: Sensitive Workspaces, BB: External Guest Accounts, BB: Approved Guest Domains
Recommended Alert Name	2026 - External Guest Added to Sensitive Workspace
Recommended Incident Name	Possible External Guest Added to Sensitive Workspace Investigation

1. Scenario

An external guest is invited to a sensitive Teams or SharePoint workspace.

Cloud and SaaS use cases must monitor human and non-human identities, OAuth grants, service principals, AI agents, guest access, policy changes and data access because cloud compromise can persist even after password reset.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1136 Create Account; T1530 Data from Cloud Storage. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Teams Audit	Provides supporting evidence for External Guest Added to Sensitive Workspace. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for External Guest Added to Sensitive Workspace. If the evidence is incomplete, the analyst should request the missing log source before closure.
SharePoint Audit	Provides post-authentication activity for External Guest Added to Sensitive Workspace. It shows what the user or application did after login, such as mailbox access, inbox rule creation, file download, file sharing, Teams activity, OneDrive sync, SharePoint access and administrative changes.	Simulation: 09:20 MailItemsAccessed from Exchange Online; 09:24 New-InboxRule forwards mail externally; 09:32 FileDownloaded from /Finance/Budget2026.xlsx. This converts a login anomaly into a possible account compromise or data exposure incident.
Entra ID Audit	Provides cloud identity evidence for External Guest Added to Sensitive Workspace. Key fields include user principal name, sign-in time, source IP, country, ASN, device ID, compliance state, MFA result, conditional access result, client app and target application. This telemetry shows whether the activity is normal user access or suspicious identity behaviour.	Simulation: user=farah.finance@company.com, app=Exchange Online, source_ip=185.220.101.34, country=DE, device=Unknown, MFA=satisfied_by_token, result=Success. This is abnormal because the user normally authenticates from Malaysia using a managed device.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For External Guest Added	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access;

	to Sensitive Workspace, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in External Guest Added to Sensitive Workspace. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to External Guest Added to Sensitive Workspace. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to External Guest Added to Sensitive Workspace. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in External Guest Added to Sensitive Workspace was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during External Guest Added to Sensitive Workspace. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For External Guest Added to Sensitive Workspace, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Sensitive Workspaces: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: External Guest Accounts: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Approved Guest Domains: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Sensitive Workspaces, BB: External Guest Accounts, BB: Approved Guest Domains];

FROM Teams Audit, SharePoint Audit, Entra ID Audit

WHERE TimeGenerated >= now() - lookback

AND event_matches('External Guest Added to Sensitive Workspace')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - External Guest Added to Sensitive Workspace
Incident Name	Possible External Guest Added to Sensitive Workspace Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Cloud, SaaS, OAuth and Non-Human Identity

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible External Guest Added to Sensitive Workspace Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 12:18:00	Teams Audit	user1066@example.local	SRV-166	203.0.113.213	Initial signal	Event indicates external guest added to sensitive workspace.
2026-05-18 12:20:00	SharePoint Audit	user1066@example.local	SRV-166	203.0.113.213	Context signal	Entity context matched BB: Sensitive Workspaces.
2026-05-18 12:25:00	Entra ID Audit	user1066@example.local	SRV-166	10.20.6.227	Follow-on activity	Related activity observed in M365.
2026-05-18 12:28:00	SIEM Correlation	user1066@example.local	SRV-166	203.0.113.213	Rule matched	Correlation matched building blocks: BB: Sensitive Workspaces, BB: External Guest Accounts.
2026-05-18 12:36:00	SOC Case Record	user1066@example.local	SRV-166	203.0.113.213	Incident created	Incident created for External Guest Added to Sensitive Workspace with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- Was MFA satisfied normally, bypassed, repeatedly challenged or modified?
- Should active sessions or tokens be revoked while validation is ongoing?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Consider session revocation, password reset, MFA reset, OAuth grant removal, conditional access review and account disablement based on confirmation.

- Hunt for the same IP, application, token, user-agent, app ID or consent pattern across the tenant.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Sensitive Workspaces, BB: External Guest Accounts, BB: Approved Guest Domains.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 067: Guest User Mass Download from SharePoint

Category	Cloud, SaaS, OAuth and Non-Human Identity
MITRE ATT&CK Mapping	T1530 Data from Cloud Storage
Detection Objective	Detect and investigate guest user mass download from sharepoint using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	SharePoint Audit, M365 Audit, CASB
Recommended Building Blocks	BB: External Guest Accounts, BB: Download Volume Baseline, BB: Sensitive Sites
Recommended Alert Name	2026 - Guest User Mass Download from SharePoint
Recommended Incident Name	Possible Guest User Mass Download from SharePoint Investigation

1. Scenario

A guest account downloads many files from a confidential project site.

Cloud and SaaS use cases must monitor human and non-human identities, OAuth grants, service principals, AI agents, guest access, policy changes and data access because cloud compromise can persist even after password reset.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1530 Data from Cloud Storage. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
SharePoint Audit	Provides post-authentication activity for Guest User Mass Download from SharePoint. It shows what the user or application did after login, such as mailbox access, inbox rule creation, file download, file sharing, Teams activity, OneDrive sync, SharePoint access and administrative changes.	Simulation: 09:20 MailItemsAccessed from Exchange Online; 09:24 New-InboxRule forwards mail externally; 09:32 FileDownloaded from /Finance/Budget2026.xlsx. This converts a login anomaly into a possible account compromise or data exposure incident.
M365 Audit	Provides post-authentication activity for Guest User Mass Download from SharePoint. It shows what the user or application did after login, such as mailbox access, inbox rule creation, file download, file sharing, Teams activity, OneDrive sync, SharePoint access and administrative changes.	Simulation: 09:20 MailItemsAccessed from Exchange Online; 09:24 New-InboxRule forwards mail externally; 09:32 FileDownloaded from /Finance/Budget2026.xlsx. This converts a login anomaly into a possible account compromise or data exposure incident.
CASB	Shows data protection evidence for Guest User Mass Download from SharePoint. DLP/CASB telemetry confirms whether sensitive data was uploaded, shared, pasted, copied, synchronised or transferred to external services.	Simulation: DLP policy=Customer PII, destination=personal-cloud.example, action=AllowedWithAlert, file=Customer_List_2026.xlsx. This is evidence for possible data leakage.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Guest User Mass Download from SharePoint, the analyst must compare the first suspicious event, the confirming event and any follow-on	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation

	activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Guest User Mass Download from SharePoint. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Guest User Mass Download from SharePoint. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Guest User Mass Download from SharePoint. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Guest User Mass Download from SharePoint was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Guest User Mass Download from SharePoint. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Guest User Mass Download from SharePoint, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: External Guest Accounts: maintain the list owner, update frequency, source of truth and exception approval process.

- BB: Download Volume Baseline: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Sensitive Sites: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: External Guest Accounts, BB: Download Volume Baseline, BB: Sensitive Sites];

FROM SharePoint Audit, M365 Audit, CASB

WHERE TimeGenerated >= now() - lookback

AND event_matches('Guest User Mass Download from SharePoint')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Guest User Mass Download from SharePoint
Incident Name	Possible Guest User Mass Download from SharePoint Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Cloud, SaaS, OAuth and Non-Human Identity

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Guest User Mass Download from SharePoint Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 12:21:00	SharePoint Audit	user1067@example.local	SRV-167	203.0.113.220	Initial signal	Event indicates guest user mass download from sharepoint.
2026-05-18 12:23:00	M365 Audit	user1067@example.local	SRV-167	203.0.113.220	Context signal	Entity context matched BB: External Guest Accounts.
2026-05-18 12:28:00	CASB	user1067@example.local	SRV-167	10.20.7.238	Follow-on activity	Related activity observed in M365.
2026-05-18 12:31:00	SIEM Correlation	user1067@example.local	SRV-167	203.0.113.220	Rule matched	Correlation matched building blocks: BB: External Guest Accounts, BB: Download Volume Baseline.
2026-05-18 12:39:00	SOC Case Record	user1067@example.local	SRV-167	203.0.113.220	Incident created	Incident created for Guest User Mass Download from SharePoint with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- Was MFA satisfied normally, bypassed, repeatedly challenged or modified?
- Should active sessions or tokens be revoked while validation is ongoing?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Consider session revocation, password reset, MFA reset, OAuth grant removal, conditional access review and account disablement based on confirmation.
- Hunt for the same IP, application, token, user-agent, app ID or consent pattern across the tenant.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.

- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: External Guest Accounts, BB: Download Volume Baseline, BB: Sensitive Sites.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 068: DLP or Sensitivity Label Policy Modified

Category	Cloud, SaaS, OAuth and Non-Human Identity
MITRE ATT&CK Mapping	T1562 Impair Defenses
Detection Objective	Detect and investigate dlp or sensitivity label policy modified using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	M365 Compliance Audit, DLP Logs, Admin Audit
Recommended Building Blocks	BB: DLP Policies, BB: Sensitivity Label Policies, BB: Approved Compliance Change
Recommended Alert Name	2026 - DLP or Sensitivity Label Policy Modified
Recommended Incident Name	Possible DLP or Sensitivity Label Policy Modified Investigation

1. Scenario

A data protection policy is disabled shortly before external sharing activity increases.

Cloud and SaaS use cases must monitor human and non-human identities, OAuth grants, service principals, AI agents, guest access, policy changes and data access because cloud compromise can persist even after password reset.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1562 Impair Defenses. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
M365 Compliance Audit	Provides post-authentication activity for DLP or Sensitivity Label Policy Modified. It shows what the user or application did after login, such as mailbox access, inbox rule creation, file download, file sharing, Teams activity, OneDrive sync, SharePoint access and administrative changes.	Simulation: 09:20 MailItemsAccessed from Exchange Online; 09:24 New-InboxRule forwards mail externally; 09:32 FileDownloaded from /Finance/Budget2026.xlsx. This converts a login anomaly into a possible account compromise or data exposure incident.
DLP Logs	Shows data protection evidence for DLP or Sensitivity Label Policy Modified. DLP/CASB telemetry confirms whether sensitive data was uploaded, shared, pasted, copied, synchronised or transferred to external services.	Simulation: DLP policy=Customer PII, destination=personal-cloud.example, action=AllowedWithAlert, file=Customer_List_2026.xlsx. This is evidence for possible data leakage.
Admin Audit	Provides supporting evidence for DLP or Sensitivity Label Policy Modified. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for DLP or Sensitivity Label Policy Modified. If the evidence is incomplete, the analyst should request the missing log source before closure.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For DLP or Sensitivity Label Policy Modified, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.

	event or part of a chained incident.	
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in DLP or Sensitivity Label Policy Modified. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to DLP or Sensitivity Label Policy Modified. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to DLP or Sensitivity Label Policy Modified. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in DLP or Sensitivity Label Policy Modified was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during DLP or Sensitivity Label Policy Modified. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For DLP or Sensitivity Label Policy Modified, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: DLP Policies: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Sensitivity Label Policies: maintain the list owner, update frequency, source of truth and exception approval process.

- BB: Approved Compliance Change: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: DLP Policies, BB: Sensitivity Label Policies, BB: Approved Compliance Change];

FROM M365 Compliance Audit, DLP Logs, Admin Audit

WHERE TimeGenerated >= now() - lookback

AND event_matches('DLP or Sensitivity Label Policy Modified')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - DLP or Sensitivity Label Policy Modified
Incident Name	Possible DLP or Sensitivity Label Policy Modified Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Cloud, SaaS, OAuth and Non-Human Identity

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible DLP or Sensitivity Label Policy Modified Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 12:24:00	M365 Compliance Audit	user1068@example.local	SRV-168	203.0.113.227	Initial signal	Event indicates dlp or sensitivity label policy modified.
2026-05-18 12:26:00	DLP Logs	user1068@example.local	SRV-168	203.0.113.227	Context signal	Entity context matched BB: DLP Policies.
2026-05-18 12:31:00	Admin Audit	user1068@example.local	SRV-168	10.20.8.249	Follow-on activity	Related activity observed in M365.
2026-05-18 12:34:00	SIEM Correlation	user1068@example.local	SRV-168	203.0.113.227	Rule matched	Correlation matched building blocks: BB: DLP Policies, BB: Sensitivity Label Policies.
2026-05-18 12:42:00	SOC Case Record	user1068@example.local	SRV-168	203.0.113.227	Incident created	Incident created for DLP or Sensitivity Label Policy Modified with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- Was MFA satisfied normally, bypassed, repeatedly challenged or modified?
- Should active sessions or tokens be revoked while validation is ongoing?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Consider session revocation, password reset, MFA reset, OAuth grant removal, conditional access review and account disablement based on confirmation.
- Hunt for the same IP, application, token, user-agent, app ID or consent pattern across the tenant.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: DLP Policies, BB: Sensitivity Label Policies, BB: Approved Compliance Change.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 069: Excessive API Calls to Sensitive Endpoint

Category	API, Application and Web Security
MITRE ATT&CK Mapping	T1499 Endpoint Denial of Service; T1530 Data from Cloud Storage
Detection Objective	Detect and investigate excessive api calls to sensitive endpoint using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	API Gateway Logs, WAF Logs, Application Logs
Recommended Building Blocks	BB: Sensitive API Endpoints, BB: Rate Baseline, BB: API Consumers
Recommended Alert Name	2026 - Excessive API Calls to Sensitive Endpoint
Recommended Incident Name	Possible Excessive API Calls to Sensitive Endpoint Investigation

1. Scenario

One token calls customer/account endpoints far above normal rate.

Application and API telemetry is becoming essential because attackers increasingly abuse tokens, business logic, object identifiers and exposed services. Detection must correlate WAF, API gateway, identity and application logs.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1499 Endpoint Denial of Service; T1530 Data from Cloud Storage. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
API Gateway Logs	Provides application and API behaviour evidence for Excessive API Calls to Sensitive Endpoint. Key fields include token/client ID, user ID, endpoint, method, response code, request rate, object ID accessed and authentication result.	Simulation: token_id=svc-prod-22, source_ip=203.0.113.50, endpoint=/api/customer/statement, request_count=18,000 in 10 minutes. This may indicate token theft or automated data harvesting.
WAF Logs	Shows web attack evidence for Excessive API Calls to Sensitive Endpoint, including request URI, source IP, HTTP method, payload pattern, rule ID, action, response code and whether the exploit attempt was blocked or allowed.	Simulation: URI=/api/account?id=10522' OR '1'='1, action=Allowed, response=200. If followed by server process creation, raise as possible web compromise.
Application Logs	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Excessive API Calls to Sensitive Endpoint. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Excessive API Calls to Sensitive Endpoint, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.

	decide whether the activity is an isolated event or part of a chained incident.	
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Excessive API Calls to Sensitive Endpoint. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Excessive API Calls to Sensitive Endpoint. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Excessive API Calls to Sensitive Endpoint. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Excessive API Calls to Sensitive Endpoint was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Excessive API Calls to Sensitive Endpoint. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Excessive API Calls to Sensitive Endpoint, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Sensitive API Endpoints: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Rate Baseline: maintain the list owner, update frequency, source of truth and exception approval process.

- BB: API Consumers: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Sensitive API Endpoints, BB: Rate Baseline, BB: API Consumers];

FROM API Gateway Logs, WAF Logs, Application Logs

WHERE TimeGenerated >= now() - lookback

AND event_matches('Excessive API Calls to Sensitive Endpoint')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Excessive API Calls to Sensitive Endpoint
Incident Name	Possible Excessive API Calls to Sensitive Endpoint Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	API, Application and Web Security

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Excessive API Calls to Sensitive Endpoint Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
------	--------	------	------	-----------	-------	-----------------

2026-05-18 12:27:00	API Gateway Logs	user1069@example.local	WS-2069	203.0.113.234	Initial signal	Event indicates excessive api calls to sensitive endpoint.
2026-05-18 12:29:00	WAF Logs	user1069@example.local	WS-2069	203.0.113.234	Context signal	Entity context matched BB: Sensitive API Endpoints.
2026-05-18 12:34:00	Application Logs	user1069@example.local	WS-2069	10.20.9.10	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 12:37:00	SIEM Correlation	user1069@example.local	WS-2069	203.0.113.234	Rule matched	Correlation matched building blocks: BB: Sensitive API Endpoints, BB: Rate Baseline.
2026-05-18 12:45:00	SOC Case Record	user1069@example.local	WS-2069	203.0.113.234	Incident created	Incident created for Excessive API Calls to Sensitive Endpoint with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- What data was accessed, exported, downloaded or uploaded?
- Is customer, confidential, regulated or long-lived sensitive data involved?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Block or rate-limit malicious source where justified, rotate exposed tokens and validate application-side impact.
- Coordinate with application, network and infrastructure teams for evidence and containment.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Sensitive API Endpoints, BB: Rate Baseline, BB: API Consumers.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 070: API Token Used from New Source IP

Category	API, Application and Web Security
MITRE ATT&CK Mapping	T1550 Use Alternate Authentication Material; T1078 Valid Accounts
Detection Objective	Detect and investigate api token used from new source ip using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	API Gateway Logs, IAM Logs, Proxy Logs
Recommended Building Blocks	BB: API Tokens, BB: Expected Source IPs, BB: New ASN
Recommended Alert Name	2026 - API Token Used from New Source IP
Recommended Incident Name	Possible API Token Used from New Source IP Investigation

1. Scenario

A production API token normally used by an app server is used from an overseas VPS.

Application and API telemetry is becoming essential because attackers increasingly abuse tokens, business logic, object identifiers and exposed services. Detection must correlate WAF, API gateway, identity and application logs.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1550 Use Alternate Authentication Material; T1078 Valid Accounts. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
API Gateway Logs	Provides application and API behaviour evidence for API Token Used from New Source IP. Key fields include token/client ID, user ID, endpoint, method, response code, request rate, object ID accessed and authentication result.	Simulation: token_id=svc-prod-22, source_ip=203.0.113.50, endpoint=/api/customer/statement, request_count=18,000 in 10 minutes. This may indicate token theft or automated data harvesting.
IAM Logs	Provides supporting evidence for API Token Used from New Source IP. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for API Token Used from New Source IP. If the evidence is incomplete, the analyst should request the missing log source before closure.
Proxy Logs	Shows outbound web access linked to API Token Used from New Source IP, including URL, domain, category, upload/download size, HTTP method, user-agent, action and reputation. It helps confirm phishing clicks, payload downloads, C2, exfiltration or unapproved AI/cloud tool usage.	Simulation: user=farah.finance, url=hxxps://unknown-file-share.example/upload, bytes_out=524288000, action=Allowed. If this occurs after sensitive file access, investigate possible exfiltration.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For API Token Used from New Source IP, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.

	whether the activity is an isolated event or part of a chained incident.	
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in API Token Used from New Source IP. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to API Token Used from New Source IP. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to API Token Used from New Source IP. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in API Token Used from New Source IP was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during API Token Used from New Source IP. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For API Token Used from New Source IP, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: API Tokens: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Expected Source IPs: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: New ASN: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: API Tokens, BB: Expected Source IPs, BB: New ASN];

FROM API Gateway Logs, IAM Logs, Proxy Logs

WHERE TimeGenerated >= now() - lookback

AND event_matches('API Token Used from New Source IP')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - API Token Used from New Source IP
Incident Name	Possible API Token Used from New Source IP Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	API, Application and Web Security

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible API Token Used from New Source IP Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 12:30:00	API Gateway Logs	user1070@example.local	WS-2070	203.0.113.241	Initial signal	Event indicates api token used from new source ip.

2026-05-18 12:32:00	IAM Logs	user1070@example.local	WS-2070	203.0.113.241	Context signal	Entity context matched BB: API Tokens.
2026-05-18 12:37:00	Proxy Logs	user1070@example.local	WS-2070	10.20.10.21	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 12:40:00	SIEM Correlation	user1070@example.local	WS-2070	203.0.113.241	Rule matched	Correlation matched building blocks: BB: API Tokens, BB: Expected Source IPs.
2026-05-18 12:48:00	SOC Case Record	user1070@example.local	WS-2070	203.0.113.241	Incident created	Incident created for API Token Used from New Source IP with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- What data was accessed, exported, downloaded or uploaded?
- Is customer, confidential, regulated or long-lived sensitive data involved?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Block or rate-limit malicious source where justified, rotate exposed tokens and validate application-side impact.
- Coordinate with application, network and infrastructure teams for evidence and containment.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: API Tokens, BB: Expected Source IPs, BB: New ASN.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.

- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 071: API Activity Without Matching Interactive Login

Category	API, Application and Web Security
MITRE ATT&CK Mapping	T1550 Use Alternate Authentication Material
Detection Objective	Detect and investigate api activity without matching interactive login using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	API Gateway Logs, Identity Logs, Application Session Logs
Recommended Building Blocks	BB: API Activity, BB: Login Session Correlation, BB: Service Token Exclusion
Recommended Alert Name	2026 - API Activity Without Matching Interactive Login
Recommended Incident Name	Possible API Activity Without Matching Interactive Login Investigation

1. Scenario

A user token performs API actions even though no matching login or session creation is observed.

Application and API telemetry is becoming essential because attackers increasingly abuse tokens, business logic, object identifiers and exposed services. Detection must correlate WAF, API gateway, identity and application logs.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1550 Use Alternate Authentication Material. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
API Gateway Logs	Provides application and API behaviour evidence for API Activity Without Matching Interactive Login. Key fields include token/client ID, user ID, endpoint, method, response code, request rate, object ID accessed and authentication result.	Simulation: token_id=svc-prod-22, source_ip=203.0.113.50, endpoint=/api/customer/statement, request_count=18,000 in 10 minutes. This may indicate token theft or automated data harvesting.
Identity Logs	Adds external intelligence context to API Activity Without Matching Interactive Login. IOC, actor, campaign, reputation, first-seen date and confidence help prioritise alerts and connect internal evidence to known malicious infrastructure.	Simulation: destination IP matched TI feed as malware C2 with confidence=High, first_seen=2026-02-10. If internal host communicated successfully, investigate compromise evidence.
Application Session Logs	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during API Activity Without Matching Interactive Login. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For API Activity Without Matching Interactive Login, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.

	reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in API Activity Without Matching Interactive Login. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to API Activity Without Matching Interactive Login. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to API Activity Without Matching Interactive Login. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in API Activity Without Matching Interactive Login was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during API Activity Without Matching Interactive Login. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For API Activity Without Matching Interactive Login, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: API Activity: maintain the list owner, update frequency, source of truth and exception approval process.

- BB: Login Session Correlation: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Service Token Exclusion: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: API Activity, BB: Login Session Correlation, BB: Service Token Exclusion];

FROM API Gateway Logs, Identity Logs, Application Session Logs

WHERE TimeGenerated >= now() - lookback

AND event_matches('API Activity Without Matching Interactive Login')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - API Activity Without Matching Interactive Login
Incident Name	Possible API Activity Without Matching Interactive Login Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	API, Application and Web Security

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible API Activity Without Matching Interactive Login Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 12:33:00	API Gateway Logs	user1071@example.local	WS-2071	203.0.113.248	Initial signal	Event indicates api activity without matching interactive login.
2026-05-18 12:35:00	Identity Logs	user1071@example.local	WS-2071	203.0.113.248	Context signal	Entity context matched BB: API Activity.
2026-05-18 12:40:00	Application Session Logs	user1071@example.local	WS-2071	10.20.11.32	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 12:43:00	SIEM Correlation	user1071@example.local	WS-2071	203.0.113.248	Rule matched	Correlation matched building blocks: BB: API Activity, BB: Login Session Correlation.
2026-05-18 12:51:00	SOC Case Record	user1071@example.local	WS-2071	203.0.113.248	Incident created	Incident created for API Activity Without Matching Interactive Login with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- What data was accessed, exported, downloaded or uploaded?
- Is customer, confidential, regulated or long-lived sensitive data involved?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Block or rate-limit malicious source where justified, rotate exposed tokens and validate application-side impact.
- Coordinate with application, network and infrastructure teams for evidence and containment.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: API Activity, BB: Login Session Correlation, BB: Service Token Exclusion.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 072: Sequential Object ID Access Pattern

Category	API, Application and Web Security
MITRE ATT&CK Mapping	T1087 Account Discovery; T1190 Exploit Public-Facing Application
Detection Objective	Detect and investigate sequential object id access pattern using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	API Gateway Logs, Application Logs, WAF
Recommended Building Blocks	BB: Sequential Object ID Pattern, BB: Sensitive Objects, BB: Normal Pagination Exclusion
Recommended Alert Name	2026 - Sequential Object ID Access Pattern
Recommended Incident Name	Possible Sequential Object ID Access Pattern Investigation

1. Scenario

A user enumerates account or customer IDs by changing object identifiers in requests.

Application and API telemetry is becoming essential because attackers increasingly abuse tokens, business logic, object identifiers and exposed services. Detection must correlate WAF, API gateway, identity and application logs.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1087 Account Discovery; T1190 Exploit Public-Facing Application. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
API Gateway Logs	Provides application and API behaviour evidence for Sequential Object ID Access Pattern. Key fields include token/client ID, user ID, endpoint, method, response code, request rate, object ID accessed and authentication result.	Simulation: token_id=svc-prod-22, source_ip=203.0.113.50, endpoint=/api/customer/statement, request_count=18,000 in 10 minutes. This may indicate token theft or automated data harvesting.
Application Logs	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Sequential Object ID Access Pattern. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
WAF	Shows web attack evidence for Sequential Object ID Access Pattern, including request URI, source IP, HTTP method, payload pattern, rule ID, action, response code and whether the exploit attempt was blocked or allowed.	Simulation: URI=/api/account?id=10522' OR '1'='1, action=Allowed, response=200. If followed by server process creation, raise as possible web compromise.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Sequential Object ID Access Pattern, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.

	whether the activity is an isolated event or part of a chained incident.	
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Sequential Object ID Access Pattern. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Sequential Object ID Access Pattern. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Sequential Object ID Access Pattern. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Sequential Object ID Access Pattern was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Sequential Object ID Access Pattern. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Sequential Object ID Access Pattern, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Sequential Object ID Pattern: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Sensitive Objects: maintain the list owner, update frequency, source of truth and exception approval process.

- BB: Normal Pagination Exclusion: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Sequential Object ID Pattern, BB: Sensitive Objects, BB: Normal Pagination Exclusion];

FROM API Gateway Logs, Application Logs, WAF

WHERE TimeGenerated >= now() - lookback

AND event_matches('Sequential Object ID Access Pattern')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Sequential Object ID Access Pattern
Incident Name	Possible Sequential Object ID Access Pattern Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	API, Application and Web Security

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Sequential Object ID Access Pattern Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 12:36:00	API Gateway Logs	user1072@example.local	WS-2072	203.0.113.5	Initial signal	Event indicates sequential object id access pattern.
2026-05-18 12:38:00	Application Logs	user1072@example.local	WS-2072	203.0.113.5	Context signal	Entity context matched BB: Sequential Object ID Pattern.
2026-05-18 12:43:00	WAF	user1072@example.local	WS-2072	10.20.12.43	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 12:46:00	SIEM Correlation	user1072@example.local	WS-2072	203.0.113.5	Rule matched	Correlation matched building blocks: BB: Sequential Object ID Pattern, BB: Sensitive Objects.
2026-05-18 12:54:00	SOC Case Record	user1072@example.local	WS-2072	203.0.113.5	Incident created	Incident created for Sequential Object ID Access Pattern with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- What data was accessed, exported, downloaded or uploaded?
- Is customer, confidential, regulated or long-lived sensitive data involved?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Block or rate-limit malicious source where justified, rotate exposed tokens and validate application-side impact.
- Coordinate with application, network and infrastructure teams for evidence and containment.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Sequential Object ID Pattern, BB: Sensitive Objects, BB: Normal Pagination Exclusion.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 073: Broken Function Level Authorisation Indicator

Category	API, Application and Web Security
MITRE ATT&CK Mapping	T1190 Exploit Public-Facing Application; T1098 Account Manipulation
Detection Objective	Detect and investigate broken function level authorisation indicator using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	API Gateway Logs, Application AuthZ Logs
Recommended Building Blocks	BB: Admin Endpoints, BB: Non-Admin Users, BB: HTTP 200 on Admin API
Recommended Alert Name	2026 - Broken Function Level Authorisation Indicator
Recommended Incident Name	Possible Broken Function Level Authorisation Indicator Investigation

1. Scenario

A normal user successfully accesses an administrative API endpoint.

Application and API telemetry is becoming essential because attackers increasingly abuse tokens, business logic, object identifiers and exposed services. Detection must correlate WAF, API gateway, identity and application logs.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1190 Exploit Public-Facing Application; T1098 Account Manipulation. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
API Gateway Logs	Provides application and API behaviour evidence for Broken Function Level Authorisation Indicator. Key fields include token/client ID, user ID, endpoint, method, response code, request rate, object ID accessed and authentication result.	Simulation: token_id=svc-prod-22, source_ip=203.0.113.50, endpoint=/api/customer/statement, request_count=18,000 in 10 minutes. This may indicate token theft or automated data harvesting.
Application AuthZ Logs	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Broken Function Level Authorisation Indicator. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Broken Function Level Authorisation Indicator, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Broken Function Level Authorisation Indicator.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same

	This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Broken Function Level Authorisation Indicator. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Broken Function Level Authorisation Indicator. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Broken Function Level Authorisation Indicator was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Broken Function Level Authorisation Indicator. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Broken Function Level Authorisation Indicator, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Admin Endpoints: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Non-Admin Users: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: HTTP 200 on Admin API: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.

- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Admin Endpoints, BB: Non-Admin Users, BB: HTTP 200 on Admin API];

FROM API Gateway Logs, Application AuthZ Logs

WHERE TimeGenerated >= now() - lookback

AND event_matches('Broken Function Level Authorisation Indicator')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Broken Function Level Authorisation Indicator
Incident Name	Possible Broken Function Level Authorisation Indicator Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	API, Application and Web Security

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Broken Function Level Authorisation Indicator Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 12:39:00	API Gateway Logs	user1073@example.local	WS-2073	203.0.113.12	Initial signal	Event indicates broken function level authorisation indicator.
2026-05-18 12:41:00	Application AuthZ Logs	user1073@example.local	WS-2073	203.0.113.12	Context signal	Entity context matched BB: Admin Endpoints.
2026-05-18	API Gateway Logs	user1073@example.local	WS-2073	10.20.13.54	Follow-on activity	Related activity observed in

12:46:00						InternalApplication.
2026-05-18 12:49:00	SIEM Correlation	user1073@example.local	WS-2073	203.0.113.12	Rule matched	Correlation matched building blocks: BB: Admin Endpoints, BB: Non-Admin Users.
2026-05-18 12:57:00	SOC Case Record	user1073@example.local	WS-2073	203.0.113.12	Incident created	Incident created for Broken Function Level Authorisation Indicator with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- What data was accessed, exported, downloaded or uploaded?
- Is customer, confidential, regulated or long-lived sensitive data involved?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Block or rate-limit malicious source where justified, rotate exposed tokens and validate application-side impact.
- Coordinate with application, network and infrastructure teams for evidence and containment.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Admin Endpoints, BB: Non-Admin Users, BB: HTTP 200 on Admin API.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.

- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 074: WAF Exploit Attempt Allowed

Category	API, Application and Web Security
MITRE ATT&CK Mapping	T1190 Exploit Public-Facing Application
Detection Objective	Detect and investigate waf exploit attempt allowed using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	WAF Logs, Application Logs, EDR Server Logs
Recommended Building Blocks	BB: WAF Attack Signature, BB: Action Allowed, BB: Internet-Facing Apps
Recommended Alert Name	2026 - WAF Exploit Attempt Allowed
Recommended Incident Name	Possible WAF Exploit Attempt Allowed Investigation

1. Scenario

WAF detects SQL injection or exploit pattern but the request is allowed and returns HTTP 200.

Application and API telemetry is becoming essential because attackers increasingly abuse tokens, business logic, object identifiers and exposed services. Detection must correlate WAF, API gateway, identity and application logs.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1190 Exploit Public-Facing Application. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
WAF Logs	Shows web attack evidence for WAF Exploit Attempt Allowed, including request URI, source IP, HTTP method, payload pattern, rule ID, action, response code and whether the exploit attempt was blocked or allowed.	Simulation: URI=/api/account?id=10522' OR '1'=1, action=Allowed, response=200. If followed by server process creation, raise as possible web compromise.
Application Logs	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during WAF Exploit Attempt Allowed. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
EDR Server Logs	Provides endpoint execution and host-level evidence for WAF Exploit Attempt Allowed. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device isolation status and sensor health.	Simulation: parent=explorer.exe, child=powershell.exe, command='-EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution rather than only file delivery.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For WAF Exploit Attempt Allowed, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.

	whether the activity is an isolated event or part of a chained incident.	
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in WAF Exploit Attempt Allowed. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to WAF Exploit Attempt Allowed. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to WAF Exploit Attempt Allowed. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in WAF Exploit Attempt Allowed was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during WAF Exploit Attempt Allowed. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For WAF Exploit Attempt Allowed, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: WAF Attack Signature: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Action Allowed: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Internet-Facing Apps: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: WAF Attack Signature, BB: Action Allowed, BB: Internet-Facing Apps];

FROM WAF Logs, Application Logs, EDR Server Logs

WHERE TimeGenerated >= now() - lookback

AND event_matches('WAF Exploit Attempt Allowed')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - WAF Exploit Attempt Allowed
Incident Name	Possible WAF Exploit Attempt Allowed Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	API, Application and Web Security

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible WAF Exploit Attempt Allowed Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 12:42:00	WAF Logs	user1074@example.local	WS-2074	203.0.113.19	Initial signal	Event indicates waf exploit attempt allowed.

2026-05-18 12:44:00	Application Logs	user1074@example.local	WS-2074	203.0.113.19	Context signal	Entity context matched BB: WAF Attack Signature.
2026-05-18 12:49:00	EDR Server Logs	user1074@example.local	WS-2074	10.20.14.65	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 12:52:00	SIEM Correlation	user1074@example.local	WS-2074	203.0.113.19	Rule matched	Correlation matched building blocks: BB: WAF Attack Signature, BB: Action Allowed.
2026-05-18 13:00:00	SOC Case Record	user1074@example.local	WS-2074	203.0.113.19	Incident created	Incident created for WAF Exploit Attempt Allowed with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- What data was accessed, exported, downloaded or uploaded?
- Is customer, confidential, regulated or long-lived sensitive data involved?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Block or rate-limit malicious source where justified, rotate exposed tokens and validate application-side impact.
- Coordinate with application, network and infrastructure teams for evidence and containment.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: WAF Attack Signature, BB: Action Allowed, BB: Internet-Facing Apps.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.

- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 075: Web Exploit Followed by Server Process Creation

Category	API, Application and Web Security
MITRE ATT&CK Mapping	T1190 Exploit Public-Facing Application; T1059 Command and Scripting Interpreter
Detection Objective	Detect and investigate web exploit followed by server process creation using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	WAF Logs, EDR Server Logs, Web Server Logs
Recommended Building Blocks	BB: Exploit Attempt, BB: Server Process Creation, BB: External Callback
Recommended Alert Name	2026 - Web Exploit Followed by Server Process Creation
Recommended Incident Name	Possible Web Exploit Followed by Server Process Creation Investigation

1. Scenario

A suspicious web request is followed by command shell execution on the web server.

Application and API telemetry is becoming essential because attackers increasingly abuse tokens, business logic, object identifiers and exposed services. Detection must correlate WAF, API gateway, identity and application logs.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1190 Exploit Public-Facing Application; T1059 Command and Scripting Interpreter. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
WAF Logs	Shows web attack evidence for Web Exploit Followed by Server Process Creation, including request URI, source IP, HTTP method, payload pattern, rule ID, action, response code and whether the exploit attempt was blocked or allowed.	Simulation: URI=/api/account?id=10522' OR '1'=1, action=Allowed, response=200. If followed by server process creation, raise as possible web compromise.
EDR Server Logs	Provides endpoint execution and host-level evidence for Web Exploit Followed by Server Process Creation. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device isolation status and sensor health.	Simulation: parent=explorer.exe, child=powershell.exe, command='- EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution rather than only file delivery.
Web Server Logs	Provides supporting evidence for Web Exploit Followed by Server Process Creation. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Web Exploit Followed by Server Process Creation. If the evidence is incomplete, the analyst should request the missing log source before closure.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Web Exploit Followed by Server Process Creation, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.

	decide whether the activity is an isolated event or part of a chained incident.	
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Web Exploit Followed by Server Process Creation. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Web Exploit Followed by Server Process Creation. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Web Exploit Followed by Server Process Creation. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Web Exploit Followed by Server Process Creation was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Web Exploit Followed by Server Process Creation. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Web Exploit Followed by Server Process Creation, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Exploit Attempt: maintain the list owner, update frequency, source of truth and exception approval process.

- BB: Server Process Creation: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: External Callback: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Exploit Attempt, BB: Server Process Creation, BB: External Callback];

FROM WAF Logs, EDR Server Logs, Web Server Logs

WHERE TimeGenerated >= now() - lookback

AND event_matches('Web Exploit Followed by Server Process Creation')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Web Exploit Followed by Server Process Creation
Incident Name	Possible Web Exploit Followed by Server Process Creation Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	API, Application and Web Security

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Web Exploit Followed by Server Process Creation Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 12:45:00	WAF Logs	user1075@example.local	SRV-175	203.0.113.26	Initial signal	Event indicates web exploit followed by server process creation.
2026-05-18 12:47:00	EDR Server Logs	user1075@example.local	SRV-175	203.0.113.26	Context signal	Entity context matched BB: Exploit Attempt.
2026-05-18 12:52:00	Web Server Logs	user1075@example.local	SRV-175	10.20.15.76	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 12:55:00	SIEM Correlation	user1075@example.local	SRV-175	203.0.113.26	Rule matched	Correlation matched building blocks: BB: Exploit Attempt, BB: Server Process Creation.
2026-05-18 13:03:00	SOC Case Record	user1075@example.local	SRV-175	203.0.113.26	Incident created	Incident created for Web Exploit Followed by Server Process Creation with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- What data was accessed, exported, downloaded or uploaded?
- Is customer, confidential, regulated or long-lived sensitive data involved?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Block or rate-limit malicious source where justified, rotate exposed tokens and validate application-side impact.
- Coordinate with application, network and infrastructure teams for evidence and containment.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Exploit Attempt, BB: Server Process Creation, BB: External Callback.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 076: Suspicious File Upload to Web Application

Category	API, Application and Web Security
MITRE ATT&CK Mapping	T1190 Exploit Public-Facing Application; T1505.003 Web Shell
Detection Objective	Detect and investigate suspicious file upload to web application using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	WAF Logs, Application Logs, EDR File Events
Recommended Building Blocks	BB: Upload Endpoint, BB: Executable Extension, BB: Web Directory Write
Recommended Alert Name	2026 - Suspicious File Upload to Web Application
Recommended Incident Name	Possible Suspicious File Upload to Web Application Investigation

1. Scenario

A user uploads a file with script-like content or extension to a web-accessible folder.

Application and API telemetry is becoming essential because attackers increasingly abuse tokens, business logic, object identifiers and exposed services. Detection must correlate WAF, API gateway, identity and application logs.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1190 Exploit Public-Facing Application; T1505.003 Web Shell. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
WAF Logs	Shows web attack evidence for Suspicious File Upload to Web Application, including request URI, source IP, HTTP method, payload pattern, rule ID, action, response code and whether the exploit attempt was blocked or allowed.	Simulation: URI=/api/account?id=10522' OR '1'=1, action=Allowed, response=200. If followed by server process creation, raise as possible web compromise.
Application Logs	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Suspicious File Upload to Web Application. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
EDR File Events	Provides endpoint execution and host-level evidence for Suspicious File Upload to Web Application. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device isolation status and sensor health.	Simulation: parent=explorer.exe, child=powershell.exe, command='-EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution rather than only file delivery.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Suspicious File Upload to Web Application, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.

	decide whether the activity is an isolated event or part of a chained incident.	
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Suspicious File Upload to Web Application. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Suspicious File Upload to Web Application. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Suspicious File Upload to Web Application. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Suspicious File Upload to Web Application was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Suspicious File Upload to Web Application. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Suspicious File Upload to Web Application, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Upload Endpoint: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Executable Extension: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Web Directory Write: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Upload Endpoint, BB: Executable Extension, BB: Web Directory Write];

FROM WAF Logs, Application Logs, EDR File Events

WHERE TimeGenerated >= now() - lookback

AND event_matches('Suspicious File Upload to Web Application')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Suspicious File Upload to Web Application
Incident Name	Possible Suspicious File Upload to Web Application Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	API, Application and Web Security

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Suspicious File Upload to Web Application Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18	WAF Logs	user1076@example.local	WS-2076	203.0.113.33	Initial signal	Event indicates suspicious file upload

12:48:00						to web application.
2026-05-18 12:50:00	Application Logs	user1076@example.local	WS-2076	203.0.113.33	Context signal	Entity context matched BB: Upload Endpoint.
2026-05-18 12:55:00	EDR File Events	user1076@example.local	WS-2076	10.20.16.87	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 12:58:00	SIEM Correlation	user1076@example.local	WS-2076	203.0.113.33	Rule matched	Correlation matched building blocks: BB: Upload Endpoint, BB: Executable Extension.
2026-05-18 13:06:00	SOC Case Record	user1076@example.local	WS-2076	203.0.113.33	Incident created	Incident created for Suspicious File Upload to Web Application with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- What data was accessed, exported, downloaded or uploaded?
- Is customer, confidential, regulated or long-lived sensitive data involved?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Block or rate-limit malicious source where justified, rotate exposed tokens and validate application-side impact.
- Coordinate with application, network and infrastructure teams for evidence and containment.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Upload Endpoint, BB: Executable Extension, BB: Web Directory Write.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.

- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 077: Admin Portal Brute Force

Category	API, Application and Web Security
MITRE ATT&CK Mapping	T1110 Brute Force; T1190 Exploit Public-Facing Application
Detection Objective	Detect and investigate admin portal brute force using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	WAF Logs, Application Login Logs, IAM Logs
Recommended Building Blocks	BB: Admin Portal URLs, BB: Failed Login Threshold, BB: External Source IP
Recommended Alert Name	2026 - Admin Portal Brute Force
Recommended Incident Name	Possible Admin Portal Brute Force Investigation

1. Scenario

A public admin portal receives repeated failed login attempts from one or more sources.

Application and API telemetry is becoming essential because attackers increasingly abuse tokens, business logic, object identifiers and exposed services. Detection must correlate WAF, API gateway, identity and application logs.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1110 Brute Force; T1190 Exploit Public-Facing Application. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
WAF Logs	Shows web attack evidence for Admin Portal Brute Force, including request URI, source IP, HTTP method, payload pattern, rule ID, action, response code and whether the exploit attempt was blocked or allowed.	Simulation: URI=/api/account?id=10522' OR '1'='1, action=Allowed, response=200. If followed by server process creation, raise as possible web compromise.
Application Login Logs	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Admin Portal Brute Force. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
IAM Logs	Provides supporting evidence for Admin Portal Brute Force. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Admin Portal Brute Force. If the evidence is incomplete, the analyst should request the missing log source before closure.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Admin Portal Brute Force, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.

	incident.	
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Admin Portal Brute Force. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Admin Portal Brute Force. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Admin Portal Brute Force. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Admin Portal Brute Force was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Admin Portal Brute Force. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Admin Portal Brute Force, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Admin Portal URLs: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Failed Login Threshold: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: External Source IP: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Admin Portal URLs, BB: Failed Login Threshold, BB: External Source IP];

FROM WAF Logs, Application Login Logs, IAM Logs

WHERE TimeGenerated >= now() - lookback

AND event_matches('Admin Portal Brute Force')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Admin Portal Brute Force
Incident Name	Possible Admin Portal Brute Force Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	API, Application and Web Security

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Admin Portal Brute Force Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 12:51:00	WAF Logs	user1077@example.local	WS-2077	203.0.113.40	Initial signal	Event indicates admin portal brute force.

2026-05-18 12:53:00	Application Login Logs	user1077@example.local	WS-2077	203.0.113.40	Context signal	Entity context matched BB: Admin Portal URLs.
2026-05-18 12:58:00	IAM Logs	user1077@example.local	WS-2077	10.20.17.98	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 13:01:00	SIEM Correlation	user1077@example.local	WS-2077	203.0.113.40	Rule matched	Correlation matched building blocks: BB: Admin Portal URLs, BB: Failed Login Threshold.
2026-05-18 13:09:00	SOC Case Record	user1077@example.local	WS-2077	203.0.113.40	Incident created	Incident created for Admin Portal Brute Force with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- What data was accessed, exported, downloaded or uploaded?
- Is customer, confidential, regulated or long-lived sensitive data involved?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Block or rate-limit malicious source where justified, rotate exposed tokens and validate application-side impact.
- Coordinate with application, network and infrastructure teams for evidence and containment.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Admin Portal URLs, BB: Failed Login Threshold, BB: External Source IP.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.

- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 078: Business Logic Abuse in Transaction Flow

Category	API, Application and Web Security
MITRE ATT&CK Mapping	T1565 Data Manipulation; T1530 Data from Cloud Storage
Detection Objective	Detect and investigate business logic abuse in transaction flow using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Application Logs, Fraud Logs, API Gateway, Core Transaction Logs
Recommended Building Blocks	BB: Sensitive Business Flow, BB: Transaction Baseline, BB: Fraud Rule Hit
Recommended Alert Name	2026 - Business Logic Abuse in Transaction Flow
Recommended Incident Name	Possible Business Logic Abuse in Transaction Flow Investigation

1. Scenario

A user repeatedly performs small transactions or state changes that avoid normal thresholds but show abuse pattern.

Application and API telemetry is becoming essential because attackers increasingly abuse tokens, business logic, object identifiers and exposed services. Detection must correlate WAF, API gateway, identity and application logs.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1565 Data Manipulation; T1530 Data from Cloud Storage. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Application Logs	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Business Logic Abuse in Transaction Flow. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
Fraud Logs	Provides supporting evidence for Business Logic Abuse in Transaction Flow. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Business Logic Abuse in Transaction Flow. If the evidence is incomplete, the analyst should request the missing log source before closure.
API Gateway	Provides application and API behaviour evidence for Business Logic Abuse in Transaction Flow. Key fields include token/client ID, user ID, endpoint, method, response code, request rate, object ID accessed and authentication result.	Simulation: token_id=svc-prod-22, source_ip=203.0.113.50, endpoint=/api/customer/statement, request_count=18,000 in 10 minutes. This may indicate token theft or automated data harvesting.
Core Transaction Logs	Explains whether the activity in Business Logic Abuse in Transaction Flow was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should

	investigation and response requirements.	become an incident.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Business Logic Abuse in Transaction Flow, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Business Logic Abuse in Transaction Flow. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Business Logic Abuse in Transaction Flow. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Business Logic Abuse in Transaction Flow. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Business Logic Abuse in Transaction Flow was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Business Logic Abuse in Transaction Flow. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Business Logic Abuse in Transaction Flow, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Sensitive Business Flow: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Transaction Baseline: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Fraud Rule Hit: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Sensitive Business Flow, BB: Transaction Baseline, BB: Fraud Rule Hit];

FROM Application Logs, Fraud Logs, API Gateway

WHERE TimeGenerated >= now() - lookback

AND event_matches('Business Logic Abuse in Transaction Flow')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Business Logic Abuse in Transaction Flow
Incident Name	Possible Business Logic Abuse in Transaction Flow Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	API, Application and Web Security

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Business Logic Abuse in Transaction Flow Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.

- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 12:54:00	Application Logs	user1078@example.local	WS-2078	203.0.113.47	Initial signal	Event indicates business logic abuse in transaction flow.
2026-05-18 12:56:00	Fraud Logs	user1078@example.local	WS-2078	203.0.113.47	Context signal	Entity context matched BB: Sensitive Business Flow.
2026-05-18 13:01:00	API Gateway	user1078@example.local	WS-2078	10.20.18.109	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 13:04:00	SIEM Correlation	user1078@example.local	WS-2078	203.0.113.47	Rule matched	Correlation matched building blocks: BB: Sensitive Business Flow, BB: Transaction Baseline.
2026-05-18 13:12:00	SOC Case Record	user1078@example.local	WS-2078	203.0.113.47	Incident created	Incident created for Business Logic Abuse in Transaction Flow with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- What data was accessed, exported, downloaded or uploaded?
- Is customer, confidential, regulated or long-lived sensitive data involved?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Block or rate-limit malicious source where justified, rotate exposed tokens and validate application-side impact.
- Coordinate with application, network and infrastructure teams for evidence and containment.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.

- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Sensitive Business Flow, BB: Transaction Baseline, BB: Fraud Rule Hit.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 079: Internal Host Communicates with Known Malicious IP

Category	Network, Perimeter and Threat Intelligence
MITRE ATT&CK Mapping	T1071 Application Layer Protocol
Detection Objective	Detect and investigate internal host communicates with known malicious ip using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Firewall Logs, Proxy Logs, Threat Intel, EDR Network
Recommended Building Blocks	BB: Threat Intel IP Match, BB: Internal Asset Criticality, BB: Allowed Business Partners
Recommended Alert Name	2026 - Internal Host Communicates with Known Malicious IP
Recommended Incident Name	Possible Internal Host Communicates with Known Malicious IP Investigation

1. Scenario

An internal host initiates outbound communication to an IP address present in threat intelligence.

Network and perimeter detections provide visibility into external threat activity, command-and-control, scanning, exfiltration and connections to known malicious infrastructure.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1071 Application Layer Protocol. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Firewall Logs	Provides network movement and perimeter evidence for Internal Host Communicates with Known Malicious IP. Important fields include source, destination, port, protocol, bytes in/out, action, rule name, zone, IPS signature and session duration.	Simulation: source=10.44.21.77, destination=10.10.4.20, port=445, action=Allowed, repeated across 30 hosts. This supports lateral movement or internal scanning analysis.
Proxy Logs	Shows outbound web access linked to Internal Host Communicates with Known Malicious IP, including URL, domain, category, upload/download size, HTTP method, user-agent, action and reputation. It helps confirm phishing clicks, payload downloads, C2, exfiltration or unapproved AI/cloud tool usage.	Simulation: user=farah.finance, url=hxxps://unknown-file-share.example/upload, bytes_out=524288000, action=Allowed. If this occurs after sensitive file access, investigate possible exfiltration.
Threat Intel	Adds external intelligence context to Internal Host Communicates with Known Malicious IP. IOC, actor, campaign, reputation, first-seen date and confidence help prioritise alerts and connect internal evidence to known malicious infrastructure.	Simulation: destination IP matched TI feed as malware C2 with confidence=High, first_seen=2026-02-10. If internal host communicated successfully, investigate compromise evidence.
EDR Network	Provides endpoint execution and host-level evidence for Internal Host Communicates with Known Malicious IP. Key fields include process name, command line, parent process, file hash,	Simulation: parent=explorer.exe, child=powershell.exe, command='-EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution

	user context, network connection, detection action, device isolation status and sensor health.	rather than only file delivery.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Internal Host Communicates with Known Malicious IP, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Internal Host Communicates with Known Malicious IP. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Internal Host Communicates with Known Malicious IP. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Internal Host Communicates with Known Malicious IP. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Internal Host Communicates with Known Malicious IP was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Internal Host Communicates with Known Malicious IP. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Internal Host Communicates with Known Malicious IP, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on

	be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	activity exists, document containment evidence and close as attempted/blocked.
--	---	--

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Threat Intel IP Match: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Internal Asset Criticality: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Allowed Business Partners: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Threat Intel IP Match, BB: Internal Asset Criticality, BB: Allowed Business Partners];

FROM Firewall Logs, Proxy Logs, Threat Intel

WHERE TimeGenerated >= now() - lookback

AND event_matches('Internal Host Communicates with Known Malicious IP')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Internal Host Communicates with Known Malicious IP
Incident Name	Possible Internal Host Communicates with Known Malicious IP Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Network, Perimeter and Threat Intelligence

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Internal Host Communicates with Known Malicious IP Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 12:57:00	Firewall Logs	user1079@example.local	WS-2079	203.0.113.54	Initial signal	Event indicates internal host communicates with known malicious ip.
2026-05-18 12:59:00	Proxy Logs	user1079@example.local	WS-2079	203.0.113.54	Context signal	Entity context matched BB: Threat Intel IP Match.
2026-05-18 13:04:00	Threat Intel	user1079@example.local	WS-2079	10.20.19.120	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 13:07:00	SIEM Correlation	user1079@example.local	WS-2079	203.0.113.54	Rule matched	Correlation matched building blocks: BB: Threat Intel IP Match, BB: Internal Asset Criticality.
2026-05-18 13:15:00	SOC Case Record	user1079@example.local	WS-2079	203.0.113.54	Incident created	Incident created for Internal Host Communicates with Known Malicious IP with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.

- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Block or rate-limit malicious source where justified, rotate exposed tokens and validate application-side impact.
- Coordinate with application, network and infrastructure teams for evidence and containment.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Threat Intel IP Match, BB: Internal Asset Criticality, BB: Allowed Business Partners.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 080: Malicious Domain Resolution

Category	Network, Perimeter and Threat Intelligence
MITRE ATT&CK Mapping	T1071.004 DNS
Detection Objective	Detect and investigate malicious domain resolution using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	DNS Logs, Proxy Logs, Threat Intel
Recommended Building Blocks	BB: Threat Intel Domain Match, BB: Newly Registered Domain, BB: Internal Host
Recommended Alert Name	2026 - Malicious Domain Resolution
Recommended Incident Name	Possible Malicious Domain Resolution Investigation

1. Scenario

A workstation resolves a domain known to be associated with malware or credential phishing.

Network and perimeter detections provide visibility into external threat activity, command-and-control, scanning, exfiltration and connections to known malicious infrastructure.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1071.004 DNS. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
DNS Logs	Shows domain resolution behaviour for Malicious Domain Resolution. DNS logs help identify newly observed domains, C2 beaconing, DNS tunnelling, malware callbacks and suspicious infrastructure before or after endpoint/network activity.	Simulation: host=BSN-LT-0441 repeatedly queries a long random subdomain every 60 seconds. This may indicate beaconing or tunnelling when correlated with endpoint process activity.
Proxy Logs	Shows outbound web access linked to Malicious Domain Resolution, including URL, domain, category, upload/download size, HTTP method, user-agent, action and reputation. It helps confirm phishing clicks, payload downloads, C2, exfiltration or unapproved AI/cloud tool usage.	Simulation: user=farah.finance, url=hxxps://unknown-file-share.example/upload, bytes_out=524288000, action=Allowed. If this occurs after sensitive file access, investigate possible exfiltration.
Threat Intel	Adds external intelligence context to Malicious Domain Resolution. IOC, actor, campaign, reputation, first-seen date and confidence help prioritise alerts and connect internal evidence to known malicious infrastructure.	Simulation: destination IP matched TI feed as malware C2 with confidence=High, first_seen=2026-02-10. If internal host communicated successfully, investigate compromise evidence.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Malicious Domain Resolution, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.

User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Malicious Domain Resolution. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Malicious Domain Resolution. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Malicious Domain Resolution. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Malicious Domain Resolution was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Malicious Domain Resolution. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Malicious Domain Resolution, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Threat Intel Domain Match: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Newly Registered Domain: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Internal Host: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Threat Intel Domain Match, BB: Newly Registered Domain, BB: Internal Host];

FROM DNS Logs, Proxy Logs, Threat Intel

WHERE TimeGenerated >= now() - lookback

AND event_matches('Malicious Domain Resolution')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Malicious Domain Resolution
Incident Name	Possible Malicious Domain Resolution Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Network, Perimeter and Threat Intelligence

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Malicious Domain Resolution Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 13:00:00	DNS Logs	user1080@example.local	WS-2080	203.0.113.61	Initial signal	Event indicates malicious domain resolution.

2026-05-18 13:02:00	Proxy Logs	user1080@example.local	WS-2080	203.0.113.61	Context signal	Entity context matched BB: Threat Intel Domain Match.
2026-05-18 13:07:00	Threat Intel	user1080@example.local	WS-2080	10.20.20.131	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 13:10:00	SIEM Correlation	user1080@example.local	WS-2080	203.0.113.61	Rule matched	Correlation matched building blocks: BB: Threat Intel Domain Match, BB: Newly Registered Domain.
2026-05-18 13:18:00	SOC Case Record	user1080@example.local	WS-2080	203.0.113.61	Incident created	Incident created for Malicious Domain Resolution with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Block or rate-limit malicious source where justified, rotate exposed tokens and validate application-side impact.
- Coordinate with application, network and infrastructure teams for evidence and containment.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Threat Intel Domain Match, BB: Newly Registered Domain, BB: Internal Host.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.

- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 081: C2 Beaconsing Pattern

Category	Network, Perimeter and Threat Intelligence
MITRE ATT&CK Mapping	T1071 Application Layer Protocol; T1102 Web Service
Detection Objective	Detect and investigate c2 beaconsing pattern using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Proxy Logs, Firewall Logs, DNS Logs, NDR
Recommended Building Blocks	BB: Beacon Interval, BB: Rare Destination, BB: Suspicious User-Agent
Recommended Alert Name	2026 - C2 Beaconsing Pattern
Recommended Incident Name	Possible C2 Beaconsing Pattern Investigation

1. Scenario

A host contacts the same rare destination every 60 seconds with similar byte size.

Network and perimeter detections provide visibility into external threat activity, command-and-control, scanning, exfiltration and connections to known malicious infrastructure.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1071 Application Layer Protocol; T1102 Web Service. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Proxy Logs	Shows outbound web access linked to C2 Beaconsing Pattern, including URL, domain, category, upload/download size, HTTP method, user-agent, action and reputation. It helps confirm phishing clicks, payload downloads, C2, exfiltration or unapproved AI/cloud tool usage.	Simulation: user=farah.finance, url=hxxps://unknown-file-share.example/upload, bytes_out=524288000, action=Allowed. If this occurs after sensitive file access, investigate possible exfiltration.
Firewall Logs	Provides network movement and perimeter evidence for C2 Beaconsing Pattern. Important fields include source, destination, port, protocol, bytes in/out, action, rule name, zone, IPS signature and session duration.	Simulation: source=10.44.21.77, destination=10.10.4.20, port=445, action=Allowed, repeated across 30 hosts. This supports lateral movement or internal scanning analysis.
DNS Logs	Shows domain resolution behaviour for C2 Beaconsing Pattern. DNS logs help identify newly observed domains, C2 beaconsing, DNS tunnelling, malware callbacks and suspicious infrastructure before or after endpoint/network activity.	Simulation: host=BSN-LT-0441 repeatedly queries a long random subdomain every 60 seconds. This may indicate beaconsing or tunnelling when correlated with endpoint process activity.
NDR	Provides supporting evidence for C2 Beaconsing Pattern. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for C2 Beaconsing Pattern. If the evidence is incomplete, the analyst should request the missing log source before closure.
TimeGenerated / EventTime	This is the anchor for timeline	Simulation: 2026-03-18 09:14:22 risky sign-

	reconstruction. For C2 Beacons Pattern, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in C2 Beacons Pattern. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to C2 Beacons Pattern. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to C2 Beacons Pattern. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in C2 Beacons Pattern was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during C2 Beacons Pattern. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For C2 Beacons Pattern, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Beacon Interval: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Rare Destination: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Suspicious User-Agent: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Beacon Interval, BB: Rare Destination, BB: Suspicious User-Agent];

FROM Proxy Logs, Firewall Logs, DNS Logs

WHERE TimeGenerated >= now() - lookback

AND event_matches('C2 Beacons Pattern')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - C2 Beacons Pattern
Incident Name	Possible C2 Beacons Pattern Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Network, Perimeter and Threat Intelligence

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible C2 Beacons Pattern Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 13:03:00	Proxy Logs	user1081@example.local	WS-2081	203.0.113.68	Initial signal	Event indicates c2 beaconing pattern.
2026-05-18 13:05:00	Firewall Logs	user1081@example.local	WS-2081	203.0.113.68	Context signal	Entity context matched BB: Beacon Interval.
2026-05-18 13:10:00	DNS Logs	user1081@example.local	WS-2081	10.20.21.142	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 13:13:00	SIEM Correlation	user1081@example.local	WS-2081	203.0.113.68	Rule matched	Correlation matched building blocks: BB: Beacon Interval, BB: Rare Destination.
2026-05-18 13:21:00	SOC Case Record	user1081@example.local	WS-2081	203.0.113.68	Incident created	Incident created for C2 Beaconing Pattern with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Block or rate-limit malicious source where justified, rotate exposed tokens and validate application-side impact.
- Coordinate with application, network and infrastructure teams for evidence and containment.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Beacon Interval, BB: Rare Destination, BB: Suspicious User-Agent.

- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 082: Internal Port Scanning from Workstation

Category	Network, Perimeter and Threat Intelligence
MITRE ATT&CK Mapping	T1046 Network Service Discovery
Detection Objective	Detect and investigate internal port scanning from workstation using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Firewall Logs, NDR, NetFlow, EDR Network
Recommended Building Blocks	BB: Internal Scan Threshold, BB: User Workstations, BB: Approved Scanner Hosts
Recommended Alert Name	2026 - Internal Port Scanning from Workstation
Recommended Incident Name	Possible Internal Port Scanning from Workstation Investigation

1. Scenario

A normal workstation scans multiple ports across a server subnet.

Network and perimeter detections provide visibility into external threat activity, command-and-control, scanning, exfiltration and connections to known malicious infrastructure.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1046 Network Service Discovery. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Firewall Logs	Provides network movement and perimeter evidence for Internal Port Scanning from Workstation. Important fields include source, destination, port, protocol, bytes in/out, action, rule name, zone, IPS signature and session duration.	Simulation: source=10.44.21.77, destination=10.10.4.20, port=445, action=Allowed, repeated across 30 hosts. This supports lateral movement or internal scanning analysis.
NDR	Provides supporting evidence for Internal Port Scanning from Workstation. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Internal Port Scanning from Workstation. If the evidence is incomplete, the analyst should request the missing log source before closure.
NetFlow	Provides network movement and perimeter evidence for Internal Port Scanning from Workstation. Important fields include source, destination, port, protocol, bytes in/out, action, rule name, zone, IPS signature and session duration.	Simulation: source=10.44.21.77, destination=10.10.4.20, port=445, action=Allowed, repeated across 30 hosts. This supports lateral movement or internal scanning analysis.
EDR Network	Provides endpoint execution and host-level evidence for Internal Port Scanning from Workstation. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device isolation status and sensor health.	Simulation: parent=explorer.exe, child=powershell.exe, command='-EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution rather than only file delivery.

TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Internal Port Scanning from Workstation, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Internal Port Scanning from Workstation. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Internal Port Scanning from Workstation. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Internal Port Scanning from Workstation. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Internal Port Scanning from Workstation was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Internal Port Scanning from Workstation. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Internal Port Scanning from Workstation, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Internal Scan Threshold: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: User Workstations: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Approved Scanner Hosts: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Internal Scan Threshold, BB: User Workstations, BB: Approved Scanner Hosts];

FROM Firewall Logs, NDR, NetFlow

WHERE TimeGenerated >= now() - lookback

AND event_matches('Internal Port Scanning from Workstation')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Internal Port Scanning from Workstation
Incident Name	Possible Internal Port Scanning from Workstation Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Network, Perimeter and Threat Intelligence

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Internal Port Scanning from Workstation Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 13:06:00	Firewall Logs	user1082@example.local	WS-2082	203.0.113.75	Initial signal	Event indicates internal port scanning from workstation.
2026-05-18 13:08:00	NDR	user1082@example.local	WS-2082	203.0.113.75	Context signal	Entity context matched BB: Internal Scan Threshold.
2026-05-18 13:13:00	NetFlow	user1082@example.local	WS-2082	10.20.22.153	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 13:16:00	SIEM Correlation	user1082@example.local	WS-2082	203.0.113.75	Rule matched	Correlation matched building blocks: BB: Internal Scan Threshold, BB: User Workstations.
2026-05-18 13:24:00	SOC Case Record	user1082@example.local	WS-2082	203.0.113.75	Incident created	Incident created for Internal Port Scanning from Workstation with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Block or rate-limit malicious source where justified, rotate exposed tokens and validate application-side impact.
- Coordinate with application, network and infrastructure teams for evidence and containment.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.

- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Internal Scan Threshold, BB: User Workstations, BB: Approved Scanner Hosts.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 083: VPN Login Followed by Internal Scan

Category	Network, Perimeter and Threat Intelligence
MITRE ATT&CK Mapping	T1133 External Remote Services; T1046 Network Service Discovery
Detection Objective	Detect and investigate vpn login followed by internal scan using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	VPN Logs, NDR, Firewall Logs, AD Logs
Recommended Building Blocks	BB: VPN Session, BB: Internal Scan, BB: New Country
Recommended Alert Name	2026 - VPN Login Followed by Internal Scan
Recommended Incident Name	Possible VPN Login Followed by Internal Scan Investigation

1. Scenario

A new-country VPN login is followed by internal probing against many hosts.

Network and perimeter detections provide visibility into external threat activity, command-and-control, scanning, exfiltration and connections to known malicious infrastructure.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1133 External Remote Services; T1046 Network Service Discovery. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
VPN Logs	Shows remote access activity related to VPN Login Followed by Internal Scan, including login time, public source IP, assigned internal IP, VPN gateway, session duration and disconnect reason. It is useful for correlating cloud sign-ins with remote network access and internal movement.	Simulation: VPN login at 09:05 from 185.220.101.34 assigned internal IP 10.44.21.77, then the same user performs M365 access at 09:08. This supports a single attacker session rather than two unrelated events.
NDR	Provides supporting evidence for VPN Login Followed by Internal Scan. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for VPN Login Followed by Internal Scan. If the evidence is incomplete, the analyst should request the missing log source before closure.
Firewall Logs	Provides network movement and perimeter evidence for VPN Login Followed by Internal Scan. Important fields include source, destination, port, protocol, bytes in/out, action, rule name, zone, IPS signature and session duration.	Simulation: source=10.44.21.77, destination=10.10.4.20, port=445, action=Allowed, repeated across 30 hosts. This supports lateral movement or internal scanning analysis.
AD Logs	Provides supporting evidence for VPN Login Followed by Internal Scan. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for VPN Login Followed by Internal Scan. If the evidence is incomplete, the analyst should request the

	activity in the same timeline.	missing log source before closure.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For VPN Login Followed by Internal Scan, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in VPN Login Followed by Internal Scan. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to VPN Login Followed by Internal Scan. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to VPN Login Followed by Internal Scan. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in VPN Login Followed by Internal Scan was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during VPN Login Followed by Internal Scan. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For VPN Login Followed by Internal Scan, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: VPN Session: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Internal Scan: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: New Country: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: VPN Session, BB: Internal Scan, BB: New Country];

FROM VPN Logs, NDR, Firewall Logs

WHERE TimeGenerated >= now() - lookback

AND event_matches('VPN Login Followed by Internal Scan')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - VPN Login Followed by Internal Scan
Incident Name	Possible VPN Login Followed by Internal Scan Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Network, Perimeter and Threat Intelligence

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible VPN Login Followed by Internal Scan Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.

- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 13:09:00	VPN Logs	user1083@example.local	WS-2083	203.0.113.82	Initial signal	Event indicates vpn login followed by internal scan.
2026-05-18 13:11:00	NDR	user1083@example.local	WS-2083	203.0.113.82	Context signal	Entity context matched BB: VPN Session.
2026-05-18 13:16:00	Firewall Logs	user1083@example.local	WS-2083	10.20.23.164	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 13:19:00	SIEM Correlation	user1083@example.local	WS-2083	203.0.113.82	Rule matched	Correlation matched building blocks: BB: VPN Session, BB: Internal Scan.
2026-05-18 13:27:00	SOC Case Record	user1083@example.local	WS-2083	203.0.113.82	Incident created	Incident created for VPN Login Followed by Internal Scan with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Block or rate-limit malicious source where justified, rotate exposed tokens and validate application-side impact.
- Coordinate with application, network and infrastructure teams for evidence and containment.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: VPN Session, BB: Internal Scan, BB: New Country.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 084: Large Outbound Transfer to Rare Destination

Category	Network, Perimeter and Threat Intelligence
MITRE ATT&CK Mapping	T1041 Exfiltration Over C2 Channel; T1048 Exfiltration Over Alternative Protocol
Detection Objective	Detect and investigate large outbound transfer to rare destination using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Proxy Logs, Firewall Logs, DLP, NetFlow
Recommended Building Blocks	BB: Large Upload, BB: Rare Destination, BB: Sensitive Asset
Recommended Alert Name	2026 - Large Outbound Transfer to Rare Destination
Recommended Incident Name	Possible Large Outbound Transfer to Rare Destination Investigation

1. Scenario

An endpoint uploads many gigabytes to a previously unseen external destination.

Network and perimeter detections provide visibility into external threat activity, command-and-control, scanning, exfiltration and connections to known malicious infrastructure.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1041 Exfiltration Over C2 Channel; T1048 Exfiltration Over Alternative Protocol. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Proxy Logs	Shows outbound web access linked to Large Outbound Transfer to Rare Destination, including URL, domain, category, upload/download size, HTTP method, user-agent, action and reputation. It helps confirm phishing clicks, payload downloads, C2, exfiltration or unapproved AI/cloud tool usage.	Simulation: user=farah.finance, url=hxxps://unknown-file-share.example/upload, bytes_out=524288000, action=Allowed. If this occurs after sensitive file access, investigate possible exfiltration.
Firewall Logs	Provides network movement and perimeter evidence for Large Outbound Transfer to Rare Destination. Important fields include source, destination, port, protocol, bytes in/out, action, rule name, zone, IPS signature and session duration.	Simulation: source=10.44.21.77, destination=10.10.4.20, port=445, action=Allowed, repeated across 30 hosts. This supports lateral movement or internal scanning analysis.
DLP	Shows data protection evidence for Large Outbound Transfer to Rare Destination. DLP/CASB telemetry confirms whether sensitive data was uploaded, shared, pasted, copied, synchronised or transferred to external services.	Simulation: DLP policy=Customer PII, destination=personal-cloud.example, action=AllowedWithAlert, file=Customer_List_2026.xlsx. This is evidence for possible data leakage.
NetFlow	Provides network movement and perimeter evidence for Large Outbound Transfer to Rare Destination. Important fields include source, destination, port, protocol, bytes in/out, action, rule name, zone, IPS signature and session duration.	Simulation: source=10.44.21.77, destination=10.10.4.20, port=445, action=Allowed, repeated across 30 hosts. This supports lateral movement or internal scanning analysis.

TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Large Outbound Transfer to Rare Destination, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Large Outbound Transfer to Rare Destination. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Large Outbound Transfer to Rare Destination. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Large Outbound Transfer to Rare Destination. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Large Outbound Transfer to Rare Destination was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Large Outbound Transfer to Rare Destination. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Large Outbound Transfer to Rare Destination, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Large Upload: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Rare Destination: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Sensitive Asset: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Large Upload, BB: Rare Destination, BB: Sensitive Asset];

FROM Proxy Logs, Firewall Logs, DLP

WHERE TimeGenerated >= now() - lookback

AND event_matches('Large Outbound Transfer to Rare Destination')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Large Outbound Transfer to Rare Destination
Incident Name	Possible Large Outbound Transfer to Rare Destination Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Network, Perimeter and Threat Intelligence

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Large Outbound Transfer to Rare Destination Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.

- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 13:12:00	Proxy Logs	user1084@example.local	WS-2084	203.0.113.89	Initial signal	Event indicates large outbound transfer to rare destination.
2026-05-18 13:14:00	Firewall Logs	user1084@example.local	WS-2084	203.0.113.89	Context signal	Entity context matched BB: Large Upload.
2026-05-18 13:19:00	DLP	user1084@example.local	WS-2084	10.20.24.175	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 13:22:00	SIEM Correlation	user1084@example.local	WS-2084	203.0.113.89	Rule matched	Correlation matched building blocks: BB: Large Upload, BB: Rare Destination.
2026-05-18 13:30:00	SOC Case Record	user1084@example.local	WS-2084	203.0.113.89	Incident created	Incident created for Large Outbound Transfer to Rare Destination with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Block or rate-limit malicious source where justified, rotate exposed tokens and validate application-side impact.
- Coordinate with application, network and infrastructure teams for evidence and containment.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.

- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Large Upload, BB: Rare Destination, BB: Sensitive Asset.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 085: DNS Tunnelling Indicator

Category	Network, Perimeter and Threat Intelligence
MITRE ATT&CK Mapping	T1048 Exfiltration Over Alternative Protocol; T1071.004 DNS
Detection Objective	Detect and investigate dns tunnelling indicator using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	DNS Logs, NDR, Firewall Logs
Recommended Building Blocks	BB: Long Subdomain, BB: High Entropy DNS, BB: Query Volume
Recommended Alert Name	2026 - DNS Tunnelling Indicator
Recommended Incident Name	Possible DNS Tunnelling Indicator Investigation

1. Scenario

A host generates many long, encoded-looking DNS queries to the same domain.

Network and perimeter detections provide visibility into external threat activity, command-and-control, scanning, exfiltration and connections to known malicious infrastructure.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1048 Exfiltration Over Alternative Protocol; T1071.004 DNS. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
DNS Logs	Shows domain resolution behaviour for DNS Tunnelling Indicator. DNS logs help identify newly observed domains, C2 beaconing, DNS tunnelling, malware callbacks and suspicious infrastructure before or after endpoint/network activity.	Simulation: host=BSN-LT-0441 repeatedly queries a long random subdomain every 60 seconds. This may indicate beaconing or tunnelling when correlated with endpoint process activity.
NDR	Provides supporting evidence for DNS Tunnelling Indicator. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for DNS Tunnelling Indicator. If the evidence is incomplete, the analyst should request the missing log source before closure.
Firewall Logs	Provides network movement and perimeter evidence for DNS Tunnelling Indicator. Important fields include source, destination, port, protocol, bytes in/out, action, rule name, zone, IPS signature and session duration.	Simulation: source=10.44.21.77, destination=10.10.4.20, port=445, action=Allowed, repeated across 30 hosts. This supports lateral movement or internal scanning analysis.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For DNS Tunnelling Indicator, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.

	incident.	
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in DNS Tunnelling Indicator. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to DNS Tunnelling Indicator. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to DNS Tunnelling Indicator. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in DNS Tunnelling Indicator was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during DNS Tunnelling Indicator. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For DNS Tunnelling Indicator, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Long Subdomain: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: High Entropy DNS: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Query Volume: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Long Subdomain, BB: High Entropy DNS, BB: Query Volume];

FROM DNS Logs, NDR, Firewall Logs

WHERE TimeGenerated >= now() - lookback

AND event_matches('DNS Tunnelling Indicator')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - DNS Tunnelling Indicator
Incident Name	Possible DNS Tunnelling Indicator Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Network, Perimeter and Threat Intelligence

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible DNS Tunnelling Indicator Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 13:15:00	DNS Logs	user1085@example.local	WS-2085	203.0.113.96	Initial signal	Event indicates dns tunnelling indicator.

2026-05-18 13:17:00	NDR	user1085@example.local	WS-2085	203.0.113.96	Context signal	Entity context matched BB: Long Subdomain.
2026-05-18 13:22:00	Firewall Logs	user1085@example.local	WS-2085	10.20.25.186	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 13:25:00	SIEM Correlation	user1085@example.local	WS-2085	203.0.113.96	Rule matched	Correlation matched building blocks: BB: Long Subdomain, BB: High Entropy DNS.
2026-05-18 13:33:00	SOC Case Record	user1085@example.local	WS-2085	203.0.113.96	Incident created	Incident created for DNS Tunnelling Indicator with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Block or rate-limit malicious source where justified, rotate exposed tokens and validate application-side impact.
- Coordinate with application, network and infrastructure teams for evidence and containment.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Long Subdomain, BB: High Entropy DNS, BB: Query Volume.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.

- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 086: High-Severity IPS Block Against Critical Asset

Category	Network, Perimeter and Threat Intelligence
MITRE ATT&CK Mapping	T1190 Exploit Public-Facing Application; T1595 Active Scanning
Detection Objective	Detect and investigate high-severity ips block against critical asset using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	IPS Logs, Firewall Logs, Asset Inventory, Threat Intel
Recommended Building Blocks	BB: High Severity IPS, BB: Critical Asset, BB: Internet-Facing Systems
Recommended Alert Name	2026 - High-Severity IPS Block Against Critical Asset
Recommended Incident Name	Possible High-Severity IPS Block Against Critical Asset Investigation

1. Scenario

IPS blocks exploit attempts targeting a critical exposed system.

Network and perimeter detections provide visibility into external threat activity, command-and-control, scanning, exfiltration and connections to known malicious infrastructure.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1190 Exploit Public-Facing Application; T1595 Active Scanning. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
IPS Logs	Provides network movement and perimeter evidence for High-Severity IPS Block Against Critical Asset. Important fields include source, destination, port, protocol, bytes in/out, action, rule name, zone, IPS signature and session duration.	Simulation: source=10.44.21.77, destination=10.10.4.20, port=445, action=Allowed, repeated across 30 hosts. This supports lateral movement or internal scanning analysis.
Firewall Logs	Provides network movement and perimeter evidence for High-Severity IPS Block Against Critical Asset. Important fields include source, destination, port, protocol, bytes in/out, action, rule name, zone, IPS signature and session duration.	Simulation: source=10.44.21.77, destination=10.10.4.20, port=445, action=Allowed, repeated across 30 hosts. This supports lateral movement or internal scanning analysis.
Asset Inventory	Identifies the endpoint, server, cloud workload or application component connected to High-Severity IPS Block Against Critical Asset. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Threat Intel	Adds external intelligence context to High-Severity IPS Block Against Critical Asset. IOC, actor, campaign, reputation, first-seen date and confidence help prioritise alerts and connect internal evidence to known malicious infrastructure.	Simulation: destination IP matched TI feed as malware C2 with confidence=High, first_seen=2026-02-10. If internal host communicated successfully, investigate compromise evidence.

TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For High-Severity IPS Block Against Critical Asset, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in High-Severity IPS Block Against Critical Asset. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to High-Severity IPS Block Against Critical Asset. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to High-Severity IPS Block Against Critical Asset. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in High-Severity IPS Block Against Critical Asset was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during High-Severity IPS Block Against Critical Asset. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For High-Severity IPS Block Against Critical Asset, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: High Severity IPS: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Critical Asset: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Internet-Facing Systems: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: High Severity IPS, BB: Critical Asset, BB: Internet-Facing Systems];

FROM IPS Logs, Firewall Logs, Asset Inventory

WHERE TimeGenerated >= now() - lookback

AND event_matches('High-Severity IPS Block Against Critical Asset')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - High-Severity IPS Block Against Critical Asset
Incident Name	Possible High-Severity IPS Block Against Critical Asset Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Network, Perimeter and Threat Intelligence

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible High-Severity IPS Block Against Critical Asset Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.

- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 13:18:00	IPS Logs	user1086@example.local	WS-2086	203.0.113.103	Initial signal	Event indicates high-severity ips block against critical asset.
2026-05-18 13:20:00	Firewall Logs	user1086@example.local	WS-2086	203.0.113.103	Context signal	Entity context matched BB: High Severity IPS.
2026-05-18 13:25:00	Asset Inventory	user1086@example.local	WS-2086	10.20.26.197	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 13:28:00	SIEM Correlation	user1086@example.local	WS-2086	203.0.113.103	Rule matched	Correlation matched building blocks: BB: High Severity IPS, BB: Critical Asset.
2026-05-18 13:36:00	SOC Case Record	user1086@example.local	WS-2086	203.0.113.103	Incident created	Incident created for High-Severity IPS Block Against Critical Asset with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Block or rate-limit malicious source where justified, rotate exposed tokens and validate application-side impact.
- Coordinate with application, network and infrastructure teams for evidence and containment.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.

- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: High Severity IPS, BB: Critical Asset, BB: Internet-Facing Systems.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 087: Sensitive File Uploaded to External Storage

Category	Data Leakage, Insider Risk and AI Security
MITRE ATT&CK Mapping	T1048 Exfiltration Over Alternative Protocol; T1537 Transfer Data to Cloud Account
Detection Objective	Detect and investigate sensitive file uploaded to external storage using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	DLP Logs, Proxy Logs, CASB, Endpoint File Events
Recommended Building Blocks	BB: Sensitive Data Pattern, BB: External Storage Domains, BB: Corporate Approved Cloud
Recommended Alert Name	2026 - Sensitive File Uploaded to External Storage
Recommended Incident Name	Possible Sensitive File Uploaded to External Storage Investigation

1. Scenario

A user uploads a file containing customer or confidential data to personal cloud storage.

Data-centric detection is critical because many incidents are now focused on data theft, unauthorised sharing, shadow AI usage and insider-like behaviour rather than only malware execution.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1048 Exfiltration Over Alternative Protocol; T1537 Transfer Data to Cloud Account. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
DLP Logs	Shows data protection evidence for Sensitive File Uploaded to External Storage. DLP/CASB telemetry confirms whether sensitive data was uploaded, shared, pasted, copied, synchronised or transferred to external services.	Simulation: DLP policy=Customer PII, destination=personal-cloud.example, action=AllowedWithAlert, file=Customer_List_2026.xlsx. This is evidence for possible data leakage.
Proxy Logs	Shows outbound web access linked to Sensitive File Uploaded to External Storage, including URL, domain, category, upload/download size, HTTP method, user-agent, action and reputation. It helps confirm phishing clicks, payload downloads, C2, exfiltration or unapproved AI/cloud tool usage.	Simulation: user=farah.finance, url=hxxps://unknown-file-share.example/upload, bytes_out=524288000, action=Allowed. If this occurs after sensitive file access, investigate possible exfiltration.
CASB	Shows data protection evidence for Sensitive File Uploaded to External Storage. DLP/CASB telemetry confirms whether sensitive data was uploaded, shared, pasted, copied, synchronised or transferred to external services.	Simulation: DLP policy=Customer PII, destination=personal-cloud.example, action=AllowedWithAlert, file=Customer_List_2026.xlsx. This is evidence for possible data leakage.
Endpoint File Events	Provides endpoint execution and host-level evidence for Sensitive File Uploaded to External Storage. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device	Simulation: parent=explorer.exe, child=powershell.exe, command='-EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution

	isolation status and sensor health.	rather than only file delivery.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Sensitive File Uploaded to External Storage, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Sensitive File Uploaded to External Storage. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Sensitive File Uploaded to External Storage. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Sensitive File Uploaded to External Storage. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Sensitive File Uploaded to External Storage was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Sensitive File Uploaded to External Storage. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Sensitive File Uploaded to External Storage, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Sensitive Data Pattern: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: External Storage Domains: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Corporate Approved Cloud: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Sensitive Data Pattern, BB: External Storage Domains, BB: Corporate Approved Cloud];

FROM DLP Logs, Proxy Logs, CASB

WHERE TimeGenerated >= now() - lookback

AND event_matches('Sensitive File Uploaded to External Storage')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Sensitive File Uploaded to External Storage
Incident Name	Possible Sensitive File Uploaded to External Storage Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Data Leakage, Insider Risk and AI Security

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Sensitive File Uploaded to External Storage Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 13:21:00	DLP Logs	user1087@example.local	WS-2087	203.0.113.110	Initial signal	Event indicates sensitive file uploaded to external storage.
2026-05-18 13:23:00	Proxy Logs	user1087@example.local	WS-2087	203.0.113.110	Context signal	Entity context matched BB: Sensitive Data Pattern.
2026-05-18 13:28:00	CASB	user1087@example.local	WS-2087	10.20.27.208	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 13:31:00	SIEM Correlation	user1087@example.local	WS-2087	203.0.113.110	Rule matched	Correlation matched building blocks: BB: Sensitive Data Pattern, BB: External Storage Domains.
2026-05-18 13:39:00	SOC Case Record	user1087@example.local	WS-2087	203.0.113.110	Incident created	Incident created for Sensitive File Uploaded to External Storage with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- What data was accessed, exported, downloaded or uploaded?
- Is customer, confidential, regulated or long-lived sensitive data involved?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Identify exactly what data was accessed or transferred and whether regulatory, privacy, customer or management notification review is required.
- Preserve DLP evidence, file access logs, destination details and user confirmation.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Sensitive Data Pattern, BB: External Storage Domains, BB: Corporate Approved Cloud.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 088: Sensitive Data Sent to Unapproved GenAI Tool

Category	Data Leakage, Insider Risk and AI Security
MITRE ATT&CK Mapping	T1048 Exfiltration Over Alternative Protocol
Detection Objective	Detect and investigate sensitive data sent to unapproved genai tool using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Proxy Logs, DLP, CASB, Browser Telemetry
Recommended Building Blocks	BB: Unapproved AI Domains, BB: Sensitive Data Pattern, BB: User Department Risk
Recommended Alert Name	2026 - Sensitive Data Sent to Unapproved GenAI Tool
Recommended Incident Name	Possible Sensitive Data Sent to Unapproved GenAI Tool Investigation

1. Scenario

An employee pastes or uploads regulated data to a public AI chatbot from a corporate device.

Data-centric detection is critical because many incidents are now focused on data theft, unauthorised sharing, shadow AI usage and insider-like behaviour rather than only malware execution.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1048 Exfiltration Over Alternative Protocol. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Proxy Logs	Shows outbound web access linked to Sensitive Data Sent to Unapproved GenAI Tool, including URL, domain, category, upload/download size, HTTP method, user-agent, action and reputation. It helps confirm phishing clicks, payload downloads, C2, exfiltration or unapproved AI/cloud tool usage.	Simulation: user=farah.finance, url=hxxps://unknown-file-share.example/upload, bytes_out=524288000, action=Allowed. If this occurs after sensitive file access, investigate possible exfiltration.
DLP	Shows data protection evidence for Sensitive Data Sent to Unapproved GenAI Tool. DLP/CASB telemetry confirms whether sensitive data was uploaded, shared, pasted, copied, synchronised or transferred to external services.	Simulation: DLP policy=Customer PII, destination=personal-cloud.example, action=AllowedWithAlert, file=Customer_List_2026.xlsx. This is evidence for possible data leakage.
CASB	Shows data protection evidence for Sensitive Data Sent to Unapproved GenAI Tool. DLP/CASB telemetry confirms whether sensitive data was uploaded, shared, pasted, copied, synchronised or transferred to external services.	Simulation: DLP policy=Customer PII, destination=personal-cloud.example, action=AllowedWithAlert, file=Customer_List_2026.xlsx. This is evidence for possible data leakage.
Browser Telemetry	Provides supporting evidence for Sensitive Data Sent to Unapproved GenAI Tool. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Sensitive Data Sent to Unapproved GenAI Tool. If the evidence is incomplete, the analyst should request the missing log source before

	in the same timeline.	closure.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Sensitive Data Sent to Unapproved GenAI Tool, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Sensitive Data Sent to Unapproved GenAI Tool. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Sensitive Data Sent to Unapproved GenAI Tool. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Sensitive Data Sent to Unapproved GenAI Tool. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Sensitive Data Sent to Unapproved GenAI Tool was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Sensitive Data Sent to Unapproved GenAI Tool. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Sensitive Data Sent to Unapproved GenAI Tool, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Unapproved AI Domains: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Sensitive Data Pattern: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: User Department Risk: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Unapproved AI Domains, BB: Sensitive Data Pattern, BB: User Department Risk];

FROM Proxy Logs, DLP, CASB

WHERE TimeGenerated >= now() - lookback

AND event_matches('Sensitive Data Sent to Unapproved GenAI Tool')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Sensitive Data Sent to Unapproved GenAI Tool
Incident Name	Possible Sensitive Data Sent to Unapproved GenAI Tool Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Data Leakage, Insider Risk and AI Security

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Sensitive Data Sent to Unapproved GenAI Tool Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.

- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 13:24:00	Proxy Logs	user1088@example.local	WS-2088	203.0.113.117	Initial signal	Event indicates sensitive data sent to unapproved genai tool.
2026-05-18 13:26:00	DLP	user1088@example.local	WS-2088	203.0.113.117	Context signal	Entity context matched BB: Unapproved AI Domains.
2026-05-18 13:31:00	CASB	user1088@example.local	WS-2088	10.20.28.219	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 13:34:00	SIEM Correlation	user1088@example.local	WS-2088	203.0.113.117	Rule matched	Correlation matched building blocks: BB: Unapproved AI Domains, BB: Sensitive Data Pattern.
2026-05-18 13:42:00	SOC Case Record	user1088@example.local	WS-2088	203.0.113.117	Incident created	Incident created for Sensitive Data Sent to Unapproved GenAI Tool with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- What data was accessed, exported, downloaded or uploaded?
- Is customer, confidential, regulated or long-lived sensitive data involved?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Identify exactly what data was accessed or transferred and whether regulatory, privacy, customer or management notification review is required.
- Preserve DLP evidence, file access logs, destination details and user confirmation.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Unapproved AI Domains, BB: Sensitive Data Pattern, BB: User Department Risk.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 089: Source Code Uploaded to AI Platform

Category	Data Leakage, Insider Risk and AI Security
MITRE ATT&CK Mapping	T1048 Exfiltration Over Alternative Protocol
Detection Objective	Detect and investigate source code uploaded to ai platform using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	DLP, Proxy Logs, Developer Endpoint Logs
Recommended Building Blocks	BB: Source Code Pattern, BB: AI Domains, BB: Developer Group
Recommended Alert Name	2026 - Source Code Uploaded to AI Platform
Recommended Incident Name	Possible Source Code Uploaded to AI Platform Investigation

1. Scenario

A developer submits application source code to an unapproved AI service for troubleshooting.

Data-centric detection is critical because many incidents are now focused on data theft, unauthorised sharing, shadow AI usage and insider-like behaviour rather than only malware execution.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1048 Exfiltration Over Alternative Protocol. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
DLP	Shows data protection evidence for Source Code Uploaded to AI Platform. DLP/CASB telemetry confirms whether sensitive data was uploaded, shared, pasted, copied, synchronised or transferred to external services.	Simulation: DLP policy=Customer PII, destination=personal-cloud.example, action=AllowedWithAlert, file=Customer_List_2026.xlsx. This is evidence for possible data leakage.
Proxy Logs	Shows outbound web access linked to Source Code Uploaded to AI Platform, including URL, domain, category, upload/download size, HTTP method, user-agent, action and reputation. It helps confirm phishing clicks, payload downloads, C2, exfiltration or unapproved AI/cloud tool usage.	Simulation: user=farah.finance, url=hxxps://unknown-file-share.example/upload, bytes_out=524288000, action=Allowed. If this occurs after sensitive file access, investigate possible exfiltration.
Developer Endpoint Logs	Provides endpoint execution and host-level evidence for Source Code Uploaded to AI Platform. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device isolation status and sensor health.	Simulation: parent=explorer.exe, child=powershell.exe, command='-EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution rather than only file delivery.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Source Code Uploaded to AI Platform, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.

	timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Source Code Uploaded to AI Platform. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Source Code Uploaded to AI Platform. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Source Code Uploaded to AI Platform. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Source Code Uploaded to AI Platform was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Source Code Uploaded to AI Platform. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Source Code Uploaded to AI Platform, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Source Code Pattern: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: AI Domains: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Developer Group: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Source Code Pattern, BB: AI Domains, BB: Developer Group];

FROM DLP, Proxy Logs, Developer Endpoint Logs

WHERE TimeGenerated >= now() - lookback

AND event_matches('Source Code Uploaded to AI Platform')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Source Code Uploaded to AI Platform
Incident Name	Possible Source Code Uploaded to AI Platform Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Data Leakage, Insider Risk and AI Security

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Source Code Uploaded to AI Platform Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18	DLP	user1089@example.local	WS-2089	203.0.113.124	Initial signal	Event indicates source code uploaded to ai

13:27:00						platform.
2026-05-18 13:29:00	Proxy Logs	user1089@example.local	WS-2089	203.0.113.124	Context signal	Entity context matched BB: Source Code Pattern.
2026-05-18 13:34:00	Developer Endpoint Logs	user1089@example.local	WS-2089	10.20.29.230	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 13:37:00	SIEM Correlation	user1089@example.local	WS-2089	203.0.113.124	Rule matched	Correlation matched building blocks: BB: Source Code Pattern, BB: AI Domains.
2026-05-18 13:45:00	SOC Case Record	user1089@example.local	WS-2089	203.0.113.124	Incident created	Incident created for Source Code Uploaded to AI Platform with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- What data was accessed, exported, downloaded or uploaded?
- Is customer, confidential, regulated or long-lived sensitive data involved?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Identify exactly what data was accessed or transferred and whether regulatory, privacy, customer or management notification review is required.
- Preserve DLP evidence, file access logs, destination details and user confirmation.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Source Code Pattern, BB: AI Domains, BB: Developer Group.

- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 090: Mass SharePoint Download by User

Category	Data Leakage, Insider Risk and AI Security
MITRE ATT&CK Mapping	T1530 Data from Cloud Storage
Detection Objective	Detect and investigate mass sharepoint download by user using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	SharePoint Audit, M365 Audit, CASB
Recommended Building Blocks	BB: Download Volume Baseline, BB: Sensitive Sites, BB: Risky Sign-in
Recommended Alert Name	2026 - Mass SharePoint Download by User
Recommended Incident Name	Possible Mass SharePoint Download by User Investigation

1. Scenario

A user downloads thousands of files from a sensitive site within a short time.

Data-centric detection is critical because many incidents are now focused on data theft, unauthorised sharing, shadow AI usage and insider-like behaviour rather than only malware execution.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1530 Data from Cloud Storage. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
SharePoint Audit	Provides post-authentication activity for Mass SharePoint Download by User. It shows what the user or application did after login, such as mailbox access, inbox rule creation, file download, file sharing, Teams activity, OneDrive sync, SharePoint access and administrative changes.	Simulation: 09:20 MailItemsAccessed from Exchange Online; 09:24 New-InboxRule forwards mail externally; 09:32 FileDownloaded from /Finance/Budget2026.xlsx. This converts a login anomaly into a possible account compromise or data exposure incident.
M365 Audit	Provides post-authentication activity for Mass SharePoint Download by User. It shows what the user or application did after login, such as mailbox access, inbox rule creation, file download, file sharing, Teams activity, OneDrive sync, SharePoint access and administrative changes.	Simulation: 09:20 MailItemsAccessed from Exchange Online; 09:24 New-InboxRule forwards mail externally; 09:32 FileDownloaded from /Finance/Budget2026.xlsx. This converts a login anomaly into a possible account compromise or data exposure incident.
CASB	Shows data protection evidence for Mass SharePoint Download by User. DLP/CASB telemetry confirms whether sensitive data was uploaded, shared, pasted, copied, synchronised or transferred to external services.	Simulation: DLP policy=Customer PII, destination=personal-cloud.example, action=AllowedWithAlert, file=Customer_List_2026.xlsx. This is evidence for possible data leakage.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Mass SharePoint Download by User, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.

	decide whether the activity is an isolated event or part of a chained incident.	
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Mass SharePoint Download by User. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Mass SharePoint Download by User. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Mass SharePoint Download by User. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Mass SharePoint Download by User was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Mass SharePoint Download by User. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Mass SharePoint Download by User, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Download Volume Baseline: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Sensitive Sites: maintain the list owner, update frequency, source of truth and exception approval process.

- BB: Risky Sign-in: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Download Volume Baseline, BB: Sensitive Sites, BB: Risky Sign-in];

FROM SharePoint Audit, M365 Audit, CASB

WHERE TimeGenerated >= now() - lookback

AND event_matches('Mass SharePoint Download by User')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Mass SharePoint Download by User
Incident Name	Possible Mass SharePoint Download by User Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Data Leakage, Insider Risk and AI Security

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Mass SharePoint Download by User Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-	SharePoint	user1090@example.local	WS-	203.0.113.131	Initial	Event indicates mass

18 13:30:00	Audit		2090		signal	sharepoint download by user.
2026-05-18 13:32:00	M365 Audit	user1090@example.local	WS-2090	203.0.113.131	Context signal	Entity context matched BB: Download Volume Baseline.
2026-05-18 13:37:00	CASB	user1090@example.local	WS-2090	10.20.0.241	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 13:40:00	SIEM Correlation	user1090@example.local	WS-2090	203.0.113.131	Rule matched	Correlation matched building blocks: BB: Download Volume Baseline, BB: Sensitive Sites.
2026-05-18 13:48:00	SOC Case Record	user1090@example.local	WS-2090	203.0.113.131	Incident created	Incident created for Mass SharePoint Download by User with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- What data was accessed, exported, downloaded or uploaded?
- Is customer, confidential, regulated or long-lived sensitive data involved?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Identify exactly what data was accessed or transferred and whether regulatory, privacy, customer or management notification review is required.
- Preserve DLP evidence, file access logs, destination details and user confirmation.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Download Volume Baseline, BB: Sensitive Sites, BB: Risky Sign-in.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 091: Sensitive Data Copied to USB

Category	Data Leakage, Insider Risk and AI Security
MITRE ATT&CK Mapping	T1052 Exfiltration Over Physical Medium
Detection Objective	Detect and investigate sensitive data copied to usb using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	EDR Device Control, Windows Removable Storage Logs, DLP
Recommended Building Blocks	BB: Removable Media Inserted, BB: Sensitive File Copy, BB: Approved USB Devices
Recommended Alert Name	2026 - Sensitive Data Copied to USB
Recommended Incident Name	Possible Sensitive Data Copied to USB Investigation

1. Scenario

A user copies confidential documents to removable media.

Data-centric detection is critical because many incidents are now focused on data theft, unauthorised sharing, shadow AI usage and insider-like behaviour rather than only malware execution.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1052 Exfiltration Over Physical Medium. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
EDR Device Control	Identifies the endpoint, server, cloud workload or application component connected to Sensitive Data Copied to USB. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Windows Removable Storage Logs	Provides supporting evidence for Sensitive Data Copied to USB. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Sensitive Data Copied to USB. If the evidence is incomplete, the analyst should request the missing log source before closure.
DLP	Shows data protection evidence for Sensitive Data Copied to USB. DLP/CASB telemetry confirms whether sensitive data was uploaded, shared, pasted, copied, synchronised or transferred to external services.	Simulation: DLP policy=Customer PII, destination=personal-cloud.example, action=AllowedWithAlert, file=Customer_List_2026.xlsx. This is evidence for possible data leakage.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Sensitive Data Copied to USB, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.

	an isolated event or part of a chained incident.	
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Sensitive Data Copied to USB. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Sensitive Data Copied to USB. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Sensitive Data Copied to USB. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Sensitive Data Copied to USB was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Sensitive Data Copied to USB. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Sensitive Data Copied to USB, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Removable Media Inserted: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Sensitive File Copy: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Approved USB Devices: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Removable Media Inserted, BB: Sensitive File Copy, BB: Approved USB Devices];

FROM EDR Device Control, Windows Removable Storage Logs, DLP

WHERE TimeGenerated >= now() - lookback

AND event_matches('Sensitive Data Copied to USB')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Sensitive Data Copied to USB
Incident Name	Possible Sensitive Data Copied to USB Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Data Leakage, Insider Risk and AI Security

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Sensitive Data Copied to USB Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 13:33:00	EDR Device Control	user1091@example.local	WS-2091	203.0.113.138	Initial signal	Event indicates sensitive data copied to usb.

2026-05-18 13:35:00	Windows Removable Storage Logs	user1091@example.local	WS-2091	203.0.113.138	Context signal	Entity context matched BB: Removable Media Inserted.
2026-05-18 13:40:00	DLP	user1091@example.local	WS-2091	10.20.1.2	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 13:43:00	SIEM Correlation	user1091@example.local	WS-2091	203.0.113.138	Rule matched	Correlation matched building blocks: BB: Removable Media Inserted, BB: Sensitive File Copy.
2026-05-18 13:51:00	SOC Case Record	user1091@example.local	WS-2091	203.0.113.138	Incident created	Incident created for Sensitive Data Copied to USB with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- What data was accessed, exported, downloaded or uploaded?
- Is customer, confidential, regulated or long-lived sensitive data involved?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Identify exactly what data was accessed or transferred and whether regulatory, privacy, customer or management notification review is required.
- Preserve DLP evidence, file access logs, destination details and user confirmation.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Removable Media Inserted, BB: Sensitive File Copy, BB: Approved USB Devices.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.

- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 092: Data Access Spike Before User Exit

Category	Data Leakage, Insider Risk and AI Security
MITRE ATT&CK Mapping	T1005 Data from Local System; T1039 Data from Network Shared Drive
Detection Objective	Detect and investigate data access spike before user exit using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	HR Feed, File Server Audit, SharePoint Audit, DLP
Recommended Building Blocks	BB: Resigned Users, BB: Sensitive Repositories, BB: Baseline Access Volume
Recommended Alert Name	2026 - Data Access Spike Before User Exit
Recommended Incident Name	Possible Data Access Spike Before User Exit Investigation

1. Scenario

A resigning employee accesses and downloads far more documents than normal.

Data-centric detection is critical because many incidents are now focused on data theft, unauthorised sharing, shadow AI usage and insider-like behaviour rather than only malware execution.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1005 Data from Local System; T1039 Data from Network Shared Drive. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
HR Feed	Provides workforce context for Data Access Spike Before User Exit. HR data such as department, role, resignation status, transfer, leave or termination date helps support insider risk and access review decisions.	Simulation: user has resignation date in 7 days and downloads abnormal volume from sensitive repository. This does not prove misuse but justifies investigation and management validation.
File Server Audit	Provides supporting evidence for Data Access Spike Before User Exit. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Data Access Spike Before User Exit. If the evidence is incomplete, the analyst should request the missing log source before closure.
SharePoint Audit	Provides post-authentication activity for Data Access Spike Before User Exit. It shows what the user or application did after login, such as mailbox access, inbox rule creation, file download, file sharing, Teams activity, OneDrive sync, SharePoint access and administrative changes.	Simulation: 09:20 MailItemsAccessed from Exchange Online; 09:24 New-InboxRule forwards mail externally; 09:32 FileDownloaded from /Finance/Budget2026.xlsx. This converts a login anomaly into a possible account compromise or data exposure incident.
DLP	Shows data protection evidence for Data Access Spike Before User Exit. DLP/CASB telemetry confirms whether sensitive data was uploaded, shared, pasted, copied, synchronised or transferred to external services.	Simulation: DLP policy=Customer PII, destination=personal-cloud.example, action=AllowedWithAlert, file=Customer_List_2026.xlsx. This is evidence for possible data leakage.

TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Data Access Spike Before User Exit, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Data Access Spike Before User Exit. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Data Access Spike Before User Exit. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Data Access Spike Before User Exit. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Data Access Spike Before User Exit was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Data Access Spike Before User Exit. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Data Access Spike Before User Exit, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Resigned Users: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Sensitive Repositories: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Baseline Access Volume: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Resigned Users, BB: Sensitive Repositories, BB: Baseline Access Volume];

FROM HR Feed, File Server Audit, SharePoint Audit

WHERE TimeGenerated >= now() - lookback

AND event_matches('Data Access Spike Before User Exit')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Data Access Spike Before User Exit
Incident Name	Possible Data Access Spike Before User Exit Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Data Leakage, Insider Risk and AI Security

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Data Access Spike Before User Exit Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.

- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 13:36:00	HR Feed	user1092@example.local	WS-2092	203.0.113.145	Initial signal	Event indicates data access spike before user exit.
2026-05-18 13:38:00	File Server Audit	user1092@example.local	WS-2092	203.0.113.145	Context signal	Entity context matched BB: Resigned Users.
2026-05-18 13:43:00	SharePoint Audit	user1092@example.local	WS-2092	10.20.2.13	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 13:46:00	SIEM Correlation	user1092@example.local	WS-2092	203.0.113.145	Rule matched	Correlation matched building blocks: BB: Resigned Users, BB: Sensitive Repositories.
2026-05-18 13:54:00	SOC Case Record	user1092@example.local	WS-2092	203.0.113.145	Incident created	Incident created for Data Access Spike Before User Exit with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- What data was accessed, exported, downloaded or uploaded?
- Is customer, confidential, regulated or long-lived sensitive data involved?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Identify exactly what data was accessed or transferred and whether regulatory, privacy, customer or management notification review is required.
- Preserve DLP evidence, file access logs, destination details and user confirmation.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.

- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Resigned Users, BB: Sensitive Repositories, BB: Baseline Access Volume.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 093: Privileged User Exports Sensitive Report

Category	Data Leakage, Insider Risk and AI Security
MITRE ATT&CK Mapping	T1005 Data from Local System; T1530 Data from Cloud Storage
Detection Objective	Detect and investigate privileged user exports sensitive report using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Application Logs, Database Audit, PAM Logs
Recommended Building Blocks	BB: Privileged Users, BB: Sensitive Export Functions, BB: Approved Report Requests
Recommended Alert Name	2026 - Privileged User Exports Sensitive Report
Recommended Incident Name	Possible Privileged User Exports Sensitive Report Investigation

1. Scenario

An administrator exports a full customer or employee report outside expected operational need.

Data-centric detection is critical because many incidents are now focused on data theft, unauthorised sharing, shadow AI usage and insider-like behaviour rather than only malware execution.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1005 Data from Local System; T1530 Data from Cloud Storage. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Application Logs	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Privileged User Exports Sensitive Report. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
Database Audit	Provides supporting evidence for Privileged User Exports Sensitive Report. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Privileged User Exports Sensitive Report. If the evidence is incomplete, the analyst should request the missing log source before closure.
PAM Logs	Provides privileged session evidence for Privileged User Exports Sensitive Report. It links admin activity to approved access requests, password checkouts, session recordings, commands executed, target systems and vendor/user identity.	Simulation: admin checked out domain admin password at 02:11 with no matching change ticket, then logged into SRV-DC01. This requires privileged access validation.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Privileged User Exports Sensitive Report, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.

	decide whether the activity is an isolated event or part of a chained incident.	
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Privileged User Exports Sensitive Report. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Privileged User Exports Sensitive Report. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Privileged User Exports Sensitive Report. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Privileged User Exports Sensitive Report was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Privileged User Exports Sensitive Report. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Privileged User Exports Sensitive Report, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Privileged Users: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Sensitive Export Functions: maintain the list owner, update frequency, source of truth and exception approval process.

- BB: Approved Report Requests: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Privileged Users, BB: Sensitive Export Functions, BB: Approved Report Requests];

FROM Application Logs, Database Audit, PAM Logs

WHERE TimeGenerated >= now() - lookback

AND event_matches('Privileged User Exports Sensitive Report')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Privileged User Exports Sensitive Report
Incident Name	Possible Privileged User Exports Sensitive Report Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Data Leakage, Insider Risk and AI Security

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Privileged User Exports Sensitive Report Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 13:39:00	Application Logs	user1093@example.local	WS-2093	203.0.113.152	Initial signal	Event indicates privileged user exports sensitive report.
2026-05-18 13:41:00	Database Audit	user1093@example.local	WS-2093	203.0.113.152	Context signal	Entity context matched BB: Privileged Users.
2026-05-18 13:46:00	PAM Logs	user1093@example.local	WS-2093	10.20.3.24	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 13:49:00	SIEM Correlation	user1093@example.local	WS-2093	203.0.113.152	Rule matched	Correlation matched building blocks: BB: Privileged Users, BB: Sensitive Export Functions.
2026-05-18 13:57:00	SOC Case Record	user1093@example.local	WS-2093	203.0.113.152	Incident created	Incident created for Privileged User Exports Sensitive Report with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- What data was accessed, exported, downloaded or uploaded?
- Is customer, confidential, regulated or long-lived sensitive data involved?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Identify exactly what data was accessed or transferred and whether regulatory, privacy, customer or management notification review is required.
- Preserve DLP evidence, file access logs, destination details and user confirmation.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Privileged Users, BB: Sensitive Export Functions, BB: Approved Report Requests.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 094: Email with Sensitive Attachment Sent to Personal Domain

Category	Data Leakage, Insider Risk and AI Security
MITRE ATT&CK Mapping	T1537 Transfer Data to Cloud Account
Detection Objective	Detect and investigate email with sensitive attachment sent to personal domain using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Email DLP, Exchange Message Trace, M365 Audit
Recommended Building Blocks	BB: Personal Email Domains, BB: Sensitive Attachment Pattern, BB: Approved Exceptions
Recommended Alert Name	2026 - Email with Sensitive Attachment Sent to Personal Domain
Recommended Incident Name	Possible Email with Sensitive Attachment Sent to Personal Domain Investigation

1. Scenario

A user sends a spreadsheet containing confidential information to a personal email address.

Data-centric detection is critical because many incidents are now focused on data theft, unauthorised sharing, shadow AI usage and insider-like behaviour rather than only malware execution.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1537 Transfer Data to Cloud Account. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Email DLP	Shows data protection evidence for Email with Sensitive Attachment Sent to Personal Domain. DLP/CASB telemetry confirms whether sensitive data was uploaded, shared, pasted, copied, synchronised or transferred to external services.	Simulation: DLP policy=Customer PII, destination=personal-cloud.example, action=AllowedWithAlert, file=Customer_List_2026.xlsx. This is evidence for possible data leakage.
Exchange Message Trace	Provides post-authentication activity for Email with Sensitive Attachment Sent to Personal Domain. It shows what the user or application did after login, such as mailbox access, inbox rule creation, file download, file sharing, Teams activity, OneDrive sync, SharePoint access and administrative changes.	Simulation: 09:20 MailItemsAccessed from Exchange Online; 09:24 New-InboxRule forwards mail externally; 09:32 FileDownloaded from /Finance/Budget2026.xlsx. This converts a login anomaly into a possible account compromise or data exposure incident.
M365 Audit	Provides post-authentication activity for Email with Sensitive Attachment Sent to Personal Domain. It shows what the user or application did after login, such as mailbox access, inbox rule creation, file download, file sharing, Teams activity, OneDrive sync, SharePoint access and administrative changes.	Simulation: 09:20 MailItemsAccessed from Exchange Online; 09:24 New-InboxRule forwards mail externally; 09:32 FileDownloaded from /Finance/Budget2026.xlsx. This converts a login anomaly into a possible account compromise or data exposure incident.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Email with Sensitive Attachment Sent to Personal Domain, the	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The

	analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	close timing increases investigation confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Email with Sensitive Attachment Sent to Personal Domain. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Email with Sensitive Attachment Sent to Personal Domain. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Email with Sensitive Attachment Sent to Personal Domain. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Email with Sensitive Attachment Sent to Personal Domain was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Email with Sensitive Attachment Sent to Personal Domain. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Email with Sensitive Attachment Sent to Personal Domain, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Personal Email Domains: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Sensitive Attachment Pattern: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Approved Exceptions: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Personal Email Domains, BB: Sensitive Attachment Pattern, BB: Approved Exceptions];

FROM Email DLP, Exchange Message Trace, M365 Audit

WHERE TimeGenerated >= now() - lookback

AND event_matches('Email with Sensitive Attachment Sent to Personal Domain')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Email with Sensitive Attachment Sent to Personal Domain
Incident Name	Possible Email with Sensitive Attachment Sent to Personal Domain Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Data Leakage, Insider Risk and AI Security

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Email with Sensitive Attachment Sent to Personal Domain Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 13:42:00	Email DLP	user1094@example.local	WS-2094	203.0.113.159	Initial signal	Event indicates email with sensitive attachment sent to personal domain.
2026-05-18 13:44:00	Exchange Message Trace	user1094@example.local	WS-2094	203.0.113.159	Context signal	Entity context matched BB: Personal Email Domains.
2026-05-18 13:49:00	M365 Audit	user1094@example.local	WS-2094	10.20.4.35	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 13:52:00	SIEM Correlation	user1094@example.local	WS-2094	203.0.113.159	Rule matched	Correlation matched building blocks: BB: Personal Email Domains, BB: Sensitive Attachment Pattern.
2026-05-18 14:00:00	SOC Case Record	user1094@example.local	WS-2094	203.0.113.159	Incident created	Incident created for Email with Sensitive Attachment Sent to Personal Domain with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- What data was accessed, exported, downloaded or uploaded?
- Is customer, confidential, regulated or long-lived sensitive data involved?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Identify exactly what data was accessed or transferred and whether regulatory, privacy, customer or management notification review is required.
- Preserve DLP evidence, file access logs, destination details and user confirmation.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Personal Email Domains, BB: Sensitive Attachment Pattern, BB: Approved Exceptions.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 095: Repeated Access Denied to Restricted Folders

Category	Data Leakage, Insider Risk and AI Security
MITRE ATT&CK Mapping	T1083 File and Directory Discovery; T1039 Data from Network Shared Drive
Detection Objective	Detect and investigate repeated access denied to restricted folders using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	File Server Audit, AD Logs, UEBA
Recommended Building Blocks	BB: Restricted Folder Paths, BB: Access Denied Threshold, BB: Department Role Mapping
Recommended Alert Name	2026 - Repeated Access Denied to Restricted Folders
Recommended Incident Name	Possible Repeated Access Denied to Restricted Folders Investigation

1. Scenario

A user repeatedly attempts to open folders outside their job role.

Data-centric detection is critical because many incidents are now focused on data theft, unauthorised sharing, shadow AI usage and insider-like behaviour rather than only malware execution.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1083 File and Directory Discovery; T1039 Data from Network Shared Drive. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
File Server Audit	Provides supporting evidence for Repeated Access Denied to Restricted Folders. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Repeated Access Denied to Restricted Folders. If the evidence is incomplete, the analyst should request the missing log source before closure.
AD Logs	Provides supporting evidence for Repeated Access Denied to Restricted Folders. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Repeated Access Denied to Restricted Folders. If the evidence is incomplete, the analyst should request the missing log source before closure.
UEBA	Provides supporting evidence for Repeated Access Denied to Restricted Folders. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Repeated Access Denied to Restricted Folders. If the evidence is incomplete, the analyst should request the missing log source before closure.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Repeated Access Denied to Restricted Folders, the analyst must compare the first suspicious event, the confirming event and any follow-on	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation

	activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Repeated Access Denied to Restricted Folders. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Repeated Access Denied to Restricted Folders. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Repeated Access Denied to Restricted Folders. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Repeated Access Denied to Restricted Folders was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Repeated Access Denied to Restricted Folders. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Repeated Access Denied to Restricted Folders, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Restricted Folder Paths: maintain the list owner, update frequency, source of truth and exception approval process.

- BB: Access Denied Threshold: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Department Role Mapping: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Restricted Folder Paths, BB: Access Denied Threshold, BB: Department Role Mapping];

FROM File Server Audit, AD Logs, UEBA

WHERE TimeGenerated >= now() - lookback

AND event_matches('Repeated Access Denied to Restricted Folders')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Repeated Access Denied to Restricted Folders
Incident Name	Possible Repeated Access Denied to Restricted Folders Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Data Leakage, Insider Risk and AI Security

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Repeated Access Denied to Restricted Folders Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 13:45:00	File Server Audit	user1095@example.local	WS-2095	203.0.113.166	Initial signal	Event indicates repeated access denied to restricted folders.
2026-05-18 13:47:00	AD Logs	user1095@example.local	WS-2095	203.0.113.166	Context signal	Entity context matched BB: Restricted Folder Paths.
2026-05-18 13:52:00	UEBA	user1095@example.local	WS-2095	10.20.5.46	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 13:55:00	SIEM Correlation	user1095@example.local	WS-2095	203.0.113.166	Rule matched	Correlation matched building blocks: BB: Restricted Folder Paths, BB: Access Denied Threshold.
2026-05-18 14:03:00	SOC Case Record	user1095@example.local	WS-2095	203.0.113.166	Incident created	Incident created for Repeated Access Denied to Restricted Folders with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- What data was accessed, exported, downloaded or uploaded?
- Is customer, confidential, regulated or long-lived sensitive data involved?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Identify exactly what data was accessed or transferred and whether regulatory, privacy, customer or management notification review is required.
- Preserve DLP evidence, file access logs, destination details and user confirmation.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Restricted Folder Paths, BB: Access Denied Threshold, BB: Department Role Mapping.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 096: Abnormal Sensitive Printing Volume

Category	Data Leakage, Insider Risk and AI Security
MITRE ATT&CK Mapping	T1052 Exfiltration Over Physical Medium
Detection Objective	Detect and investigate abnormal sensitive printing volume using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Print Server Logs, DLP, HR Context
Recommended Building Blocks	BB: Sensitive Print Jobs, BB: Print Volume Baseline, BB: Restricted Printers
Recommended Alert Name	2026 - Abnormal Sensitive Printing Volume
Recommended Incident Name	Possible Abnormal Sensitive Printing Volume Investigation

1. Scenario

A user prints hundreds of pages of sensitive documents outside normal usage.

Data-centric detection is critical because many incidents are now focused on data theft, unauthorised sharing, shadow AI usage and insider-like behaviour rather than only malware execution.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1052 Exfiltration Over Physical Medium. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Print Server Logs	Provides supporting evidence for Abnormal Sensitive Printing Volume. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Abnormal Sensitive Printing Volume. If the evidence is incomplete, the analyst should request the missing log source before closure.
DLP	Shows data protection evidence for Abnormal Sensitive Printing Volume. DLP/CASB telemetry confirms whether sensitive data was uploaded, shared, pasted, copied, synchronised or transferred to external services.	Simulation: DLP policy=Customer PII, destination=personal-cloud.example, action=AllowedWithAlert, file=Customer_List_2026.xlsx. This is evidence for possible data leakage.
HR Context	Provides workforce context for Abnormal Sensitive Printing Volume. HR data such as department, role, resignation status, transfer, leave or termination date helps support insider risk and access review decisions.	Simulation: user has resignation date in 7 days and downloads abnormal volume from sensitive repository. This does not prove misuse but justifies investigation and management validation.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Abnormal Sensitive Printing Volume, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.

	event or part of a chained incident.	
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Abnormal Sensitive Printing Volume. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Abnormal Sensitive Printing Volume. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Abnormal Sensitive Printing Volume. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Abnormal Sensitive Printing Volume was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Abnormal Sensitive Printing Volume. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Abnormal Sensitive Printing Volume, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Sensitive Print Jobs: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Print Volume Baseline: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Restricted Printers: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Sensitive Print Jobs, BB: Print Volume Baseline, BB: Restricted Printers];

FROM Print Server Logs, DLP, HR Context

WHERE TimeGenerated >= now() - lookback

AND event_matches('Abnormal Sensitive Printing Volume')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Abnormal Sensitive Printing Volume
Incident Name	Possible Abnormal Sensitive Printing Volume Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Data Leakage, Insider Risk and AI Security

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Abnormal Sensitive Printing Volume Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 13:48:00	Print Server Logs	user1096@example.local	WS-2096	203.0.113.173	Initial signal	Event indicates abnormal sensitive printing volume.

2026-05-18 13:50:00	DLP	user1096@example.local	WS-2096	203.0.113.173	Context signal	Entity context matched BB: Sensitive Print Jobs.
2026-05-18 13:55:00	HR Context	user1096@example.local	WS-2096	10.20.6.57	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 13:58:00	SIEM Correlation	user1096@example.local	WS-2096	203.0.113.173	Rule matched	Correlation matched building blocks: BB: Sensitive Print Jobs, BB: Print Volume Baseline.
2026-05-18 14:06:00	SOC Case Record	user1096@example.local	WS-2096	203.0.113.173	Incident created	Incident created for Abnormal Sensitive Printing Volume with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?
- What data was accessed, exported, downloaded or uploaded?
- Is customer, confidential, regulated or long-lived sensitive data involved?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.
- Identify exactly what data was accessed or transferred and whether regulatory, privacy, customer or management notification review is required.
- Preserve DLP evidence, file access logs, destination details and user confirmation.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Sensitive Print Jobs, BB: Print Volume Baseline, BB: Restricted Printers.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.

- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 097: Critical Log Source Stops Sending Logs to SIEM

Category	Governance, Control Monitoring and Crypto Readiness
MITRE ATT&CK Mapping	T1562 Impair Defenses
Detection Objective	Detect and investigate critical log source stops sending logs to siem using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	SIEM Health, Log Collector Logs, Asset Inventory
Recommended Building Blocks	BB: Critical Log Sources, BB: No Log Threshold, BB: Maintenance Window
Recommended Alert Name	2026 - Critical Log Source Stops Sending Logs to SIEM
Recommended Incident Name	Possible Critical Log Source Stops Sending Logs to SIEM Investigation

1. Scenario

A firewall, EDR, identity or core application log source goes silent, reducing SOC visibility.

Control monitoring ensures that the SOC can trust its visibility and response capability. Detection rules, log sources, crypto controls and governance evidence must be monitored like security assets.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1562 Impair Defenses. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
SIEM Health	Provides supporting evidence for Critical Log Source Stops Sending Logs to SIEM. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Critical Log Source Stops Sending Logs to SIEM. If the evidence is incomplete, the analyst should request the missing log source before closure.
Log Collector Logs	Provides supporting evidence for Critical Log Source Stops Sending Logs to SIEM. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Critical Log Source Stops Sending Logs to SIEM. If the evidence is incomplete, the analyst should request the missing log source before closure.
Asset Inventory	Identifies the endpoint, server, cloud workload or application component connected to Critical Log Source Stops Sending Logs to SIEM. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Critical Log Source Stops Sending Logs to SIEM, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.

	reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Critical Log Source Stops Sending Logs to SIEM. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Critical Log Source Stops Sending Logs to SIEM. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Critical Log Source Stops Sending Logs to SIEM. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Critical Log Source Stops Sending Logs to SIEM was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Critical Log Source Stops Sending Logs to SIEM. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Critical Log Source Stops Sending Logs to SIEM, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Critical Log Sources: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: No Log Threshold: maintain the list owner, update frequency, source of truth and exception approval process.

- BB: Maintenance Window: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Critical Log Sources, BB: No Log Threshold, BB: Maintenance Window];

FROM SIEM Health, Log Collector Logs, Asset Inventory

WHERE TimeGenerated >= now() - lookback

AND event_matches('Critical Log Source Stops Sending Logs to SIEM')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Critical Log Source Stops Sending Logs to SIEM
Incident Name	Possible Critical Log Source Stops Sending Logs to SIEM Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Governance, Control Monitoring and Crypto Readiness

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Critical Log Source Stops Sending Logs to SIEM Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
------	--------	------	------	-----------	-------	-----------------

2026-05-18 13:51:00	SIEM Health	user1097@example.local	WS-2097	203.0.113.180	Initial signal	Event indicates critical log source stops sending logs to siem.
2026-05-18 13:53:00	Log Collector Logs	user1097@example.local	WS-2097	203.0.113.180	Context signal	Entity context matched BB: Critical Log Sources.
2026-05-18 13:58:00	Asset Inventory	user1097@example.local	WS-2097	10.20.7.68	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 14:01:00	SIEM Correlation	user1097@example.local	WS-2097	203.0.113.180	Rule matched	Correlation matched building blocks: BB: Critical Log Sources, BB: No Log Threshold.
2026-05-18 14:09:00	SOC Case Record	user1097@example.local	WS-2097	203.0.113.180	Incident created	Incident created for Critical Log Source Stops Sending Logs to SIEM with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Critical Log Sources, BB: No Log Threshold, BB: Maintenance Window.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.

- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 098: SIEM Detection Rule Disabled or Modified

Category	Governance, Control Monitoring and Crypto Readiness
MITRE ATT&CK Mapping	T1562 Impair Defenses
Detection Objective	Detect and investigate siem detection rule disabled or modified using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	SIEM Audit Logs, Change Management, SOC Admin Logs
Recommended Building Blocks	BB: Critical Detection Rules, BB: Approved Rule Change, BB: SOC Admin Accounts
Recommended Alert Name	2026 - SIEM Detection Rule Disabled or Modified
Recommended Incident Name	Possible SIEM Detection Rule Disabled or Modified Investigation

1. Scenario

A high-value detection rule is disabled or its threshold is weakened without approval.

Control monitoring ensures that the SOC can trust its visibility and response capability. Detection rules, log sources, crypto controls and governance evidence must be monitored like security assets.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1562 Impair Defenses. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
SIEM Audit Logs	Provides supporting evidence for SIEM Detection Rule Disabled or Modified. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for SIEM Detection Rule Disabled or Modified. If the evidence is incomplete, the analyst should request the missing log source before closure.
Change Management	Provides supporting evidence for SIEM Detection Rule Disabled or Modified. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for SIEM Detection Rule Disabled or Modified. If the evidence is incomplete, the analyst should request the missing log source before closure.
SOC Admin Logs	Provides supporting evidence for SIEM Detection Rule Disabled or Modified. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for SIEM Detection Rule Disabled or Modified. If the evidence is incomplete, the analyst should request the missing log source before closure.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For SIEM Detection Rule Disabled or Modified, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.

	decide whether the activity is an isolated event or part of a chained incident.	
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in SIEM Detection Rule Disabled or Modified. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to SIEM Detection Rule Disabled or Modified. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to SIEM Detection Rule Disabled or Modified. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in SIEM Detection Rule Disabled or Modified was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during SIEM Detection Rule Disabled or Modified. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For SIEM Detection Rule Disabled or Modified, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Critical Detection Rules: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Approved Rule Change: maintain the list owner, update frequency, source of truth and exception approval process.

- BB: SOC Admin Accounts: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Critical Detection Rules, BB: Approved Rule Change, BB: SOC Admin Accounts];

FROM SIEM Audit Logs, Change Management, SOC Admin Logs

WHERE TimeGenerated >= now() - lookback

AND event_matches('SIEM Detection Rule Disabled or Modified')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - SIEM Detection Rule Disabled or Modified
Incident Name	Possible SIEM Detection Rule Disabled or Modified Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Governance, Control Monitoring and Crypto Readiness

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible SIEM Detection Rule Disabled or Modified Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
------	--------	------	------	-----------	-------	-----------------

2026-05-18 13:54:00	SIEM Audit Logs	user1098@example.local	WS-2098	203.0.113.187	Initial signal	Event indicates siem detection rule disabled or modified.
2026-05-18 13:56:00	Change Management	user1098@example.local	WS-2098	203.0.113.187	Context signal	Entity context matched BB: Critical Detection Rules.
2026-05-18 14:01:00	SOC Admin Logs	user1098@example.local	WS-2098	10.20.8.79	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 14:04:00	SIEM Correlation	user1098@example.local	WS-2098	203.0.113.187	Rule matched	Correlation matched building blocks: BB: Critical Detection Rules, BB: Approved Rule Change.
2026-05-18 14:12:00	SOC Case Record	user1098@example.local	WS-2098	203.0.113.187	Incident created	Incident created for SIEM Detection Rule Disabled or Modified with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Critical Detection Rules, BB: Approved Rule Change, BB: SOC Admin Accounts.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.

- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 099: Private Key or Certificate Exported Unexpectedly

Category	Governance, Control Monitoring and Crypto Readiness
MITRE ATT&CK Mapping	T1552 Unsecured Credentials
Detection Objective	Detect and investigate private key or certificate exported unexpectedly using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Certificate Management Logs, Windows Security Logs, EDR File Events
Recommended Building Blocks	BB: Private Key Paths, BB: Certificate Export Events, BB: Approved PKI Admins
Recommended Alert Name	2026 - Private Key or Certificate Exported Unexpectedly
Recommended Incident Name	Possible Private Key or Certificate Exported Unexpectedly Investigation

1. Scenario

A private certificate key is exported from a sensitive system outside an approved PKI operation.

Control monitoring ensures that the SOC can trust its visibility and response capability. Detection rules, log sources, crypto controls and governance evidence must be monitored like security assets.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1552 Unsecured Credentials. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Certificate Management Logs	Adds external intelligence context to Private Key or Certificate Exported Unexpectedly. IOC, actor, campaign, reputation, first-seen date and confidence help prioritise alerts and connect internal evidence to known malicious infrastructure.	Simulation: destination IP matched TI feed as malware C2 with confidence=High, first_seen=2026-02-10. If internal host communicated successfully, investigate compromise evidence.
Windows Security Logs	Provides on-premise identity and Windows authentication evidence for Private Key or Certificate Exported Unexpectedly. Useful fields include Event ID 4624, 4625, 4672, 4720, 4728, 4732, 4768, 4769, 4771, logon type, source workstation, target account and privilege assignment.	Simulation: EventID=4625 repeated failures from WS-0441, followed by EventID=4624 successful logon type 10 to SRV-FILE01. If EventID=4672 also appears, the account received privileged logon rights.
EDR File Events	Provides endpoint execution and host-level evidence for Private Key or Certificate Exported Unexpectedly. Key fields include process name, command line, parent process, file hash, user context, network connection, detection action, device isolation status and sensor health.	Simulation: parent=explorer.exe, child=powershell.exe, command='-EncodedCommand ...', destination=api.telegram.org, action=Allowed. This confirms execution rather than only file delivery.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Private Key or Certificate Exported Unexpectedly, the analyst must compare the first suspicious	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation

	event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Private Key or Certificate Exported Unexpectedly. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Private Key or Certificate Exported Unexpectedly. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Private Key or Certificate Exported Unexpectedly. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Private Key or Certificate Exported Unexpectedly was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Private Key or Certificate Exported Unexpectedly. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Private Key or Certificate Exported Unexpectedly, do not review the telemetry as isolated rows. Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Private Key Paths: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Certificate Export Events: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Approved PKI Admins: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Private Key Paths, BB: Certificate Export Events, BB: Approved PKI Admins];

FROM Certificate Management Logs, Windows Security Logs, EDR File Events

WHERE TimeGenerated >= now() - lookback

AND event_matches('Private Key or Certificate Exported Unexpectedly')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Private Key or Certificate Exported Unexpectedly
Incident Name	Possible Private Key or Certificate Exported Unexpectedly Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Governance, Control Monitoring and Crypto Readiness

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Private Key or Certificate Exported Unexpectedly Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.

- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 13:57:00	Certificate Management Logs	user1099@example.local	WS-2099	203.0.113.194	Initial signal	Event indicates private key or certificate exported unexpectedly.
2026-05-18 13:59:00	Windows Security Logs	user1099@example.local	WS-2099	203.0.113.194	Context signal	Entity context matched BB: Private Key Paths.
2026-05-18 14:04:00	EDR File Events	user1099@example.local	WS-2099	10.20.9.90	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 14:07:00	SIEM Correlation	user1099@example.local	WS-2099	203.0.113.194	Rule matched	Correlation matched building blocks: BB: Private Key Paths, BB: Certificate Export Events.
2026-05-18 14:15:00	SOC Case Record	user1099@example.local	WS-2099	203.0.113.194	Incident created	Incident created for Private Key or Certificate Exported Unexpectedly with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.

- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Private Key Paths, BB: Certificate Export Events, BB: Approved PKI Admins.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.

Use Case 100: Quantum-Vulnerable Cryptography on Sensitive Long-Lived Data

Category	Governance, Control Monitoring and Crypto Readiness
MITRE ATT&CK Mapping	T1552 Unsecured Credentials; Governance Control
Detection Objective	Detect and investigate quantum-vulnerable cryptography on sensitive long-lived data using correlated SIEM telemetry, entity context and analyst-driven incident workflow.
Primary Log Sources	Crypto Inventory, Data Classification, Asset Inventory, TLS Scan
Recommended Building Blocks	BB: Sensitive Long-Lived Data, BB: RSA/ECC Inventory, BB: Critical Applications
Recommended Alert Name	2026 - Quantum-Vulnerable Cryptography on Sensitive Long-Lived Data
Recommended Incident Name	Possible Quantum-Vulnerable Cryptography on Sensitive Long-Lived Data Investigation

1. Scenario

A system storing long-retention sensitive data relies on legacy cryptography and has no crypto-agility roadmap.

Control monitoring ensures that the SOC can trust its visibility and response capability. Detection rules, log sources, crypto controls and governance evidence must be monitored like security assets.

In a mature SOC, this scenario should not be treated as one isolated event. The analyst should view it as part of a timeline and ask whether there was an earlier trigger such as phishing, credential exposure, token theft, unauthorised access request, exploit attempt, suspicious endpoint activity or control tampering. The value of the use case is the ability to connect weak signals into a stronger investigation path.

2. Why This Use Case Matters in 2026

The primary MITRE ATT&CK mapping for this use case is T1552 Unsecured Credentials; Governance Control. The mapping should be validated during investigation because a single alert may represent different tactics depending on what happened before and after the event.

This use case is important because attackers increasingly rely on normal-looking activity, valid accounts, trusted tools, SaaS workflows, cloud APIs, automation identities and business processes. A simple rule that only checks for one field may miss the real behaviour. The detection should combine the event itself, the identity involved, the asset or data impacted, the surrounding activity, the control status and the expected business process.

3. Required Telemetry and Field Requirements

Telemetry / Field	Detailed SOC Explanation	Real Example / Simulated Evidence
Crypto Inventory	Provides supporting evidence for Quantum-Vulnerable Cryptography on Sensitive Long-Lived Data. The analyst should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Quantum-Vulnerable Cryptography on Sensitive Long-Lived Data. If the evidence is incomplete, the analyst should request the missing log source before closure.
Data Classification	Adds external intelligence context to Quantum-Vulnerable Cryptography on Sensitive Long-Lived Data. IOC, actor, campaign, reputation, first-seen date and confidence help prioritise alerts and connect internal evidence to known malicious infrastructure.	Simulation: destination IP matched TI feed as malware C2 with confidence=High, first_seen=2026-02-10. If internal host communicated successfully, investigate compromise evidence.
Asset Inventory	Identifies the endpoint, server, cloud workload or application component connected to Quantum-Vulnerable Cryptography on Sensitive Long-Lived Data. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
TLS Scan	Provides supporting evidence for Quantum-Vulnerable Cryptography on Sensitive Long-Lived Data. The analyst	Simulation: the field should show the affected entity, timestamp, source, destination, action and result for Quantum-

	should confirm whether this telemetry proves the event occurred, whether the action succeeded and whether it links to other suspicious activity in the same timeline.	Vulnerable Cryptography on Sensitive Long-Lived Data. If the evidence is incomplete, the analyst should request the missing log source before closure.
TimeGenerated / EventTime	This is the anchor for timeline reconstruction. For Quantum-Vulnerable Cryptography on Sensitive Long-Lived Data, the analyst must compare the first suspicious event, the confirming event and any follow-on activity in the correct order. Without a reliable timestamp, the SOC cannot decide whether the activity is an isolated event or part of a chained incident.	Simulation: 2026-03-18 09:14:22 risky sign-in observed; 09:16:03 successful access; 09:20:41 mailbox or file activity begins. The close timing increases investigation confidence.
User / Account / Service Principal	Identifies the human account, admin account, service account or cloud application identity involved in Quantum-Vulnerable Cryptography on Sensitive Long-Lived Data. This field is required for entity mapping, privilege validation, historical baseline review and ownership confirmation.	Simulation: account=farah.finance@company.com, role=Finance Manager, privilege=standard user, department=Finance. If the same account also triggers risky login and file download events, the alerts should be grouped into one incident.
Host / Device / Asset	Identifies the endpoint, server, cloud workload or application component connected to Quantum-Vulnerable Cryptography on Sensitive Long-Lived Data. It helps determine whether the activity affected a normal workstation, critical server, domain controller, payment application or internet-facing service.	Simulation: device=BSN-LT-0441, compliance=Unmanaged, owner=Finance, EDR status=Online. If the device is unmanaged or critical, the incident priority and containment decision should increase.
Source IP / Destination IP / Geo / ASN	Shows the network origin and destination of activity linked to Quantum-Vulnerable Cryptography on Sensitive Long-Lived Data. The SOC uses this to identify new countries, high-risk ASNs, hosting providers, anonymisation services, external command infrastructure, internal lateral movement and unusual access paths.	Simulation: source_ip=185.220.101.34, country=DE, ASN=Hosting Provider, destination=login.microsoftonline.com. The user usually logs in from MY corporate IP ranges, so this becomes a strong anomaly.
Action / Result / Status	Explains whether the activity in Quantum-Vulnerable Cryptography on Sensitive Long-Lived Data was attempted, allowed, blocked, failed, completed or partially completed. This is important because an attempted event and a successful event have different investigation and response requirements.	Simulation: result=Success, action=Allowed, status=Completed. If the same event was Blocked, the case may remain as an attempted attack; if Allowed and followed by related activity, it should become an incident.
Application / Resource / Object	Identifies the application, mailbox, SharePoint site, API endpoint, database, cloud object, file path or business resource touched during Quantum-Vulnerable Cryptography on Sensitive Long-Lived Data. This allows SOC to assess business impact and data sensitivity.	Simulation: application=SharePoint Online, resource=/Finance/Payroll/Salary_2026.xlsx, action=FileDownloaded. Because payroll data is sensitive, the incident should be treated as possible data exposure.
	For Quantum-Vulnerable Cryptography on Sensitive Long-Lived Data, do not review the telemetry as isolated rows.	Example SOC reading: the same account or host appears across authentication, network and application logs within the investigation

	Reconstruct the evidence sequence: first indicator, validating signal, affected entity, business resource touched, action result and follow-on activity. The incident should only be closed when the available telemetry explains the full story and proves whether the activity was benign, attempted, blocked, successful or still unknown.	window. If the source is unusual, the action succeeded and sensitive resources were touched, create or escalate the incident. If the action was blocked and no follow-on activity exists, document containment evidence and close as attempted/blocked.
--	---	---

4. Building Blocks / BB Design

Building blocks make the rule maintainable. Instead of hard-coding every user, IP, host or application directly into the rule, the SOC should maintain reusable lists and logic blocks. If the SIEM platform supports QRadar-style building blocks, Splunk macros, Sentinel watchlists, Elastic lists or data tables, use them to keep the detection clean.

- BB: Sensitive Long-Lived Data: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: RSA/ECC Inventory: maintain the list owner, update frequency, source of truth and exception approval process.
- BB: Critical Applications: maintain the list owner, update frequency, source of truth and exception approval process.

5. Rule Creation Logic

The rule should trigger when the core event is observed and at least one risk-enhancing context is present. In production, the SOC should avoid triggering on raw volume alone unless the event itself has very high confidence. Better rules combine the primary activity with user or asset context, abnormal behaviour, threat intelligence, control state or follow-on activity.

- Primary condition: detect the core activity described by the use case.
- Context condition: enrich with building blocks, baseline, user risk, device compliance, asset criticality and data sensitivity.
- Correlation condition: search for related activity within a defined lookback window.
- Suppression condition: exclude approved change windows, known scanners, approved automation and documented business processes.
- Incident condition: create or update an incident when evidence indicates risk beyond a single benign event.

// Defensive SIEM pseudocode - adapt to KQL, SPL, QRadar AQL, Elastic EQL or your platform

LET lookback = 60m;

LET building_blocks = [BB: Sensitive Long-Lived Data, BB: RSA/ECC Inventory, BB: Critical Applications];

FROM Crypto Inventory, Data Classification, Asset Inventory

WHERE TimeGenerated >= now() - lookback

AND event_matches('Quantum-Vulnerable Cryptography on Sensitive Long-Lived Data')

AND not in_approved_exception_list(Entity, SourceIP, Application)

ENRICH with UserRisk, AssetCriticality, GeoIP, DeviceCompliance, ThreatIntel, ChangeTicket

CORRELATE related_events by User, Host, SourceIP, SessionId within 30m

SCORE = risk_score(EventConfidence, UserPrivilege, AssetCriticality, DataSensitivity, ControlStatus)

TRIGGER alert when SCORE >= organisation_threshold

GROUP alerts into incident when same User/Host/SourceIP/SessionId appears in related detections within 24h

6. Alert Design

Field	Example Value
Alert Name	2026 - Quantum-Vulnerable Cryptography on Sensitive Long-Lived Data
Incident Name	Possible Quantum-Vulnerable Cryptography on Sensitive Long-Lived Data Investigation
Primary Entity	User, Host, Source IP, Application, Session ID
Supporting Context	GeoIP, ASN, user privilege, device compliance, asset criticality, data sensitivity, threat-intel match, related change ticket
Grouping Key	Same user/host/source IP/session/application within 24 hours
Business Impact Tag	Governance, Control Monitoring and Crypto Readiness

The alert description should explain the detection in plain language. Analysts should be able to see the user, host, source, destination, application, rule reason, business context and recommended next action without opening multiple tools. If the SIEM supports custom details, include the most important evidence fields directly in the alert.

7. Incident Creation and Grouping Logic

Create an incident when the alert is correlated with other suspicious activity or when the affected entity is sensitive. For this use case, group alerts using the same user, host, source IP, session ID, application, service principal, mailbox, API token, file hash or destination within a 24-hour window. The incident should be titled 'Possible Quantum-Vulnerable Cryptography on Sensitive Long-Lived Data Investigation' and should include the timeline, impacted assets, impacted data, containment status and business owner.

- Group by same user and source IP when identity or cloud activity is involved.
- Group by same host, process, file hash or destination when endpoint activity is involved.
- Group by same mailbox, site, file repository or external recipient when email or data activity is involved.
- Group by same API token, endpoint, session or customer object when application/API activity is involved.
- Escalate to a higher-level incident when two or more categories appear in the same timeline.

8. Example Timeline

Time	Source	User	Host	IP/Target	Stage	Analyst Reading
2026-05-18 14:00:00	Crypto Inventory	user1100@example.local	WS-2100	203.0.113.201	Initial signal	Event indicates quantum-vulnerable cryptography on sensitive long-lived data.
2026-05-18 14:02:00	Data Classification	user1100@example.local	WS-2100	203.0.113.201	Context signal	Entity context matched BB: Sensitive Long-Lived Data.
2026-05-18 14:07:00	Asset Inventory	user1100@example.local	WS-2100	10.20.10.101	Follow-on activity	Related activity observed in InternalApplication.
2026-05-18 14:10:00	SIEM Correlation	user1100@example.local	WS-2100	203.0.113.201	Rule matched	Correlation matched building blocks: BB: Sensitive Long-Lived Data, BB: RSA/ECC Inventory.
2026-05-18 14:18:00	SOC Case Record	user1100@example.local	WS-2100	203.0.113.201	Incident created	Incident created for Quantum-Vulnerable Cryptography on Sensitive Long-Lived Data with evidence timeline attached.

Analyst interpretation: the timeline should be reviewed as a sequence, not as isolated log lines. The analyst should confirm whether the first signal is benign, whether the second signal increases confidence, whether the follow-on activity shows impact and whether containment is needed before deeper analysis continues.

9. Triage Questions

- Is the user, host, application or service account expected to perform this activity?
- Is there an approved change, service request, incident ticket or business justification?
- Did the same entity trigger other related alerts before or after this event?
- Is the source IP, country, ASN, device, user-agent or session new for this entity?
- Is the affected asset, mailbox, data repository or application business-critical?
- Was the activity allowed, blocked, partially completed or only attempted?
- Is there evidence of data access, privilege change, control tampering, lateral movement or persistence?
- Should this be escalated to L2/L3, Incident Response, IAM, endpoint, cloud, network, application or risk/compliance team?

10. Recommended Response Actions

- Validate the alert against the simulated or real evidence timeline and preserve raw events.
- Enrich the entities with user role, asset owner, department, asset criticality, privilege level and recent activity.
- Check for matching activity across SIEM, EDR, identity, cloud, proxy, email, application and network telemetry.
- Escalate according to the incident classification and business impact, not only the technical event type.
- Document the final decision, containment actions, evidence and closure rationale in the case record.

11. False Positive Possibilities

- Approved maintenance, migration, testing, vulnerability assessment or administrative activity.
- Known automation account, service integration, backup process, security tool, scanner or deployment platform.
- Business travel, remote work, vendor support activity or approved temporary access.
- False reputation match, geolocation inaccuracy, NAT/proxy aggregation or log parsing issue.
- Application behaviour change after release, patch, policy update or workflow redesign.

12. Tuning Notes

- Create and maintain the building blocks used by this rule: BB: Sensitive Long-Lived Data, BB: RSA/ECC Inventory, BB: Critical Applications.
- Do not tune by broad user or IP exclusion alone. Prefer conditional exclusions using asset, application, time window, change ticket and expected source.
- Use dynamic baselines per user, host, application or service account where possible. A single global threshold will create noise or miss high-risk low-volume activity.
- Review the rule after every confirmed true positive, false positive spike, application migration, logging schema change or major incident.
- Record tuning decisions in the use case register so future analysts understand why thresholds, exceptions and suppression rules exist.

13. Closure Evidence Required

- Raw log evidence exported or attached to the case record.
- Entity summary showing affected user, host, source IP, application, service account or data repository.
- Analyst decision explaining whether the event is true positive, benign true positive, false positive or policy violation.
- Containment and recovery evidence if action was taken.
- Tuning recommendation if the alert was noisy, incomplete or missing useful context.
- Management or risk/compliance summary if the incident involves sensitive data, privileged access, customer impact or regulatory relevance.